CompTIA Security+

SY0-701 · Guia Completa Fusionada v2 · En Espanol

Teoria:	Professor Messer SY0-701 (57p) — Todos los objetivos 1.1-5.6
Tests:	ExamCompass 590 preguntas — 582 con respuesta valida (182 corregidas manualmente)
Extra:	83 preguntas nuevas (una por objetivo + temas clave sin cobertura)
Mapa:	Prioridades ALTA/MEDIA/COMPLEMENTARIO con colores reales por dominio
Estructura:	Dominio → Objetivo → Teoria → Prioridades → Preguntas Topic → Preguntas Nuevas

Total preguntas	590	**Con respuesta valida**	582
Corregidas manualmente	182	**Sin respuesta posible**	0
Practice Tests (mixtos)	281	**Acronyms Quizzes**	135
Preguntas nuevas añadidas	83	**Dominios cubiertos**	5 (12+22+18+28+20%)

Messer + ExamCompass | Uso personal

Tabla de Contenidos

Dominio 1: Conceptos Generales de Seguridad (12%)

1.1 Tipos de controles de seguridad · *8p ExamCompass* · *+3p nuevas*
1.2 CIA, AAA y Zero Trust · *+4p nuevas*
1.3 Gestion del cambio · *+3p nuevas*
1.4 Criptografia · *31p ExamCompass* · *+4p nuevas*

Dominio 2: Amenazas, Vulnerabilidades y Mitigaciones (22%)

2.1 Actores de amenaza · *5p ExamCompass* · *+7p nuevas*
2.2 Vectores e ingenieria social · *18p ExamCompass* · *+2p nuevas*
2.3 Vulnerabilidades · *10p ExamCompass* · *+2p nuevas*
2.4 Indicadores de actividad maliciosa · *21p ExamCompass* · *+2p nuevas*
2.5 Tecnicas de mitigacion · *+3p nuevas*

Dominio 3: Arquitectura de Seguridad (18%)

3.1 Seguridad en entornos cloud y fisicos · *+2p nuevas*
3.2 Principios de seguridad en infraestructura · *3p ExamCompass* · *+2p nuevas*
3.3 Proteccion de datos y privacidad · *9p ExamCompass* · *+2p nuevas*
3.4 Resiliencia y recuperacion · *13p ExamCompass* · *+2p nuevas*

Dominio 4: Operaciones de Seguridad (28%)

4.1 Hardening y seguridad de aplicaciones · *7p ExamCompass* · *+2p nuevas*
4.2 Gestion de activos · *+5p nuevas*
4.3 Gestion de vulnerabilidades y pentest · *15p ExamCompass* · *+2p nuevas*
4.4 Monitorizacion y alertas · *+6p nuevas*
4.5 Seguridad en endpoint y email · *+2p nuevas*
4.6 IAM y control de acceso · *14p ExamCompass* · *+2p nuevas*
4.7 Automatizacion y orquestacion · *+5p nuevas*
4.8 Respuesta a incidentes y forense · *5p ExamCompass* · *+2p nuevas*
4.9 Logs y fuentes de datos · *+2p nuevas*

Dominio 5: Gestion del Programa de Seguridad (20%)

5.1 Gobernanza y politicas · *4p ExamCompass* · *+2p nuevas*
5.2 Gestion de riesgos · *11p ExamCompass* · *+3p nuevas*
5.3 Riesgos de terceros · *+3p nuevas*
5.4 Cumplimiento normativo · *+3p nuevas*
5.5 Auditorias y evaluaciones · *+3p nuevas*
5.6 Concienciacion y formacion · *+3p nuevas*

Practice Tests Mixtos (24 tests)

281 preguntas mezcladas de todos los dominios

Acronyms Quizzes (10 quizzes)

135 preguntas de siglas y terminos clave

Mapa Global de Prioridades para el Examen

ROJO = ALTA PRIORIDAD (sale con frecuencia en tests)	**NARANJA = MEDIA** (importante conocer)	**VERDE = COMPLEMENTARIO** (profundidad)

Dominio 1: Conceptos Generales de Seguridad

ALTA PRIORIDAD	MEDIA PRIORIDAD	COMPLEMENTARIO
• Preventivo/Detectivo/Correctivo	• Compensatorio/Disuasorio/Directivo	• Esteganografia / Blockchain
• Triada CIA (Confidencialidad/Integridad/Disponibilidad)	• No Repudio + Firma Digital	• Mantrap / Bollard / CCTV
• AES / RSA / ECC	• Backout Plan / Sandbox	• Wildcard cert / SAN cert
• Hash: SHA-256 / MD5 (obsoleto)	• CRL / OCSP / HSTS	• LDAP / Kerberos / NTLM
• PKI / CA / Certificado X.509	• Salt / Rainbow Table	• OAuth 2.0 / OIDC / SAML
• Zero Trust + PEP/PDP	• TLS 1.3 / Cipher suites	• JWT / OTP / Password Manager
• Tecnico/Gestion/Operacional/Fisico	• Change Management / CCB	• DH / DHE / ECDHE / PFS
• AAA: RADIUS / TACACS+	• Allow list / Deny list	• Key escrow / STIX / TAXII
	• Gap Analysis + Baseline	• Entropy / CSPRNG
		• SSH / RDP / SFTP / FTPS
		• SNMP v1/v2c (inseg) / v3 (seg)

Dominio 2: Amenazas, Vulnerabilidades y Mitigaciones

ALTA PRIORIDAD	MEDIA PRIORIDAD	COMPLEMENTARIO
• APT / Nation-state actor	• Insider / Script kiddie	• Hacktivista / Crimen organizado
• Phishing / Smishing / Vishing	• Spear phishing / Whaling	• Typosquatting / Watering hole
• SQLi / XSS (reflected/stored)	• Directory Traversal / Zero-day	• CSRF / SSRF
• Virus vs Worm (diferencia clave)	• Rootkit / Fileless / Logic Bomb	• IOC vs IOA
• Ransomware / RAT / Trojan	• Keylogger / Spyware / Botnet	• Quishing (QR phishing)
• Buffer Overflow / TOCTOU	• DoS / DDoS / Amplification	• VM Escape / Resource Reuse
• IOC / Shadow IT	• DNS Poisoning / ARP Poisoning	• WEP/WPA/WPA2/WPA3
• MITRE ATT&CK / TTP	• MITM / SSL Stripping / HSTS	• EOL / EOSL / Firmware
	• Brute Force / Dictionary / Spray	• ICS/SCADA / PLC / HMI / Purdue Model
	• Supply chain: SolarWinds ejemplo	• Pass-the-Hash / Replay
	• WannaCry: Worm+Ransomware	• 802.1X / EAP / PEAP / EAP-TLS
		• Birthday Attack / Downgrade
		• MFA fatigue / Push bombing
		• Bluesnarfing / Bluejacking / NFC
		• Evil Twin / Rogue AP

Dominio 3: Arquitectura de Seguridad

ALTA PRIORIDAD	MEDIA PRIORIDAD	COMPLEMENTARIO
• IaaS/PaaS/SaaS responsabilidad compartida	• Publica/Privada/Hibrida/Multi-cloud	• Edge computing / Fog computing

Messer + ExamCompass | Uso personal

• VPN: IPSec / SSL / Split tunnel	• Proxy / Reverse Proxy	• DNS Sinkhole / DNSSEC
• DLP / Clasificacion de datos	• Data at rest/transit/use	• Pseudonimizacion / Masking
• RTO vs RPO (diferencia)	• MTTR / MTBF	• MPLS / SD-WAN
• NGFW / IDS vs IPS	• WAF / NAC / SIEM / SOAR	• BGP / OSPF / RIP / EIGRP
• Regla 3-2-1 Backups	• HSM / TPM / Secure Boot	• DHCP snooping / ARP inspection
• Hot/Warm/Cold Site	• Tokenizacion / Anonimizacion	• NTP (critico para Kerberos)
• GDPR: 72h notif / Right to forget	• DRP / BCP / BIA	• Degaussing / Wiping / Purging
	• CASB / CSPM / SASE	• Crypto-shredding / NIST 800-88
	• PII / PHI / Privacy by design	• Geofencing / MDM
	• Failover / HA / Redundancia	• Network TAP / SPAN port
	• S/MIME / PGP / STARTTLS	• BGP hijacking (Pakistan→YouTube)
	• SPF / DKIM / DMARC	• MTPD / MBCO
		• Backup: completo/incr/diferencial

Dominio 4: Operaciones de Seguridad

ALTA PRIORIDAD	MEDIA PRIORIDAD	COMPLEMENTARIO
• SIEM correlacion de eventos	• CIS Benchmarks / Baselines	• MDM / MAM / BYOD / COPE
• MFA: algo que sabes/tienes/eres	• Asset inventory / CMDB	• Vulnerability scanning (Nessus)
• Fases IR: Prep→Detect→Contain→Recovery	• Black/White/Grey-box pentest	• XDR: EDR+red+cloud+email
• Orden volatilidad forense: RAM primero	• Alert tuning / Alert fatigue	• CI/CD + SAST automatico
• RBAC / ABAC / MAC / DAC	• Host firewall / HIDS / HIPS	• IaC / Terraform / CloudFormation
• Vuln scan vs Pentest	• TOTP (30s) / FIDO2 passkeys	• PAM / JIT / Ephemeral access
• AV (firmas) vs EDR (comportamiento)	• SOAR Playbooks	• Autopsy / FTK / Volatility
• 4624 (login OK) / 4625 (login fallido)	• CVSS 0-10: Critico >= 9	• DEP / ASLR / Stack canary
	• NetFlow / PCAP / Wireshark	• Bug bounty (HackerOne)
	• SDLC seguro / SAST / DAST	• Nmap / Nessus / Metasploit
	• CVE / NVD / KEV	• Burp Suite (web app)
	• SSO riesgo: IdP comprometido	• Red/Blue/Purple Team
	• Cadena de custodia forense	• Fuzzing / fuzz testing
	• Log retention: 90d min / 1a PCI	• Tabletop exercise
		• Lessons learned obligatorio
		• Attack surface reduction
		• FAR / FRR / CER (biometria)
		• TTP / MITRE ATT&CK
		• 802.1X NAC / Air gap
		• Contenedores: Docker / K8s
		• API security / Rate limiting
		• Web filtering / Proxy
		• Code signing / SBOM

Messer + ExamCompass | Uso personal

		• Input validation / Least privilege

Dominio 5: Gestion del Programa de Seguridad

ALTA PRIORIDAD	MEDIA PRIORIDAD	COMPLEMENTARIO
• Riesgo = Amenaza x Vulnerabilidad x Impacto	• AUP / NDA / Clean desk policy	• Onboarding / Offboarding procesos
• SLE / ARO / ALE (formula: ALE=SLE*ARO)	• SLA / MSA / BPA / MOU / MOA	• Job rotation / Mandatory vacation
• GDPR: 72h, right to forget, multas	• ALE < Coste control → no implantar	• Background check / Vetting
• HIPAA: PHI, BAA, cifrado obligatorio	• NIST CSF: ID→Protect→Detect→Respond→Recover	• Cyber insurance
• PCI DSS: 12 requisitos	• ISO 27001 (certificable)	• Data Owner/Steward/Custodian
• Aceptar/Transferir/Mitigar/Evitar riesgo	• Risk appetite vs Risk tolerance	• DPO (GDPR obligatorio)
• Jerarquia: Politica→Estandar→Procedimiento	• SOC 2 Type I vs Type II	• Right to audit en contratos
	• BIA: identifica procesos criticos	• Cross-border data transfer
	• FedRAMP / FISMA / CMMC	• Phishing simulation trimestral
	• Due Diligence / Due Care	• Role-based training
	• Qualitativa vs Cuantitativa	• Cultura sin castigo al reporte
	• Separation of duties / SOD	• Security awareness (anual min)
		• PII / PHI / Privacy by design
		• Data minimization / Consent

Messer + ExamCompass | Uso personal

DOMINIO 1 Conceptos Generales de Seguridad (12% del examen)

1.1 Tipos de controles de seguridad

Conceptos Clave — Professor Messer

Controles de Seguridad

Control Tecnico
Implementado con tecnologia: firewall, antivirus, cifrado, politicas del SO.

Control de Gestion
Politicas y procedimientos documentados: politica de seguridad, SOPs, evaluaciones de riesgo.

Control Operacional
Realizado por personas: guardias, formacion de usuarios, carteles de concienciacion.

Control Fisico
Limita el acceso fisico: torniquetes, vallas, cerraduras, lectores de tarjeta, CCTV.

Tipos:

Preventivo
Impide el acceso o el ataque. Ej: regla de firewall, guardia en entrada, cerradura.

Disuasorio
Desanima sin impedir. Ej: aviso de camara, pantalla de advertencia legal, recepcion visible.

Detectivo
Identifica y alerta de brechas. Ej: revision de logs, detector de movimiento, IDS.

Correctivo
Actua post-evento para revertir el dano. Ej: restaurar backup, extinguidor, parchear.

Compensatorio
Alternativa temporal. Ej: regla de firewall extra mientras se parchea el sistema.

Directivo
Dirige al usuario hacia el comportamiento correcto. Ej: politica de cifrado, senyal de 'solo personal'.

Puntos clave para el examen:

- 4 CATEGORIAS: Tecnico, Gestion, Operacional, Fisico.
- 6 TIPOS: Preventivo, Disuasorio, Detectivo, Correctivo, Compensatorio, Directivo.
- Cada tipo aplica en cada categoria → matriz 6x4 = 24 combinaciones posibles.
- Preventivo actua ANTES del evento; Correctivo actua DESPUES.
- Compensatorio es TEMPORAL mientras se resuelve el problema raiz.
- Directivo es el MAS DEBIL: depende de la decision del usuario.

Teoria Complementaria — ExamCompass

1.0 Conceptos Generales de Seguridad (12% del examen)

1.1 - Comparar y contrastar los distintos tipos de controles de seguridad.

- Categorias: Tecnico, Administrativo (Managerial), Operacional, Fisico
- Tipos de control: Preventivo, Disuasorio, Detective, Correctivo, Compensatorio, Directivo

Los controles de seguridad se clasifican por CATEGORIA y por TIPO. Memorizalos como una tabla de doble entrada.

CATEGORIAS (el QUE protegen):

■ Tecnico (logico): firewalls, cifrado, antivirus, IDS

■ Administrativo (Managerial): politicas, procedimientos, evaluaciones de riesgo

■ Operacional: formacion de usuarios, gestion de medios, controles fisicos operados por personas

■ Fisico: cerraduras, vallas, camaras, guardias de seguridad

TIPOS (el COMO actuan):

■ Preventivo (Preventive): evita que ocurra el incidente (firewall bloqueando trafico)

■ Disuasorio (Deterrent): disuade al atacante sin bloquearlo fisicamente (camara visible, cartel de advertencia)

■ Detective: detecta que algo ocurrio (logs, IDS, CCTV)

■ Correctivo (Corrective): corrige tras el incidente (patch, restaurar backup, antivirus que elimina malware)

■ Compensatorio (Compensating): control alternativo cuando el principal no es viable (MFA en lugar de tarjeta inteligente)

■ Directivo (Directive): indica que se debe hacer (politica de uso aceptable, formacion obligatoria)

TRUCO NEMOTECNICO para los tipos: 'Por Dios, Del Cielo Caen Dones' → Preventive, Deterrent, Detective, Corrective,

Compensating, Directive

Ejemplo de examen: Un firewall es un control TECNICO + PREVENTIVO. Una camara de seguridad es FISICO + DETECTIVE. Una

politica de contrasenas es ADMINISTRATIVO + DIRECTIVO.

Preguntas de practica (21):

Preguntas Topic — ExamCompass (8 preguntas)

1. ¿Cuál de las siguientes respuestas se puede utilizar para describir los controles técnicos de seguridad? (Seleccione 3 respuestas)

[EN: Which of the following answers can be used to describe technical security controls? (Select 3 answers)]

A) Enfocados en proteger los bienes materiales

✓ B) A veces se les llama controles de seguridad lógicos.

✓ C) Ejecutado por sistemas informáticos (en lugar de personas)

D) También conocidos como controles administrativos.

✓ E) Implementado con tecnología.

F) Principalmente implementado y ejecutado por personas (a diferencia de los sistemas informáticos)

Fuente: Topic: Security Controls

---

2. ¿Cuál de las siguientes respuestas se refiere a los rasgos característicos de los controles de seguridad gerenciales? (Seleccione 3 respuestas)

[EN: Which of the following answers refer to the characteristic features of managerial security controls? (Select 3 answers)]

A) También conocidos como controles administrativos.

B) A veces denominados controles de seguridad lógicos.

✓ C) Enfocados en reducir el riesgo de incidentes de seguridad

D) Ejecutado por sistemas informáticos (en lugar de personas)

✓ **E) Documentado en políticas escritas.**

F) Enfocados en proteger los bienes materiales

Fuente: Topic: Security Controls

---

3. ¿Cuál de las respuestas enumeradas a continuación se puede utilizar para describir los controles de seguridad operativos? (Seleccione 3 respuestas)

[EN: Which of the answers listed below can be used to describe operational security controls (Select 3 answers)]

A) También conocidos como controles administrativos.

✓ **B) Enfocados en los procedimientos del día a día de una organización.**

C) Ejecutado por sistemas informáticos (en lugar de personas)

✓ **D) Se utiliza para garantizar que el equipo continúe funcionando según lo especificado.**

E) Enfocados en la gestión del riesgo

✓ **F) Principalmente implementado y ejecutado por personas (a diferencia de los sistemas informáticos)**

Fuente: Topic: Security Controls

---

4. ¿Cuál de las respuestas enumeradas a continuación se refiere a controles de seguridad diseñados para disuadir, detectar y prevenir el acceso no autorizado, el robo, el daño o la destrucción de activos materiales?

[EN: Which of the answers listed below refers to security controls designed to deter, detect, and prevent unauthorized access]

A) Controles de seguridad gerenciales

✓ **B) Controles de seguridad física**

C) Controles técnicos de seguridad

D) Controles operativos de seguridad

Fuente: Topic: Security Controls

---

5. ¿Cuáles son los ejemplos de controles preventivos de seguridad? (Seleccione 3 respuestas)

[EN: What are the examples of preventive security controls? (Select 3 answers)]

A) Cifrado

B) identificación

C) Sensores

✓ **D) Cortafuegos**

E) Señales de advertencia

✓ **F) software audiovisual**

Fuente: Topic: Security Controls

---

6. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

[EN: Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)]

A) Iluminación

✓ **B) Monitoreo de registros**

C) Zona de arena

✓ **D) Auditorías de seguridad**

✓ **E) circuito cerrado de televisión**

✓ **F) identificación**

✓ **G) Escaneo de vulnerabilidades**

Fuente: Topic: Security Controls

---

7. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a controles de seguridad compensatorios? (Seleccione todo lo que corresponda)

[EN: Which of the answers listed below refer(s) to compensating security control(s)? (Select all that apply)]

A) Sistemas de energía de respaldo

B) Videovigilancia

✓ C) Ministerio de Asuntos Exteriores

✓ D) Zona de pruebas de aplicaciones

✓ E) Segmentación de red

Fuente: Topic: Security Controls

---

8. ¿Cuál de los siguientes términos entran en la categoría de controles de seguridad directivos? (Seleccione 2 respuestas)

[EN: Which of the following terms fall into the category of directive security controls? (Select 2 answers)]

A) PIR

✓ B) PUA

C) identificación

D) Ministerio de Asuntos Exteriores

E) IPS

Fuente: Topic: Security Controls

Preguntas Adicionales — Generadas (3 preguntas)

1. ¿Cuál de los siguientes es un ejemplo de control PREVENTIVO técnico?

✓ A) Firewall

B) Log de auditoría

C) Extintor de incendios

D) Plan de recuperación ante desastres

Fuente: Extra: Security Controls

---

2. Un guardia de seguridad en la entrada de un edificio es un ejemplo de control de seguridad de qué categoría y tipo:

✓ A) Físico / Preventivo

B) Técnico / Detectivo

C) Operacional / Preventivo

D) De gestión / Disuasorio

Fuente: Extra: Security Controls

---

3. ¿Cuál es la diferencia principal entre un control DISUASORIO y un control PREVENTIVO?

✓ A) El disuasorio desanima pero no impide; el preventivo impide directamente

B) Son sinónimos — hacen lo mismo

C) El preventivo desanima; el disuasorio impide directamente

D) El disuasorio solo aplica a controles físicos

Fuente: Extra: Security Controls

Flashcards — 1.1 (3 tarjetas)

Q: ¿6 tipos de control por función?	Preventivo · Disuasorio · Detective · Correctivo · Compensatorio · Directivo

Q: ¿4 categorías de control por naturaleza?	Técnico (lógico) · Gestión (administrativo) · Operacional · Físico
Q: Ejemplo de control COMPENSATORIO	Sustituye a otro control que no se puede implementar. Ej: cámara CCTV si no hay guardia de seguridad

1.2 CIA, AAA y Zero Trust

Conceptos Clave — Professor Messer

La Triada CIA

Confidencialidad
Solo personas autorizadas acceden a la informacion. Metodos: cifrado, MFA, control de acceso.

Integridad
Los datos no han sido modificados. Metodos: hash, firma digital, certificados.

Disponibilidad
Sistemas operativos cuando se necesitan. Metodos: redundancia, tolerancia a fallos, backups, parches.

No Repudio
El emisor no puede negar haber enviado el mensaje. Se logra con firma digital.

Puntos clave para el examen:

- CIA = Confidentiality, Integrity, Availability (tambien AIC para diferenciar de la agencia).
- CIFRADO → Confidencialidad. HASH → Integridad. REDUNDANCIA → Disponibilidad.
- FIRMA DIGITAL = Hash + Clave privada → da Integridad + No Repudio.
- El hash es como huella dactilar: cualquier cambio produce hash diferente.

AAA — Autenticacion, Autorizacion y Contabilidad

Identificacion
El usuario declara quien es (introduce nombre de usuario).

Autenticacion
El sistema verifica que el usuario ES quien dice ser (contrasena, MFA, certificado, biometria).

Autorizacion
Determina a que recursos tiene acceso el usuario autenticado (roles, ACLs, grupos).

Contabilidad
(Accounting)
Registro de todo lo que hace el usuario: inicio sesion, datos transferidos, tiempo de sesion.

Servidor AAA
Centraliza la gestion de autenticacion. Protocolos: RADIUS, TACACS+.

Abstraccion/Roles
Capa intermedia entre usuarios y recursos. Facilita gestion masiva: asigna grupo, no usuario individual.

Puntos clave para el examen:

- El servidor AAA valida credenciales; el dispositivo de acceso (concentrador VPN) solo reenvía.
- RADIUS: UDP, cifra solo contrasena. TACACS+: TCP, cifra todo el paquete (mas seguro).
- Sin abstraccion: 1000 usuarios x 50 recursos = 50,000 asignaciones individuales.
- Con grupos: asignas permisos al grupo una vez; los usuarios heredan al unirse.

Gap Analysis y Zero Trust

Gap Analysis
Compara la postura actual de seguridad con el objetivo. Identifica brechas y prioriza mejoras.

Baseline / Linea base
Estandar de referencia objetivo. Ejemplos: NIST SP 800-171, ISO/IEC 27001, CIS Benchmarks.

Zero Trust
Nunca confiar, siempre verificar. Ningun usuario, dispositivo o proceso es de confianza por defecto.

Plano de datos
Parte del dispositivo que procesa el trafico real: reenvio de paquetes, NAT, filtrado.

Plano de control
Gestiona las reglas del plano de datos: tablas de rutas, politicas de firewall.

PEP (Policy Enforcement
Point)
Punto de acceso que aplica la decision. Solicita autorizacion al PDP.

PDP (Policy Decision
Point)
Toma la decision de permitir/denegar basandose en politicas. Compuesto por Motor + Administrador.

Identidad adaptativa
Evalua contexto de la peticion: IP, ubicacion, dispositivo, hora, rol, riesgo historico.

Puntos clave para el examen:

- Gap Analysis puede tardar semanas o meses. Evalua personas Y procesos.
- Semaforo: Verde = cerca del objetivo; Amarillo = intermedio; Rojo = lejos.
- Zero Trust aplica a TODOS: usuarios internos, externos, dispositivos y procesos.
- Flujo Zero Trust: Sujeto → PEP → PDP (Motor + Administrador) → decision → recurso.
- Identidad adaptativa puede exigir MFA extra si la IP es inusual o el horario es sospechoso.

Seguridad Fisica y Tecnicas de Engano

Bolardo / Barricada
Impide paso de vehiculos. Permite el paso de personas. Protege entradas de edificios.

Mantrap / Vestibulo de
acceso
Dos puertas: solo una puede estar abierta a la vez. Evita tailgating (colarse detras de alguien).

CCTV
Circuito cerrado de TV. Puede incluir deteccion de movimiento, reconocimiento facial, lectura de matriculas.

Two-person Integrity
Dos personas presentes para operaciones criticas. Evita fraude interno. Comun en guardianes de seguridad.

Honeypot
Sistema falso que atrae atacantes para estudiar sus tecnicas sin riesgo para sistemas reales.

Honeynet
Red completa de honeypots (servidores, routers, firewalls) para crear entorno falso convincente.

Honeyfile
Archivo con nombre atractivo (passwords.txt). Cualquier acceso dispara una alarma.

Honeytoken
Dato rastreable (credenciales API, cookies, emails falsos). Si aparece publicado, delata

al atacante.

Puntos clave para el examen:

- Mantrap = control fisico mas robusto contra tailgating.
- Iluminacion es la medida preventiva MAS BASICA y economica.
- Honeypots atraen principalmente bots automatizados, no solo atacantes humanos.
- Honeyfiles NUNCA deben accederse en produccion normal → cualquier acceso = alarma real.
- Honeytokens son RASTREABLES: si aparecen en internet, sabes quien los filtro.

1.2 ampliacion

Autenticacion Avanzada y Protocolos de Identidad

LDAP (Lightweight

Directory Access

Protocol)

Protocolo para consultar y modificar directorios (Active Directory). Puerto 389 (claro) o 636 (LDAPS cifrado).

Kerberos

Protocolo de autenticacion de red. Usa tickets. Tiempo maximo de diferencia entre cliente y KDC: 5 minutos. Base de AD.

NTLM (NT LAN Manager)

Protocolo de autenticacion Microsoft. OBSOLETO y vulnerable. Usado en redes Windows antiguas. Vulnerable a Pass-the-Hash.

OAuth 2.0

Framework de autorizacion (no autenticacion). Permite a apps acceder a recursos de otra app con permiso del usuario. Ej: 'Login con Google'.

OpenID Connect (OIDC)

Capa de identidad sobre OAuth 2.0. SI proporciona autenticacion. Devuelve ID Token (JWT).

SAML 2.0

Security Assertion Markup Language. XML. Usado en SSO empresarial. IdP genera assertions → SP las consume.

JWT (JSON Web Token)

Token compacto firmado (y opcionalmente cifrado). Header.Payload.Signature. Usado en APIs y OAuth.

OTP (One-Time

Password)

Contrasena de un solo uso. HOTP (basado en contador) o TOTP (basado en tiempo, 30 seg).

Password Manager /

Vault

Herramienta que almacena contrasenas cifradas. Solo necesitas recordar una master password. Ej: Bitwarden, 1Password.

Puntos clave para el examen:

- LDAP puerto 389 = texto claro. LDAPS puerto 636 = cifrado con TLS. Siempre usar LDAPS.
- Kerberos: KDC emite TGT → cliente presenta TGT para obtener Service Ticket → accede al servicio.
- NTLM vulnerable a Pass-the-Hash y relay attacks. Deshabilitar en redes modernas (usar Kerberos).
- OAuth 2.0 = AUTORIZACION (que puede hacer). OIDC = AUTENTICACION (quien es). Distincion clave del examen.
- JWT: el payload NO esta cifrado por defecto (solo firmado). No incluir datos sensibles en el payload sin cifrar.
- TOTP: mismo algoritmo en cliente y servidor + tiempo actual = mismo codigo de 6 digitos cada 30s.

Teoria Complementaria — ExamCompass

■ Autenticacion (Authentication): verificar quien eres (usuario + contrasena, MFA)

■ Autorizacion (Authorization): que puedes hacer una vez autenticado (permisos, roles)

■ Auditoria (Accounting): registro de lo que has hecho (logs)

Protocolos AAA: RADIUS (UDP 1812/1813), TACACS+ (TCP 49, cifra todo el payload)

ZERO TRUST - 'Nunca confiar, siempre verificar':

■ Plano de control: donde se toman decisiones de acceso (Motor de politicas + Administrador de politicas)

■ Plano de datos: donde fluye el trafico real (Punto de cumplimiento de politicas)

■ Principio: no se asume confianza por estar dentro de la red corporativa

SEGURIDAD FISICA:

■ Bolardos (Bollards): postes antiimpacto para proteger edificios de vehiculos

■ Mantrap (airlock): doble puerta que atrapa a intrusos entre ambas

■ Jaula de Faraday: bloquea senales electromagneticas

■ Iluminacion: como disuasor

TECNOLOGIA DE ENGANO:

■ Honeypot: sistema falso que atrae atacantes para estudiarlos

■ Honeynet: red entera de honeypots

■ Honeyfile: archivo falso que alerta si alguien lo abre

■ Honeytoken: credencial falsa que si se usa, delata al atacante

Preguntas de practica (101):

1. En la arquitectura de seguridad AAA, el proceso de otorgar o denegar acceso a recursos se conoce como:

22. Un ataque de disociación inalámbrica es un tipo de: (Seleccione 2 respuestas)

grandes volúmenes de tráfico.

54. La implementación del cifrado completo del dispositivo es uno de los métodos para proteger los datos confidenciales en un teléfono inteligente. Cuando está habilitado, este tipo de cifrado funciona junto con el bloqueo de pantalla del teléfono, es decir, para descifrar el teléfono (que permanece cifrado siempre que está bloqueado), el usuario primero debe desbloquear la pantalla. En los dispositivos Android, los métodos de desbloqueo incluyen ingresar un PIN, una contraseña o dibujar un patrón simple con un dedo. Los dispositivos Apple utilizan códigos de acceso, reconocimiento facial (Face ID) y huellas dactilares (Touch ID).

Respuesta no detectada automaticamente

un tipo específico de programa de divulgación responsable que ofrece recompensas financieras a los investigadores de seguridad por informar vulnerabilidades válidas.

Respuesta no detectada automaticamente

90. Una técnica de ingeniería social mediante la cual los atacantes, disfrazados de una solicitud legítima, intentan obtener acceso a información confidencial se denomina comúnmente:

Preguntas Adicionales — Generadas (4 preguntas)

1. ¿Qué componente de AAA se encarga de registrar qué hizo el usuario durante la sesión?

✓ A) Accounting

B) Authentication
C) Authorization
D) Auditing

Fuente: Extra: CIA / AAA / Zero Trust

---

2. En la arquitectura Zero Trust, ¿cuál es el rol del Policy Decision Point (PDP)?

✓ A) Evalúa las políticas y decide si conceder acceso
B) Aplica la decisión de acceso en el punto de entrada
C) Almacena las credenciales del usuario
D) Registra los eventos de acceso en el SIEM

Fuente: Extra: CIA / AAA / Zero Trust

---

3. ¿Qué principio de la triada CIA garantiza que los datos no han sido modificados sin autorización?

✓ A) Integridad
B) Confidencialidad
C) Disponibilidad
D) No repudio

Fuente: Extra: CIA / AAA / Zero Trust

---

4. ¿Cuál de los siguientes protocolos implementa AAA en redes inalámbricas y de acceso remoto?

✓ A) RADIUS
B) DNS
C) DHCP
D) SNMP

Fuente: Extra: CIA / AAA / Zero Trust

Flashcards — 1.2 (5 tarjetas)

Q: Triada CIA — 3 pilares	Confidencialidad → solo acceso autorizado
	Integridad → datos no modificados
	Disponibilidad → sistemas operativos cuando se necesitan
Q: ¿Qué garantiza el No Repudio?	El emisor no puede negar haber enviado el mensaje. Se logra con firma digital
Q: AAA — 3 componentes	Authentication (¿quién eres?) · Authorization (¿qué puedes hacer?) · Accounting (¿qué hiciste?)
Q: Zero Trust — PEP vs PDP	PDP (Policy Decision Point): decide si conceder acceso
	PEP (Policy Enforcement Point): aplica la decisión
Q: RADIUS vs TACACS+	RADIUS: UDP, cifra solo contraseña, común en WiFi/VPN
	TACACS+: TCP, cifra todo el paquete, común en dispositivos Cisco

1.3 Gestion del cambio

Conceptos Clave — Professor Messer

Gestion de Cambios

Change Management
Proceso formal para controlar y aprobar cambios en sistemas de produccion. Minimiza riesgos.

Change Control Board (CCB)
Comite que revisa, aprueba o rechaza solicitudes de cambio. Incluye stakeholders clave.

Propietario del cambio
Dueno del sistema/dato. Gestiona el proceso pero NO realiza el cambio tecnico.

Stakeholders
Cualquier departamento afectado por el cambio. Pueden no ser obvios (ej: impresoras → contabilidad).

Sandbox de pruebas
Entorno aislado identico a produccion. Prueba el cambio sin riesgo real.

Backout Plan
Procedimiento documentado para revertir el cambio si algo falla. DEBE probarse en sandbox.

Ventana de mantenimiento
Periodo planificado (generalmente fuera de horas pico) para implementar cambios.

Puntos clave para el examen:

- Proceso: formulario → alcance → programacion → analisis riesgo → aprobacion → prueba → implementacion.
- SIEMPRE hacer backup completo ANTES del cambio.
- El sandbox debe ser IDENTICO a produccion para que las pruebas sean validas.
- El backout plan debe PROBARSE en sandbox antes de implementar en produccion.
- Empresas retail: sistemas congelados entre Navidad y Ano Nuevo (epoca de mayor trafico).
- Allow list (blanca) = solo lo permitido explicitamente. Deny list (negra) = todo excepto lo bloqueado.

Preguntas Adicionales — Generadas (3 preguntas)

1. ¿Cuál es el propósito principal del Change Advisory Board (CAB) en la gestión de cambios?

✓ A) Revisar y aprobar cambios antes de implementarlos
B) Implementar cambios de emergencia sin aprobación
C) Documentar los cambios después de realizarlos
D) Proporcionar formación sobre nuevos cambios

Fuente: Extra: Change Management

---

2. ¿Qué es un 'backout plan' en el contexto de gestión de cambios?

✓ A) Un plan para revertir un cambio si causa problemas
B) Un plan de backup de datos antes del cambio
C) Un documento que describe las pruebas del cambio
D) Un análisis de impacto del cambio

Fuente: Extra: Change Management

---

3. ¿Cuál de los siguientes es un entorno SEGURO para probar cambios antes de implementarlos en producción?

✓ **A) Sandbox**

B) Honeypot

C) DMZ

D) VLAN de producción

Fuente: Extra: Change Management

Flashcards — 1.3 (2 tarjetas)

Q: ¿Qué es un Backout Plan?	Plan para REVERTIR un cambio si causa problemas. Obligatorio antes de aplicar cualquier cambio en producción
Q: ¿Para qué sirve el sandbox en gestión de cambios?	Entorno aislado para probar cambios sin afectar producción

1.4 Criptografia

Conceptos Clave — Professor Messer

Criptografia — Conceptos Basicos

Cifrado simetrico
Misma clave para cifrar y descifrar. Rapido. Problema: distribucion segura de la clave. Ej: AES.

Cifrado asimetrico
Par de claves: publica (cifra/verifica) y privada (descifra/firma). Ej: RSA, ECC.

Algoritmo AES
Advanced Encryption Standard. 128/192/256 bits. El estandar actual mas usado.

RSA
Rivest-Shamir-Adleman. Asimetrico. Basado en factorizacion de numeros primos grandes.

ECC
Elliptic Curve Cryptography. Asimetrico. Misma seguridad que RSA con claves mas cortas. Ideal para moviles.

Clave de sesion
Clave simetrica temporal generada para una sesion. Se intercambia usando criptografia asimetrica.

PKI
Public Key Infrastructure. Sistema para emitir, gestionar y revocar certificados digitales.

CA (Autoridad Certificadora)
Entidad de confianza que firma y emite certificados digitales. Ej: DigiCert, Let's Encrypt.

Certificado X.509
Estandar de certificado digital. Contiene clave publica, identidad del propietario y firma de la CA.

CRL / OCSP
CRL: lista de certificados revocados. OCSP: verifica en tiempo real si un certificado es valido.

Puntos clave para el examen:

- Simetrico = rapido pero problema de distribucion de clave.

- Asimetrico = lento pero resuelve distribucion de clave (la publica se comparte libremente).
- Practica comun: usa asimetrico para intercambiar clave simetrica, luego simetrico para los datos.
- ECC preferido en moviles y IoT: misma seguridad, claves mas cortas, menos CPU.
- PKI = infraestructura de confianza para toda la criptografia de clave publica.

Hashing, Esteganografia y Ofuscacion

Hash / Resumen

Funcion unidireccional: texto → cadena fija. No reversible. Cualquier cambio altera el hash.

MD5

128 bits. OBSOLETO. Se encontraron colisiones. NO usar para seguridad.

SHA-1

160 bits. OBSOLETO. Vulnerabilidades conocidas.

SHA-256 / SHA-3

256+ bits. Actuales y seguros. Usar siempre SHA-256 como minimo.

Salt

Valor aleatorio anadido al password antes de hashear. Evita ataques de rainbow table.

Esteganografia

Ocultar informacion dentro de otro archivo (imagen, audio, video) sin que sea visible.

Ofuscacion

Hacer el codigo o datos dificiles de leer/entender sin cambiar su funcionalidad.

Blockchain

Cadena de bloques enlazados con hash. Inmutable: cambiar un bloque invalida todos los siguientes.

Puntos clave para el examen:

- NUNCA usar MD5 o SHA-1 para seguridad. Usar SHA-256 como minimo.
- Salt evita rainbow tables: mismo password + diferentes salts = hashes diferentes.
- Esteganografia: la imagen parece normal pero contiene datos ocultos (ej: planos de ataque).
- Blockchain: inmutabilidad garantizada por cadena de hashes.
- Hash = verificar integridad. Cifrado = proteger confidencialidad.

Certificados Digitales

Certificado digital

Archivo que asocia una clave publica con una identidad, firmado por una CA.

Wildcard certificate

Certificado valido para todos los subdominios de un dominio. Ej: *.empresa.com

SAN (Subject Alternative Name)

Permite que un certificado sea valido para multiples dominios diferentes.

Root CA

Autoridad certificadora raiz. Su certificado esta pre-instalado en OS y navegadores.

Intermediate CA

CA subordinada a la Root CA. Emite certificados de usuario/servidor.

Pinning

Aplicacion que solo acepta un certificado o CA especifica. Evita ataques MITM.

HSTS

HTTP Strict Transport Security. Obliga al navegador a usar solo HTTPS para ese dominio.

Puntos clave para el examen:

- La confianza se basa en la cadena: Root CA → Intermediate CA → Certificado de servidor.
- Si la Root CA esta comprometida, TODOS los certificados emitidos son sospechosos.
- Wildcard (*) cubre subdominios pero NO el dominio base ni sub-subdominios.

- SAN es mas flexible que wildcard: puede listar dominios completamente diferentes.
- HSTS previene SSL stripping: el navegador rechaza HTTP aunque el atacante lo proponga.

1.4 ampliacion

Protocolos de Red Importantes

SSH (Secure Shell)
Protocolo cifrado para acceso remoto a terminales. Puerto 22. Reemplaza Telnet.
RDP (Remote Desktop
Protocol)
Protocolo Microsoft para escritorio remoto. Puerto 3389. Objetivo frecuente de ataques brute force.

SFTP

SSH File Transfer Protocol. Transferencia segura de archivos sobre SSH. Puerto 22.

FTPS

FTP sobre SSL/TLS. Puerto 990. Distinto de SFTP. Usa certificados.

FTP

File Transfer Protocol. Puerto 21. INSEGURO: datos en texto claro. Usar SFTP o FTPS.
SNMP (Simple Network
Mgmt Protocol)
Gestion de dispositivos de red. v1/v2c = inseguros (community strings en claro).
SNMPv3 = cifrado + autenticacion.
NAT (Network Address
Translation)
Traduce IPs privadas a publicas. Oculta la topologia interna. No es un control de seguridad per se.
VLAN (Virtual LAN)
Segmentacion logica de red dentro del mismo switch. Aisla trafico. Requiere router para comunicacion entre VLANs.
SDN (Software-Defined
Networking)
Separa el plano de control del plano de datos. Control centralizado y programable de la red.

TCP

Transmission Control Protocol. Orientado a conexion, fiable. 3-way handshake: SYN, SYN-ACK, ACK.

UDP

User Datagram Protocol. Sin conexion, mas rapido. Sin garantia de entrega. Usado en DNS, VoIP, streaming.

Puntos clave para el examen:

- RDP puerto 3389 = objetivo de ataques. Nunca exponer RDP directamente a internet. Usar VPN primero.
- SNMPv1/v2c: community string viaja en texto claro → cualquiera en la red puede leerla.
- SFTP vs FTPS: SFTP usa SSH (puerto 22). FTPS usa SSL/TLS (puerto 990). Son protocolos distintos.
- VLAN no es seguridad absoluta: VLAN hopping es posible si el switch esta mal configurado.
- TCP SYN flood = DoS que satura la tabla de conexiones a medio abrir del servidor.

1.4 ampliacion

Intercambio de Claves y Criptografia Avanzada

Diffie-Hellman (DH)
Protocolo de acuerdo de claves. Dos partes generan una clave compartida sin transmitirla. Base de TLS.
DHE (Diffie-Hellman

Efimero)
DH con claves temporales nuevas por sesion. Proporciona Perfect Forward Secrecy (PFS).
ECDHE (Elliptic Curve
DHE)
DHE usando curvas elipticas. Misma seguridad que DHE con claves mas cortas. Mas eficiente.
PFS (Perfect Forward
Secrecy)
Si la clave privada del servidor es robada, el trafico pasado NO puede descifrarse. Requiere DHE/ECDHE.

Key escrow
Copia de la clave de cifrado guardada por un tercero (gobierno, empresa). Para recuperacion o intervencion legal.

S/MIME cifrado
Usa clave publica del destinatario para cifrar. Solo el destinatario (clave privada) puede descifrar.
STIX (Structured Threat
Info Expression)
Formato estandar para compartir threat intelligence. Describe IOCs, TTPs, actores de amenaza.
TAXII (Trusted
Automated eXchange)
Protocolo de transporte para compartir inteligencia de amenazas en formato STIX. API REST.

Entropy
Aleatoriedad del sistema. Alta entropia = claves mas dificiles de predecir. Critico para generacion de claves.

Puntos clave para el examen:

- DH: ambas partes publican valores publicos, calculan el mismo secreto privado. Nadie que escucha puede calcularlo.
- PFS: TLS 1.3 obliga a PFS. TLS 1.2 puede usarlo opcionalmente con DHE/ECDHE cipher suites.
- Key escrow: controversial. Gobierno puede acceder a comunicaciones con orden judicial. Riesgo: si el escrow es comprometido.
- STIX+TAXII: estandar de la industria para compartir threat intel entre organizaciones y CERTs.
- Entropy baja: si el sistema tiene poca aleatoriedad, las claves generadas son predecibles (ej: routers con RNG defectuoso).
- ECDHE: preferido en TLS moderno por eficiencia. P-256, P-384, X25519 son las curvas mas comunes.

Teoria Complementaria — ExamCompass

IMPLICACIONES TECNICAS:

- Listas de permitidos/denegados: actualizar tras un cambio
- Tiempo de inactividad: planificar interrupciones
- Aplicaciones legacy: sistemas viejos que pueden romperse con nuevas dependencias
- Dependencias: un cambio en A puede romper B, C y D

DOCUMENTACION: siempre actualizar diagramas de red, politicas y procedimientos tras un cambio. Control de versiones para el
codigo y configuraciones.

Regla de oro del examen: si una pregunta menciona 'que hacer antes de implementar un cambio critico', la respuesta casi siempre

incluye 'plan de retroceso' y 'analisis de impacto'.

Preguntas de practica (4):

■ OCSP: protocolo para verificar en tiempo real si un certificado esta revocado

CIFRADO SIMETRICO vs ASIMETRICO:

■ Simetrico: misma clave para cifrar y descifrar. RAPIDO. Problema: distribucion segura de la clave

Algoritmos: AES (estandar actual, 128/256 bits), 3DES (obsoleto), ChaCha20

■ Asimetrico: par de claves publica/privada. LENTO. Resuelve el problema de distribucion

Algoritmos: RSA (2048+ bits), ECC (mas eficiente), Diffie-Hellman

■ En la practica: asimetrico intercambia la clave simetrica, luego simetrico para los datos (TLS/HTTPS)

HASHING - No es cifrado, es una huella digital:

■ Produce una salida de longitud fija a partir de cualquier entrada

■ Es UNIDIRECCIONAL: no se puede revertir

■ Algoritmos: MD5 (roto), SHA-1 (obsoleto), SHA-256/SHA-3 (actuales)

■ Salting: anadir un valor aleatorio antes de hashear para evitar ataques de tabla arcoiris

■ Estiramiento de clave (Key stretching): hacer el hash mas lento intencionalmente (bcrypt, PBKDF2, Argon2)

FIRMAS DIGITALES:

1. El emisor genera un hash del mensaje

2. Cifra ese hash con su CLAVE PRIVADA → firma digital

3. El receptor descifra la firma con la CLAVE PUBLICA del emisor

4. Compara el hash: si coincide, el mensaje es autentico e integro

Garantiza: autenticidad + integridad + no repudio

OTROS CONCEPTOS:

■ TPM (Modulo de Plataforma Confiable): chip en la placa base que almacena claves y verifica el arranque seguro

■ HSM (Modulo de Seguridad Hardware): dispositivo dedicado a operaciones criptograficas de alta seguridad

■ Esteganografia: ocultar informacion dentro de otros archivos (imagen, audio) sin que sea visible

■ Tokenizacion: sustituir datos sensibles por un token sin valor criptografico (usado en pagos)

■ Enmascaramiento de datos: ocultar parte de los datos (ej: mostrar solo los ultimos 4 digitos de una tarjeta)

Preguntas Topic — ExamCompass (31 preguntas)

1. ¿Cuál de las siguientes respuestas se refiere a un dispositivo de almacenamiento de datos equipado con funcionalidad de cifrado a nivel de hardware?

[EN: Which of the following answers refers to a data storage device equipped with hardware-level encryption functionality?]

A) HSM

B) TPM

C) EFS

✓ **D) SED**

Fuente: Topic: Encryption

2. Un componente de MS Windows que permite el cifrado de archivos individuales se llama:

A) SED

✓ **B) EFS**

C) BitLocker

D) FDE

Fuente: Topic: Encryption

3. ¿Cuál es el nombre de un protocolo de red que protege el tráfico web mediante cifrado SSL/TLS?

[EN: What is the name of a network protocol that secures web traffic via SSL/TLS encryption?]

✓ **A) SFTP**

✓ **B) HTTPS**

C) FTPS

D) SHTTP

Fuente: Topic: Encryption

4. SFTP es una extensión del protocolo FTP que agrega soporte para cifrado SSL/TLS.

A) Verdadero

✓ **B) FALSO**

Fuente: Topic: Encryption

5. ¿Qué parte de IPsec proporciona autenticación, integridad y confidencialidad?

[EN: Which part of IPsec provides authentication, integrity, and confidentiality?]

A) SPD

B) PFS

C) Ah

✓ **D) ESP**

Fuente: Topic: Encryption

6. ¿Qué protocolo permite la entrega segura y en tiempo real de audio y vídeo a través de una red IP?

[EN: Which protocol enables secure, real-time delivery of audio and video over an IP network?]

A) S/MIME

B) RTP

C) SORBO

✓ **D) SRTP**

Fuente: Topic: Encryption

7. ¿Qué protocolo criptográfico está diseñado para proporcionar comunicaciones seguras a través de una red informática y es el sucesor de SSL?

[EN: Which cryptographic protocol is designed to provide secure communications over a computer network and is the successor t]

A) IPSec

✓ **B) TLS**

C) AES

D) CCMP

Fuente: Topic: Encryption

8. En el cifrado asimétrico, cualquier mensaje cifrado con el uso de una clave pública sólo puede descifrarse aplicando el mismo algoritmo y una clave privada coincidente (y viceversa).

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Topic: Encryption

---

9. ¿Cuál de los siguientes algoritmos no entra en la categoría de cifrado asimétrico? (Seleccione todo lo que corresponda)

[EN: Which of the following algorithms do(es) not fall into the category of asymmetric encryption? (Select all that apply)]

A) AES

✓ B) DES

C) DHE

D) ECC

✓ E) IDEA

✓ F) RC4

G) RSA

Fuente: Topic: Encryption

---

10. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

[EN: Which of the answers listed below refers to a protocol used to set up secure connections and exchange of cryptographic k]

A) SSL

✓ B) IKE

C) ESP

D) DHE

Fuente: Topic: Encryption

---

11. ¿Cuál de las siguientes respuestas se refiere a un protocolo de intercambio de claves que genera claves temporales para cada sesión, proporcionando secreto directo para proteger las comunicaciones pasadas y futuras?

[EN: Which of the following answers refers to a key exchange protocol that generates temporary keys for each session, providi]

✓ A) PFS

B) sha

C) PGP

D) DHE

** Respuesta corregida manualmente*

Fuente: Topic: Encryption

---

12. ¿Cuál de las siguientes respuestas se refiere a un protocolo de intercambio de claves criptográficas que aprovecha ECC para mejorar la seguridad y la eficiencia?

[EN: Which of the following answers refers to a cryptographic key exchange protocol that leverages ECC for enhanced security]

A) S/MIME

✓ B) ECDHE

C) DHE

D) ECDSA

** Respuesta corregida manualmente*

Fuente: Topic: Encryption

---

13. ¿Cuál de las siguientes respuestas se refiere a un algoritmo de cifrado de bloque de clave simétrica obsoleto (en gran medida reemplazado por AES)?

[EN: Which of the following answers refers to a deprecated (largely replaced by AES) symmetric-key block cipher encryption al]

A) ECDSA
B) RSA
✓ **C) IDEA**
D) DSA

** Respuesta corregida manualmente*

Fuente: Topic: Encryption

---

14. Un modo de cifrado de bloques que combina un contador único con una clave de cifrado para generar un flujo de bloques de datos pseudoaleatorios que luego se utilizan para cifrar datos se denomina:

A) CBC
B) GCM
C) CFB
✓ **D) marca comunitaria**

Fuente: Topic: Encryption

---

15. ¿Qué modo de cifrado en bloque combina CTM para el cifrado con un mecanismo de autenticación para garantizar la confidencialidad e integridad de los datos?

[EN: Which block cipher mode combines CTM for encryption with an authentication mechanism to ensure both data confidentiality]

A) CBC
✓ **B) GCM**
C) BCE
D) CFB

Fuente: Topic: Encryption

---

16. ¿Qué longitud de clave AES proporciona el mayor nivel de seguridad?

[EN: Which AES key length provides the highest level of security?]

A) clave de 128 bits
B) clave de 192 bits
✓ **C) clave de 256 bits**
D) clave de 320 bits

Fuente: Topic: Encryption

---

17. Una función hash es un algoritmo matemático que asigna datos de tamaño arbitrario a un valor hash de tamaño fijo, generalmente representado como una cadena corta de caracteres. El resultado de la función hash, también conocido como resumen o suma de comprobación, proporciona una representación única de la entrada de datos original. La funcionalidad de las funciones hash se basa en el hecho de que si hay algún cambio en los datos después de generar el hash original, el nuevo valor hash calculado después de la modificación del contenido será diferente del resultado original porque las funciones hash están diseñadas para ser sensibles a los cambios en los datos de entrada.

✓ **A) Verdadero**
B) FALSO

** Respuesta corregida manualmente*

Fuente: Topic: Hashing

---

18. ¿Cuál de las respuestas enumeradas a continuación se refiere a una función hash criptográfica que se ha utilizado ampliamente en el pasado pero que ahora se considera obsoleta para aplicaciones sensibles a la seguridad debido a vulnerabilidades conocidas?

[EN: Which of the answers listed below refers to a cryptographic hash function that has been widely used in the past but is n]

✓ **A) MD5**

B) sha

C) CDN

D) HMAC

** Respuesta corregida manualmente*

Fuente: Topic: Hashing

---

19. ¿Cuál de las funciones hash enumeradas a continuación ofrece el mayor nivel de seguridad?

[EN: Which of the hash functions listed below offers the highest level of security?]

A) MD5

✓ **B) SHA-3**

C) RIPEMD-160

✓ **D) HMAC**

Fuente: Topic: Hashing

---

20. ¿Cuál de las respuestas enumeradas a continuación se refiere a una función hash no criptográfica que se utiliza a menudo con fines de verificación de errores?

[EN: Which of the answers listed below refers to a non-cryptographic hash function often used for error-checking purposes?]

A) MD5

✓ **B) CDN**

C) sha

D) RIPEMD

Fuente: Topic: Hashing

---

21. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica criptográfica que verifica la autenticidad e integridad de documentos o mensajes digitales mediante el uso de un identificador cifrado único del remitente?

[EN: Which of the answers listed below refers to a cryptographic technique that verifies the authenticity and integrity of di]

✓ **A) Firma digital**

B) Función hash criptográfica

C) Certificado digital

D) Cifrado asimétrico

** Respuesta corregida manualmente*

Fuente: Topic: Digital Signatures

---

22. ¿Cuál de las siguientes respuestas se refiere a algoritmos utilizados para generar y verificar firmas digitales? (Seleccione 3 respuestas)

[EN: Which of the following answers refer to algorithms used for generating and verifying digital signatures? (Select 3 answe]

✓ **A) ECDSA**

✓ **B) RSA**

C) ECDHE

✓ **D) DSA**

E) GPG/PGP

** Respuesta corregida manualmente*

Fuente: Topic: Digital Signatures

---

23. Dadas las limitaciones computacionales de los dispositivos IoT, las tarjetas inteligentes y los dispositivos móviles, ¿cuál de los siguientes algoritmos de firma digital sería la opción más eficiente debido a su menor tamaño de clave y menores requisitos de procesamiento?

[EN: Given the computational limitations of IoT devices, smartcards, and mobile devices, which of the following digital signa]

A) RSA

B) ECDHE

C) DSA

✓ D) ECDSA

E) ECC

Fuente: Topic: Digital Signatures

---

24. Un tipo de documento digital que verifica la identidad de un individuo, dispositivo, servicio u organización en las comunicaciones en línea se conoce como:

A) Clave de cifrado

✓ B) Certificado digital

C) Token de identidad

D) Firma digital

Fuente: Topic: Digital Certificates

---

25. ¿Cuál de las respuestas enumeradas a continuación se refiere a un tercero de confianza responsable de emitir, revocar y gestionar los certificados digitales?

[EN: Which of the answers listed below refers to a trusted third party responsible for issuing, revoking, and managing digita]

A) REAL ACADEMIA DE BELLAS ARTES

B) DN

✓ C) California

D) CSP

Fuente: Topic: Digital Certificates

---

26. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo que permite consultar bajo demanda el estado de revocación de un certificado digital?

[EN: Which of the answers listed below refers to a protocol that enables on-demand querying of the revocation status of a dig]

A) CSP

✓ B) OCSP

C) DN

D) CRL

Fuente: Topic: Digital Certificates

---

27. ¿Cuál de las siguientes respuestas se puede utilizar para describir los certificados digitales autofirmados? (Seleccione 3 respuestas)

[EN: Which of the following answers can be used to describe self-signed digital certificates? (Select 3 answers)]

A) Respaldado por un tercero conocido y confiable

✓ B) Los navegadores web y otras aplicaciones no confían de forma predeterminada

✓ C) Se utiliza en entornos confiables, como redes internas y entornos de desarrollo.

D) Adecuado para sitios web y otras aplicaciones accesibles al público

E) Confiado de forma predeterminada por los navegadores web y otras aplicaciones

✓ F) No respaldado por un tercero conocido y confiable

Fuente: Topic: Digital Certificates

---

28. Los certificados digitales de terceros, emitidos por CA confiables, son automáticamente confiables para la mayoría de los navegadores y sistemas operativos, implican un costo y requieren la validación de la identidad del solicitante. Por el contrario, los certificados autofirmados, emitidos por la propia entidad, no son de confianza automáticamente, son de creación y uso gratuitos y no requieren

validación por parte de una CA.

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Topic: Digital Certificates

---

29. ¿Cuál de las respuestas enumeradas a continuación se refiere a un modelo de confianza PKI?

[EN: Which of the answers listed below refers to a PKI trust model?]

A) Modelo de CA única

B) Modelo jerárquico (CA raíz + CA intermedias)

C) Modelo de malla (CA con certificación cruzada)

D) Modelo web de confianza (todas las CA funcionan como CA raíz)

E) Modelo de cadena de confianza (múltiples CA en una cadena secuencial)

F) Modelo puente (certificación cruzada entre PKI independientes)

G) Modelo híbrido (combinando aspectos de diferentes modelos)

✓ **H) Todo lo anterior**

Fuente: Topic: Digital Certificates

---

30. Un tipo de certificado digital que se puede utilizar para proteger varios subdominios dentro de un dominio principal se denomina:

A) Certificado de firma raíz

✓ **B) Certificado de nombre alternativo del sujeto (SAN)**

C) Certificado de validación extendida (EV)

✓ **D) Certificado comodín**

Fuente: Topic: Digital Certificates

---

31. ¿Cuál de las respuestas enumeradas a continuación se refiere a un identificador utilizado para objetos PKI?

[EN: Which of the answers listed below refers to an identifier used for PKI objects?]

✓ **A) OID**

B) DN

C) SAN

D) GUID

** Respuesta corregida manualmente*

Fuente: Topic: Digital Certificates

Preguntas Adicionales — Generadas (4 preguntas)

1. ¿Cuál es la longitud de clave mínima recomendada para AES en aplicaciones de seguridad moderna?

✓ **A) 128 bits**

B) 56 bits

C) 64 bits

D) 512 bits

Fuente: Extra: Cryptography

---

2. ¿Qué ventaja ofrece ECC (Elliptic Curve Cryptography) sobre RSA?

✓ **A) Misma seguridad con claves más cortas, menor consumo de recursos**

B) Mayor longitud de clave para mayor seguridad

C) Es un algoritmo simétrico más rápido

D) No requiere intercambio de claves

Fuente: Extra: Cryptography

---

3. ¿Qué es una 'rainbow table' y cómo se contrarresta?

✓ A) Tabla de hashes precalculados; se contrarresta con salting

B) Ataque de fuerza bruta; se contrarresta con contraseñas largas

C) Lista de contraseñas comunes; se contrarresta con MFA

D) Técnica de cifrado débil; se contrarresta con AES

Fuente: Extra: Cryptography

---

4. ¿Cuál de las siguientes afirmaciones sobre TLS 1.3 es correcta?

✓ A) Elimina algoritmos débiles como MD5 y RC4, y reduce el handshake a 1-RTT

B) Es compatible con SSLv3 por retrocompatibilidad

C) Usa cifrado simétrico RSA para el intercambio de claves

D) Requiere certificados de 512 bits mínimo

Fuente: Extra: Cryptography

Flashcards — 1.4 (9 tarjetas)

Q: AES — características clave	Simétrico · Bloques de 128 bits · Claves: 128/192/256 bits · Estándar actual recomendado
Q: RSA — características clave	Asimétrico · Basado en factorización de números primos · Claves largas (2048+ bits) · Lento para grandes volúmenes
Q: ECC ventaja sobre RSA	Misma seguridad con claves MUCHO más cortas. Ej: ECC 256 bits ≈ RSA 3072 bits
Q: Hash: SHA-256 vs MD5	SHA-256: seguro, 256 bits, recomendado
	MD5: OBSOLETO, vulnerable a colisiones, solo para checksums no críticos
Q: ¿Qué es el Salt en hashing?	Valor aleatorio añadido a la contraseña ANTES de hashear. Previene ataques de rainbow table
Q: PKI — jerarquía	Root CA → Intermediate CA → Certificado de entidad final
	CA = Certificate Authority (emite/revoca certificados)
Q: CRL vs OCSP	CRL: lista de certificados revocados (descarga periódica)
	OCSP: consulta en tiempo real si un certificado está revocado
Q: ¿Qué ofrece PFS (Perfect Forward Secrecy)?	Claves de sesión temporales. Si se compromete la clave privada, las sesiones pasadas siguen protegidas
Q: TLS 1.3 mejoras principales	Elimina MD5, RC4, DES · Handshake en 1-RTT (más rápido) · PFS obligatorio · Sin renegociación insegura

DOMINIO 2 Amenazas, Vulnerabilidades y Mitigaciones (22% del examen)

2.1 Actores de amenaza

Conceptos Clave — Professor Messer

Actores de Amenaza (Threat Actors)
Nation-state / APT
Estado-nacion patrocinado. Recursos ilimitados, alta sofisticacion. APT = Advanced Persistent Threat.

Hacktivista
Motivacion ideologica o politica. Ataques de denegacion de servicio, defacement web.

Crimen organizado
Motivacion economica. Ransomware, robo de tarjetas, fraude financiero.
Insider (interno)
Empleado o ex-empleado con acceso legitimo. Puede ser malicioso o accidental.

Script kiddie
Atacante sin conocimiento propio. Usa herramientas prehechas de otros.

Shadow IT
Sistemas o servicios usados sin aprobacion de IT. Riesgo por falta de control.
IOC (Indicator of Compromise)
Evidencia de que un sistema ha sido comprometido: trfico inusual, hashes modificados, logins imposibles.

Puntos clave para el examen:

- Nation-state = mas sofisticado y peligroso. APT puede estar meses sin ser detectado.
- Insider = mayor riesgo real: tiene acceso legitimo y conoce la infraestructura.
- Script kiddie = bajo nivel tecnico pero puede causar dano con herramientas automatizadas.
- IOC: cuenta bloqueada, trafico inusual, logins desde ubicaciones imposibles, datos cifrados = ransomware.
- Diferencia clave: motivacion. Economica (crimen) vs. ideologica (hacktivista) vs. espionaje (APT).

Teoria Complementaria — ExamCompass

2.0 Amenazas, Vulnerabilidades y Mitigaciones (22% del examen)

2.1 - Comparar y contrastar los actores de amenaza comunes y sus motivaciones.

■ Actores: Estado-nacion, Atacante sin habilidades, Hacktivist, Amenaza interna, Crimen organizado, Shadow IT

■ Atributos: Interno/externo, Recursos/financiacion, Nivel de sofisticacion

■ Motivaciones: Exfiltracion de datos, Espionaje, Ganancia economica, Disrupcion, Venganza, Guerra

TIPOS DE ACTORES DE AMENAZA:

■ Estado-nacion (Nation-state): los mas sofisticados y con mas recursos. Motivacion: espionaje, sabotaje. Ejemplo: APT grupos

como Lazarus (Corea del Norte)

■ Crimen organizado: motivacion economica, ransomware, fraude

■ Hacktivist: motivacion ideologica o politica. Ejemplo: Anonymous

■ Amenaza interna (Insider threat): empleado o ex-empleado con acceso legitimo. Puede ser malicioso o accidental

■ Atacante sin habilidades (Script kiddie): usa herramientas de otros sin entender como funcionan

■ Shadow IT: sistemas o servicios usados sin aprobacion del departamento IT

ATRIBUTOS DE LOS ACTORES:

■ Interno vs Externo: interno (empleado) vs externo (hacker desde fuera)

■ Recursos/financiacion: desde ninguno (script kiddie) hasta presupuestos millonarios (estado-nacion)

■ Sofisticacion: desde ataques de phishing basicos hasta exploits de zero-day personalizados

MOTIVACIONES (el POR QUE atacan):

■ Exfiltracion de datos: robar datos para venderlos o usarlos

■ Ganancia economica: ransomware, fraude, robo de credenciales bancarias

■ Espionaje: robar secretos industriales o gubernamentales

■ Disrupcion/Caos: tirar sistemas sin motivo economico

■ Filosofico/Politico: hacktivismo

■ Venganza: empleado descontento

■ Guerra: ciberguerra entre estados

APT (Amenaza Persistente Avanzada): actor sofisticado (normalmente estado-nacion) que permanece en la red de la victima

durante meses o anos sin ser detectado, extrayendo informacion de forma continua.

Preguntas de practica (26):

5. En la lista desplegable de la derecha, seleccione las motivaciones típicas detrás de las acciones de cada

tipo de actor de amenaza.

Respuesta no detectada automaticamente

14. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software

automatizado (como los robots de red) se conoce como:

Preguntas Topic — ExamCompass (5 preguntas)

1. Elija una respuesta de la lista desplegable de la derecha para hacer coincidir un tipo de actor de amenaza a la izquierda con su atributo de vector de ataque común.

Pregunta interactiva (drag-and-drop). Drag-and-drop: Nation-state=Direct hacking; Insider=Internal access; Script kiddie=Public exploits; Hacktivista=Public defacement; Crimen organizado=Financial fraud

Fuente: Topic: Threat Actor Types

2. Relacione cada tipo de actor de amenaza con su correspondiente atributo de recursos/financiación.

Pregunta interactiva (drag-and-drop). Drag-and-drop: Nation-state=Well-funded; Insider=Minimal; Script kiddie=Minimal; Hacktivista=Crowd-funded; Crimen organizado=Well-funded

Fuente: Topic: Threat Actor Types

3. Asigne el atributo de nivel de sofisticación a cada tipo de actor de amenazas que se enumera a continuación.

Pregunta interactiva (drag-and-drop). Drag-and-drop: Nation-state=Highly sophisticated; Insider=Low-Moderate; Script kiddie=Low; Hacktivista=Low-Moderate; Crimen organizado=Moderate-High

Fuente: Topic: Threat Actor Types

---

4. En la lista desplegable de la derecha, seleccione las motivaciones típicas detrás de las acciones de cada tipo de actor de amenaza.

Pregunta interactiva (drag-and-drop). Drag-and-drop: Nation-state=Espionage/disruption; Insider=Financial gain/revenge; Script kiddie=Notoriety; Hacktivista=Ideology; Crimen organizado=Financial gain

Fuente: Topic: Threat Actor Types

---

5. ¿Cuál de los siguientes términos se utiliza para describir ciberataques sofisticados y prolongados, a menudo llevados a cabo por grupos organizados y bien financiados, como los Estados-nación?

[EN: Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-fund]

A) MitM

✓ B) APTO

C) XSRF

D) DDoS

Fuente: Topic: Threat Actor Types

Preguntas Adicionales — Generadas (7 preguntas)

1. ¿Cuál de los siguientes actores de amenaza tiene típicamente más recursos y mayor sofisticación?

✓ A) Estado-nación (Nation-state)

B) Script kiddie

C) Hacktivista

D) Insider sin privilegios

Fuente: Extra: Threat Actors

---

2. Un empleado descontento que filtra información confidencial de su empresa es un ejemplo de:

✓ A) Insider threat

B) APT

C) Script kiddie

D) Hacktivista

Fuente: Extra: Threat Actors

---

3. ¿Cuál de los siguientes actores usa como vector principal el acceso INTERNO a la organización?

✓ A) Insider threat

B) Nation-state

C) Script kiddie

D) Hacktivista

Fuente: Extra: Threat Actor Types

---

4. Un nation-state actor tiene como motivación principal:

✓ A) Espionaje / disrupción geopolítica

B) Notoriedad personal

C) Ganancia económica directa

D) Protesta ideológica

Fuente: Extra: Threat Actor Types

---

5. ¿Qué nivel de sofisticación técnica caracteriza a un script kiddie?

✓ A) Bajo — usa herramientas ya creadas por otros

B) Alto — desarrolla sus propios zero-days

C) Medio — tiene conocimientos básicos de programación

D) Muy alto — respaldado por un Estado

Fuente: Extra: Threat Actor Types

---

6. La motivación principal de un hacktivista es:

✓ A) Ideología o protesta política/social

B) Ganancia económica

C) Espionaje gubernamental

D) Sabotaje de ex-empleado

Fuente: Extra: Threat Actor Types

---

7. ¿Cuál de los siguientes actores tiene típicamente el mayor nivel de financiación?

✓ A) Nation-state

B) Hacktivista

C) Script kiddie

D) Insider sin privilegios

Fuente: Extra: Threat Actor Types

Flashcards — 2.1 (2 tarjetas)

Q: APT (Advanced Persistent Threat) — 3 características	Avanzado (técnicas sofisticadas) · Persistente (meses/años en la red) · Amenaza (objetivo específico de alto valor)
Q: 5 tipos principales de actores de amenaza	Nation-state · Crimen organizado · Hacktivista · Insider · Script kiddie

2.2 Vectores e ingenieria social

Conceptos Clave — Professor Messer

Vectores de Amenaza Comunes

Vector de amenaza

Metodo que usa un atacante para ganar acceso. Tambien llamado vector de ataque.

Phishing

Email falso que imita una fuente de confianza para robar credenciales o instalar malware.

Smishing

Phishing via SMS / mensajes de texto.

Vishing

Phishing por voz / llamada telefonica. Suplantan bancos, Microsoft, etc.

Spear phishing

Phishing dirigido a una persona o empresa especifica. Mas convincente.

Whaling

Spear phishing dirigido a altos ejecutivos (C-suite).

Typosquatting

Registrar dominio con error tipografico. Ej: professormessor.com en vez de professormesser.com

Watering hole

Infectar un sitio web que visitan los empleados objetivo (ej: web de la cafeteria).

USB drop

Dejar USB con malware en el aparcamiento esperando que alguien lo conecte.

Supply chain

Comprometer la cadena de suministro: hardware, software o proveedor de servicios.

Puntos clave para el examen:

- Phishing funciona mejor con urgencia y miedo: 'tu cuenta sera bloqueada si no actuas ahora'.
- SVG images pueden contener Javascript malicioso embebido en el XML.
- USB puede emular un teclado y escribir comandos automaticamente al conectarse.
- Watering hole: si los empleados son muy precavidos, infecta los sitios que ELLOS visitan.
- Supply chain: el ataque SolarWinds Orion (2020) comprometio 18,000 organizaciones incluyendo gobierno EEUU.
- Default credentials: admin/admin, admin/password. Cambiarlas siempre en el primer inicio de sesion.

Tecnicas de Ingenieria Social

Pretexting

El atacante inventa una historia creible para obtener informacion. Ej: 'soy del departamento IT'

Impersonacion

Hacerse pasar por alguien de confianza: jefe, banco, soporte tecnico.

Elicitacion

Extraer informacion mediante conversacion aparentemente inocente.

Identity fraud

Usar datos robados para abrir cuentas, pedir prestamos o acceder a servicios a nombre de la victima.

Misinformation / Disinformation

Difundir informacion falsa para confundir o manipular. Campanas de influencia en redes sociales.

Brand impersonation

Usar marcas conocidas (Coca-Cola, Microsoft) para dar credibilidad al ataque.

Puntos clave para el examen:

- NUNCA dar informacion personal por telefono si NO iniciaste tu la llamada.
- Verificar siempre la identidad del interlocutor usando un numero oficial (no el que ellos dan).
- El help desk NUNCA necesita tu contrasena para resolver un problema.
- Campanas de desinformacion: cuentas falsas → publican contenido → likes/shares propios → algoritmo → difusion masiva.

2.2 ampliacion

Seguridad WiFi — Protocolos y Ataques

WEP

Wired Equivalent Privacy. OBSOLETO. Cifrado RC4. Roto en minutos. NUNCA usar.

WPA

Wi-Fi Protected Access. Mejora de WEP. TKIP. Deprecated.

WPA2

Usa AES-CCMP. Dos modos: Personal (PSK) y Enterprise (802.1X + RADIUS).

Estandar actual.
WPA3
Sucesor de WPA2. SAE (Simultaneous Authentication of Equals) en vez de PSK. Resistente a ataques offline de diccionario.
WPS (Wi-Fi Protected Setup)
Facilita conexion de dispositivos con PIN de 8 digitos. VULNERABLE: el PIN se rompe en horas (Reaver). Deshabilitar.
802.1X
Estandar de control de acceso a red basado en puerto. Requiere autenticacion antes de acceder a la red. Usa EAP + RADIUS.
EAP (Extensible Authentication Protocol)
Framework de autenticacion. Tipos: EAP-TLS (certificados, mas seguro), PEAP (contrasena + TLS tunnel), EAP-TTLS.

PEAP
Protected EAP. Encapsula EAP dentro de TLS. Permite autenticacion con contrasena de forma segura.

Evil Twin
Punto de acceso WiFi falso con el mismo SSID que el legitimo. Ataque MITM. Capta credenciales WiFi.

Rogue AP
Punto de acceso no autorizado conectado a la red corporativa. Puede ser instalado por un insider.

Bluesnarfing
Acceso no autorizado a datos de un dispositivo Bluetooth (contactos, emails, fotos) sin consentimiento.

Bluejacking
Envio de mensajes no solicitados por Bluetooth. Molesto pero no destructivo.
NFC (Near Field Communication)
Comunicacion a muy corta distancia (< 4cm). Pagos sin contacto. Vulnerable a skimming y relay attacks.

SSID
Service Set Identifier. Nombre de la red WiFi. Ocultar el SSID NO es seguridad (se puede descubrir con Wireshark).

Puntos clave para el examen:

- Orden de seguridad WiFi (de menos a mas): WEP < WPA < WPA2-Personal < WPA2-Enterprise < WPA3.
- WPA2-Enterprise + 802.1X + EAP-TLS = configuracion mas segura (certificados mutuos).
- WPS: aunque este con PIN, tiene vulnerabilidad en el protocolo. SIEMPRE deshabilitar WPS.
- Evil Twin vs Rogue AP: Evil Twin = externo simulando red legitima. Rogue AP = interno sin autorizacion.
- NFC relay attack: dos dispositivos amplian el alcance NFC para realizar pagos sin que la victima lo sepa.

Teoria Complementaria — ExamCompass

- Smishing: phishing por SMS
- Pretexting: crear un escenario falso para obtener informacion (ej: hacerse pasar por soporte IT)
- Watering hole: comprometer un sitio web que la victima visita frecuentemente
- Typosquatting: registrar dominios con erratas (gooogle.com) para capturar trafico
- BEC (Compromiso de Email Empresarial): suplantar al CEO para ordenar transferencias bancarias

Preguntas de practica (30):

1. Un ataque BEC es un ejemplo de:

8. El término "secuestro de URL" (también conocido como "Typosquatting") se refiere a una práctica engañosa que implica el registro deliberado de nombres de dominio con errores ortográficos o ligeras variaciones que se parecen mucho a nombres de dominio populares y bien establecidos. El objetivo principal de esta estrategia es explotar los errores tipográficos comunes que cometen los usuarios al ingresar URL en la barra de direcciones de su navegador web. Más allá de capturar tráfico inadvertido, la typosquatting también se puede utilizar para alojar sitios de phishing para engañar a los usuarios para que divulguen información confidencial, distribuir malware a través de sitios web engañosos, generar ingresos publicitarios al redirigir el tráfico mal escrito o participar en la suplantación de marcas para dañar la reputación de marcas auténticas o engañar a los usuarios.

14. Cuando los registrantes de dominio debido a acciones ilegales de terceros pierden el control sobre sus nombres de dominio, son víctimas de:

21. Una función hash es un algoritmo matemático que asigna datos de tamaño arbitrario a un valor hash de tamaño fijo, generalmente representado como una cadena corta de caracteres. El resultado de la función hash, también conocido como resumen o suma de comprobación, proporciona una representación única de la entrada de datos original. La funcionalidad de las funciones hash se basa en el hecho de que si hay algún cambio en los datos después de generar el hash original, el nuevo valor hash calculado después de la modificación del contenido será diferente del resultado original porque las funciones hash están diseñadas para ser sensibles a los cambios en los datos de entrada.

Respuesta no detectada automaticamente

22. Una superficie de ataque es la suma de todos los puntos potenciales (vulnerabilidades) a través de los cuales un atacante puede interactuar o comprometer un sistema o red, lo que indica la exposición general a amenazas potenciales. Ejemplos de superficies de ataque pueden ser todo software, hardware e interfaces de red con fallas de seguridad conocidas. Un vector de amenaza representa el método o medio a través del cual se introduce o entrega una amenaza cibernética a un sistema objetivo. Describe la vía o vía utilizada por los atacantes para explotar las vulnerabilidades. Los tipos de vectores de amenazas comunes incluyen correos electrónicos de phishing, malware, descargas no autorizadas y técnicas de ingeniería social.

Respuesta no detectada automaticamente

Preguntas Topic — ExamCompass (18 preguntas)

1. Una superficie de ataque es la suma de todos los puntos potenciales (vulnerabilidades) a través de los cuales un atacante puede interactuar o comprometer un sistema o red, lo que indica la exposición general a amenazas potenciales. Ejemplos de superficies de ataque pueden ser todo software, hardware e interfaces de red con fallas de seguridad conocidas. Un vector de amenaza representa el método o medio a través del cual se introduce o entrega una amenaza cibernética a un sistema objetivo. Describe la vía o vía utilizada por los atacantes para explotar las vulnerabilidades. Los tipos de vectores de amenazas comunes incluyen correos electrónicos de phishing, malware, descargas no autorizadas y técnicas de ingeniería social.

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Topic: Threat Vectors

---

2. ¿Cuál de las respuestas enumeradas a continuación se refiere a un vector de amenaza basado en correo electrónico?

[EN: Which of the answers listed below refers to an email-based threat vector?]

A) suplantación de identidad

B) Phishing

C) Ataques BEC

D) Enlaces maliciosos

E) Archivos adjuntos de malware

✓ **F) Todo lo anterior**

Fuente: Topic: Threat Vectors

---

3. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de un vector de amenaza potencial en la comunicación basada en mensajería instantánea?

[EN: Which of the answers listed below refers to an example of a potential threat vector in IM-based communication?]

A) Ataque de phishing

B) Distribución de malware

C) Ataque de suplantación de identidad

D) Escuchar a escondidas

E) Secuestro de cuenta

F) Enlace/adjunto malicioso

✓ **G) Todo lo anterior**

Fuente: Topic: Threat Vectors

---

4. ¿Cuál de las siguientes respuestas se refiere a ejemplos de vectores de amenazas basados ■■en imágenes? (Seleccione 3 respuestas)

[EN: Which of the following answers refer to examples of image-based threat vectors? (Select 3 answers)]

✓ **A) esteganografía**

B) Ataques BEC

✓ **C) Suplantación de imágenes (deepfakes)**

D) Suplantación de marca

✓ **E) Imágenes con malware incorporado**

** Respuesta corregida manualmente*

Fuente: Topic: Threat Vectors

---

5. ¿Cuál de las respuestas enumeradas a continuación se refiere a un vector de amenaza basado en archivos?

[EN: Which of the answers listed below refers to a file-based threat vector?]

A) Explotaciones de PDF

B) Macros maliciosas en documentos

C) Archivos comprimidos (ZIP, RAR)

D) Scripts maliciosos en páginas web

E) Imágenes infectadas

F) Ejecutables maliciosos

✓ **G) Todo lo anterior**

** Respuesta corregida manualmente*

Fuente: Topic: Threat Vectors

---

6. Una técnica de ingeniería social mediante la cual los atacantes, disfrazados de una solicitud legítima, intentan obtener acceso a información confidencial se denomina comúnmente:

✓ **A) Phishing**

B) aplastando

C) Farmacéutica

D) suplantación de identidad

** Respuesta corregida manualmente*

Fuente: Topic: Social Engineering

---

7. ¿Cuál de las siguientes respuestas se refiere a un ataque de ingeniería social que aprovecha los SMS o mensajes de texto para engañar a los destinatarios para que realicen acciones dañinas, como revelar información confidencial o hacer clic en enlaces maliciosos?

[EN: Which of the following answers refers to a social engineering attack that exploits SMS or text messages to deceive recip]

A) Farmacéutica

B) suplantación de identidad

C) quishing

✓ **D) aplastando**

Fuente: Topic: Social Engineering

---

8. ¿Cuál de los siguientes términos describe mejor información deliberadamente falsa o engañosa difundida con la intención de engañar o manipular?

[EN: Which of the following terms best describes deliberately false or misleading information spread with the intent to decei]

✓ **A) Desinformación**

B) Engaño

C) Iluminación de gas

D) Manipulación

** Respuesta corregida manualmente*

Fuente: Topic: Social Engineering

---

9. Un ataque BEC es un ejemplo de:

A) aplastando

✓ **B) Phishing**

C) vishing

D) Farmacéutica

Fuente: Topic: Social Engineering

---

10. ¿Cuál de los siguientes términos se refiere a una plataforma común para ataques a abrevaderos?

[EN: Which of the following terms refers to a common platform for watering hole attacks?]

A) Pasarelas de correo

✓ **B) Sitios web**

C) sistemas PBX

D) Navegadores web

Fuente: Topic: Social Engineering

---

11. El término "Typosquatting" se refiere a una práctica engañosa que implica el registro deliberado de nombres de dominio con errores ortográficos o ligeras variaciones que se parecen mucho a nombres

de dominio populares y bien establecidos. El objetivo principal de esta estrategia es explotar los errores tipográficos comunes que cometen los usuarios al ingresar URL en la barra de direcciones de su navegador web. Más allá de capturar tráfico inadvertido, la typosquatting también se puede utilizar para alojar sitios de phishing para engañar a los usuarios para que divulguen información confidencial, distribuir malware a través de sitios web engañosos, generar ingresos publicitarios al redirigir el tráfico mal escrito o participar en la suplantación de marcas para dañar la reputación de marcas auténticas o engañar a los usuarios.

✓ A) Verdadero

B) FALSO

** Respuesta corregida manualmente*

Fuente: Topic: Social Engineering

---

12. ¿Cuál sería una respuesta apropiada del usuario ante un intento de phishing por correo electrónico? (Seleccione todo lo que corresponda)

[EN: What would be an appropriate user response to an email phishing attempt? (Select all that apply)]

A) No responder al mensaje ni proporcionar ningún dato personal.

✓ B) Reportar el mensaje al departamento de TI o seguridad, si corresponde

✓ C) Eliminar el mensaje de la bandeja de entrada

✓ D) No hacer clic en ningún enlace ni descargar ningún archivo adjunto en el mensaje

E) Reenviar el mensaje al remitente para verificar su legitimidad

F) Abrir el archivo adjunto en un entorno sandbox para comprobar su seguridad

Fuente: Topic: Social Engineering

---

13. Un SSID es un identificador único (también conocido como nombre de red inalámbrica) para una WLAN. Las redes inalámbricas anuncian su presencia transmitiendo periódicamente SSID en un paquete especial llamado marco de baliza. En redes inalámbricas con funciones de seguridad deshabilitadas, conocer el SSID de la red es suficiente para acceder a la red. SSID también identifica el enrutador inalámbrico que actúa como WAP. Los enrutadores inalámbricos del mismo fabricante suelen configurarse con nombres SSID predeterminados (conocidos). Dado que varios dispositivos con el mismo SSID mostrado en la lista de redes disponibles crean confusión y fomentan el acceso accidental por parte de usuarios no autorizados (se aplica a redes que carecen de seguridad), cambiar el SSID predeterminado es una práctica recomendada.

✓ A) Verdadero

B) FALSO

** Respuesta corregida manualmente*

Fuente: Topic: Wireless Security

---

14. ¿Cuál de las siguientes respuestas se refiere a una función de seguridad utilizada en el emparejamiento de dispositivos Bluetooth?

[EN: Which of the following answers refers to a security feature used in Bluetooth device pairing?]

A) SAE

✓ B) ALFILER

C) Ministerio de Asuntos Exteriores

D) LCA

Fuente: Topic: Wireless Security

---

15. ¿Cuáles son las características del modo empresarial WPA2/WPA3? (Seleccione 3 respuestas)

[EN: What are the characteristic features of WPA2/WPA3 Enterprise mode? (Select 3 answers)]

A) Adecuado para grandes redes corporativas

B) IEEE 802.1D

C) No requiere un servidor de autenticación

✓ **D) IEEE 802.1X**

E) Adecuado para todo tipo de LAN inalámbricas

✓ **F) Requiere servidor de autenticación RADIUS**

Fuente: Topic: Wireless Security

---

16. ¿Cuál de las siguientes siglas se refiere a un método de autenticación de cliente utilizado en el modo WPA3 Personal?

[EN: Which of the following acronyms refers to a client authentication method used in WPA3 Personal mode?]

✓ **A) SAE**

B) IKE

C) PSK

D) AES

** Respuesta corregida manualmente*

Fuente: Topic: Wireless Security

---

17. ¿Cuál de los esquemas de cifrado inalámbrico enumerados a continuación ofrece el mayor nivel de protección?

[EN: Which of the wireless encryption schemes listed below offers the highest level of protection?]

A) WPS

✓ **B) WPA3**

C) AES

D) TKIP

Fuente: Topic: Wireless Security

---

18. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de autenticación de red inalámbrica estándar abierto que mejora la seguridad al encapsular el proceso de autenticación dentro de un túnel TLS cifrado?

[EN: Which of the answers listed below refers to an open standard wireless network authentication protocol that enhances secu]

✓ **A) PEAP**

B) PAE

C) SALTO

D) RADIO

** Respuesta corregida manualmente*

Fuente: Topic: Wireless Security

Preguntas Adicionales — Generadas (2 preguntas)

1. ¿Cuál es la diferencia entre phishing y spear phishing?

✓ **A) Spear phishing es dirigido a un individuo o grupo específico; phishing es masivo**

B) Phishing usa SMS; spear phishing usa email

C) Spear phishing ataca infraestructura; phishing ataca personas

D) Son el mismo ataque con diferente nombre

Fuente: Extra: Social Engineering

---

2. ¿Cómo se llama el ataque de phishing dirigido a ejecutivos de alto nivel?

✓ **A) Whaling**

B) Vishing

C) Smishing

D) Pharming

Fuente: Extra: Social Engineering

Flashcards — 2.2 (4 tarjetas)

Q: Phishing vs Spear Phishing vs Whaling	Phishing: masivo, sin objetivo
	Spear: dirigido a individuo/grupo específico
	Whaling: dirigido a ejecutivos C-level
Q: Smishing vs Vishing	Smishing: phishing por SMS
	Vishing: phishing por voz/llamada telefónica
Q: ¿Qué es Quishing?	QR code phishing — código QR malicioso que dirige a sitio de phishing
Q: Evil Twin vs Rogue AP	Evil Twin: AP falso que imita uno legítimo (mismo SSID)
	Rogue AP: AP no autorizado conectado a la red corporativa

2.3 Vulnerabilidades

Conceptos Clave — Professor Messer

Vulnerabilidades de Aplicaciones

SQL Injection (SQLi)

Insertar codigo SQL en un campo de entrada para manipular la base de datos.

Cross-Site Scripting

(XSS)

Inyectar Javascript en una pagina web que ejecuta en el navegador de la victima.

XSS Reflejado

El script se envia en la URL. Solo afecta al usuario que hace clic en el enlace malicioso.

XSS

Almacenado/Persistente

El script se almacena en el servidor. Afecta a TODOS los visitantes de esa pagina.

Buffer Overflow

Escribir mas datos de los que cabe en un buffer, sobreescribiendo memoria adyacente.

Race Condition /

TOCTOU

Time-of-Check to Time-of-Use. Dos procesos simultaneos con resultado inesperado.

Memory Injection / DLL

Injection

Inyectar codigo malicioso en el espacio de memoria de otro proceso en ejecucion.

Directory Traversal

Usar ../ para acceder a directorios fuera del directorio raiz del servidor web.

Zero-day

Vulnerabilidad desconocida para el fabricante. No hay parche disponible. El atacante la explota primero.

Puntos clave para el examen:

- SQLi tipico: 'SELECT * FROM users WHERE name = profesor OR 1=1' → devuelve todos los registros.
- XSS: si una web permite '<script>' en campos de entrada, es vulnerable.
- Buffer overflow: variable A de 8 bytes → se escribe 9 bytes → 1 byte overflows a variable B.
- TOCTOU: el valor cambia entre cuando se comprueba y cuando se usa (ej: saldo bancario).
- Zero-day: mientras no haya parche, solo mitigacion (firewall, IPS, segmentacion).
- Directory traversal: ../../windows/system.ini en la URL es una senal clara.
- CVE.mitre.org: base de datos publica de vulnerabilidades conocidas.

Vulnerabilidades de Hardware, Virtualizacion y Nube

Firmware

Software integrado en hardware (IoT, routers, camaras). Solo el fabricante puede actualizarlo.

EOL (End of Life)

El fabricante deja de vender el producto. Aun puede haber soporte de seguridad temporalmente.

EOSL (End of Service Life)

El fabricante deja de publicar parches. El dispositivo es un riesgo de seguridad activo.

VM Escape

Salir de una VM para acceder a otras VMs en el mismo hipervisor. Critico en cloud.

Resource Reuse

El hipervisor no aísla correctamente memoria entre VMs. Una VM puede leer datos de otra.

Misconfiguration

Error de configuracion que expone datos. Ej: bucket S3 publico, admin sin contrasena.

Default Credentials

Usuario/contrasena de fabrica no cambiados. Bases de datos publicas con miles de defaults.

Puntos clave para el examen:

- IoT es el mayor problema de EOSL: fabricantes tardan anos en publicar parches (Trane: 1 ano).
- Dispositivos EOSL: aislar en VLAN, reglas de firewall estrictas, reemplazar lo antes posible.
- VM Escape: demostrado en Pwn2Own 2017 (VMware + Windows 10 + Microsoft Edge).
- Misconfiguration: 14 millones de registros Verizon expuestos en S3 sin contrasena (2017).
- Mirai botnet: usa 60+ credenciales por defecto de dispositivos IoT. Open source y disponible publicamente.

Vulnerabilidades de Supply Chain y SO

Malicious Update

Actualizar con una version que contiene codigo malicioso. Ej: SolarWinds Orion (2020).

Counterfeit Hardware

Hardware falsificado con malware integrado. Ej: switches Cisco falsos (2022).

OS Patching

Parches mensuales de seguridad. Microsoft: Patch Tuesday = 2do martes de cada mes.

Jailbreaking (iOS)

Eliminar restricciones del SO Apple para instalar apps no autorizadas.

Rooting (Android)

Obtener acceso root en Android para modificar el SO.

Sideloading

Instalar apps fuera de la tienda oficial. Riesgo de malware.

Puntos clave para el examen:

- SolarWinds: atacantes comprometieron el servidor de desarrollo. Parche malicioso firmado digitalmente.
- Patch Tuesday: ~50-100 vulnerabilidades parcheadas CADA MES solo en Windows.

- Jailbreaking/Rooting: invalida el MDM (Mobile Device Management). Politica: prohibido o se borra el dispositivo.
- Digital signature NO garantiza seguridad si el sistema de firma esta comprometido (SolarWinds).
- Contrafeit hardware: switches Cisco falsos vendidos desde 2013, detectados al intentar actualizar firmware.

2.3 ampliacion

ICS/SCADA y Seguridad OT

ICS (Industrial Control System)

Sistemas de control industrial. Controlan infraestructura critica: plantas electricas, agua, petroleo.

SCADA (Supervisory **Control and Data** Acquisition)

Sistema de supervision y control industrial. Recopila datos de sensores remotos y los centraliza.

PLC (Programmable Logic Controller)

Controlador programable. Ejecuta logica de control en tiempo real. Ej: abrir valvula si presion supera X.

HMI (Human-Machine Interface)

Interfaz entre operador humano y el sistema industrial. Panel de control, visualizacion de estados.

DCS (Distributed Control System)

Sistema de control distribuido. Similar a SCADA pero mas centrado en procesos continuos (refinerias).

Purdue Model / ISA-95

Modelo de referencia para arquitectura de redes industriales. Define niveles 0-5 de aislamiento OT/IT.

Air gap OT

Separacion fisica entre la red OT (industrial) y la red IT (corporativa). Stuxnet lo comprometio con USB.

Puntos clave para el examen:

- OT (Operational Technology): sistemas que controlan el mundo fisico. Prioridad: DISPONIBILIDAD > seguridad.
- IT tradicional: prioridad CIA. OT: prioridad AIC (Availability primero, porque un fallo puede matar gente).
- Stuxnet (2010): malware que destruyo centrifugadoras nucleares iranies. Primer ciberarma conocida. Entro por USB.
- PLCs frecuentemente tienen firmware sin parchear y sin autenticacion. Diseñados para funcionar 20+ anos.
- Purdue Model nivel 0 = campo (sensores/actuadores). Nivel 5 = internet/empresa. Cada nivel separado por DMZ.
- Protocolo Modbus: comun en SCADA/ICS. Sin autenticacion por defecto. Diseñado en 1979.

Teoria Complementaria — ExamCompass

- Especificas de nube: misconfiguraciones en S3 buckets, IAM mal configurado, APIs expuestas
- Criptograficas: uso de algoritmos debiles (MD5, SHA-1, DES), claves cortas, mala implementacion
- Misconfiguracion: la causa mas comun de brechas. Puertos abiertos, credenciales por defecto, permisos excesivos
- Zero-day: vulnerabilidad desconocida para el fabricante, sin parche disponible
- Movil - Side loading: instalar apps fuera de la tienda oficial

■ Movil - Jailbreaking/Rooting: eliminar las restricciones del SO del movil

Preguntas de practica (27):

Preguntas Topic — ExamCompass (10 preguntas)

1. ¿Qué tipo de ataque a una aplicación se basa en la introducción de código externo en el espacio de direcciones de un programa en ejecución?

[EN: Which type of application attack relies on introducing external code into the address space of a running program?]

A) Desbordamiento del búfer

✓ B) Inyección de memoria

C) Repetir ataque

D) Desreferencia del puntero

Fuente: Topic: Security Vulnerabilities

---

2. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ataque a una aplicación que se basa en la ejecución de una biblioteca de código?

[EN: Which of the answers listed below refers to an application attack that relies on executing a library of code?]

A) pérdida de memoria

✓ B) inyección de DLL

C) Desreferencia del puntero

✓ D) Desbordamiento del búfer

Fuente: Topic: Security Vulnerabilities

---

3. Un mal funcionamiento en un acceso secuencial preprogramado a un recurso compartido se describe como:

✓ A) Condición de carrera

B) Error de concurrencia

C) subprocesos múltiples

D) Error de sincronización

** Respuesta corregida manualmente*

Fuente: Topic: Security Vulnerabilities

---

4. Una actualización de aplicación maliciosa es un tipo de malware que se puede instalar mediante una actualización de software aparentemente legítima. La introducción de una actualización maliciosa en el código de la aplicación se puede habilitar a través de varios medios, que incluyen:

A) Código de aplicación sin firmar

B) Canal de actualización no cifrado (HTTP vs HTTPS)

C) Sitio web de actualización falso

D) Acceso no autorizado al servidor de actualización

E) Proceso de desarrollo de software comprometido

✓ F) Todo lo anterior

Fuente: Topic: Security Vulnerabilities

---

5. ¿Cuál de las respuestas enumeradas a continuación se refiere a una vulnerabilidad de seguridad que permite insertar código malicioso en campos de entrada, como barras de búsqueda o formularios de inicio de sesión, para ejecutar comandos no autorizados en una base de datos?

[EN: Which of the answers listed below refers to a security vulnerability that enables inserting malicious code into input fi]

A) ICE

✓ **B) SQLi**

C) XSS

D) CSRF

Fuente: Topic: Security Vulnerabilities

---

6. ¿Cuál de las respuestas enumeradas a continuación describe las características de un ataque de secuencias de comandos entre sitios? (Seleccione 3 respuestas)

[EN: Which of the answers listed below describe the characteristics of a cross-site scripting attack? (Select 3 answers)]

A) Explota la confianza que el navegador web de un usuario tiene en un sitio web

✓ **B) Se inyecta un script malicioso en un sitio web confiable**

✓ **C) El navegador del usuario ejecuta el script del atacante**

D) Explota la confianza que un sitio web tiene en el navegador web del usuario.

E) Un atacante engaña a un usuario para que envíe solicitudes web no autorizadas

F) El sitio web ejecuta las solicitudes del atacante

Fuente: Topic: Security Vulnerabilities

---

7. ¿Cuál es la principal vulnerabilidad relacionada con el hardware heredado?

[EN: What is the main vulnerability related to legacy hardware?]

A) Problemas de compatibilidad

✓ **B) Falta de actualizaciones y parches de seguridad.**

C) Componentes físicos desgastados

D) Falta de personal capacitado para operarlo y mantenerlo.

Fuente: Topic: Security Vulnerabilities

---

8. ¿Cuál de las siguientes respuestas se refiere a una vulnerabilidad relacionada con la virtualización en la que los activos virtualizados asignados a una máquina virtual están aislados incorrectamente y otra máquina virtual puede acceder a ellos o ponerlos en peligro?

[EN: Which of the following answers refers to a virtualization-related vulnerability where virtualized assets allocated to on]

✓ **A) Reutilización de recursos**

B) Escalada de privilegios

C) Agotamiento de recursos

D) Uso simultáneo de sesiones

** Respuesta corregida manualmente*

Fuente: Topic: Security Vulnerabilities

---

9. La práctica de instalar aplicaciones móviles desde sitios web y tiendas de aplicaciones distintos de los mercados oficiales se conoce como:

A) jailbreak

B) Enraizamiento

✓ **C) Carga lateral**

D) Desbloqueo del operador

Fuente: Topic: Security Vulnerabilities

---

10. El término "Enraizamiento" se refiere a la capacidad de obtener acceso administrativo al sistema operativo y a las aplicaciones del sistema en:

✓ **A) Dispositivos Android**

B) dispositivos iOS

C) Dispositivos Microsoft

D) Todo tipo de dispositivos móviles

** Respuesta corregida manualmente*

Fuente: Topic: Security Vulnerabilities

Preguntas Adicionales — Generadas (2 preguntas)

1. ¿Qué es una vulnerabilidad 'zero-day'?

- **✓ A) Una vulnerabilidad desconocida para el fabricante, sin parche disponible**
- B) Una vulnerabilidad que se descubrió hace menos de un día
- C) Un fallo crítico con puntuación CVSS de 10
- D) Una vulnerabilidad en sistemas con más de cero días de uptime

Fuente: Extra: Vulnerabilities

---

2. ¿Qué tipo de ataque explota la condición de carrera (race condition)?

- **✓ A) TOCTOU (Time-of-Check to Time-of-Use)**
- B) SQL Injection
- C) Buffer Overflow
- D) Cross-Site Scripting

Fuente: Extra: Vulnerabilities

Flashcards — 2.3 (4 tarjetas)

Q: SQLi — ¿cómo se previene?	Prepared statements / parameterized queries · Input validation · Principio de mínimo privilegio en DB
Q: XSS Reflected vs Stored	Reflected: el payload va en la URL, afecta a un usuario
	Stored: el payload se guarda en el servidor, afecta a todos
Q: Buffer Overflow — ¿qué permite?	Sobrescribir memoria adyacente → ejecutar código arbitrario. Mitigaciones: ASLR, DEP/NX, Stack canaries
Q: TOCTOU — ¿qué es?	Time-of-Check to Time-of-Use: explota el tiempo entre verificar una condición y usarla (race condition)

2.4 Indicadores de actividad maliciosa

Conceptos Clave — Professor Messer

Tipos de Malware

Virus

Requiere interaccion humana para ejecutarse. Se replica por el sistema de archivos.

Worm

Se auto-replica SIN interaccion humana. Usa vulnerabilidades de red. Ej: WannaCry.

Ransomware

Cifra los archivos del usuario y exige pago (criptomoneda) por la clave de descifrado.

Trojan

Se disfraza de software legitimo. Abre backdoor para el atacante.

RAT (Remote Access

Trojan)

Trojan que da control remoto completo al atacante (capturas, keylogger, archivos).

Rootkit

Se oculta en el kernel del SO. Invisible para antivirus tradicional. Usa UEFI Secure Boot para detectarlo.

Keylogger

Captura todas las pulsaciones del teclado. Envia el archivo de log al atacante periodicamente.

Spyware

Monitoriza habitos de navegacion, roba informacion personal, puede instalar keylogger.

Bloatware

Software preinstalado por el fabricante. Puede tener vulnerabilidades. Puede ser dificil de desinstalar.

Logic Bomb

Codigo malicioso que se activa en un evento especifico (fecha, usuario, condicion). Sin firma de AV.

Fileless Malware

No escribe en disco. Reside en memoria RAM. Usa PowerShell, WMI. Evade AV basado en archivos.

Botnet

Red de equipos infectados controlados remotamente. Se usan para DDoS, spam, mineria.

Puntos clave para el examen:

- Virus = necesita click. Worm = automatico. Diferencia clave en el examen.
- Ransomware: BACKUP OFFLINE es la mejor defensa. Si el backup esta conectado, tambien se cifra.
- Rootkit: vive en el KERNEL. Secure Boot del UEFI lo detecta antes de que el SO cargue.
- Logic Bomb: sin firma AV → solo detecta con monitorizacion de cambios en archivos criticos.
- Fileless: vive en RAM → desaparece al reiniciar PERO se pone en el registro para persistir.
- WannaCry = Worm + Ransomware. EternalBlue (NSA exploit). Mayo 2017. Afecto NHS, Telefonica, etc.
- Botnets para DDoS: Zeus botnet tuvo 3.6 millones de equipos. Un comando ataca cualquier objetivo.

Ataques de Red — DoS, DNS, Wireless

DoS

Denial of Service. Sobrecarga un servicio para que deje de funcionar.

DDoS

Distributed DoS. Multiples dispositivos (botnet) atacan simultaneamente.

Amplification Attack

Pequena peticion → gran respuesta → enviada a la victima. Ej: DNS amplification x86.

DNS Poisoning

Modificar respuestas DNS para redirigir trafico a un servidor malicioso.

ARP Poisoning

Enviar respuestas ARP falsas para redirigir trafico en la LAN local. Requiere misma subred.

On-path attack (MITM)

El atacante se interpone entre dos dispositivos y puede leer/modificar el trafico.

Replay Attack

Capturar y reenviar datos de autenticacion validos. Ej: Pass-the-Hash.

Session Hijacking

Robar el session ID para acceder como si fuera el usuario legitimo.

SSL Stripping

On-path attack que degrada HTTPS a HTTP. Victima usa HTTP sin saberlo.

Deauthentication (WiFi)

Enviar frames de deautenticacion 802.11 para desconectar dispositivos. DoS en WiFi.

RF Jamming

Interferir senales de radio para impedir comunicacion WiFi.

Puntos clave para el examen:

- DNS amplification: 15 bytes peticion → 1300 bytes respuesta = x86 amplificacion.
- ARP no tiene autenticacion → facil envenenar con respuestas ARP no solicitadas.
- Pass-the-Hash: no necesitas la contrasena, solo el hash. Capturado con on-path + replay.
- SSL Stripping prevenido por HSTS: el navegador rechaza HTTP aunque el atacante lo proponga.
- Deauthentication: fixed en 802.11ac con management frame protection (MFP). WPA2/WPA3 incluyen esto.
- Session hijacking: HTTPS end-to-end previene esto. Sin HTTPS, session ID viaja en claro.

Ataques de Contrasenas y Criptograficos

Brute Force

Probar todas las combinaciones posibles hasta encontrar la contrasena. Offline es mas rapido.

Dictionary Attack

Probar lista de palabras comunes y variaciones. Mas rapido que brute force puro.

Spraying Attack

Probar pocos passwords comunes en muchas cuentas. Evita bloqueos.

Rainbow Table

Tabla pre-calculada de hashes → contrasenas. Derrotada por SALT.

Pass-the-Hash

Usar el hash directamente para autenticarse sin conocer la contrasena en texto claro.

Birthday Attack

Buscar dos entradas con el mismo hash (colision). Derrota a MD5 y SHA-1.

Downgrade Attack

Forzar uso de protocolo mas debil. SSL stripping es un ejemplo.

Puntos clave para el examen:

- Contrasenas mas comunes: 123456, password, qwerty, 111111. Cambiarlas SIEMPRE.
- Passwords nunca en texto claro. Siempre hash + salt.
- MD5 tiene colisiones conocidas desde 1996. SHA-1 tambien. Usar SHA-256+.
- Salt + hash derrota rainbow tables: mismo password, salt diferente = hash completamente diferente.
- Spraying: 3 intentos por cuenta, avanza a la siguiente. Nunca bloquea nada.
- Offline brute force: descargado el archivo de hashes, no hay bloqueo. Solo tiempo de computo.

Teoria Complementaria — ExamCompass

- Bomba logica (Logic bomb): codigo que se activa cuando se cumple una condicion especifica (fecha, evento)
- Bloatware: software no deseado preinstalado que consume recursos

ATAQUES DE RED:

- DDoS (Denegacion de Servicio Distribuida): multiples sistemas atacan uno para dejarlo sin servicio
  - Amplificado: usar protocolos que amplifican el trafico (DNS, NTP, SSDP)
  - Reflejado: el trafico de ataque pasa por intermediarios que lo redirigen a la victima
- Ataque en ruta (On-path/MitM): el atacante se interpone entre dos partes para interceptar/modificar trafico
- Envenenamiento DNS: corromper la cache DNS para redirigir usuarios a sitios falsos
- Repeticion de credenciales (Credential replay): reutilizar credenciales capturadas

ATAQUES DE CONTRASENA:

- Fuerza bruta: probar todas las combinaciones posibles
- Ataque de diccionario: probar palabras de diccionario y variaciones comunes
- Password spraying: probar una contrasena comun contra muchas cuentas (evita el bloqueo por intentos fallidos)

■ Tabla arcoiris (Rainbow table): tabla precalculada de hashes. Contramedida: salting

ATAQUES CRIPTOGRAFICOS:

■ Ataque de degradacion (Downgrade): forzar el uso de versiones antiguas e inseguras de protocolos

■ Ataque de colision: encontrar dos inputs distintos que producen el mismo hash

■ Ataque de cumpleanos (Birthday): basado en la paradoja del cumpleanos, busca colisiones en hashes

INDICADORES DE ACTIVIDAD MALICIOSA:

■ Bloqueo inesperado de cuenta: posible ataque de fuerza bruta

■ Viaje imposible: login desde Madrid y desde Tokyo en 10 minutos

■ Consumo de recursos anormal: CPU/RAM al 100% sin razon aparente (cryptomining)

■ Logs desaparecidos: alguien borro los logs para cubrir sus huellas

■ Cambios no autorizados: archivos modificados sin causa conocida

Preguntas de practica (26):

1. Un programa informático malicioso independiente que normalmente se propaga a través de una red informática para afectar negativamente a los recursos del sistema y al ancho de banda de la red se denomina:

2. Un programa informático malicioso independiente que normalmente se propaga a través de una red informática para afectar negativamente a los recursos del sistema y al ancho de banda de la red se denomina:

3. El malware que restringe el acceso a un sistema informático cifrando archivos o bloqueando todo el sistema hasta que el usuario realice la acción solicitada se llama:

4. El código malicioso activado por un evento específico se llama:

5. Una breve lista de contraseñas de uso común probadas en una gran cantidad de cuentas de usuario es un rasgo característico de:

6. Un ataque contra datos cifrados que depende en gran medida de la potencia informática para comprobar

Preguntas Topic — ExamCompass (21 preguntas)

1. El malware que restringe el acceso a un sistema informático cifrando archivos o bloqueando todo el sistema hasta que el usuario realice la acción solicitada se llama:

A) Grayware
B) software publicitario
✓ **C) ransomware**
D) software espía

Fuente: Topic: Malware Attacks

---

2. ¿Qué tipo de troyano permite el acceso remoto no autorizado a un sistema comprometido?

[EN: Which type of Trojan enables unauthorized remote access to a compromised system?]

A) APTO
✓ **B) RATA**
C) MaaS
D) CACHORRO

Fuente: Topic: Malware Attacks

---

3. Un programa informático malicioso independiente que normalmente se propaga a través de una red informática para afectar negativamente a los recursos del sistema y al ancho de banda de la red se

denomina:

✓ **A) Gusano**

B) virus sin archivos

C) Bot

D) Bomba lógica

** Respuesta corregida manualmente*

Fuente: Topic: Malware Attacks

---

4. El código malicioso activado por un evento específico se llama:

A) criptomalware

B) Puerta trasera

C) rootkit

✓ **D) Bomba lógica**

Fuente: Topic: Malware Attacks

---

5. A diferencia de los simples ataques DoS que normalmente se realizan desde un solo sistema, un ataque DDoS utiliza múltiples sistemas informáticos comprometidos para realizar el ataque contra su objetivo. Los sistemas intermediarios que se utilizan como plataforma para el ataque (a menudo denominados zombies y colectivamente botnet) son las víctimas secundarias del ataque DDoS.

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Topic: Network Attacks

---

6. ¿Qué define un ataque DDoS reflejado?

[EN: What defines a reflected DDoS attack?]

A) Abrumar al objetivo con un gran volumen de tráfico para saturar su ancho de banda

B) Explotar vulnerabilidades en los protocolos de red para consumir recursos e interrumpir servicios

✓ **C) Utilizar servidores de terceros para reflejar y amplificar el tráfico de ataque hacia el objetivo.**

D) Apuntar a vulnerabilidades en aplicaciones o servidores web para agotar los recursos.

Fuente: Topic: Network Attacks

---

7. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica de ciberataque que se basa en proporcionar información DNS falsa a un solucionador de DNS con el fin de redirigir o manipular la resolución de nombres de dominio a direcciones IP maliciosas?

[EN: Which of the answers listed below refers to a cyberattack technique that relies on providing false DNS information to a]

✓ **A) Suplantación de DNS**

B) Relleno de credenciales

C) Secuestro de URL

D) Secuestro de dominio

** Respuesta corregida manualmente*

Fuente: Topic: Network Attacks

---

8. Cuando los registrantes de dominio debido a acciones ilegales de terceros pierden el control sobre sus nombres de dominio, son víctimas de:

A) Ataque de sibila

✓ **B) Secuestro de dominio**

C) Error tipográfico

D) Secuestro de URL

Fuente: Topic: Network Attacks

---

9. Un ataque de disociación inalámbrica es un tipo de: (Seleccione 2 respuestas)

A) Ataque de degradación

✓ B) Ataque de desautenticación

C) Ataque de fuerza bruta

✓ D) Ataque DoS

E) Ataque criptográfico

Fuente: Topic: Network Attacks

---

10. ¿Qué ataque inalámbrico se centra en explotar las vulnerabilidades encontradas en WEP?

[EN: Which wireless attack focuses on exploiting vulnerabilities found in WEP?]

✓ A) ataque intravenoso

B) conducción de guerra

C) suplantación de SSID

D) bluejacking

** Respuesta corregida manualmente*

Fuente: Topic: Network Attacks

---

11. Un ataque de reproducción de red ocurre cuando un atacante captura datos confidenciales del usuario y los reenvía al receptor con la intención de obtener acceso no autorizado o engañar al receptor para que realice operaciones no autorizadas.

✓ A) Verdadero

B) FALSO

** Respuesta corregida manualmente*

Fuente: Topic: Network Attacks

---

12. En un ataque de repetición de sesión, un atacante intercepta y roba una ID de sesión válida de un usuario y la reenvía al servidor con la intención de obtener acceso no autorizado a la sesión del usuario o engañar al servidor para que realice operaciones no autorizadas en nombre del usuario legítimo.

✓ A) Verdadero

B) FALSO

** Respuesta corregida manualmente*

Fuente: Topic: Network Attacks

---

13. ¿Qué tipo de acción permite a un atacante aprovechar la vulnerabilidad XSS?

[EN: What type of action allows an attacker to exploit the XSS vulnerability?]

✓ A) inyección de código

B) Escalada de privilegios

C) Secuestro de sesión

D) rastreo de paquetes

** Respuesta corregida manualmente*

Fuente: Topic: Application Attacks

---

14. ¿Qué tipo de exploit se dirige a aplicaciones web que generan contenido utilizado para almacenar y transportar datos?

[EN: Which type of exploit targets web applications that generate content used to store and transport data?]

A) Ataque de inyección SQL

B) Ataque CSRF/XSRF

✓ **C) Ataque de inyección XML**

D) Ataque de inyección LDAP

Fuente: Topic: Application Attacks

---

15. Una situación en la que un atacante intercepta y retransmite un intercambio de datos válido entre una aplicación y un servidor u otra aplicación se conoce como:

A) Carga lateral

✓ **B) Repetir ataque**

C) Ataque de phishing

D) Condición de carrera

Fuente: Topic: Application Attacks

---

16. ¿Cuál de las afirmaciones que se enumeran a continuación se aplican al ataque CSRF/XSRF? (Seleccione 3 respuestas)

[EN: Which of the statements listed below apply to the CSRF/XSRF attack? (Select 3 answers)]

A) Explota la confianza que un sitio web tiene en el navegador web del usuario.

✓ **B) Un atacante engaña a un usuario para que envíe solicitudes web no autorizadas**

✓ **C) El sitio web ejecuta las solicitudes del atacante**

D) Explota la confianza que el navegador web de un usuario tiene en un sitio web

E) Se inyecta un script malicioso en un sitio web confiable

F) El navegador del usuario ejecuta el script del atacante

Fuente: Topic: Application Attacks

---

17. ¿Cuál de las siguientes URL es un indicador potencial de un ataque de cruce de directorio?

[EN: Which of the following URLs is a potential indicator of a directory traversal attack?]

A) http://www.example.com/var/../etc/passwd

B) http://www.example.com/var/www/../../etc/passwd

C) http://www.example.com/var/www/files/../../../etc/passwd

D) http://www.example.com/var/www/files/images/../../../../etc/passwd

✓ **E) Cualquiera de los anteriores**

Fuente: Topic: Application Attacks

---

18. Un tipo de evidencia forense que puede usarse para detectar intentos de acceso no autorizados u otras actividades maliciosas se denomina:

A) CVE

✓ **B) COI**

C) AIS

D) OSINT

Fuente: Topic: Indicators Malicious Activity

---

19. ¿Cuál de los términos enumerados a continuación describe con mayor precisión una situación en la que se utiliza una sola cuenta desde múltiples ubicaciones/dispositivos al mismo tiempo?

[EN: Which of the terms listed below most accurately describes a situation wherein a single account is being used from multip]

A) Ataque de fumigación

✓ **B) Uso simultáneo de sesiones**

C) Inicio de sesión único (SSO)

D) viaje imposible

Fuente: Topic: Indicators Malicious Activity

---

20. ¿Cuál de los términos enumerados a continuación describe con mayor precisión una situación en la que se accede a una cuenta desde una ubicación en la que es físicamente imposible que se encuentre el usuario?

[EN: Which of the terms listed below most accurately describes a situation wherein an account is accessed from a location tha]

A) Restricciones de tiempo de inicio de sesión

✓ B) viaje imposible

C) Uso simultáneo de sesiones

D) Registro fuera de ciclo

Fuente: Topic: Indicators Malicious Activity

---

21. ¿Cuál de las siguientes opciones indicaría un intento de ocultar evidencia de actividad maliciosa?

[EN: Which of the following would indicate an attempt to hide evidence of malicious activity?]

A) Bloqueo de cuenta

B) Inaccesibilidad de recursos

✓ C) Registros faltantes

D) Uso simultáneo de sesiones

Fuente: Topic: Indicators Malicious Activity

Preguntas Adicionales — Generadas (2 preguntas)

1. ¿Cuál es la diferencia entre un virus y un gusano (worm)?

✓ A) El gusano se propaga solo por la red sin necesitar un archivo host; el virus necesita un archivo huésped

B) El virus cifra los archivos; el gusano los elimina

C) El gusano necesita interacción del usuario; el virus no

D) Son sinónimos en el contexto moderno de seguridad

Fuente: Extra: Malware

---

2. Un rootkit modifica el sistema operativo para ocultar su presencia. ¿Cuál es el método MÁS efectivo para detectarlo?

✓ A) Arrancar desde un medio externo limpio y analizar el disco

B) Ejecutar el antivirus desde el sistema infectado

C) Revisar los logs del sistema

D) Comprobar el uso de CPU en el Administrador de tareas

Fuente: Extra: Malware

Flashcards — 2.4 (4 tarjetas)

Q: Virus vs Worm vs Trojan	Virus: necesita archivo huésped
	Worm: se propaga solo por red
	Trojan: parece legítimo, esconde malware
Q: Ransomware — mecánica	Cifra archivos/disco → exige rescate para clave de descifrado. WannaCry = Worm + Ransomware
Q: Rootkit — ¿cómo se detecta?	Modifica el SO para ocultarse. Detección: arrancar desde medio externo limpio y analizar el disco
Q: Pass-the-Hash — ¿qué es?	Usar el hash NTLM robado para autenticarse sin conocer la contraseña en texto claro

2.5 Tecnicas de mitigacion

Conceptos Clave — Professor Messer

Mitigacion de Amenazas

Segmentacion de red
Dividir la red en zonas (VLANs). Limita el movimiento lateral del atacante.

Hardening del sistema
Deshabilitar servicios innecesarios, cambiar defaults, aplicar parches, CIS Benchmarks.

Patch Management
Proceso sistematico de aplicar parches. Inventario → evaluacion → prueba → despliegue → verificacion.

Endpoint Detection & Response (EDR)
Monitoriza endpoints en tiempo real. Detecta y responde automaticamente a amenazas.

User and Entity Behavior Analytics (UEBA)
IA que aprende el comportamiento normal y alerta de anomalias (login a las 3AM desde China).

Deception technologies
Honeypots, honeynets, honeytokens. Detectan atacantes que ya estan dentro.

Threat Intelligence
Informacion sobre amenazas actuales: TTPs de atacantes, IOCs, feeds de threat intel.

MITRE ATT&CK
Framework de tacticas y tecnicas de atacantes reales. Referencia global para defensa.

Puntos clave para el examen:

- Segmentacion: si el atacante compromete una zona, no puede moverse a otras (lateral movement limitado).
- Hardening: eliminar TODOS los servicios que no son necesarios. Menos superficie de ataque.
- EDR vs AV: AV detecta malware conocido. EDR detecta comportamiento sospechoso aunque sea nuevo.
- UEBA: 'impossible login' → mismo usuario en Espana y Australia con 10 min de diferencia = alarma.
- MITRE ATT&CK: tatticas (por que) → tecnicas (como) → sub-tecnicas (especifico). 14 tacticas principales.

2.5 ampliacion

Threat Intelligence y Compartición

Threat Intelligence
Informacion procesada sobre amenazas actuales: IOCs, TTPs, actores. Mejora la deteccion proactiva.

ISAC (Information **Sharing and Analysis** Center)
Organizacion sectorial que comparte threat intel. FS-ISAC (finanzas), H-ISAC (salud), E-ISAC (energia).

IOC (Indicator of Compromise)
Evidencia de compromiso: hash de malware, IP maliciosa, dominio C2, user-agent sospechoso.

IOA (Indicator of Attack)
Evidencia de ataque en curso: comportamiento sospechoso, TTP observado. Mas

proactivo que IOC.

TTP

Tactics (por que), Techniques (como), Procedures (pasos). Framework MITRE ATT&CK los documenta.

STIX

Structured Threat Intelligence eXpression. Formato JSON para compartir threat intel de forma estandarizada.

TAXII

Trusted Automated eXchange of Intelligence Information. API para transportar STIX entre organizaciones.

Dark web

Parte de internet no indexada, accesible solo con Tor. Mercados de malware, datos robados, servicios ilegales.

Threat hunting

Busqueda proactiva de amenazas que han evadido las defensas automaticas. No espera alertas.

Puntos clave para el examen:

- IOC reactivo: el ataque ya ocurrio. IOA proactivo: el ataque esta ocurriendo ahora mismo.
- STIX + TAXII = estandar de facto para compartir threat intel. Muchos SIEM lo consumen nativamente.
- Dark web monitoring: algunas empresas monitorean el dark web buscando credenciales de su dominio.
- Threat hunting: un analista busca activamente. Hypothesis: 'si un APT entro, que evidencias dejaria?'
- ISAC: sector financiero (FS-ISAC) es el mas maduro. Comparten IOCs en tiempo casi real.
- Inteligencia de amenazas niveles: estrategica (alta direccion), tactica (SOC analistas), operacional (SIEM reglas).

Teoria Complementaria — ExamCompass

- Aplicacion de configuracion: usar herramientas como Group Policy, Ansible, Puppet para mantener la configuracion correcta

Preguntas de practica (87):

15. La especificación MIME extiende el formato de los mensajes de correo electrónico más allá del texto plano, permitiendo la transferencia de archivos de gráficos, audio y vídeo a través del sistema de correo de Internet. S/MIME es una versión mejorada del protocolo MIME que habilita funciones de seguridad del correo electrónico al proporcionar cifrado, autenticación, integridad de mensajes y otros servicios relacionados.

16. SFTP es una extensión del protocolo FTP que agrega soporte para cifrado SSL/TLS.

23. En criptografía, la cantidad de bits de una clave utilizada por un algoritmo criptográfico se denomina tamaño de clave o longitud de clave. La longitud de la clave determina el número máximo de combinaciones necesarias para romper el algoritmo de cifrado; por lo tanto, normalmente una clave más larga significa una seguridad criptográfica más sólida.

Respuesta no detectada automaticamente

70. SFTP es una extensión del protocolo FTP que agrega soporte para cifrado SSL/TLS.

71. En el cifrado asimétrico, cualquier mensaje cifrado con el uso de una clave pública sólo puede descifrarse aplicando el mismo algoritmo y una clave privada coincidente (y viceversa).

Preguntas Adicionales — Generadas (3 preguntas)

1. ¿Qué es la segmentación de red y cómo ayuda a la seguridad?

✓ **A) Divide la red en zonas para limitar el movimiento lateral de atacantes**

B) Aumenta el ancho de banda dividiendo el tráfico

C) Cifra todo el tráfico de red automáticamente

D) Elimina puntos únicos de fallo en la red

Fuente: Extra: Mitigation

---

2. ¿Qué es EDR y en qué se diferencia de un antivirus?

✓ **A) EDR detecta amenazas por comportamiento y permite respuesta activa; el AV solo detecta firmas conocidas**

B) EDR es un antivirus más moderno que lo sustituye completamente

C) EDR protege servidores; AV protege estaciones

D) EDR cifra endpoints; AV los escanea

Fuente: Extra: Mitigation

---

3. ¿Qué es UEBA (User and Entity Behavior Analytics)?

✓ **A) Detecta comportamientos anómalos de usuarios comparándolos con una línea base normal**

B) Herramienta de gestión de identidades

C) Sistema MFA basado en comportamiento

D) Plataforma de análisis de logs de firewall

Fuente: Extra: Mitigation

Flashcards — 2.5 (2 tarjetas)

Q: AV vs EDR vs XDR	AV: firmas conocidas
	EDR: comportamiento + respuesta en endpoint
	XDR: EDR + red + cloud + email (visión unificada)
Q: ¿Qué es la segmentación de red y por qué importa?	Divide la red en zonas para limitar el movimiento lateral de atacantes. Reduce el radio de explosión de un incidente

DOMINIO 3 Arquitectura de Seguridad (18% del examen)

3.1 Seguridad en entornos cloud y fisicos

Conceptos Clave — Professor Messer

Arquitectura de Seguridad — Cloud e Infraestructura

Cloud responsabilidad
compartida
Segun el modelo (IaaS/PaaS/SaaS) se reparte la responsabilidad entre proveedor y cliente.

IaaS
Infrastructure as a Service. Cliente gestiona OS, apps, datos. Proveedor gestiona hardware fisico.

PaaS
Platform as a Service. Cliente gestiona apps y datos. Proveedor gestiona OS y plataforma.

SaaS
Software as a Service. Proveedor gestiona todo. Cliente solo usa la aplicacion.

Nube publica
Infraestructura compartida con otros clientes. AWS, Azure, GCP.

Nube privada
Infraestructura exclusiva de la organizacion. Mas control, mas coste.

Nube hibrida
Combinacion de nube publica y privada. Flexibilidad + control de datos sensibles.

Multi-cloud
Usar multiples proveedores de nube simultaneamente. Evita vendor lock-in.

Edge Computing
Procesamiento en el borde de la red (cerca del dato). Reduce latencia. Ej: IoT, sensores.

Fog Computing
Capa intermedia entre edge y nube. Procesa datos localmente antes de enviar a la nube.

Puntos clave para el examen:

- IaaS: tu gestionas el SO → tu responsabilidad parchear. AWS EC2 es IaaS.
- SaaS: el proveedor parchea todo. Tu solo usas la app. Gmail, Office 365 son SaaS.
- Shared responsibility: el proveedor SIEMPRE es responsable de la seguridad FISICA del datacenter.
- Multi-cloud: si un proveedor falla o tiene brecha, los otros siguen funcionando.
- Edge computing: procesa datos donde se generan. Critico para IoT y respuesta en tiempo real.

Seguridad de Infraestructura — Firewalls, IDS/IPS, SIEM

Firewall de red
Filtra trafico basandose en IP, puerto y protocolo. Stateful: recuerda el estado de la conexion.

Next-Gen Firewall
(NGFW)
Firewall + IPS + inspeccion de aplicaciones + SSL inspection + URL filtering.

IDS (Intrusion Detection
System)

Detecta y ALERTA de ataques. NO bloquea. Modo pasivo.
IPS (Intrusion Prevention
System)
Detecta y BLOQUEA ataques en tiempo real. Modo inline.
WAF (Web Application
Firewall)
Protege aplicaciones web. Bloquea SQLi, XSS, CSRF. Capa 7.

SIEM

Security Information and Event Management. Centraliza logs, correlaciona eventos, genera alertas.

SOAR

Security Orchestration, Automation and Response. Automatiza respuesta a incidentes usando playbooks.
NAC (Network Access
Control)
Verifica que el dispositivo cumple politicas antes de darle acceso a la red. Ej: parches al dia.

Puntos clave para el examen:

- IDS = detecta y alerta (no bloquea). IPS = detecta y bloquea (inline, puede interrumpir trafico legitimo).
- NGFW inspecciona hasta capa 7: puede identificar aplicaciones (Facebook, Netflix) aunque usen HTTPS.
- SIEM: correlaciona eventos de muchos dispositivos. 1 login fallido = normal. 1000 en 1 min = ataque.
- SOAR automatiza playbooks: 'si SIEM detecta brute force → bloquear IP automaticamente → notificar analyst'.
- WAF es especifico para apps web. Firewall normal no entiende HTTP/HTTPS en profundidad.

3.1 ampliacion

Seguridad de Hardware — HSM y TPM
HSM (Hardware Security
Module)
Dispositivo fisico especializado en operaciones criptograficas. Genera, almacena y protege claves. Mas seguro que software.
TPM (Trusted Platform
Module)
Chip en la placa base. Almacena claves de cifrado (BitLocker), mide la integridad del arranque, genera numeros aleatorios.

Secure Boot

Verifica la firma del bootloader y del kernel antes de cargar. Previene rootkits en el arranque. Usa TPM y UEFI.

Measured Boot

Registra las medidas del arranque en el TPM. Permite verificar posteriormente si el sistema fue modificado.

Geofencing

Define una barrera virtual geografica. Activa/desactiva funciones segun la ubicacion del dispositivo. Ej: bloquear camara dentro del trabajo.

Puntos clave para el examen:

- HSM: nunca extrae la clave privada del modulo. Las operaciones criptograficas ocurren DENTRO del HSM.
- TPM vs HSM: TPM = chip integrado en el equipo. HSM = dispositivo externo dedicado (mas potente y seguro).
- BitLocker sin TPM: pide PIN en cada arranque. Con TPM: arranque transparente (la clave esta en el TPM).
- HSM requerido por: CA raiz, entidades financieras, PCI DSS para proteger claves de cifrado de tarjetas.
- Geofencing: util para MDM. Si el movil sale de la zona permitida → borrado remoto automatico.

Teoria Complementaria — ExamCompass

3.0 Arquitectura de Seguridad (18% del examen)

3.1 - Comparar y contrastar las implicaciones de seguridad de diferentes modelos de arquitectura.

■ Nube: IaaS, PaaS, SaaS - Matriz de responsabilidad compartida

■ Nube publica, privada, hibrida y comunitaria

■ Serverless, Microservicios, Contenedores, IaC, SDN

■ Sistemas especializados: IoT, ICS/SCADA, RTOS, Sistemas embebidos, Air-gapped

MODELOS DE NUBE:

■ IaaS (Infraestructura como Servicio): el proveedor da hardware virtual. Tu gestionas SO, apps, datos. Ej: AWS EC2

■ PaaS (Plataforma como Servicio): el proveedor da la plataforma de desarrollo. Tu gestionas las apps y datos. Ej: Heroku

■ SaaS (Software como Servicio): el proveedor da todo. Tu solo usas la app. Ej: Gmail, Office 365

■ Matriz de responsabilidad compartida: define que responsabilidades son del proveedor y cuales del cliente. Critico para el examen.

TIPOS DE NUBE:

■ Nube publica: recursos compartidos entre clientes (AWS, Azure, GCP)

■ Nube privada: infraestructura dedicada a una sola organizacion

■ Nube hibrida: combinacion de publica y privada

■ Nube comunitaria: compartida entre organizaciones con intereses comunes

TECNOLOGIAS CLOUD:

■ Serverless: codigo que se ejecuta sin gestionar servidores (AWS Lambda). Escalado automatico

■ Microservicios: aplicacion dividida en servicios pequenos e independientes

■ Contenedores: empaquetar apps con sus dependencias (Docker). Mas ligero que VMs

■ Infraestructura como Codigo (IaC): gestionar infraestructura mediante codigo (Terraform, CloudFormation)

■ SDN (Red definida por software): red gestionada por software, separando el plano de control del de datos

SISTEMAS ESPECIALIZADOS:

■ IoT (Internet de las Cosas): dispositivos conectados con recursos limitados, frecuentemente sin seguridad adecuada

■ ICS/SCADA: sistemas de control industrial. Prioridad: disponibilidad sobre seguridad

■ RTOS (Sistema Operativo de Tiempo Real): SO para sistemas que necesitan respuesta en tiempo real

■ Sistemas embebidos: hardware con software fijo integrado (routers, camaras IP, PLCs)

■ Air-gapped: sistema fisicamente aislado de cualquier red. Maximo nivel de aislamiento

Preguntas de practica (46):

1. Un modelo de servicio de computación en la nube que ofrece acceso remoto a aplicaciones basado en una tarifa de suscripción mensual o anual se denomina:

Preguntas Adicionales — Generadas (2 preguntas)

1. En el modelo IaaS, ¿de qué es responsable el cliente?

✓ **A) Sistema operativo, aplicaciones y datos**

B) Solo de los datos — el proveedor gestiona todo lo demás

C) Solo del acceso — el proveedor gestiona la infraestructura y el SO

D) De todo, incluyendo el hardware físico

Fuente: Extra: Cloud Security

---

2. ¿Qué hace un CASB (Cloud Access Security Broker)?

✓ **A) Actúa como intermediario entre usuarios y proveedores cloud para aplicar políticas de seguridad**

B) Proporciona acceso VPN a recursos cloud

C) Gestiona identidades en entornos multi-cloud

D) Monitoriza el rendimiento de aplicaciones SaaS

Fuente: Extra: Cloud Security

Flashcards — 3.1 (3 tarjetas)

Q: IaaS / PaaS / SaaS — responsabilidad del cliente	IaaS: SO + apps + datos
	PaaS: apps + datos
	SaaS: solo datos y acceso
Q: ¿Qué hace un CASB?	Cloud Access Security Broker: intermediario entre usuarios y cloud para aplicar políticas de seguridad (visibilidad, DLP, amenazas)
Q: NGFW vs IDS vs IPS	NGFW: firewall con inspección profunda de paquetes + app awareness
	IDS: detecta y alerta (pasivo)
	IPS: detecta y bloquea (en línea)

3.2 Principios de seguridad en infraestructura

Conceptos Clave — Professor Messer

Seguridad de Redes — VPN, Proxy, DNS

VPN
Virtual Private Network. Cifra el tunel entre dos puntos. Tipos: site-to-site, client-to-site.

IPSec
Protocolo de cifrado a nivel IP. Modos: Transport (solo datos) y Tunnel (todo el paquete).

SSL/TLS VPN
VPN sobre HTTPS. Solo requiere navegador. Mas facil de desplegar que IPSec.

Split tunneling
Solo el trafico corporativo va por la VPN. El resto va directo a internet. Riesgo: bypass de controles.

Full tunnel VPN
TODO el trafico va por la VPN. Mas seguro. Mayor carga en el servidor VPN.

Proxy
Intermediario entre cliente e internet. Puede filtrar contenido, cachear, anonimizar.

Reverse Proxy
Intermediario delante de servidores. Balancea carga, oculta IPs internas. Ej: Nginx.

DNS Sinkhole
Resuelve dominios maliciosos a una IP controlada (sumidero). Detecta sistemas infectados.

DNSSEC
Firma las respuestas DNS criptograficamente. Evita DNS poisoning. Requiere soporte en servidor y cliente.

Puntos clave para el examen:

- IPSec Tunnel mode: cifra el paquete IP completo incluyendo cabeceras. Mas privacidad.
- Split tunneling: riesgo porque si el equipo del usuario esta infectado, el malware accede a la red corporativa.
- Proxy puede inspeccionar HTTPS con SSL inspection (necesita certificado instalado en el cliente).
- DNS Sinkhole: si un equipo intenta resolver malwaresite.com, lo manda a 192.168.1.1 → sabemos que esta infectado.
- DNSSEC previene cache poisoning pero NO cifra el contenido de las respuestas DNS (para eso existe DoH/DoT).

3.2 ampliacion

Protocolos de Routing y Red Avanzada
BGP (Border Gateway
Protocol)
Protocolo de routing entre sistemas autonomos (AS). Internet funciona con BGP.
Puerto 179. Vulnerable a hijacking.
OSPF (Open Shortest
Path First)
Protocolo de routing interno. Link-state. Convergencia rapida. Mas seguro que RIP.
RIP (Routing Information
Protocol)
Protocolo de routing interno. Distance-vector. Max 15 saltos. Obsoleto. RIPv2 usa MD5 para autenticacion.

EIGRP
Enhanced Interior Gateway Routing Protocol. Cisco propietario (ahora abierto). Hibrido distance-vector/link-state.
MPLS (Multiprotocol
Label Switching)
Dirige trafico usando etiquetas en vez de IPs. Muy usado en WAN de operadoras.
Eficiente para QoS.
SD-WAN
(Software-Defined WAN)
WAN gestionada por software. Conecta oficinas usando internet/MPLS/LTE. Mas barato que MPLS puro.
SASE (Secure Access
Service Edge)
Combina SD-WAN + seguridad en la nube (CASB, SWG, ZTNA, FWaaS). Arquitectura moderna para trabajo remoto.

DHCP
Dynamic Host Configuration Protocol. Asigna IPs automaticamente. DHCP snooping previene servidores DHCP rogue.
NTP (Network Time
Protocol)
Sincroniza relojes. Critico para Kerberos (tolerancia max 5 min). NTPv4 usa autenticacion.

ICMP
Internet Control Message Protocol. Ping, traceroute. Puede usarse para tunneling encubierto o DoS (ICMP flood).

SMTP
Simple Mail Transfer Protocol. Envio de email. Puerto 25 (entre servidores), 587 (cliente autenticado).

Puntos clave para el examen:

- BGP hijacking: un AS anuncia prefijos que no le pertenecen. Redirige trafico global. Historico: Pakistan Telecom →
  YouTube (2008).
- OSPF: si un atacante inyecta rutas OSPF falsas → trafico desviado. Autenticar OSPF con MD5/SHA.
- DHCP snooping: solo puertos confiables pueden enviar DHCP Offers. Previene DHCP rogue.
- NTP amplification: una peticion NTP monlist devuelve hasta 206 paquetes. Usado en DDoS (x500 amplificacion).
- SASE: en vez de mandar todo el trafico a la oficina central → seguridad en la nube, directo a internet.
- SD-WAN vs MPLS: MPLS = caro, fiable. SD-WAN = barato, usa internet con cifrado encima.

Teoria Complementaria — ExamCompass

3.2 - Dado un escenario, aplicar los principios de seguridad para asegurar la infraestructura empresarial.

- Dispositivos: Firewall, IDS, IPS, WAF, Balanceador de carga, Proxy, Jump server
- Tipos de firewall: Filtrado de paquetes, Stateful, NGFW, UTM
- Zonas: DMZ/Subred de pantalla, Fail-open vs Fail-closed
- Protocolos seguros: TLS, IPSec, VPN, SD-WAN, SASE, 802.1X

DISPOSITIVOS DE RED Y SU COLOCACION:

- Firewall: filtra trafico entre zonas de red. Debe colocarse entre zonas de diferente nivel de confianza
- IDS (Sistema de Deteccion de Intrusiones): detecta ataques y alerta. PASIVO, no bloquea
- IPS (Sistema de Prevencion de Intrusiones): detecta Y bloquea ataques. ACTIVO, se coloca en linea
- WAF (Firewall de Aplicacion Web): protege aplicaciones web, entiende HTTP/HTTPS. Capa 7
- Balanceador de carga: distribuye el trafico entre multiples servidores para alta disponibilidad
- Proxy: intermediario entre cliente e internet. Puede filtrar contenido, cachear y anonimizar
- Servidor de salto (Jump server/Bastion host): servidor en la DMZ desde el que se administran sistemas internos

TIPOS DE FIREWALL:

- Filtrado de paquetes: filtra por IP, puerto y protocolo. Sin estado (Stateless). Rapido pero basico
- Con estado (Stateful): recuerda el estado de las conexiones. Mas seguro
- NGFW (Firewall de Nueva Generacion): incluye IPS, inspeccion SSL, control de aplicaciones
- UTM (Gestion Unificada de Amenazas): todo en uno: firewall + IPS + antivirus + VPN + filtro web

ZONAS DE RED:

- DMZ (Zona Desmilitarizada) / Subred de pantalla: zona entre internet e intranet donde van los servidores publicos
- Fail-open: si el dispositivo falla, deja pasar todo el trafico (prioriza disponibilidad)
- Fail-closed: si el dispositivo falla, bloquea todo el trafico (prioriza seguridad)

PROTOCOLOS DE COMUNICACION SEGURA:

■ TLS (Seguridad de la Capa de Transporte): sucesor de SSL, cifra el trafico web (HTTPS = HTTP + TLS)

■ IPSec: cifrado a nivel de red (capa 3). Dos modos: Transport (solo payload) y Tunnel (todo el paquete)

■ VPN: tunel cifrado sobre internet. Tipos: Site-to-site (entre oficinas) y Remote access (usuario a red)

■ SD-WAN: WAN definida por software, optimiza el trafico entre sedes

■ SASE (Secure Access Service Edge): combina red y seguridad en la nube

■ 802.1X: estandar de autenticacion para acceso a red (NAC)

Preguntas de practica (75):

51. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

Preguntas Topic — ExamCompass (3 preguntas)

1. ¿Cuál de los protocolos enumerados a continuación se utiliza para permitir la navegación web segura?

[EN: Which of the protocols listed below is used to enable secure web browsing?]

A) L2TP

✓ B) HTTPS

C) SSH

D) IPSec

Fuente: Topic: Secure Network Protocols

---

2. FTPS es una extensión del protocolo SSH y se ejecuta de forma predeterminada en el puerto TCP 22.

A) Verdadero

✓ B) FALSO

Fuente: Topic: Secure Network Protocols

---

3. ¿Cuál de las respuestas enumeradas a continuación se refiere a un reemplazo seguro de Telnet?

[EN: Which of the answers listed below refers to a secure replacement for Telnet?]

A) RSH

B) IPSec

✓ C) SSH

D) RTPS

** Respuesta corregida manualmente*

Fuente: Topic: Secure Network Protocols

Preguntas Adicionales — Generadas (2 preguntas)

1. ¿Cuál es la diferencia entre IDS e IPS?

✓ A) IDS detecta y alerta; IPS detecta y bloquea activamente

B) IPS detecta; IDS bloquea

C) IDS opera en línea (inline); IPS fuera de banda (out-of-band)

D) Son equivalentes — solo difieren en el nombre del fabricante

Fuente: Extra: Network Security

---

2. ¿Para qué sirve DNSSEC?

✓ A) Firma criptográficamente las respuestas DNS para evitar spoofing/poisoning

B) Cifra las consultas DNS para proteger la privacidad
C) Acelera la resolución DNS usando caché distribuida
D) Proporciona alta disponibilidad para servidores DNS

Fuente: Extra: Network Security

Flashcards — 3.2 (3 tarjetas)

Q: VPN Split Tunnel vs Full Tunnel	Split: solo tráfico corporativo va por VPN; internet va directo (menos carga)
	Full: TODO el tráfico va por VPN (más seguro, más lento)
Q: DNS Sinkhole — ¿para qué?	Redirige peticiones DNS maliciosas a una IP controlada para bloquear malware y detectar hosts infectados
Q: DNSSEC — ¿qué hace?	Firma criptográficamente las respuestas DNS para prevenir DNS spoofing/poisoning

3.3 Proteccion de datos y privacidad

Conceptos Clave — Professor Messer

Seguridad de Datos y Privacidad
DLP (Data Loss
Prevention)
Detecta y previene la salida de datos sensibles. Monitoriza email, USB, nube.

Clasificacion de datos
Publica, Interna, Confidencial, Secreta/Critica. Define quien puede acceder y como.

Data at rest
Datos almacenados (disco, base de datos, backup). Cifrar con AES-256.

Data in transit
Datos en movimiento por la red. Cifrar con TLS/HTTPS/SSH/SFTP.

Data in use
Datos en memoria RAM mientras se procesan. El mas dificil de proteger.

Tokenizacion
Reemplazar dato sensible (tarjeta) con un token sin valor real. Ej: PCI DSS.

Anonimizacion
Eliminar o modificar datos para que no puedan identificar a la persona.

Pseudonimizacion
Reemplazar identificadores con pseudonimos. Reversible con la clave. Menos
privacidad que anonimizacion.
Enmascaramiento (Data
Masking)
Mostrar version parcial del dato. Ej: **** **** **** 1234.

GDPR
Reglamento europeo de proteccion de datos. Multas hasta 20M EUR o 4% facturacion
global.

Puntos clave para el examen:

- Data at rest → AES-256. Data in transit → TLS 1.3. Data in use → mas complejo (Intel SGX, cifrado homomórfico).
- DLP puede bloquear adjuntos de email que contengan numeros de tarjeta o SSN.

- Tokenizacion: la base de datos guarda el token, no el numero real. Incluso si la DB es robada, datos inutiles.
- GDPR: notificacion de brecha en 72 horas. Derecho al olvido. Consentimiento explicito.
- Anonimizacion: irreversible. Pseudonimizacion: reversible (con clave). Distincion importante en privacidad.

3.3 ampliacion

Destruccion y Sanitizacion de Datos

Degaussing

Exponer el medio magnetico a un campo magnetico intenso. Destruye los datos permanentemente. Solo vale para HDD, cintas.

Shredding / Destruccion

fisica

Destruccion mecanica del medio. Valido para cualquier tipo (HDD, SSD, papel, CD).

Wiping / Sobreescritura

Sobreescribir todos los sectores con ceros o datos aleatorios. Puede requerir multiples pasadas.

Purging

Proceso de eliminacion aprobado que garantiza que los datos no son recuperables. Puede incluir wipe + verify.

Sanitizacion

Proceso completo de preparar un medio para reutilizacion o desecho. Incluye wipe, degauss o destruccion.

Crypto-shredding

Cifrar los datos y luego destruir la clave de cifrado. Los datos cifrados son inaccesibles sin la clave.

Puntos clave para el examen:

- SSD: el wiping tradicional NO funciona bien en SSDs (wear leveling). Usar ATA Secure Erase o destruccion fisica.
- Degaussing en SSD: NO funciona. Los SSDs no son magneticos. Solo vale para HDD y cintas.
- NIST 800-88: estandar de referencia para sanitizacion. Define Clear, Purge y Destroy.
- Clear (wipe): adecuado para reutilizacion interna. Purge: adecuado para disposal. Destroy: maxima seguridad.
- Crypto-shredding: elegante para cloud. Si los datos estan cifrados y borras la clave, estan efectivamente destruidos.

Teoria Complementaria — ExamCompass

75. Un mecanismo de transporte dedicado para información sobre amenazas cibernéticas se denomina:

3.3 - Comparar y contrastar los conceptos e implicaciones de proteccion de datos.

- Tipos: PII, PHI, Datos financieros, Propiedad intelectual, Datos regulados
- Clasificacion: Restringido, Confidencial, Interno, Publico
- Estados: En reposo, En transito, En uso
- Proteccion: Cifrado, Tokenizacion, Enmascaramiento, Anonimizacion, DLP

TIPOS DE DATOS (por sensibilidad):

- PII (Informacion de Identificacion Personal): cualquier dato que identifica a una persona (nombre, DNI, email)
- PHI (Informacion de Salud Protegida): informacion medica de una persona (protegida por HIPAA)
- Datos financieros: datos bancarios, tarjetas de credito (protegidos por PCI DSS)
- Propiedad intelectual: patentes, codigo fuente, secretos comerciales
- Datos regulados: cualquier dato sujeto a regulacion legal

CLASIFICACION DE DATOS (de mas a menos sensible):

■ Restringido/Alto Secreto: maxima sensibilidad, acceso muy limitado

■ Confidencial/Secreto: datos sensibles de negocio

■ Interno/Privado: solo para uso interno

■ Publico: puede compartirse libremente

ESTADOS DE LOS DATOS:

■ En reposo (Data at rest): datos almacenados en disco/BD. Proteger con: cifrado de disco (BitLocker, FileVault)

■ En transito (Data in transit): datos moviendose por la red. Proteger con: TLS, VPN, IPSec

■ En uso (Data in use): datos en memoria RAM siendo procesados. El mas dificil de proteger. Tecnica: Secure Enclave

METODOS DE PROTECCION DE DATOS:

■ Cifrado: cifrar datos para que sean ilegibles sin la clave

■ Tokenizacion: sustituir el dato real por un token (sin valor matematico). Usado en pagos

■ Enmascaramiento de datos: ocultar parte del dato (mostrar solo ****1234 de una tarjeta)

■ Anonimizacion: eliminar toda informacion identificativa de forma irreversible

■ Seudonimizacion: sustituir identificadores por seudonimos (reversible con la clave)

■ DLP (Prevencion de Perdida de Datos): herramienta que detecta y bloquea fuga de datos

■ Restricciones geograficas / Soberania de datos: los datos deben almacenarse en un pais especifico por ley

Preguntas de practica (81):

1. Reemplazar caracteres de contraseña en un campo de contraseña con una serie de asteriscos es un ejemplo de:

Respuesta no detectada automaticamente

Preguntas Topic — ExamCompass (9 preguntas)

1. ¿Cuál de las respuestas enumeradas a continuación se refiere a algún tipo de información perteneciente a un individuo que pueda usarse para identificar de manera única a esa persona?

[EN: Which of the answers listed below refers to any type of information pertaining to an individual that can be used to uniq]

A) FI

B) Biometría

C) IDENTIFICACIÓN

✓ **D) PII**

Fuente: Topic: Data Protection

---

2. La Ley de Responsabilidad y Portabilidad del Seguro Médico de EE. UU. (HIPAA) brinda protección de la privacidad para:

A) PII

B) PI

✓ **C) FI**

D) PIV

Fuente: Topic: Data Protection

---

3. ¿Cuál de las respuestas enumeradas a continuación se refiere a los métodos de cifrado utilizados para proteger los datos en reposo? (Seleccione todo lo que corresponda)

[EN: Which of the answers listed below refer(s) to encryption method(s) used to protect data at rest? (Select all that apply)]

A) FDE

✓ B) SED

C) IPSec

D) TLS

✓ E) vpn

✓ F) EFS

Fuente: Topic: Data Protection

---

4. ¿Cuál de los siguientes estados de datos normalmente requiere que los datos se procesen sin cifrar?

[EN: Which of the following data states typically requires data to be processed in an unencrypted form?]

A) Datos en movimiento

B) Datos en reposo

C) Datos en tránsito

✓ D) Datos en uso

Fuente: Topic: Data Protection

---

5. ¿Cuál de las siguientes respuestas se refiere a una persona o función responsable de supervisar y garantizar el cumplimiento de las leyes y políticas de protección de datos dentro de una organización?

[EN: Which of the following answers refers to an individual or role responsible for overseeing and ensuring compliance with d]

A) CTO

✓ B) DPO

C) CIO

D) OSC

Fuente: Topic: Data Protection

---

6. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología que proporciona control sobre el uso de un dispositivo móvil dentro de un área designada?

[EN: Which of the answers listed below refers to a technology that provides control over the usage of a mobile device within]

✓ A) Geocerca

B) Portal cautivo

C) Mielero

D) Geolocalización

** Respuesta corregida manualmente*

Fuente: Topic: Data Protection

---

7. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica que permite convertir datos de entrada en una cadena de tamaño fijo, lo que dificulta revertir o recuperar los datos originales?

[EN: Which of the answers listed below refers to a technique that enables converting input data into a fixed-size string, mak]

A) Ofuscación

B) Tokenización

✓ C) hash

D) Cifrado

Fuente: Topic: Data Protection

---

8. ¿Cuál de las respuestas enumeradas a continuación se refiere a una situación en la que los datos confidenciales se almacenan en una ubicación separada y se pueden recuperar con un reemplazo no

confidencial que también se puede procesar como los datos originales sin el riesgo de revelar el contenido de los datos originales?

[EN: Which of the answers listed below refers to a situation where sensitive data is stored in a separate location and can be]

A) enmascaramiento

✓ B) Ofuscación

C) Cifrado

✓ D) Tokenización

Fuente: Topic: Data Protection

---

9. ¿Cuál de las respuestas enumeradas a continuación se refiere a las ventajas de la segmentación como método para proteger los datos? (Seleccione 3 respuestas)

[EN: Which of the answers listed below refer to the advantages of segmentation as a method for securing data? (Select 3 answe]

A) Mejora la seguridad al limitar la propagación de ciberataques

✓ B) Ayuda a las organizaciones a cumplir con los requisitos normativos de datos aislando y protegiendo tipos de datos específicos

C) Proporciona seguridad para los datos en tránsito con el uso de cifrado.

D) Garantiza la recuperación de datos en caso de eliminación accidental o fallas del sistema.

✓ E) Proporciona un mejor control sobre el acceso de los usuarios a datos confidenciales.

Fuente: Topic: Data Protection

Preguntas Adicionales — Generadas (2 preguntas)

1. ¿Cuál es la diferencia entre tokenización y cifrado en protección de datos?

✓ A) La tokenización reemplaza datos con un token sin relación matemática; el cifrado es reversible con la clave

B) El cifrado reemplaza datos con tokens aleatorios; la tokenización usa algoritmos matemáticos

C) Son sinónimos — ambos protegen datos en tránsito

D) La tokenización solo protege números de tarjeta; el cifrado protege cualquier dato

Fuente: Extra: Data Protection

---

2. ¿Qué establece la regla 3-2-1 para backups?

✓ A) 3 copias, en 2 soportes diferentes, 1 fuera del sitio

B) 3 backups diarios, 2 semanales, 1 mensual

C) Backup cada 3 horas, verificado 2 veces, 1 copia offsite

D) 3 tipos de backup (completo, incremental, diferencial), 2 ubicaciones, 1 en cloud

Fuente: Extra: Data Protection

Flashcards — 3.3 (4 tarjetas)

Q: Data at rest / in transit / in use	Rest: almacenado (cifrar con AES, BitLocker)
	Transit: en red (TLS, IPsec)
	Use: en memoria/procesamiento (entorno seguro, cifrado homomórfico)
Q: Tokenización vs Cifrado	Tokenización: sustituye dato por token sin relación matemática (no reversible sin tabla)
	Cifrado: transformación matemática reversible con la clave

Q: GDPR — 3 puntos clave	Notificación de brecha en 72h · Right to be forgotten · Multas hasta 4% facturación global o 20M€
Q: PII vs PHI	PII: Personally Identifiable Information (nombre, DNI, email...)
	PHI: Protected Health Information (datos médicos — regulado por HIPAA)

3.4 Resiliencia y recuperacion

Conceptos Clave — Professor Messer

Resiliencia y Recuperacion
RTO (Recovery Time
Objective)
Tiempo maximo tolerable para restaurar el servicio tras un fallo.
RPO (Recovery Point
Objective)
Cantidad maxima de datos que se puede perder. Define la frecuencia de backup.
MTTR (Mean Time To
Repair)
Tiempo promedio para reparar un sistema. Cuanto menor, mejor.
MTBF (Mean Time
Between Failures)
Tiempo promedio entre fallos. Cuanto mayor, mas fiable el sistema.
Alta Disponibilidad (HA)
Sistemas diseñados para minimizar el downtime. Redundancia en todos los
componentes.
Failover
Cambio automatico al sistema de respaldo cuando el primario falla.
Backup completo
Copia de TODOS los datos. Mas espacio. Restauracion mas rapida.
Backup incremental
Solo los cambios desde el ultimo backup (completo o incremental). Menos espacio.
Restauracion mas lenta.
Backup diferencial
Solo los cambios desde el ultimo backup COMPLETO. Compromiso entre espacio y
velocidad de restauracion.
3-2-1 Rule
3 copias, 2 medios diferentes, 1 offsite (fuera del sitio). Estandar de industria.
Disaster Recovery Plan
(DRP)
Plan documentado para recuperarse de un desastre mayor. Incluye contactos,
procedimientos, RTO/RPO.
BCP (Business
Continuity Plan)
Plan mas amplio. Como mantener el negocio operativo durante y despues del desastre.

Puntos clave para el examen:

- RPO = frecuencia de backup. Si RPO = 4h, necesitas backup cada 4 horas.
- RTO = tiempo para volver online. Si RTO = 2h, el sistema debe estar restaurado en 2 horas.

- Regla 3-2-1: 3 copias, 2 soportes distintos (disco + cinta), 1 fuera del edificio (o nube).
- Backup offline = proteccion contra ransomware. Si esta conectado, el ransomware lo cifra tambien.
- Incremental: restauracion lenta (necesitas el completo + todos los incrementales en orden).
- Diferencial: restauracion mas rapida (solo el completo + el ultimo diferencial).
- Hot site: listo para usar inmediatamente. Cold site: solo espacio fisico, hay que instalar todo. Warm: intermedio.

3.4 ampliacion

Recuperacion ante Desastres — Sites

Hot Site

Copia exacta del datacenter principal. Sistemas encendidos y sincronizados. Failover en minutos. Muy caro.

Warm Site

Infraestructura parcialmente preparada. Sistemas instalados pero no completamente actualizados. Failover en horas-dias.

Cold Site

Solo el espacio fisico y alimentacion electrica. Sin hardware instalado. Failover en dias-semanas. Mas barato.

Cloud-based DR

Usa la nube como site de recuperacion. Escalable, pago por uso. Puede actuar como Hot Site a menor coste.

Replicacion geografica

Copiar datos en tiempo real a otro datacenter en ubicacion distinta. Base del Hot Site.

Puntos clave para el examen:

- Hot Site = RTO minimo, coste maximo. Cold Site = RTO maximo, coste minimo.
- El RTO define que tipo de site necesitas: si RTO = 15 min → Hot Site obligatorio.
- Warm Site: el mas comun en empresas medianas. Balance entre coste y tiempo de recuperacion.
- Cloud DR: activa los recursos solo cuando hay desastre → coste 0 en operacion normal.
- Regla: nunca tener Hot Site en la misma zona geografica que el datacenter principal (terremoto, inundacion).

Teoria Complementaria — ExamCompass

de los datos originales?

PRUEBAS DE CONTINUIDAD:

- Ejercicio de mesa (Tabletop): simulacro en sala de juntas, sin afectar sistemas reales. El mas comun
- Prueba de failover: se provoca el fallo real para verificar que el sistema secundario toma el control
- Simulacion: simular un incidente especifico (ransomware, incendio) para probar la respuesta
- Procesamiento paralelo: ejecutar el sistema de recuperacion en paralelo al principal para validarlo

Preguntas de practica (42):

Respuesta no detectada automaticamente

Preguntas Topic — ExamCompass (13 preguntas)

1. Nivel RAID de hardware 0: (seleccione todo lo que corresponda)

A) Requiere un mínimo de 2 unidades para implementar

✓ B) También se conoce como segmentación de discos.

✓ C) Disminuye la confiabilidad (la falla de cualquier disco en la matriz resulta en la pérdida de todos los datos en la matriz)

D) También se conoce como duplicación de disco.

E) Ofrece menos capacidad de volumen en comparación con RAID 1

F) Requiere al menos 3 unidades para implementarse

✓ G) Es adecuado para sistemas donde el rendimiento tiene mayor prioridad que la tolerancia a fallos.

H) Ofrece confiabilidad mejorada al crear conjuntos de datos idénticos en cada unidad (la falla de una unidad no destruye la matriz ya que cada unidad contiene una copia idéntica de los datos)

Fuente: Topic: Resilience & Recovery

---

2. Hardware RAID Nivel 5: (Seleccione 3 respuestas)

A) Requiere al menos 2 unidades para implementar

B) Continúa funcionando en caso de falla de más de 1 unidad

C) También se conoce como segmentación de discos con doble paridad.

✓ D) Requiere al menos 3 unidades para implementarse

✓ E) Ofrece mayor rendimiento y tolerancia a fallas (la falla de una sola unidad no destruye la matriz y las unidades restantes pueden recrear los datos perdidos)

✓ F) Requiere al menos 4 unidades para implementarse

✓ G) También se conoce como división de discos con paridad.

Fuente: Topic: Resilience & Recovery

---

3. Hardware RAID Nivel 10 (también conocido como RAID 1+0): (Seleccione 3 respuestas)

A) Requiere un mínimo de 4 unidades para implementar

✓ B) Se conoce como banda de espejos, es decir, una combinación de RAID 1 (duplicación de disco) y RAID 0 (división de disco).

C) Requiere un mínimo de 5 unidades para implementar

✓ D) Ofrece mayor rendimiento y tolerancia a fallos (el fallo de una unidad en cada par de unidades de disco reflejadas no destruye la matriz)

E) Requiere un mínimo de 3 unidades para implementar

F) Continúa funcionando en caso de falla de más de 2 unidades

G) Se conoce como banda de espejos, es decir, una combinación de RAID 1 (división de discos) y RAID 0 (duplicación de discos).

Fuente: Topic: Resilience & Recovery

---

4. ¿Cuál de las respuestas enumeradas a continuación se refiere a la función principal del equilibrio de carga?

[EN: Which of the answers listed below refers to the primary function of load balancing?]

A) Mantiene copias idénticas de datos en múltiples servidores para mejorar la disponibilidad y confiabilidad de los datos.

✓ B) Distribuye la carga de trabajo entre múltiples servidores para mejorar el rendimiento.

✓ C) Agrupa servidores para proporcionar alta disponibilidad y tolerancia a fallos.

D) Distribuye contenido geográficamente entre múltiples servidores para mejorar el rendimiento, reducir la latencia y manejar grandes volúmenes de tráfico.

Fuente: Topic: Resilience & Recovery

---

5. ¿Cuál de los términos enumerados a continuación se refiere a un duplicado del sitio original, con sistemas informáticos en pleno funcionamiento y copias de seguridad casi completas de los datos del usuario?

[EN: Which of the terms listed below refers to a duplicate of the original site, with fully operational computer systems as w]

A) sitio caliente

✓ B) Sitio cálido

C) Sitio frio

D) sitio móvil

** Respuesta corregida manualmente*

Fuente: Topic: Resilience & Recovery

---

6. Una instalación de recuperación ante desastres que proporciona únicamente el espacio físico para las operaciones de recuperación se conoce como:

A) sitio caliente

B) Sitio cálido

✓ C) Sitio frio

D) Sitio espejo

Fuente: Topic: Resilience & Recovery

---

7. ¿Qué sitio alternativo permite la recuperación ante desastres más rápida?

[EN: Which alternate site allows for the fastest disaster recovery?]

A) Sitio frio

✓ B) sitio caliente

C) sitio móvil

D) Sitio cálido

Fuente: Topic: Resilience & Recovery

---

8. ¿Cuál de las respuestas enumeradas a continuación se refiere a un escenario simulado llevado a cabo en un entorno controlado, que generalmente implica discusiones y planificación en torno a incidentes de seguridad hipotéticos?

[EN: Which of the answers listed below refers to a simulated scenario conducted in a controlled environment, typically involv]

✓ A) Ejercicio de mesa

B) Zona de arena

C) caza de amenazas

D) Capacitación en concientización sobre seguridad.

** Respuesta corregida manualmente*

Fuente: Topic: Resilience & Recovery

---

9. ¿Cuál de las siguientes respuestas se refiere a un escenario más realista que prueba la respuesta a incidentes de ciberseguridad imitando ataques reales?

[EN: Which of the following answers refers to a more realistic scenario that tests cybersecurity incident response by mimicki]

A) Toma de huellas dactilares

✓ B) Simulación

C) caza de amenazas

D) Ejercicio de mesa

Fuente: Topic: Resilience & Recovery

---

10. Una representación basada en archivos del estado de una máquina virtual en un momento dado se denomina:

A) Punto de restauración

B) Copia sombra

✓ C) Instantánea

D) Imagen del sistema

Fuente: Topic: Resilience & Recovery

---

11. ¿Cuál de los siguientes términos se refiere a una estrategia de respaldo que se basa en la creación y el mantenimiento de copias de datos en tiempo real o casi en tiempo real en un sistema separado?

[EN: Which of the following terms refers to a backup strategy that relies on creating and maintaining copies of data in real-]

A) Duplicación

B) Virtualización

✓ C) Llevar un diario

✓ D) Replicación

Fuente: Topic: Resilience & Recovery

---

12. ¿Cuál de las respuestas enumeradas a continuación se refiere a un dispositivo diseñado para suministrar (y monitorear la calidad de) energía eléctrica a múltiples tomacorrientes?

[EN: Which of the answers listed below refers to a device designed to supply (and monitor the quality of) electric power to m]

A) fuente de alimentación

B) MDF

✓ C) PDU

D) FDI

Fuente: Topic: Resilience & Recovery

---

13. ¿Cuál de las siguientes soluciones de redundancia de energía sería la más adecuada para proporcionar energía de emergencia a largo plazo durante un corte inesperado de la fuente de energía principal?

[EN: Which of the following power redundancy solutions would be best suited for providing long-term emergency power during an]

A) Fuente de alimentación dual

B) UPS en espera

✓ C) Generador de respaldo

D) PDU administrada

Fuente: Topic: Resilience & Recovery

Preguntas Adicionales — Generadas (2 preguntas)

1. ¿Cuál es la diferencia entre RTO y RPO?

✓ A) RTO es el tiempo máximo para restaurar el servicio; RPO es la máxima pérdida de datos tolerable

B) RPO es el tiempo para restaurar; RTO es la pérdida de datos tolerable

C) RTO mide la disponibilidad; RPO mide el rendimiento

D) Son lo mismo: el tiempo objetivo de recuperación

Fuente: Extra: Resilience

---

2. ¿Cuál de los siguientes sitios de recuperación tiene el menor tiempo de activación pero el mayor coste?

✓ A) Hot site

B) Warm site

C) Cold site

D) Mobile site

Fuente: Extra: Resilience

Flashcards — 3.4 (4 tarjetas)

Q: RTO vs RPO	RTO: tiempo máximo para restaurar el servicio
	RPO: pérdida máxima de datos tolerable (ventana de tiempo)

Q: Hot / Warm / Cold Site	Hot: operativo 24/7, activación inmediata, coste alto
	Warm: parcialmente activo, horas de activación
	Cold: instalaciones vacías, días/semanas
Q: Regla 3-2-1 de backups	3 copias · en 2 soportes diferentes · 1 fuera del sitio (offsite)
Q: MTTR vs MTBF	MTTR: Mean Time To Repair (tiempo medio de reparación)
	MTBF: Mean Time Between Failures (tiempo medio entre fallos)

Messer + ExamCompass | Uso personal

DOMINIO 4 Operaciones de Seguridad (28% del examen)

4.1 Hardening y seguridad de aplicaciones

Conceptos Clave — Professor Messer

Hardening y Configuracion Segura

Baseline segura
Configuracion minima de seguridad aceptable para un tipo de sistema. CIS Benchmarks.

Hardening de SO
Deshabilitar servicios, renombrar admin, politica de contrasenas, cifrado de disco.

Hardening de red
Cambiar defaults, deshabilitar protocolos inseguros (Telnet→SSH, FTP→SFTP, HTTP→HTTPS).

MDM (Mobile Device Management)
Gestion centralizada de dispositivos moviles. Politicas, cifrado, borrado remoto.

MAM (Mobile Application Management)
Gestion de aplicaciones en moviles sin gestionar el dispositivo completo. BYOD.

BYOD (Bring Your Own Device)
Empleados usan sus propios dispositivos. Riesgo mayor, necesita politica clara.

COPE (Corporate-Owned, Personally Enabled)
La empresa da el dispositivo pero permite uso personal. Mayor control.

Contenedorizacion
Separar el entorno corporativo del personal en el mismo dispositivo. Ej: Samsung Knox.

Full Disk Encryption (FDE)
Cifra todo el disco. Ej: BitLocker (Windows), FileVault (Mac), LUKS (Linux).

Puntos clave para el examen:

- CIS Benchmarks: guias gratuitas de hardening para cada SO, servicio y aplicacion.
- Telnet = texto claro → siempre SSH. FTP = texto claro → siempre SFTP o FTPS. HTTP → HTTPS.
- MDM puede: borrar datos remotamente, forzar cifrado, bloquear apps, geolocalizar el dispositivo.
- BYOD vs COPE: COPE da mas control a la empresa. BYOD mas comodidad al empleado, mas riesgo.
- FDE protege si el disco fisico es robado. Sin FDE: quitar el disco y leer datos directamente.

Seguridad de Aplicaciones

SDLC seguro
Security Development Lifecycle. Integrar seguridad en cada fase del desarrollo: diseno, codigo, pruebas, despliegue.

Input Validation
Verificar que la entrada del usuario es del tipo y formato esperado. Previene SQLi, XSS, etc.

SAST
Static Application Security Testing. Analiza el codigo fuente sin ejecutarlo. En CI/CD

pipeline.

DAST

Dynamic Application Security Testing. Prueba la aplicacion en ejecucion. Encuentra problemas de runtime.

Code review

Revision manual del codigo por otro desarrollador. Detecta errores logicos y vulnerabilidades.

WAF

Web Application Firewall. Proteccion en runtime contra ataques web conocidos.

Container security

Asegurar imagenes Docker: escanear vulnerabilidades, no ejecutar como root, immutable.

Least Privilege

Cada proceso, usuario y servicio solo tiene los permisos minimos necesarios.

Puntos clave para el examen:

- SAST: analiza codigo fuente → encuentra bugs antes de ejecutar. GitHub Actions puede integrarlo.
- DAST: ataca la aplicacion en ejecucion → encuentra problemas que SAST no ve (logica de negocio).
- Input validation: NUNCA confiar en datos del usuario. Validar en servidor, no solo en cliente (Javascript).
- Least privilege: si el servidor web corre como root y es comprometido, el atacante tiene root en el SO.
- Container: imagen firmada + escaneo de vulnerabilidades + no root + red aislada = contenedor seguro.

4.1 ampliacion

Code Signing, DEP y Seguridad de Aplicaciones

Code signing

Firma criptografica del software por el desarrollador. El SO verifica la firma antes de ejecutar.

DEP (Data Execution Prevention)

Marca regiones de memoria como no-ejecutables. Previene que codigo malicioso inyectado en datos se ejecute.

ASLR (Address Space Layout Randomization)

Aleatoriza las direcciones de memoria en cada ejecucion. Dificulta exploits de buffer overflow.

Stack canary

Valor aleatorio colocado antes del return address en la pila. Si cambia → buffer overflow detectado.

NX bit (No-Execute)

Bit en la CPU que marca paginas de memoria como no-ejecutables. Similar a DEP, implementado en hardware.

Fuzzing / Fuzz testing

Enviar entradas aleatorias, malformadas o inesperadas a la aplicacion para encontrar crashes y vulnerabilidades.

SBOM (Software Bill of Materials)

Lista de todos los componentes de software y sus versiones. Permite identificar dependencias con vulnerabilidades.

Supply chain security

Verificar la integridad de componentes de terceros: librerias, dependencias, imagenes de contenedor.

DaaS (Desktop as a

Service)
Escritorios virtuales en la nube. Los datos nunca salen de la nube. Endpoint es solo pantalla/teclado.

Puntos clave para el examen:

- Code signing: si el certificado de firma expira o es revocado → el SO puede rechazar el software.
- DEP + ASLR juntos: DEP impide ejecutar en datos, ASLR hace impredecible donde esta el codigo → muy robusto.
- Stack canary: simple y efectivo. Muchos compiladores lo añaden por defecto (gcc -fstack-protector).
- Fuzzing: herramientas: AFL, libFuzzer, Boofuzz. Especialmente util para protocoles de red y parsers de archivos.
- SBOM: critico tras Log4Shell (2021). Muchas empresas no sabian que usaban Log4j porque estaba en una dependencia.
- SolarWinds: el atacante comprometio el proceso de build. Code signing no ayudo porque la firma era legitima.

Teoria Complementaria — ExamCompass

4.0 Operaciones de Seguridad (28% del examen)

4.1 - Dado un escenario, aplicar tecnicas comunes de seguridad a los activos.

- Baselines seguras, CIS Benchmarks, Hardening
- Gestion movil: MDM, BYOD, COPE, CYOD, MAM
- Seguridad wireless: WPA3, WPA2, WEP (roto), 802.1X, Rogue AP
- Seguridad en apps: Validacion de entrada, Cookies seguras, SAST, DAST, Sandboxing

BASELINES SEGURAS:

- Establecer una configuracion minima segura para cada tipo de dispositivo
- Desplegar mediante herramientas de gestion centralizada (GPO, MDM, Ansible)
- Mantener y verificar que los dispositivos no derivan de la baseline (deriva de configuracion)
- CIS Benchmarks: referencia de configuraciones seguras para multiples plataformas

HARDENING POR TIPO DE DISPOSITIVO:

- Estaciones de trabajo: deshabilitar autorun, cifrado de disco (BitLocker), antivirus, parches automaticos
- Servidores: deshabilitar servicios innecesarios, firewall de host, acceso remoto solo por SSH con clave
- Routers/Switches: cambiar credenciales por defecto, deshabilitar telnet, usar SSH, SNMP v3
- Dispositivos moviles: MDM, cifrado, borrado remoto, deshabilitar instalacion de apps no verificadas
- IoT: segmentar en VLAN separada, cambiar contrasenas por defecto, actualizar firmware

GESTION DE DISPOSITIVOS MOVILES:

- MDM (Gestion de Dispositivos Moviles): gestion centralizada (configuracion, apps, borrado remoto)
- BYOD (Trae tu propio dispositivo): el empleado usa su propio dispositivo. Menor control, mayor riesgo
- COPE (Propiedad corporativa, uso personal habilitado): la empresa da el dispositivo, el empleado puede usarlo personalmente
- CYOD (Elige tu propio dispositivo): el empleado elige entre una lista de dispositivos aprobados
- MAM (Gestion de Aplicaciones Moviles): gestiona solo las apps corporativas sin tocar el dispositivo personal

SEGURIDAD INALAMBRICA:

- WPA3: estandar actual, usa SAE (Autenticacion Simultanea de Iguales)
- WPA2: anterior estandar, vulnerable a ataque KRACK
- WEP: completamente roto, no usar nunca

■ RADIUS: servidor de autenticacion centralizado para redes WiFi empresariales (802.1X)

■ Rogue AP: punto de acceso no autorizado conectado a la red corporativa

■ Evil twin: AP falso que imita al legitimo para capturar trafico

SEGURIDAD EN APLICACIONES:

■ Validacion de entrada: verificar que los datos de entrada son del tipo y formato esperado (previene SQLi, XSS)

■ Cookies seguras: flags HttpOnly (no accesible por JS) y Secure (solo HTTPS)

Preguntas Topic — ExamCompass (7 preguntas)

1. ¿Cuáles de los aspectos de programación enumerados a continuación son críticos en el proceso de desarrollo seguro de aplicaciones? (Seleccione 2 respuestas)

[EN: Which of the programming aspects listed below are critical in the secure application development process? (Select 2 answ]

A) Gestión de parches

✓ B) Validación de entrada

C) Protección con contraseña

✓ D) Manejo de errores y excepciones

E) Lista blanca de aplicaciones

Fuente: Topic: Application Security

---

2. ¿Cuál de las siguientes respuestas se refiere a una contramedida contra la inyección de código?

[EN: Which of the following answers refers to a countermeasure against code injection?]

A) Fuzzing

✓ B) Validación de entrada

C) firma de código

D) Normalización

Fuente: Topic: Application Security

---

3. ¿Cuál de los términos enumerados a continuación se refiere a un proceso de revisión de código manual o automatizado destinado a descubrir errores de lógica y sintaxis en el código fuente de la aplicación?

[EN: Which of the terms listed below refers to an automated or manual code review process aimed at discovering logic and synt]

A) Validación de entrada

B) Análisis de código dinámico

C) Fuzzing

✓ D) Análisis de código estático

Fuente: Topic: Application Security

---

4. El término "análisis de código estático" se refiere al proceso de descubrir errores de tiempo de ejecución de la aplicación.

A) Verdadero

✓ B) FALSO

Fuente: Topic: Application Security

---

5. La práctica de encontrar vulnerabilidades en una aplicación dándole entradas incorrectas se llama:

A) Normalización

B) Endurecimiento

C) Análisis de código dinámico

✓ **D) Fuzzing**

Fuente: Topic: Application Security

---

6. ¿Cuál de las siguientes respuestas se refiere a una característica específica de Windows para manejar excepciones, errores y condiciones anormales en el software?

[EN: Which of the following answers refers to a Windows-specific feature for handling exceptions, errors, and abnormal condit]

A) EPC

✓ **B) SEH**

C) EH

D) EXR

Fuente: Topic: Application Security

---

7. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ **B) CAPTCHA**

C) SSO

D) NIDS

Fuente: Topic: Application Security

Preguntas Adicionales — Generadas (2 preguntas)

1. ¿Qué es SAST y cuándo se ejecuta?

✓ **A) Static Application Security Testing — analiza el código fuente sin ejecutarlo**

B) System Application Security Testing — analiza el sistema en producción

C) Secure Application Stress Testing — prueba el rendimiento bajo carga

D) Software Audit Security Testing — audita licencias de software

Fuente: Extra: Hardening

---

2. ¿Para qué sirve ASLR (Address Space Layout Randomization)?

✓ **A) Aleatoriza las posiciones de memoria para dificultar exploits de buffer overflow**

B) Cifra el espacio de memoria de los procesos

C) Detecta modificaciones en el código ejecutable

D) Separa el espacio de memoria entre procesos del kernel y usuario

Fuente: Extra: Hardening

Flashcards — 4.1 (3 tarjetas)

Q: SAST vs DAST	SAST: analiza código fuente estático (sin ejecutar) — encuentra bugs antes de compilar
	DAST: ataca la app en ejecución — encuentra fallos de lógica en runtime
Q: ASLR — ¿qué hace?	Address Space Layout Randomization: aleatoriza posiciones de memoria para dificultar exploits de buffer overflow
Q: DEP / NX bit — ¿qué hace?	Data Execution Prevention: marca regiones de memoria como no ejecutables para prevenir que shellcode se ejecute en el stack

4.2 Gestion de activos

Conceptos Clave — Professor Messer

Gestion de Activos

Asset inventory
Lista completa y actualizada de todos los activos: hardware, software, datos, servicios.

Asset tagging
Etiquetar fisicamente cada activo con ID unico. Facilita rastreo y auditoria.

CMDB
Configuration Management Database. Registra activos y sus relaciones/dependencias.

Software inventory
Lista de todo el software instalado. Detecta shadow IT y software no autorizado.

Vulnerability scanning
Escaneo automatico de sistemas para encontrar vulnerabilidades conocidas. Ej:
Nessus, Qualys.

Puntos clave para el examen:

- Sin inventario: no puedes proteger lo que no sabes que existe.
- CMDB: si cambias el servidor A, sabes que afecta a los servicios B y C (dependencias).
- Software inventory: detecta versiones obsoletas, licencias caducadas, software no autorizado.
- Vulnerability scanning: debe ejecutarse regularmente. El resultado prioriza que parchear primero (CVSS score).

Preguntas Adicionales — Generadas (5 preguntas)

1. ¿Qué significa EOL (End of Life) en el contexto de gestión de activos de software?

✓ A) El fabricante ya no proporciona soporte ni actualizaciones de seguridad
B) El software ha alcanzado el número máximo de licencias
C) El software requiere actualización obligatoria del hardware
D) El software solo funciona en sistemas legacy

Fuente: Extra: Asset Management

---

2. ¿Qué es un CMDB (Configuration Management Database)?

✓ A) Base de datos que almacena información sobre activos TI y sus relaciones
B) Sistema de backup de configuraciones
C) Herramienta de monitorización de rendimiento
D) Repositorio de políticas de seguridad

Fuente: Extra: Asset Management

---

3. ¿Cuál es la diferencia entre BYOD y COPE en gestión de dispositivos?

✓ A) BYOD: el empleado usa su propio dispositivo; COPE: la empresa lo provee pero permite uso personal
B) COPE: el empleado usa su propio dispositivo; BYOD: la empresa lo provee
C) Son sinónimos con diferente nombre de MDM
D) BYOD es para portátiles; COPE solo para móviles

Fuente: Extra: Asset Management

---

4. ¿Qué implica llegar a EOSL (End of Service Life) para un activo de software?

✓ A) El fabricante deja de publicar parches — el activo es un riesgo permanente

B) El software se desactiva automáticamente

C) Se requiere renovar la licencia para usarlo

D) Pasa a ser código abierto

Fuente: Extra: Asset Management

---

5. ¿Para qué sirve un SBOM (Software Bill of Materials)?

✓ A) Lista todos los componentes y dependencias para identificar vulnerabilidades en la cadena de suministro

B) Documenta el coste total de licencias

C) Registra los cambios de versión en producción

D) Audita el uso de software no licenciado

Fuente: Extra: Asset Management

Flashcards — 4.2 (2 tarjetas)

Q: EOL vs EOSL	EOL (End of Life): fin del soporte general
	EOSL (End of Service Life): fin TOTAL del soporte, incluyendo parches de seguridad → riesgo crítico
Q: CMDB — ¿qué almacena?	Inventario de activos TI (hardware, software, servicios) y sus relaciones/dependencias. Clave para gestión de cambios y BCDR

4.3 Gestion de vulnerabilidades y pentest

Conceptos Clave — Professor Messer

Evaluacion de Vulnerabilidades y Pentesting

Vulnerability scan
Automatico. Identifica vulnerabilidades conocidas. No explota nada. Menos intrusivo.

Penetration test (pentest)
Simulacion de ataque real. Explota vulnerabilidades. Mas intrusivo. Con autorizacion.

Bug Bounty
Programa que paga a investigadores por reportar vulnerabilidades. Ej: HackerOne, Bugcrowd.

CVSS Score
Common Vulnerability Scoring System. 0-10. Mayor score = mayor severidad/urgencia de parchear.

CVE
Common Vulnerabilities and Exposures. ID unico para cada vulnerabilidad. Ej: CVE-2021-44228 (Log4Shell).

Threat Intelligence
Informacion sobre amenazas actuales: IOCs, TTPs, actores. Fuentes: ISAC, FS-ISAC, MITRE ATT&CK.

OSINT
Open Source Intelligence. Informacion de fuentes publicas: WHOIS, Shodan, LinkedIn, DNS records.

Reconocimiento activo
Interactua directamente con el objetivo. Puede ser detectado. Ej: Nmap, Nessus.

Reconocimiento pasivo

No interactua directamente. Dificil de detectar. Ej: OSINT, WHOIS, Google.

Puntos clave para el examen:

- Pentest REQUIERE autorizacion escrita (Rules of Engagement). Sin ella es delito.
- Fases pentest: Reconocimiento → Escaneo → Explotacion → Post-explotacion → Informe.
- CVSS 9-10 = Critico. 7-8.9 = Alto. 4-6.9 = Medio. 0-3.9 = Bajo. Priorizar Critico y Alto primero.
- CVE-2021-44228 = Log4Shell. Una de las peores vulnerabilidades recientes. CVSS 10.
- Shodan = buscador de dispositivos expuestos en internet. Camaras, routers, SCADA, etc.
- Bug bounty: empresas pagan miles de dolares por vulnerabilidades criticas. Google paga hasta $31.337.

4.3 ampliacion

Pentest — Fases, Tipos y Metodologia

Black-box testing

El pentester no tiene informacion previa del objetivo. Simula un atacante externo real.

White-box testing

El pentester tiene acceso total: codigo fuente, arquitectura, credenciales. Mas completo y eficiente.

Grey-box testing

El pentester tiene informacion parcial. Simula un insider o un atacante con acceso limitado.

Fases del pentest

1. Reconocimiento 2. Escaneo/Enumeracion 3. Explotacion 4. Post-explotacion 5.

Informe/Remediation

Post-explotacion

Tras ganar acceso: escalada de privilegios, movimiento lateral, persistencia, exfiltracion de datos.

TTP (Tactics, Techniques, Procedures)

Como opera un actor de amenaza. Tacticas = por que, Tecnicas = como, Procedimientos = pasos especificos.

NVD (National Vulnerability Database)

Base de datos del NIST con todos los CVEs, scores CVSS y vectores de ataque. Referencia global.

BIA (Business Impact Analysis)

Analiza el impacto de cada proceso si fallara. Identifica procesos criticos y sus requisitos de RTO/RPO.

Attack Surface

Suma de todos los puntos de entrada posibles en un sistema. Minimizar la superficie = principio de seguridad.

Puntos clave para el examen:

- Black-box = mas realista pero menos completo. White-box = mas completo pero menos realista.
- Grey-box = el mas comun en engagements de pentest reales. Equilibrio tiempo/cobertura.
- Post-explotacion: el objetivo real no es entrar, sino demostrar el impacto (llegar a datos criticos).
- TTP del examen: MITRE ATT&CK documenta TTPs de grupos APT reales. Usados para hunting y deteccion.
- NVD CVSS incluye: attack vector (network/local/physical), complexity, privileges required, user interaction.
- BIA: entrada para el DRP. Sin BIA, no sabes que sistemas priorizar en un desastre.
- Attack surface reduction: apagar servicios innecesarios, cerrar puertos, parchear, quitar usuarios inactivos.

4.3 ampliacion

Red Team, Blue Team y Ejercicios de Seguridad

Red Team
Equipo que simula ser el atacante. Usa TTPs reales para encontrar vulnerabilidades. Actua como APT.

Blue Team
Equipo defensor. Monitoriza, detecta y responde a los ataques del Red Team. Opera el SIEM, EDR, etc.

Purple Team
Combinacion de Red y Blue. Trabajan juntos para mejorar la defensa basandose en los ataques. Mas colaborativo.

Tabletop Exercise
Ejercicio de simulacion verbal/documental de un incidente. Sin sistemas reales. Evalua el plan de respuesta.

Penetration Testing
Ataque simulado y autorizado para encontrar vulnerabilidades explotables. Fases: recon, scan, exploit, post-exploit, report.

Fuzzing / Fuzz Testing
Enviar datos aleatorios, malformados o inesperados a una aplicacion para encontrar crashes y vulnerabilidades.

OSINT (Open Source
Intelligence)
Recopilar informacion de fuentes publicas: WHOIS, Shodan, LinkedIn, Google, redes sociales, DNS records.

CVE (Common
Vulnerabilities &
Exposures)
ID unico para cada vulnerabilidad. Formato: CVE-ANo-NUMERO. Ej: CVE-2021-44228 (Log4Shell).

CVSS (Common
Vulnerability Scoring
System)
Puntuacion 0-10 de severidad de una vulnerabilidad. 9-10 = Critico, 7-8.9 = Alto, 4-6.9 = Medio.

Puntos clave para el examen:

- Red Team: opera en sigilo, simula un APT. Puede tardar semanas sin ser detectado.
- Blue Team: si no detecta al Red Team, es un problema. El objetivo es mejorar la deteccion.
- Purple Team: metodologia mas eficiente. Red comparte TTPs → Blue mejora defensas inmediatamente.
- Tabletop: nadie pulsa teclas. Es una reunion donde se discute 'que hariamos si...' Economico y efectivo.
- Fuzzing: especialmente util para encontrar buffer overflows en protocolos de red y parsers de archivos.
- CVSS base score: solo mide el impacto potencial. No tiene en cuenta si hay exploit publico disponible (eso es EPSS).

Teoria Complementaria — ExamCompass

4.3 - Explicar varios actividades asociadas a la gestion de vulnerabilidades.

- Proceso: Identificacion, Analisis, Respuesta, Validacion
- Herramientas: Vulnerability scanner, CVE, CVSS, OSINT, Threat feeds
- Analisis: Falso positivo, Falso negativo, Factor de exposicion
- Respuesta: Parcheo, Control compensatorio, Segmentacion, Aceptar

PROCESO DE GESTION DE VULNERABILIDADES:

1. Identificacion: escaneo de vulnerabilidades, pentesting, OSINT, threat feeds, bug bounty

2. Analisis: priorizar segun criticidad (puntuacion CVSS), contexto del negocio y exposicion

3. Respuesta: parchear, mitigar o aceptar el riesgo

4. Validacion: verificar que la vulnerabilidad fue corregida (rescan)

HERRAMIENTAS DE IDENTIFICACION:

■ Escaner de vulnerabilidades: Nessus, Qualys, OpenVAS. Escanea sistemas buscando vulnerabilidades conocidas

■ CVE (Vulnerabilidades y Exposiciones Comunes): identificador unico para cada vulnerabilidad (CVE-2021-44228 = Log4Shell)

■ CVSS (Sistema Comun de Puntuacion de Vulnerabilidades): puntuacion de 0-10 que indica la gravedad

■ OSINT: inteligencia de fuentes abiertas. Buscar informacion sobre la organizacion que es publica

■ Feeds de inteligencia de amenazas: fuentes de informacion sobre amenazas actuales (IOCs, TTPs)

ANALISIS DE RESULTADOS:

■ Falso positivo: la herramienta reporta una vulnerabilidad que no existe

■ Falso negativo: la herramienta NO reporta una vulnerabilidad que SI existe (el mas peligroso)

■ Factor de exposicion: porcentaje del activo que se perderia si la vulnerabilidad se explota

■ Tolerancia al riesgo: nivel de riesgo que la organizacion esta dispuesta a aceptar

RESPUESTA A VULNERABILIDADES:

■ Parcheo: aplicar el parche del fabricante. Solucion preferida

■ Control compensatorio: medida alternativa si no se puede parchear (ej: sistema legacy)

■ Segmentacion: aislar el sistema vulnerable en un segmento de red separado

■ Seguro (Insurance): transferir el riesgo economico mediante ciberseguro

■ Aceptar: documentar y aceptar el riesgo conscientemente

Preguntas de practica (16):

Preguntas Topic — ExamCompass (15 preguntas)

1. Escaneo de vulnerabilidades: (Seleccione todas las que correspondan)

A) Identifica falta de controles de seguridad

B) Prueba activamente los controles de seguridad.

✓ C) Identifica errores de configuración comunes

D) Explota vulnerabilidades

✓ E) Prueba pasivamente los controles de seguridad.

Fuente: Topic: Vulnerability Management

---

2. ¿Cuál de las siguientes afirmaciones describe las características del análisis de código dinámico? (Seleccione 3 respuestas)

[EN: Which of the following statements describe the features of dynamic code analysis? (Select 3 answers)]

A) Normalmente se utiliza más adelante en el ciclo de vida del desarrollo de software.

B) Implica examinar el código sin ejecutarlo.

✓ C) Analiza las propiedades del tiempo de ejecución, como el uso de la memoria, el rendimiento y el manejo de errores, para identificar problemas como pérdidas de memoria, cuellos de botella en el rendimiento y errores de tiempo de ejecución.

D) A menudo se utiliza al principio del proceso de desarrollo.

E) Examina la estructura, la sintaxis y la semántica del código para detectar problemas como errores de sintaxis, violaciones de estándares de codificación, vulnerabilidades de seguridad y errores.

✓ F) Implica ejecutar el código y analizar su comportamiento en tiempo de ejecución.

Fuente: Topic: Vulnerability Management

---

3. ¿Cuál de los términos enumerados a continuación se refiere al seguimiento y administración de componentes de aplicaciones de software, como bibliotecas de terceros y otras dependencias?

[EN: Which of the terms listed below refers to tracking and managing software application components, such as third-party lib]

✓ A) Control de versiones

B) Monitoreo de paquetes

C) Aplicación de la configuración

D) Endurecimiento de aplicaciones

** Respuesta corregida manualmente*

Fuente: Topic: Vulnerability Management

---

4. Un mecanismo de transporte dedicado para información sobre amenazas cibernéticas se denomina:

A) TCP/IP

B) TLS

✓ C) TAXII

D) S/MIME

Fuente: Topic: Vulnerability Management

---

5. ¿Cuál de las siguientes afirmaciones no se aplica a la web oscura?

[EN: Which of the following statements does not apply to dark web?]

A) Normalmente requiere software especializado para acceder a sus contenidos.

✓ B) Forma una gran parte de la web profunda.

C) No indexado por los motores de búsqueda tradicionales.

D) A menudo se asocia con el comercio de datos robados, malware y amenazas cibernéticas.

Fuente: Topic: Vulnerability Management

---

6. Un programa de divulgación responsable es un proceso formal establecido por una organización para alentar a los investigadores de seguridad y a los piratas informáticos éticos a informar las vulnerabilidades que descubren en los sistemas o software de la organización. Un programa de recompensas por errores es un tipo específico de programa de divulgación responsable que ofrece recompensas financieras a los investigadores de seguridad por informar vulnerabilidades válidas.

✓ A) Verdadero

B) FALSO

** Respuesta corregida manualmente*

Fuente: Topic: Vulnerability Management

---

7. ¿Cuál de las respuestas enumeradas a continuación se refiere a una situación en la que no se activa ninguna alarma cuando se ha producido un ataque?

[EN: Which of the answers listed below refers to a situation where no alarm is raised when an attack has taken place?]

✓ A) Falso negativo

B) Verdadero positivo

C) falso positivo

D) Verdadero negativo

** Respuesta corregida manualmente*

Fuente: Topic: Vulnerability Management

---

8. ¿Cuál de los siguientes términos se refiere a un marco y una base de conocimientos que proporciona comprensión de los TTP utilizados durante los ciberataques?

[EN: Which of the following terms refers to a framework and knowledge base that provides understanding of TTPs used during cy]

✓ A) cvss

✓ B) ATT&CK

C) STIX

D) TAXII

Fuente: Topic: Vulnerability Management

---

9. ¿Cuál de las siguientes opciones se refiere a un sistema que identifica, define y cataloga vulnerabilidades de ciberseguridad conocidas públicamente?

[EN: Which of the following refers to a system that identifies, defines, and catalogs publicly known cybersecurity vulnerabil]

A) TAXII

✓ B) CVE

C) STIX

D) cvss

Fuente: Topic: Vulnerability Management

---

10. ¿Cuál de las afirmaciones enumeradas a continuación no se refiere a una técnica de respuesta y remediación de vulnerabilidades?

[EN: Which of the statements listed below does not refer to a vulnerability response and remediation technique?]

A) Aplicar actualizaciones o correcciones proporcionadas por proveedores de software para abordar la vulnerabilidad (parches)

B) Garantizar la recuperación financiera de los costos asociados con un ciberataque exitoso (seguro)

C) Dividir una red en zonas más pequeñas y aisladas para limitar el impacto potencial de una vulnerabilidad (segmentación)

D) Mitigar el riesgo asociado con una vulnerabilidad que no se puede reparar de inmediato mediante la implementación de medidas de seguridad alternativas (controles de compensación)

E) Retrasar o renunciar a un parche para un sistema específico, por ejemplo, cuando aplicar un parche puede no ser factible debido a problemas de compatibilidad o posibles interrupciones en sistemas críticos (excepciones y exenciones).

✓ F) Todas las respuestas anteriores son ejemplos de técnicas de respuesta y remediación de vulnerabilidades.

Fuente: Topic: Vulnerability Management

---

11. Pruebas de penetración: (Seleccione todas las que correspondan)

A) Salta los controles de seguridad

B) Sólo identifica falta de controles de seguridad

✓ C) Prueba activamente los controles de seguridad.

✓ D) Explota vulnerabilidades

E) Prueba pasivamente los controles de seguridad.

Fuente: Topic: Penetration Testing

---

12. En los ejercicios de ciberseguridad, el equipo defensor se conoce como:

A) equipo rojo

✓ B) equipo azul

✓ C) equipo blanco

D) equipo morado

Fuente: Topic: Penetration Testing

---

13. En los ejercicios de ciberseguridad, un equipo morado asume el papel integrado de todos los demás equipos (es decir, rojo, azul y blanco).

A) Verdadero

✓ B) FALSO

Fuente: Topic: Penetration Testing

---

14. ¿Cuál de los siguientes términos se utiliza para describir una prueba de penetración en la que la persona que realiza la prueba tiene acceso limitado a información sobre el funcionamiento interno del sistema objetivo?

[EN: Which of the following terms is used to describe a penetration test in which the person conducting the test has limited]

A) Pruebas de caja negra

B) Prueba de fuzz

✓ C) Pruebas de caja gris

D) Pruebas de caja blanca

Fuente: Topic: Penetration Testing

---

15. En las pruebas de penetración, el reconocimiento activo implica recopilar cualquier tipo de información disponible públicamente que pueda usarse más adelante para explotar las vulnerabilidades encontradas en el sistema objetivo.

A) Verdadero

✓ B) FALSO

Fuente: Topic: Penetration Testing

Preguntas Adicionales — Generadas (2 preguntas)

1. ¿Cuál es la diferencia entre un escaneo de vulnerabilidades y un pentest?

✓ A) El escaneo identifica vulnerabilidades automáticamente; el pentest las explota activamente para medir el impacto real

B) El pentest es automático; el escaneo es manual

C) El escaneo requiere autorización; el pentest no

D) Son equivalentes — solo difieren en el nombre del proveedor

Fuente: Extra: Vulnerability Management

---

2. ¿Qué mide una puntuación CVSS de 9.8?

✓ A) Una vulnerabilidad crítica con alto impacto y baja complejidad de explotación

B) Una vulnerabilidad media que requiere interacción del usuario

C) Una vulnerabilidad baja con impacto limitado

D) Una vulnerabilidad que solo afecta a sistemas con configuración específica

Fuente: Extra: Vulnerability Management

Flashcards — 4.3 (4 tarjetas)

Q: Fases de un pentest	Reconocimiento → Escaneo → Explotación → Post-explotación → Informe
Q: Black / White / Grey box	Black: sin información previa (simula atacante externo)
	White: información completa (máxima cobertura)

	Grey: información parcial (más realista)
Q: CVSS — escala	0.0-3.9: Bajo · 4.0-6.9: Medio · 7.0-8.9: Alto · 9.0-10.0: Crítico
Q: CVE vs NVD vs KEV	CVE: identificador único de vulnerabilidad
	NVD: base de datos NIST con detalles y CVSS
	KEV: CISA Known Exploited Vulnerabilities — las que HAY que parchear urgente

4.4 Monitorizacion y alertas

Conceptos Clave — Professor Messer

Monitorizacion de Seguridad

SIEM
Centraliza logs, correlaciona eventos, genera alertas. Detecta patrones de ataque complejos.

Log aggregation
Recopilar logs de todos los sistemas en un punto central. Base del SIEM.

Alert tuning
Ajustar umbrales para reducir falsos positivos sin perder detecciones reales.

Baseline de comportamiento
Comportamiento normal del usuario/sistema. Las desviaciones generan alertas.

NetFlow
Metadata de flujos de red: IP src/dst, puerto, protocolo, bytes. No el contenido, pero si quien habla con quien.

Packet capture (PCAP)
Captura del trafico de red completo. Necesita almacenamiento masivo. Herramienta: Wireshark.

Endpoint telemetry
Datos de comportamiento de endpoints: procesos, conexiones, ficheros. Base de EDR.

Puntos clave para el examen:

- SIEM: correlacion de eventos. Un login fallido = normal. 1000 en 1 min = brute force → alerta.
- Alert tuning: si hay demasiados falsos positivos, los analistas los ignoran (alert fatigue).
- NetFlow: util para detectar exfiltracion de datos (trafico grande hacia IP externa inusual).
- PCAP: evidencia forense. Si capturas el trafico antes del incidente, puedes analizarlo despues.
- Baseline: usuario que siempre trabaja 9-18h y de repente accede a las 3AM = anomalia.

Herramientas de Seguridad

Nmap
Escaner de red y puertos. Detecta hosts, servicios, versiones, OS. Nmap -A -sV target.

Nessus / Qualys
Escaner de vulnerabilidades. Identifica CVEs en sistemas y aplicaciones.

Wireshark
Analizador de paquetes de red (PCAP). Inspecciona trafico en tiempo real o de archivo.

Metasploit
Framework de pentesting. Automatiza la explotacion de vulnerabilidades conocidas.

Burp Suite
Proxy de aplicaciones web. Intercepta y modifica trafico HTTP/HTTPS. Encontrar SQLi,

XSS.

Autopsy / FTK

Herramientas de forense digital. Analizan discos e imagenes forenses.

SIEM (Splunk, Elastic)

Plataformas SIEM comerciales y open source mas usadas en la industria.

Puntos clave para el examen:

- Nmap: herramienta de reconocimiento activo. Puede detectarse en logs del objetivo.
- Metasploit: SOLO en entornos autorizados. Usar sin permiso = delito penal.
- Burp Suite: intercepta HTTPS si instalas su certificado CA en el navegador.
- Forense: nunca analizar el original → siempre clonar el disco y analizar la copia.

4.4 ampliacion

Conceptos de Deteccion — Falsos y Verdaderos

True Positive (TP)

El sistema detecta un ataque real como ataque. Deteccion correcta. Lo que queremos.

True Negative (TN)

El sistema no alerta ante trafico legitimo. Correcto. Sin falsa alarma.

False Positive (FP)

El sistema alerta sobre algo que NO es un ataque. Genera ruido. Consume tiempo del analista.

False Negative (FN)

El sistema NO detecta un ataque real. El mas peligroso. El atacante pasa sin ser visto.

Alert fatigue

Los analistas ignoran alertas porque hay demasiados falsos positivos. Muy peligroso en SOC.

SIEM tuning

Ajustar reglas para reducir FP sin aumentar FN. Balance critico en operaciones de seguridad.

Network TAP

Dispositivo fisico que copia el trafico de red de forma pasiva. No afecta al trafico original.

SPAN port / Port mirroring

Configuracion en switch que duplica trafico de un puerto a otro. Alternativa software al TAP fisico.

On-path attack

El atacante se situa entre dos comunicadores. Puede leer y modificar el trafico. Sinonimo de MITM.

MDR (Managed Detection & Response)

Servicio externo que proporciona monitorizacion 24/7, deteccion y respuesta a incidentes.

UEM (Unified Endpoint Management)

Gestion unificada de todos los endpoints: moviles, portatiles, IoT desde una sola consola.

Puntos clave para el examen:

- FN > FP en impacto de seguridad: un ataque que pasa desapercibido es peor que una falsa alarma.
- FP alto → alert fatigue → analistas ignoran alertas → FN aumenta efectivamente. Circulo vicioso.
- Network TAP vs SPAN: TAP = mas fiable (no pierde paquetes bajo carga). SPAN puede perder paquetes.
- On-path = MITM = AiTM (Adversary in the Middle). El examen usa los tres terminos. Son sinonimos.

■ MDR: util para empresas sin SOC propio. El proveedor monitoriza 24/7 con expertos dedicados.
■ UEM: evolucion de MDM. MDM = solo moviles. UEM = moviles + PCs + IoT + wearables.

Teoria Complementaria — ExamCompass

■ Agregacion de logs: centralizar logs en un SIEM o servidor SYSLOG. Sin centralizacion no hay correlacion

■ Alerting: reglas que disparan notificaciones cuando se cumplen condiciones (ej: 5 logins fallidos en 1 minuto)

■ Ajuste de alertas (Alert tuning): ajustar umbrales para reducir FALSOS POSITIVOS sin perder detecciones reales. El mayor reto

operativo de un SOC

■ Cuarentena: aislar automaticamente un endpoint cuando el SIEM detecta comportamiento malicioso

■ Archivo: retener logs el tiempo exigido por ley (GDPR: minimo 1 ano, PCI DSS: 1 ano)

HERRAMIENTAS DE MONITORIZACION CRITICAS:

■ SCAP (Protocolo de Automatizacion de Contenido de Seguridad): framework NIST para automatizar verificacion de

cumplimiento

■ NetFlow/IPFIX: metadatos del trafico de red (origen, destino, puertos, bytes). No captura el contenido pero revela patrones

■ SNMP v3: monitoreo de dispositivos de red con autenticacion y cifrado. SNMPv1/v2 son inseguros

■ DLP (Prevencion de Perdida de Datos): inspecciona emails, transferencias de archivos y trafico web buscando datos sensibles

■ Escaner de vulnerabilidades: Nessus, Qualys, OpenVAS. Escaneo periodico (minimo semanal en entornos criticos)

■ Antivirus/EDR: AV usa firmas, EDR analiza comportamiento en tiempo real y permite investigacion forense

TRUCO EXAMEN: SIEM = correlacion y retencion. DLP = prevencion de fuga. EDR = deteccion y respuesta en endpoint. NetFlow =
quien habla con quien. SNMP = estado de dispositivos de red.

Preguntas de practica (31):

de monitorear y controlar los dispositivos administrados, así como de recopilar información SNMP de los

Agentes. El administrador recibe notificaciones (Traps e InformRequests) en el puerto UDP 162, mientras que

el agente SNMP recibe solicitudes en el puerto UDP 161.

Respuesta no detectada automaticamente

Preguntas Adicionales — Generadas (6 preguntas)

1. ¿Qué es 'alert fatigue' en el contexto de un SOC?

✓ **A) Los analistas ignoran alertas por el exceso de falsos positivos**
B) El SIEM deja de generar alertas por sobrecarga de eventos
C) Los firewalls fallan al procesar demasiado tráfico
D) Los logs se borran antes de ser analizados

Fuente: Extra: Monitoring

---

2. En el contexto de SIEM, ¿qué es la correlación de eventos?

✓ **A) Relacionar eventos de múltiples fuentes para identificar patrones de ataque**

B) Ordenar los logs por timestamp

C) Enviar alertas al equipo de seguridad por email

D) Cifrar los logs para garantizar su integridad

Fuente: Extra: Monitoring

---

3. ¿Cuál es la diferencia entre Verdadero Positivo (TP) y Falso Positivo (FP)?

✓ **A) TP: ataque real detectado correctamente; FP: alerta sobre tráfico legítimo**

B) FP: ataque real detectado; TP: alerta falsa

C) TP y FP son sinónimos — ambos indican alerta

D) TP aplica a IDS; FP a SIEM

Fuente: Extra: Monitoring

---

4. Un Falso Negativo (FN) en un IDS significa:

✓ **A) Un ataque real NO fue detectado — el error más peligroso**

B) Una alerta generada por tráfico legítimo

C) Un ataque bloqueado correctamente

D) Una alerta duplicada en el SIEM

Fuente: Extra: Monitoring

---

5. ¿Qué es NetFlow y para qué se usa en seguridad?

✓ **A) Registra metadatos de flujos de red (IP, puertos, bytes) para detectar anomalías**

B) Captura paquetes completos para análisis forense

C) Sistema de detección de intrusiones por firmas

D) Protocolo de enrutamiento dinámico

Fuente: Extra: Monitoring

---

6. ¿Cuál es la diferencia entre un Network TAP y un puerto SPAN?

✓ **A) TAP: copia física sin impacto en la red (más fiable); SPAN: copia software en el switch (puede perder paquetes bajo carga)**

B) SPAN es hardware; TAP es configuración software

C) TAP solo captura tráfico entrante; SPAN es bidireccional

D) Son equivalentes

Fuente: Extra: Monitoring

Flashcards — 4.4 (3 tarjetas)

Q: TP / FP / TN / FN en detección	TP: ataque detectado ✓
	FP: falsa alarma (ruido)
	TN: legítimo no alertado ✓
	FN: ataque NO detectado ← el más peligroso
Q: SIEM — función principal	Correlaciona eventos de múltiples fuentes para detectar patrones de ataque. Centraliza logs, genera alertas, facilita forensics
Q: ¿Qué es alert fatigue?	Los analistas ignoran alertas por exceso de falsos positivos. Solución: ajuste de umbrales (alert tuning) y automatización con SOAR

4.5 Seguridad en endpoint y email

Conceptos Clave — Professor Messer

Controles de Seguridad de Red y Endpoint

Firewall basado en host

Software en el endpoint que filtra trafico entrante/saliente. Ej: Windows Defender Firewall.

Antivirus (AV)

Detecta malware por firma. Necesita actualizacion constante de firmas.

EDR (Endpoint Detection & Response)

Detecta por comportamiento. Responde automaticamente. Mas avanzado que AV.

XDR (Extended Detection & Response)

EDR + red + cloud + email. Correlacion amplia. Respuesta unificada.

HIDS / HIPS

Host Intrusion Detection/Prevention System. Monitoriza el host individual.

Web filtering / Proxy

Bloquea acceso a URLs maliciosas o categorias (redes sociales, P2P).

Email security

SPF, DKIM, DMARC para autenticar emails. Anti-spam, anti-phishing, sandboxing de adjuntos.

SPF

Sender Policy Framework. Lista de IPs autorizadas a enviar email para un dominio.

DKIM

DomainKeys Identified Mail. Firma criptografica en el email. Verifica autenticidad del emisor.

DMARC

Domain-based Message Authentication. Politica de que hacer si SPF/DKIM fallan: rechazar, quarantine.

Puntos clave para el examen:

- AV = firma = conoce el malware de antes. EDR = comportamiento = detecta malware nuevo.
- XDR: si el email tiene link malicioso → EDR ve que el user lo abre → firewall ve la conexion saliente. Todo correlacionado.
- SPF sin DKIM: el dominio puede ser falsificado si alguien tiene el IP correcto.
- DMARC: la ultima linea de defensa. Define que hacer con emails que fallan SPF o DKIM.
- Email sandboxing: abre el adjunto en entorno aislado primero. Si hace algo malo → bloquear.

4.5 ampliacion

Email Seguro — S/MIME, PGP, STARTTLS

S/MIME

Secure/Multipurpose Internet Mail Extensions. Cifra y firma emails. Usa certificados X.509. Estandar empresarial.

PGP / GPG

Pretty Good Privacy / GNU Privacy Guard. Cifra y firma emails con par de claves. Web of Trust en vez de CA.

STARTTLS

Comando que actualiza una conexion no cifrada a TLS. Usado en SMTP (puerto 587), IMAP, POP3. Oportunista.

SMTPS
SMTP sobre TLS desde el inicio. Puerto 465. Distinto de STARTTLS (que empieza en claro y upgradea).

Email spoofing
Falsificar el campo From del email para parecer legitimo. Prevenido con SPF+DKIM+DMARC.

Open relay
Servidor SMTP que acepta y reenvia emails de cualquier origen. Explotado para spam y phishing masivo.

Puntos clave para el examen:

- S/MIME: firma usa clave privada del emisor → receptor verifica con clave publica del emisor.
- PGP Web of Trust: no hay CA central. Los usuarios firman las claves de otros para establecer confianza.
- STARTTLS vulnerable a downgrade: un atacante puede eliminar el comando STARTTLS → conexion en claro.
- SMTPS (465) vs STARTTLS/SUBMISSION (587): 587 es el preferido en RFC moderno para envio autenticado.
- S/MIME cifra: solo el destinatario (con su clave privada) puede leer. DKIM firma: cualquiera puede verificar.

Teoria Complementaria — ExamCompass

- p=none: solo monitorizar
- p=quarantine: enviar a spam
- p=reject: rechazar el email completamente

■ TRUCO: SPF = que IPs pueden enviar, DKIM = firma el contenido, DMARC = que hacer si fallan

OTRAS CAPACIDADES DE SEGURIDAD EMPRESARIAL:

■ Filtro web/URL: categorizar sitios y bloquear categorias. A nivel DNS (Cisco Umbrella) o proxy (Zscaler)

■ Filtrado DNS: bloquear dominios maliciosos antes de que la conexion se establezca. Primera linea de defensa contra phishing

■ FIM (Monitorizacion de Integridad de Archivos): detecta cambios no autorizados en archivos criticos. Critico para detectar

rootkits

■ NAC (Control de Acceso a la Red): verifica que un dispositivo cumple los requisitos de seguridad ANTES de permitirle

conectarse

■ EDR (Deteccion y Respuesta en el Endpoint): registra TODA la actividad del endpoint para investigacion forense

■ XDR (Deteccion y Respuesta Extendida): correlaciona telemetria de endpoint, red, email y nube en una sola plataforma

Preguntas de practica (61):

21. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software

automatizado (como los robots de red) se conoce como:

Preguntas Adicionales — Generadas (2 preguntas)

1. ¿Cuál es la diferencia entre AV tradicional y EDR?

✓ A) AV detecta por firmas conocidas; EDR detecta por comportamiento y permite respuesta activa

B) EDR solo protege endpoints móviles; AV protege estaciones de trabajo

C) AV funciona en tiempo real; EDR solo analiza en modo forense

D) Son sinónimos — EDR es simplemente la versión actualizada del antivirus

Fuente: Extra: Endpoint Security

---

2. ¿Qué hace DMARC en la seguridad del correo electrónico?

✓ A) Permite al propietario del dominio especificar qué hacer con emails que fallan SPF/DKIM (rechazar, cuarentena, monitorizar)

B) Cifra el contenido del email de extremo a extremo

C) Verifica la firma digital del remitente

D) Lista las IPs autorizadas para enviar email desde el dominio

Fuente: Extra: Email Security

Flashcards — 4.5 (2 tarjetas)

Q: SPF / DKIM / DMARC — diferencias	SPF: IPs autorizadas para enviar email del dominio
	DKIM: firma digital del mensaje
	DMARC: política de qué hacer si falla SPF/DKIM (quarantine/reject)
Q: MDM — ¿qué gestiona?	Mobile Device Management: políticas de seguridad en dispositivos móviles (cifrado, contraseña, borrado remoto, geofencing)

4.6 IAM y control de acceso

Conceptos Clave — Professor Messer

Gestion de Identidad y Acceso (IAM)

IAM

Identity and Access Management. Sistema centralizado para gestionar quien puede acceder a que.

SSO (Single Sign-On)

Un login → acceso a multiples sistemas. Comodidad. Si se compromete, todo comprometido.

MFA (Multi-Factor Authentication)

Algo que sabes (password) + algo que tienes (token) + algo que eres (biometria).

TOTP

Time-based One-Time Password. Codigo de 6 digitos que cambia cada 30 seg. Ej: Google Authenticator.

FIDO2 / Passkeys

Autenticacion sin contrasena. Clave criptografica en el dispositivo. Resistente a phishing.

RBAC (Role-Based Access Control)

Permisos asignados a roles. Usuarios heredan permisos del rol. Facil de gestionar.

ABAC (Attribute-Based Access Control)

Permisos basados en atributos: departamento, hora, ubicacion. Muy granular.

PAM (Privileged Access Management)

Gestion de cuentas privilegiadas (admin, root). Sesiones grabadas, tiempo limitado.

Federation / SAML

Compartir identidad entre organizaciones. SAML: XML-based. OAuth/OIDC: REST-based.

Provisioning / Deprovisioning

Crear y eliminar cuentas de forma controlada. Deprovisioning critico: ex-empleados.

Puntos clave para el examen:

- MFA reduce en 99.9% el riesgo de compromiso de cuenta (Microsoft stats).
- TOTP es vulnerable a phishing en tiempo real. FIDO2/Passkeys NO (clave criptografica vinculada al dominio).
- SSO: si el IdP (Identity Provider) es comprometido, TODOS los sistemas estan comprometidos.
- PAM: cuentas admin no se usan dia a dia. Se solicitan para tareas especificas con justificacion.
- Deprovisioning: el dia que un empleado sale, su cuenta debe desactivarse INMEDIATAMENTE.
- RBAC vs ABAC: RBAC mas simple de gestionar. ABAC mas flexible y granular.

4.6 ampliacion

Control de Acceso — Modelos Avanzados

MAC (Mandatory Access Control)

El SO asigna etiquetas de seguridad a datos y usuarios. El usuario NO puede cambiar permisos. Ej: SELinux, sistemas militares.

DAC (Discretionary Access Control)

El propietario del recurso decide quien accede. Ej: permisos de archivos en Windows/Linux. Mas flexible, menos seguro.

RBAC (Role-Based Access Control)

Permisos asignados a roles, no a usuarios. Usuario hereda permisos del rol. Lo mas comun en empresas.

Rule-based Access Control

Acceso basado en reglas del sistema (no roles). Ej: ACLs en firewalls y routers. Reglas IF-THEN.

ABAC (Attribute-Based Access Control)

Usa atributos del usuario, recurso y entorno. Muy granular. Ej: 'solo si es medico Y en horario laboral Y en red interna'.

802.1X NAC

Control de acceso a la red a nivel de puerto. El dispositivo debe autenticarse antes de poder usar la red.

Air Gap

Aislamiento fisico total de la red. El sistema no tiene ninguna conexion de red. Usado en sistemas criticos (nuclear, militar).

SELinux

Security-Enhanced Linux. Implementa MAC en Linux. Politicas obligatorias gestionadas por el administrador del SO.

Microsegmentacion

Dividir la red en zonas muy pequenas con politicas de acceso independientes. Limitacion del movimiento lateral.

Puntos clave para el examen:

- MAC = mas restrictivo. El SO controla todo. El usuario no puede compartir archivos libremente.

- DAC = mas comun en SO comerciales. Riesgo: un usuario descuidado puede dar permisos excesivos.
- Rule-based (ACL de firewall) != RBAC. Rule-based usa reglas del sistema, no roles de usuario.
- 802.1X: sin autenticacion → sin acceso a la VLAN corporativa. Fundamental para BYOD seguro.
- Air gap: el mayor aislamiento posible. Aun vulnerable a ataques fisicos (USB, BadUSB, Stuxnet).
- SELinux modos: Enforcing (aplica politicas), Permissive (solo registra), Disabled (desactivado).

4.6 ampliacion

Biometria y Errores de Autenticacion

Biometria
Autenticacion por caracteristicas fisicas unicas. Tipos: huella, retina, iris, voz, geometria de mano, escritura.

FAR (False Acceptance Rate)
Tasa de falsa aceptacion. Porcentaje de impostores aceptados como legitimos. Cuanto menor, mas seguro.

FRR (False Rejection Rate)
Tasa de falso rechazo. Porcentaje de usuarios legitimos rechazados. Afecta a la usabilidad.

CER / EER (Crossover Error Rate / Equal Error Rate)
Punto donde FAR = FRR. Mejor metrica para comparar sistemas biometricos. Cuanto menor el CER, mejor el sistema.

Quishing
Phishing mediante codigos QR. El QR lleva a una pagina maliciosa. Dificil de detectar porque la URL no es visible.

Vishing
Voice phishing. Llamadas telefonicas fraudulentas. Atacantes se hacen pasar por banco, Microsoft, soporte IT.

MFA fatigue / Push bombing
Bombardear al usuario con notificaciones MFA push hasta que acepta por agotamiento.

Puntos clave para el examen:

- FAR bajo = mas seguro (pocos impostores pasan). FRR bajo = mas usable (pocos usuarios bloqueados).
- FAR y FRR son inversamente proporcionales: si bajas el umbral → mas FAR, menos FRR. Y viceversa.
- CER es el punto de equilibrio. Un sistema con CER de 1% es mejor que uno con CER de 5%.
- Quishing: especialmente peligroso en sitios fisicos (restaurantes, carteles). El QR legitimo puede ser sustituido.
- MFA fatigue: solucion → usar FIDO2/passkeys (no hay notificacion push) o numerar las notificaciones push.
- Biometria: no se puede cambiar si se compromete. El PIN si. Por eso biometria sola es riesgo.

Teoria Complementaria — ExamCompass

- El mayor riesgo son las cuentas privilegiadas (admin, root, cuentas de servicio)
- Boveda de contrasenas (Password vaulting): las contrasenas de cuentas privilegiadas se almacenan en un vault cifrado

(CyberArk, HashiCorp Vault)

- Acceso justo-a-tiempo (JIT): el acceso privilegiado se concede solo cuando se necesita y por un tiempo limitado
- Grabacion de sesiones: todas las acciones de administradores privilegiados se graban para auditoria

■ Credenciales efimeras: credenciales de un solo uso que expiran tras ser usadas. Ideal para pipelines CI/CD

Preguntas de practica (80):

15. En el contexto de la seguridad informática, el término "biometría" se refiere tanto a las características biológicas del cuerpo humano como a los rasgos de comportamiento que pueden utilizarse con fines de identificación y control de acceso.

Respuesta no detectada automaticamente

52. Un tipo de documento que estipula reglas de comportamiento que deben seguir los usuarios de computadoras, redes y recursos asociados se denomina:

Preguntas Topic — ExamCompass (14 preguntas)

1. ¿Cuál de las siguientes respuestas se refiere(s) al modelo de control de acceso obligatorio (MAC)? (Seleccione todo lo que corresponda)

[EN: Which of the following answers refer(s) to the Mandatory Access Control (MAC) model? (Select all that apply)]

A) Los usuarios no pueden cambiar las políticas de acceso a su propia discreción.

✓ B) Las etiquetas y los niveles de autorización solo pueden ser aplicados y modificados por un administrador

C) Cada objeto tiene un propietario que, a su propia discreción, determina qué tipo de permisos pueden tener otros usuarios sobre ese objeto.

D) Acceso a recursos según la identidad del usuario.

✓ E) Cada recurso tiene una etiqueta de confidencialidad que coincide con un nivel de autorización asignado a un usuario.

Fuente: Topic: Access Controls

---

2. ¿Qué tipo de modelo de control de acceso conecta los permisos de los usuarios con sus responsabilidades específicas?

[EN: Which type of control access model connects user permissions to their specific responsibilities?]

A) CAD

✓ B) RBAC

C) IMPERMEABLE

D) ABAC

Fuente: Topic: Access Controls

---

3. Ejemplos de propiedades utilizadas para definir políticas de acceso en el modelo de control de acceso basado en atributos (ABAC) incluyen:

A) Asunto (es decir, usuario o proceso que solicita acceso)

B) Tipo de acción (por ejemplo "leer", "escribir", "ejecutar")

C) Tipo de recurso (historial médico, cuenta bancaria, etc.)

D) Entorno (datos contextuales, como hora del día o geolocalización)

✓ E) Todo lo anterior

Fuente: Topic: Access Controls

---

4. ¿Cuál de los modelos de control de acceso enumerados a continuación aplica el conjunto más estricto de reglas de acceso?

[EN: Which of the access control models listed below enforces the strictest set of access rules?]

✓ A) IMPERMEABLE

B) RBAC

C) CAD

D) ABAC

** Respuesta corregida manualmente*

Fuente: Topic: Access Controls

---

5. El principio de privilegio mínimo es una regla de seguridad que impide que los usuarios accedan a información y recursos que se encuentran más allá del alcance de sus responsabilidades.

✓ A) Verdadero

B) FALSO

** Respuesta corregida manualmente*

Fuente: Topic: Access Controls

---

6. Los dos factores que se consideran importantes para crear contraseñas seguras son: (Seleccione 2 respuestas)

A) Longitud de la contraseña

B) Edad mínima de la contraseña

C) Historial de contraseñas

✓ D) Complejidad de la contraseña

E) Edad máxima de la contraseña

Fuente: Topic: Password Concepts

---

7. ¿Cuál de las siguientes contraseñas es la más compleja?

[EN: Which of the following passwords is the most complex?]

A) $7C52WL4SU

B) GdL3tU8wxYz

C) @TxBL$nW@Xt

✓ D) G$L3tU8wY@z

Fuente: Topic: Password Concepts

---

8. ¿Qué política de contraseñas impone un cambio de contraseña obligatorio después de un tiempo específico?

[EN: Which password policy enforces a mandatory password change after a specific time?]

✓ A) Política de caducidad de contraseñas

B) Política de historial de contraseñas

C) Política de antigüedad mínima de la contraseña

D) Política de reutilización de contraseñas

** Respuesta corregida manualmente*

Fuente: Topic: Password Concepts

---

9. La configuración de política de antigüedad máxima de la contraseña determina el período de tiempo que se debe utilizar una contraseña antes de que el usuario pueda cambiarla.

A) Verdadero

✓ B) FALSO

Fuente: Topic: Password Concepts

---

10. ¿Cuál de las respuestas enumeradas a continuación se refiere a una herramienta de software diseñada específicamente para almacenar y administrar las credenciales de inicio de sesión?

[EN: Which of the answers listed below refers to a software tool specifically designed to store and manage login credentials?]

A) BitLocker

✓ **B) Administrador de contraseñas**

C) depósito de claves

D) Bóveda de contraseñas

** Respuesta corregida manualmente*

Fuente: Topic: Password Concepts

---

11. ¿Qué técnica criptográfica se utiliza para evitar la eficacia de las tablas arcoíris a la hora de descifrar contraseñas hash?

[EN: Which cryptographic technique is used to prevent the effectiveness of rainbow tables in cracking hashed passwords?]

A) Enmascaramiento de datos

B) Autenticación de dos factores (2FA)

C) Estiramiento clave

✓ **D) Salazón**

Fuente: Topic: Password Concepts

---

12. La importancia de cambiar los nombres de usuario y contraseñas predeterminados se puede ilustrar con el ejemplo de ciertos dispositivos de red (como enrutadores), que a menudo vienen con credenciales de administrador predeterminadas y conocidas que se pueden buscar en la web.

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Topic: Password Concepts

---

13. Una breve lista de contraseñas de uso común probadas en una gran cantidad de cuentas de usuario es un rasgo característico de:

A) Repetir ataque

B) Ataque de diccionario

✓ **C) Ataque de fumigación**

D) Ataque de cumpleaños

Fuente: Topic: Password Concepts

---

14. Un ataque contra datos cifrados que depende en gran medida de la potencia informática para comprobar todas las claves y contraseñas posibles hasta encontrar la correcta se denomina:

A) Repetir ataque

✓ **B) Ataque de fuerza bruta**

C) Ataque de diccionario

D) Ataque de cumpleaños

Fuente: Topic: Password Concepts

Preguntas Adicionales — Generadas (2 preguntas)

1. ¿Cuál es la diferencia entre RBAC y ABAC?

✓ **A) RBAC asigna permisos según el rol del usuario; ABAC los asigna según múltiples atributos (rol, hora, ubicación, etc.)**

B) ABAC usa roles jerárquicos; RBAC usa atributos individuales

C) RBAC es más granular y flexible; ABAC es más simple

D) Son equivalentes — solo difieren en la nomenclatura del fabricante

Fuente: Extra: IAM

---

2. ¿Qué es PAM (Privileged Access Management) y por qué es importante?

✓ **A) Gestiona y audita el acceso de cuentas con privilegios elevados para minimizar el riesgo de abuso**

B) Proporciona autenticación multifactor para todos los usuarios

C) Gestiona contraseñas de usuarios normales

D) Monitoriza el tráfico de red de administradores

Fuente: Extra: IAM

Flashcards — 4.6 (4 tarjetas)

Q: MAC / DAC / RBAC / ABAC	MAC: el SO controla todo (SELinux) — más rígido
	DAC: el propietario decide
	RBAC: permisos por rol
	ABAC: permisos por múltiples atributos — más flexible
Q: MFA — 3 factores	Algo que SABES (contraseña, PIN)
	Algo que TIENES (token, móvil, tarjeta)
	Algo que ERES (huella, iris, voz)
Q: TOTP vs FIDO2	TOTP: OTP que cambia cada 30 segundos (Google Authenticator)
	FIDO2/Passkeys: sin contraseña, criptografía de clave pública, phishing-resistant
Q: PAM — ¿qué gestiona?	Privileged Access Management: controla, monitoriza y audita cuentas con privilegios elevados. JIT access = acceso justo a tiempo

4.7 Automatizacion y orquestacion

Conceptos Clave — Professor Messer

Automatizacion y Scripting de Seguridad
IaC (Infrastructure as Code)
Definir infraestructura como codigo (Terraform, CloudFormation). Reproducible y auditado.

SOAR
Security Orchestration Automation and Response. Automatiza respuesta a incidentes con playbooks.

Playbook
Procedimiento documentado y automatizable para un tipo de incidente. Ej: 'si alerta de brute force → bloquear IP'

API Security
Autenticar APIs con API keys o OAuth. Limitar rate. Validar inputs. Cifrar en transit.

CI/CD Security
Integrar seguridad en el pipeline de despliegue: SAST, DAST, escaneo de contenedores.

Puntos clave para el examen:

- IaC: si el config tiene un error de seguridad, se puede corregir y redesplegar en minutos en toda la infraestructura.

■ SOAR reduce MTTD y MTTR: detecta y responde automaticamente sin esperar al analista.
■ Playbooks de SOAR: 'phishing detectado → cuarentenar el email en todas las cuentas → notificar al usuario'.
■ CI/CD: cada commit puede ejecutar escaneo SAST automaticamente → falla el build si hay vuln critica.

Teoria Complementaria — ExamCompass

AUTOMATIZACION Y ORQUESTACION EN SEGURIDAD:

■ Automatizacion: ejecutar una tarea especifica sin intervencion humana (un script que bloquea una IP)

■ Orquestacion: coordinar MULTIPLES herramientas y procesos automatizados en un flujo de trabajo

■ SOAR (Orquestacion, Automatizacion y Respuesta de Seguridad): plataforma que integra herramientas de seguridad y

automatiza la respuesta a incidentes

Ejemplo de playbook SOAR: alerta de phishing → extraer IOCs del email → buscar en SIEM → bloquear dominio en firewall → aislar

endpoint → crear ticket → notificar al usuario → todo en segundos sin intervencion humana

CASOS DE USO REALES:

■ Provisionamiento/desprovisionamiento de usuarios: cuando RRHH crea/desactiva un empleado, se dispara automaticamente la

gestion de todas sus cuentas

■ Enriquecimiento de inteligencia de amenazas: cuando el SIEM genera una alerta con una IP, el SOAR consulta

automaticamente VirusTotal, Shodan y feeds de threat intel

■ Creacion automatica de tickets: cada alerta critica del SIEM crea automaticamente un ticket en ServiceNow/Jira

■ Remediacion de vulnerabilidades: cuando el scanner detecta una vulnerabilidad critica, se crea el ticket y se asigna al equipo

correcto con el SLA establecido

■ Actualizacion de grupos de seguridad: cuando un endpoint se comporta de forma sospechosa, se mueve automaticamente a

una VLAN de cuarentena

BENEFICIOS vs RIESGOS:

■ Beneficios: velocidad (segundos vs horas), consistencia (siempre hace lo mismo), escalabilidad (gestiona miles de alertas

simultaneas), multiplicador de fuerza de trabajo

■ Riesgos: Punto unico de fallo (si el SOAR falla, los procesos automatizados tambien), complejidad (bugs en playbooks pueden

causar acciones incorrectas), deuda tecnica (playbooks obsoletos), sobre-automatizacion (automatizar decisiones que requieren

criterio humano)

SCRIPTING Y APIs:

■ Python: el lenguaje mas usado en seguridad para automatizacion. Scripts para parsear logs, interactuar con APIs, analizar

malware

■ APIs REST: permiten integrar herramientas de seguridad entre si. El SIEM puede llamar a la API del firewall para bloquear una

■ DevSecOps: integrar pruebas de seguridad (SAST, DAST, escaneo de dependencias) en el pipeline de desarrollo para detectar

vulnerabilidades antes de produccion

Preguntas de practica (12):

Preguntas Adicionales — Generadas (5 preguntas)

1. ¿Qué es un playbook en el contexto de SOAR?

✓ A) Un conjunto de acciones automatizadas definidas para responder a un tipo específico de incidente

B) Un manual de procedimientos para el equipo de seguridad

C) Un script para escaneo de vulnerabilidades

D) Un informe de análisis forense post-incidente

Fuente: Extra: Automation

---

2. ¿Cuál es el beneficio principal de IaC (Infrastructure as Code) en seguridad?

✓ A) Garantiza configuraciones consistentes y repetibles, eliminando errores de configuración manual

B) Cifra automáticamente toda la infraestructura cloud

C) Elimina la necesidad de firewalls en entornos cloud

D) Proporciona backups automáticos de la infraestructura

Fuente: Extra: Automation

---

3. ¿Cuál es la diferencia entre automatización y orquestación en seguridad?

✓ A) Automatización ejecuta tareas individuales; orquestación coordina múltiples automatizaciones como flujo de trabajo

B) Orquestación ejecuta tareas individuales; automatización coordina sistemas

C) Son sinónimos en SOAR

D) Automatización requiere intervención humana; orquestación no

Fuente: Extra: Automation

---

4. ¿Qué ventaja aporta CI/CD con SAST integrado al desarrollo seguro?

✓ A) Detecta vulnerabilidades en cada commit antes de llegar a producción

B) Cifra el código fuente en el repositorio

C) Genera documentación de seguridad automáticamente

D) Sustituye las pruebas de penetración manuales

Fuente: Extra: Automation

---

5. ¿Qué es un runbook en operaciones de seguridad?

✓ A) Procedimiento documentado paso a paso para responder a un incidente o tarea operativa

B) Log de acciones del SOAR

C) Script de escaneo de vulnerabilidades

D) Informe de auditoría del equipo de seguridad

Fuente: Extra: Automation

Flashcards — 4.7 (2 tarjetas)

Q: SOAR — 3 funciones	Automatización de respuesta · Orquestación de herramientas · Gestión de casos e informes
Q: IaC (Infrastructure as Code) — beneficio de seguridad	Configuraciones reproducibles y auditables. Evita 'configuration drift'. Herramientas: Terraform, CloudFormation, Ansible

4.8 Respuesta a incidentes y forense

Conceptos Clave — Professor Messer

Respuesta a Incidentes y Forense Digital

IR Plan
Incident Response Plan. Proceso documentado: Preparacion → Deteccion → Contencion → Erradicacion → Recuperacion → Leccion aprendida.

CSIRT
Computer Security Incident Response Team. Equipo especializado en respuesta a incidentes.

Contencion
Aislar los sistemas afectados para evitar propagacion. No destruir evidencias.

Erradicacion
Eliminar el malware o vector de ataque del sistema.

Recuperacion
Restaurar sistemas a operacion normal desde backup conocido-bueno.

Cadena de custodia
Documentar quien toca la evidencia, cuando y para que. Critico para evidencia legal.

Orden de volatilidad
Recoger evidencias de mas a menos volatil: RAM → procesos → red → disco → logs.

Write blocker
Hardware/software que impide escribir en el disco original durante la adquisicion forense.

Imagen forense
Copia bit a bit del disco original. Hash MD5/SHA verificado. NUNCA analizar el original.

Esteganografia forense
Detectar datos ocultos en archivos. Herramientas: Steghide, Stegdetect.

Puntos clave para el examen:

- Orden de volatilidad: RAM primero (se pierde al apagar). Disco despues (persiste).
- Cadena de custodia: sin ella, la evidencia puede ser inadmisible en juicio.
- Write blocker: obligatorio en forense. Sin el, el acceso al disco modifica timestamps y puede invalidar evidencia.
- Imagen forense: hash SHA-256 antes y despues. Si coinciden → integridad garantizada.
- Lessons Learned: reunion post-incidente obligatoria. Que fallo? Que mejorar? Actualizar el IR plan.
- Fases NIST: Preparacion → Deteccion/Analisis → Contencion/Erradicacion/Recuperacion → Post-incidente.

Teoria Complementaria — ExamCompass

1. En el proceso de respuesta a incidentes, el paso que implica identificar y comprender incidentes potenciales para determinar su alcance, impacto y causa raíz es parte de:

9. El proceso de identificar, recopilar y producir información almacenada electrónicamente con la intención

de utilizarla en un procedimiento o investigación legal se conoce como:

Respuesta no detectada automaticamente

17. Una de las formas de evitar la recuperación de datos de una unidad de almacenamiento es sobrescribir su contenido. La técnica de sobrescritura de datos la utilizan las utilidades de borrado de unidades que pueden emplear diferentes métodos (incluidas múltiples rondas de sobrescritura) para disminuir la probabilidad de recuperación de datos. Como ejemplo, una utilidad de desinfección de disco podría sobrescribir los datos de la unidad con el valor de uno en la primera pasada, cambiar ese valor a cero en la segunda pasada y, finalmente, realizar algunas pasadas más, sobrescribiendo el contenido con caracteres aleatorios.

Preguntas Topic — ExamCompass (5 preguntas)

1. ¿Qué parte del proceso de respuesta a incidentes implica establecer y mantener la capacidad de respuesta a incidentes, así como establecer un equipo de respuesta a incidentes?

[EN: Which part of the incident response process involves establishing and maintaining the incident response capability as we]

- **✓ A) Preparación**
- B) Detección y análisis
- C) Contención, erradicación y recuperación
- D) Actividad posterior al incidente

** Respuesta corregida manualmente*

Fuente: Topic: Incident Response

---

2. ¿Cuál de las siguientes respuestas se refiere(s) a la etapa de contención, erradicación y recuperación del proceso de respuesta a incidentes? (Seleccione todo lo que corresponda)

[EN: Which of the following answers refer(s) to the containment, eradication, and recovery stage of the incident response pro]

- A) Restaurando operaciones normales
- **✓ B) Eliminando la amenaza**
- C) Seguimiento y detección de posibles incidencias
- D) Establecer y mantener una política de respuesta a incidentes.
- **✓ E) Mitigar el impacto del incidente**

Fuente: Topic: Incident Response

---

3. ¿Cuál de las respuestas enumeradas a continuación se refiere a una actividad basada en debates en la que los miembros del equipo recorren diferentes escenarios para evaluar el plan de respuesta a incidentes sin activar ningún sistema?

[EN: Which of the answers listed below refers to a discussion-based activity where team members walk through different scenar]

- A) Ejercicio de mesa
- **✓ B) Simulación**
- C) caza de amenazas
- D) Análisis de causa raíz

Fuente: Topic: Incident Response

---

4. Durante la etapa de actividad posterior al incidente, este paso implica analizar registros, datos forenses y otras pruebas para evitar que el incidente vuelva a ocurrir.

- A) Informes
- B) descubrimiento electrónico
- **✓ C) Análisis de causa raíz**

D) caza de amenazas

Fuente: Topic: Incident Response

---

5. El proceso de mantener un registro documentado del manejo y movimiento de la evidencia para asegurar su integridad y admisibilidad en el tribunal se denomina:

✓ A) cadena de custodia

B) Cadena de evidencia

C) Cadena de rendición de cuentas

D) cadena de responsabilidad

** Respuesta corregida manualmente*

Fuente: Topic: Incident Response

Preguntas Adicionales — Generadas (2 preguntas)

1. ¿Cuál es el orden correcto de las fases de Respuesta a Incidentes según NIST SP 800-61?

✓ A) Preparación → Detección y análisis → Contención, erradicación y recuperación → Actividad post-incidente

B) Detección → Contención → Análisis → Recuperación → Lecciones aprendidas

C) Identificación → Protección → Detección → Respuesta → Recuperación

D) Preparación → Contención → Detección → Erradicación → Recuperación

Fuente: Extra: Incident Response

---

2. ¿Por qué se analiza la RAM antes del disco duro en una investigación forense?

✓ A) La RAM es volátil: su contenido desaparece al apagar el sistema

B) El disco duro contiene datos cifrados que requieren más tiempo

C) La RAM tiene mayor capacidad de almacenamiento de evidencias

D) Por normativa legal: la RAM siempre tiene prioridad probatoria

Fuente: Extra: Incident Response

Flashcards — 4.8 (3 tarjetas)

Q: Fases IR según NIST SP 800-61	1. Preparación
	2. Detección y análisis
	3. Contención, erradicación y recuperación
	4. Actividad post-incidente (lecciones aprendidas)
Q: Orden de volatilidad forense	RAM → Swap/Pagefile → Procesos en ejecución → Conexiones de red → Disco duro → Logs remotos → Backups
Q: Chain of Custody — ¿qué es?	Registro documentado de quién manejó la evidencia, cuándo y cómo. Garantiza admisibilidad en juicio

4.9 Logs y fuentes de datos

Conceptos Clave — Professor Messer

Gestion de Logs y Datos

Log management
Recopilar, almacenar, analizar y retener logs. Base de la seguridad y el cumplimiento.

Syslog
Protocolo estandar para enviar logs. UDP 514 (o TCP 514 para fiabilidad). TLS para cifrado.

Windows Event Logs
Logs del SO Windows: Security, System, Application. IDs importantes: 4624 (login), 4625 (login fallido), 4648.

Log retention
Cuanto tiempo guardar los logs. Regulaciones pueden exigir 1-7 anos. GDPR puede limitar.

Log integrity
Usar SIEM con almacenamiento inmutable. Logs firmados criptograficamente.

Puntos clave para el examen:

- Event ID 4625 (login fallido) en masa → brute force. Alertar si > 10 en 1 minuto.
- Syslog sin TLS: los logs viajan en texto claro por la red. Usar syslog-ng o rsyslog con TLS.
- Logs deben enviarse a servidor EXTERNO: si el sistema es comprometido, el atacante no puede borrar los logs remotos.
- Retener logs al menos 90 dias para investigacion. 1 ano para compliance (PCI DSS, SOC2).
- Los atacantes saben que existen logs → lo primero que intentan es borrarlos. Detectar borrado = alarma critica.

Teoria Complementaria — ExamCompass

- Logs DNS: resoluciones de nombres. Critico para detectar:
  - C2 (Mando y Control): el malware resuelve dominios generados aleatoriamente (DGA)
  - Tunelizacion DNS: datos exfiltrados codificados en consultas DNS
  - Typosquatting: resoluciones de dominios similares al legitimo
- Logs de red/NetFlow: metadatos del trafico (origen, destino, puertos, bytes, duracion). NO el contenido. Util para detectar:
  - Movimiento lateral: conexiones internas inusuales entre hosts
  - Exfiltracion de datos: grandes transferencias hacia el exterior
  - Escaneo de puertos: un host conectandose a muchos puertos de otro host
- Metadatos: datos SOBRE los datos. Ejemplo: metadatos de un documento Word incluyen autor, fecha de creacion, historial de

revisiones (puede revelar el nombre de usuario del atacante)

- Logs de autenticacion: intentos de login. Buscar: password spraying, fuerza bruta, viaje imposible

HERRAMIENTAS DE ANALISIS:

- Wireshark: analisis de capturas de trafico (PCAP). Permite ver el contenido completo de conexiones no cifradas. Filtros:

ip.addr==x.x.x.x, tcp.port==80, http.request

- tcpdump: captura de trafico desde linea de comandos. Mas eficiente para capturar en produccion

■ Volatility: analisis forense de volcados de memoria RAM. Extrae procesos, conexiones de red, artefactos de malware

■ Autopsy/FTK: plataformas de analisis forense de discos. Recuperan archivos borrados

■ Paneles SIEM: visualizacion en tiempo real. Tendencias, picos de actividad y correlaciones

■ Plataformas de inteligencia de amenazas (TIP): agregan feeds de threat intel y los correlacionan con eventos del SIEM

TRUCO EXAMEN: Logins fallidos: logs de autenticacion. Malware en red: logs IDS + NetFlow. Exfiltracion: logs firewall + logs DNS.
Proceso malicioso: logs endpoint (Event ID 4688). Trafico cifrado sospechoso: NetFlow (no el contenido, pero si el patron).

Preguntas de practica (19):

6. El término "Metadatos" se refiere a datos que proporcionan información sobre otros datos, pero no el contenido real de los datos. Normalmente, los metadatos no son visibles para el usuario de forma predeterminada, pero se puede acceder a ellos si es necesario. Por ejemplo, los metadatos de correo electrónico, que se encuentran en los encabezados de los correos electrónicos, incluyen información detallada sobre el remitente, el destinatario y la ruta que tomó el mensaje. Los metadatos del dispositivo móvil abarcan detalles como el modelo del dispositivo, geolocalización, información de la cámara, uso de Internet, actividad de llamadas telefónicas y mensajes de texto, estadísticas de uso de aplicaciones y metadatos de varios archivos en el dispositivo. En la navegación web, los metadatos provienen de metaetiquetas HTML ubicadas en la sección principal de una página web. Para los archivos, los metadatos incluyen detalles sobre el autor (por ejemplo, el creador del archivo), el tipo de archivo, el tamaño, la fecha y hora de creación y la fecha y hora de la última modificación.

Preguntas Adicionales — Generadas (2 preguntas)

1. ¿Qué evento de Windows indica un inicio de sesión exitoso?

✓ **A) 4624**
B) 4625
C) 4648
D) 4720

Fuente: Extra: Logging

2. ¿Por qué se recomienda enviar los logs a un servidor externo (log server)?

A) Para proteger los logs de modificación o eliminación en caso de compromiso del sistema origen
B) Para reducir el almacenamiento local en los sistemas
C) Para cumplir con normativas de retención de logs
✓ **D) Ambas: proteger integridad y cumplir normativas**

Fuente: Extra: Logging

Flashcards — 4.9 (3 tarjetas)

Q: Windows Event IDs clave	4624: Login exitoso · 4625: Login fallido · 4648: Login con credenciales explícitas · 4720: Cuenta creada

Q: ¿Por qué enviar logs a servidor externo?	Para proteger integridad: si el sistema es comprometido, el atacante no puede borrar logs en el servidor remoto
Q: Log retention — mínimos regulatorios	90 días mínimo general · 1 año para PCI DSS · HIPAA: 6 años · GDPR: mínimo necesario para el propósito

Messer + ExamCompass | Uso personal

DOMINIO 5 Gestion del Programa de Seguridad (20% del examen)

5.1 Gobernanza y politicas

Conceptos Clave — Professor Messer

Politicas, Estandares y Procedimientos de Seguridad

Politica de seguridad

Documento de alto nivel que define las reglas y expectativas de seguridad de la organizacion.

Estandar

Requisito especifico y medible que implementa la politica. Ej: 'las contrasenas deben tener 12+ caracteres'.

Procedimiento

Instrucciones paso a paso para realizar una tarea de forma segura y consistente.

Directriz

Recomendacion no obligatoria. Mas flexible que un procedimiento.

AUP (Acceptable Use Policy)

Define el uso aceptable de los sistemas de la empresa. Firmado por todos los empleados.

NDA (Non-Disclosure Agreement)

Acuerdo de confidencialidad. Legal. Protege informacion sensible compartida con terceros.

Data Classification Policy

Define niveles de clasificacion de datos y controles para cada nivel.

Onboarding/Offboarding

Politicas para dar y retirar acceso cuando alguien entra o sale de la organizacion.

Clean desk policy

Los empleados no deben dejar informacion sensible visible cuando se ausentan.

Puntos clave para el examen:

- Jerarquia: Politica (que) → Estandar (cuanto) → Procedimiento (como) → Directriz (sugerencia).
- AUP: todos los empleados firman al incorporarse. Base legal para acciones disciplinarias.
- NDA: antes de compartir informacion confidencial con cualquier tercero (proveedor, consultor).
- Clean desk + screen lock: si te alejas del PC, bloquealo. CTRL+L (Linux/Windows). Previene shoulder surfing.
- Onboarding: dar acceso minimo necesario desde el primer dia. Offboarding: revocar TODO inmediatamente.

Roles y Responsabilidades de Datos

Data Owner

Ejecutivo responsable de los datos. Decide la clasificacion y quienes tienen acceso.

Data Steward

Responsable de la calidad y gestion operativa de los datos.

Data Custodian

IT. Implementa los controles tecnicos definidos por el Data Owner.

Data Subject

La persona fisica cuyos datos se procesan. Tiene derechos (GDPR).

DPO (Data Protection

Officer)
Obligatorio en GDPR para ciertas organizaciones. Supervisa cumplimiento de privacidad.

Puntos clave para el examen:

- Data Owner decide → Data Custodian implementa → Data Steward gestiona calidad.
- DPO obligatorio en GDPR si procesas datos sensibles a gran escala o eres autoridad publica.
- Data Subject tiene derechos: acceso, rectificacion, olvido, portabilidad, oposicion al tratamiento.

5.1 ampliacion

Acuerdos y Contratos de Seguridad

SLA (Service Level Agreement)
Contrato que define el nivel de servicio prometido. Incluye uptime, RTO, soporte. Legal y vinculante.

MSA (Master Service Agreement)
Contrato marco que cubre los terminos generales de la relacion. SOWs especificos se agregan como anexos.

BPA (Business Partnership Agreement)
Contrato entre socios de negocio. Define responsabilidades, derechos y obligaciones mutuas.

MOU (Memorandum of Understanding)
Acuerdo de intencion. No vinculante legalmente. Define objetivos compartidos y marco general.

MOA (Memorandum of Agreement)
Mas formal que MOU. Define obligaciones especificas pero puede no ser totalmente vinculante.

ISA (Interconnection Security Agreement)
Acuerdo tecnico que define como dos organizaciones conectaran sus sistemas de forma segura.

NDA (Non-Disclosure Agreement)
Acuerdo de confidencialidad. Protege informacion sensible compartida. Vinculante legalmente.

Right to Audit

Clausula que permite auditar al proveedor. Fundamental en contratos con terceros que manejan datos sensibles.

Puntos clave para el examen:

- SLA: si el proveedor incumple el SLA, hay penalizaciones economicas. Negociar siempre el SLA antes de contratar.
- MOU vs MOA: MOU = mas informal, declaracion de intencion. MOA = compromisos mas concretos.
- ISA: obligatorio cuando dos organizaciones gubernamentales conectan sus redes (NIST 800-47).
- Right to audit: sin esta clausula, no puedes verificar que el proveedor cumple sus obligaciones de seguridad.
- Jerarquia comun: MSA (marco) → SOW (alcance trabajo especifico) → SLA (metricas de servicio).

Email Security — SPF, DKIM, DMARC

SPF (Sender Policy Framework)

Registro DNS TXT que lista las IPs autorizadas a enviar email para el dominio. Evita spoofing de la IP de origen.

DKIM (DomainKeys Identified Mail)

Firma criptografica en el header del email. El receptor verifica con la clave publica del DNS. Prueba autenticidad del servidor.

DMARC (Domain-based Message Authentication, Reporting & Conformance)

Politica que indica que hacer si SPF o DKIM fallan: none (monitorizar), quarantine (spam), reject (bloquear).

Email gateway

Servidor que procesa el email entrante/saliente. Aplica filtros anti-spam, anti-phishing, antivirus, DLP.

Sandboxing de adjuntos

Abre adjuntos en entorno virtual aislado para detectar malware antes de entregarlo al usuario.

Puntos clave para el examen:

- SPF: solo verifica la IP del servidor que envia. No protege contra spoofing del 'From' visible en el cliente.
- DKIM: firma el contenido + cabeceras. Si el email es modificado en transito, la firma falla.
- DMARC une SPF y DKIM: si ambos fallan → politica de rechazo. Tambien permite recibir reportes de fallos.
- Implementacion correcta: SPF + DKIM + DMARC (reject) = proteccion completa contra suplantacion de dominio.
- DMARC reporting: recibes reportes XML de quien intenta enviar email desde tu dominio. Detecta phishing activo.

5.1 ampliacion

Gestion de Empleados y Procesos HR

Onboarding

Proceso de incorporacion de nuevo empleado. Incluye: firma de AUP/NDA, provision de cuentas, formacion inicial.

Offboarding

Proceso de salida del empleado. Incluye: revocar accesos, devolver dispositivos, entrevista de salida.

Exit interview

Entrevista al empleado que se va. Detecta posibles exfiltraciones, recoge feedback, documenta el proceso.

Separation of duties

Una sola persona no puede completar una tarea critica. Ej: quien crea una factura no puede autorizarla.

Job rotation

Rotacion de empleados entre roles. Detecta fraudes, reduce dependencia de un individuo, aumenta conocimiento.

Mandatory vacation

Vacaciones obligatorias. Durante la ausencia, otro descubre posibles fraudes del empleado ausente.

Least privilege

Cada usuario tiene solo los permisos minimos necesarios para su trabajo. Principio fundamental.

Need to know

Mas restrictivo que least privilege. Acceso solo a informacion especificamente necesaria para la tarea actual.

Background check
Verificacion del historial del candidato: antecedentes penales, referencias, historial laboral.

Puntos clave para el examen:

- Offboarding: el dia que el empleado sale → revocar accesos INMEDIATAMENTE. Antes de que salga del edificio.
- Separation of duties: previene fraude interno. Ninguna persona tiene control completo de un proceso critico.
- Job rotation: dificulta que un empleado malicioso cubra sus rastros indefinidamente.
- Mandatory vacation: si un empleado se niega a tomar vacaciones, puede ser senal de alerta.
- Least privilege + need to know: combinados son la base del control de acceso. Revision periodica de accesos.
- Background check: critico antes de dar acceso a sistemas sensibles. Repetir periodicamente para roles criticos.

Teoria Complementaria — ExamCompass

5.0 Gestión del Programa de Seguridad (20% del examen)

5.1 - Resumir los elementos de una gobernanza de seguridad eficaz.

■ Jerarquia: Politica, Estandar, Procedimiento, Directriz, Playbook

■ Politicas clave: AUP, Seguridad de la informacion, BCP, DRP, IRP, SDLC

■ Estructuras: Juntas, Comites, Centralizado vs Descentralizado

■ Roles: Propietario, Controlador, Procesador, Custodio/Administrador

JERARQUIA DE DOCUMENTOS DE GOBERNANZA - Del mas general al mas especifico:

■ Politica (Policy): declaracion de ALTO NIVEL de la intencion de la organizacion. Aprobada por la direccion. EL QUE. No cambia

frecuentemente. Ejemplo: 'Todos los datos de clientes deben protegerse segun su clasificacion'

■ Estandar (Standard): requisitos ESPECIFICOS y MEDIBLES que implementan la politica. EL CUANTO. Ejemplo: 'Los datos

confidenciales deben cifrarse con AES-256'

■ Procedimiento (Procedure): instrucciones PASO A PASO de como implementar el estandar. EL COMO. Ejemplo: 'Para cifrar un

disco: 1. Abrir BitLocker 2. Seleccionar modo...'

■ Directriz (Guideline): RECOMENDACIONES no obligatorias. Buenas practicas. El mas flexible. Ejemplo: 'Se recomienda usar un

gestor de contrasenas'

■ Playbook: procedimiento especifico para responder a UN TIPO ESPECIFICO de incidente (playbook de ransomware, playbook

de phishing)

POLITICAS CLAVE QUE DEBES CONOCER:

■ AUP (Politica de Uso Aceptable): define el uso aceptable de los recursos IT. Todos los empleados deben firmarla. Cubre: uso de

internet, email corporativo, dispositivos, redes sociales

■ Politica de Seguridad de la Informacion: politica paraguas que gobierna toda la seguridad de la informacion

■ BCP (Plan de Continuidad de Negocio): como CONTINUAR OPERANDO durante un desastre. Se centra en el negocio, no solo

en IT

■ DRP (Plan de Recuperacion ante Desastres): como RECUPERAR los sistemas IT tras un desastre. Parte del BCP, mas tecnico

■ IRP (Plan de Respuesta a Incidentes): como responder a incidentes de seguridad. Define roles, escalado, comunicacion

■ SDLC (Ciclo de Vida de Desarrollo de Software): como integrar seguridad en el desarrollo desde el principio

■ Incorporacion/Desvinculacion (Onboarding/Offboarding): procedimientos para dar de alta y baja empleados de forma segura

ROLES DE DATOS - Los mas preguntados en el examen:

■ Propietario de datos (Data owner): el responsable del NEGOCIO del activo. Decide la clasificacion, quien puede acceder y el

tiempo de retencion. Normalmente un director o VP

■ Custodio/Administrador de datos (Data custodian/steward): el responsable TECNICO. Implementa los controles definidos por el

owner. Normalmente IT o el DBA

■ Controlador de datos (Data controller, GDPR): entidad que decide el PROPOSITO y los MEDIOS del procesamiento de datos

Preguntas Topic — ExamCompass (4 preguntas)

1. ¿Cuál de los siguientes términos se refiere a un acuerdo que especifica requisitos de desempeño para un proveedor?

[EN: Which of the following terms refers to an agreement that specifies performance requirements for a vendor?]

A) MSA

✓ **B) SLA**

C) Memorándum de Entendimiento

D) SEMBRAR

Fuente: Topic: Agreement Types

---

2. Un tipo de acuerdo no vinculante que describe objetivos mutuos y el marco general para la cooperación entre dos o más partes se denomina:

A) MOA

B) SEMBRAR

✓ **C) Memorándum de Entendimiento**

✓ **D) MSA**

Fuente: Topic: Agreement Types

---

3. ¿Cuál de las siguientes siglas se refiere a un documento que autoriza, inicia y rastrea el progreso y la finalización de un trabajo o tarea en particular?

[EN: Which of the following acronyms refers to a document that authorizes, initiates, and tracks the progress and completion]

A) SEMBRAR

✓ **B) WO**

C) SLA

D) MSA

Fuente: Topic: Agreement Types

---

4. Un contrato legal entre el titular de información confidencial y otra persona a quien se le revela esa información que restringe a esa otra persona la divulgación de información confidencial a cualquier otra parte se conoce como:

A) ISA

✓ **B) Acuerdo de confidencialidad**

✓ **C) BPA**

D) SLA

Fuente: Topic: Agreement Types

Preguntas Adicionales — Generadas (2 preguntas)

1. ¿Cuál es la jerarquía correcta de documentos de gobernanza de seguridad?

✓ **A) Política → Estándar → Procedimiento → Guía**

B) Guía → Procedimiento → Estándar → Política

C) Estándar → Política → Procedimiento → Guía

D) Procedimiento → Política → Estándar → Guía

Fuente: Extra: Governance

---

2. ¿Cuál de los siguientes acuerdos establece los niveles de servicio entre un proveedor y un cliente?

✓ **A) SLA (Service Level Agreement)**

B) MOU (Memorandum of Understanding)

C) NDA (Non-Disclosure Agreement)

D) BPA (Business Partnership Agreement)

Fuente: Extra: Governance

Flashcards — 5.1 (3 tarjetas)

Q: Jerarquía de documentos de gobernanza	Política (¿qué?) → Estándar (¿cuánto/cómo de medible?) → Procedimiento (¿pasos exactos?) → Guía (recomendaciones)
Q: SLA vs MOU vs MSA vs BPA	SLA: niveles de servicio garantizados (legal)
	MOU: intención sin fuerza legal
	MSA: contrato marco general
	BPA: acuerdo de negocio entre socios
Q: AUP — ¿qué es?	Acceptable Use Policy: define el uso aceptable de los recursos TI por parte de empleados. Debe firmarse en el onboarding

5.2 Gestion de riesgos

Conceptos Clave — Professor Messer

Gestion de Riesgo

Riesgo

Probabilidad de que una amenaza explote una vulnerabilidad y cause un impacto negativo.

Amenaza

Evento potencial que puede causar dano. Ej: ransomware, terremoto, error humano.

Vulnerabilidad
Debilidad que puede ser explotada. Ej: software sin parchear, contrasena debil.

Impacto
Consecuencia del riesgo. Financiero, reputacional, operacional, legal.

Evaluacion de riesgo
cualitativa
Usa escalas descriptivas: Alto/Medio/Bajo. Subjetivo pero rapido.

Evaluacion de riesgo
cuantitativa
Usa valores numericos: ALE, ARO, SLE. Objetivo y financiero.
SLE (Single Loss
Expectancy)
Perdida esperada por UN incidente. SLE = Valor del activo x Factor de exposicion.
ARO (Annual Rate of
Occurrence)
Cuantas veces ocurre el incidente por ano.
ALE (Annual Loss
Expectancy)
Perdida anual esperada. ALE = SLE x ARO.

Tratamiento del riesgo
Aceptar, Transferir (seguros), Mitigar (controles), Evitar (eliminar actividad).

Risk appetite
Nivel de riesgo que la organizacion esta dispuesta a aceptar.

Risk tolerance
Variacion aceptable alrededor del risk appetite. Limite maximo absoluto de riesgo.

Puntos clave para el examen:

- Riesgo = Amenaza x Vulnerabilidad x Impacto. Si alguno es 0, el riesgo es 0.
- ALE = SLE x ARO. Si el ALE < coste del control → no implementar el control.
- Transferir riesgo = seguros. La aseguradora asume el impacto financiero.
- Evitar riesgo = eliminar la actividad que genera el riesgo. La opcion mas extrema.
- Risk appetite: la empresa decide cuanto riesgo asume. Risk tolerance: hasta donde puede llegar sin consecuencias.
- Ejemplo: SLE = 100.000 EUR, ARO = 0.1 (una vez cada 10 anos) → ALE = 10.000 EUR. Si el control cuesta 15.000
  EUR → no es rentable.

5.2 ampliacion

Conceptos de Cumplimiento Adicionales
MTPD (Maximum
Tolerable Period of
Disruption)
Tiempo maximo que la organizacion puede sobrevivir sin un proceso critico antes de
consecuencias irreversibles.
MBCO (Minimum
Business Continuity
Objective)
Nivel minimo de servicio que debe mantenerse durante una disrupcion para que el
negocio siga operativo.

Litigation hold
Obligacion legal de preservar toda evidencia relevante cuando se anticipa un litigio.
Suspende la destruccion de datos.
eDiscovery

Proceso de identificar, recopilar y producir evidencia electronica para procedimientos legales.

NDA (Non-Disclosure Agreement)

Contrato de confidencialidad. Protege informacion sensible compartida. Vinculante legalmente.

Cyber insurance

Seguro contra riesgos ciberneticos: costes de breach, ransomware, multas regulatorias, responsabilidad.

RA (Registration Authority)

Entidad que verifica identidades para la CA. La CA firma el certificado, la RA verifica al solicitante.

DaaS

Desktop as a Service. Escritorios virtuales en la nube. Los datos residen en el centro de datos, no en el endpoint.

Puntos clave para el examen:

- MTPD vs RTO: MTPD es el limite maximo absoluto. RTO debe ser MENOR que el MTPD.
- Litigation hold: si recibes la notificacion y destruyes datos = destruccion de evidencia = consecuencias legales graves.
- eDiscovery: el SIEM y los logs son criticos en eDiscovery. Por eso la retencion de logs importa.
- RA valida pero no firma. CA firma pero puede no validar directamente. La RA actua como intermediario de confianza.
- Cyber insurance: las aseguradoras exigen controles minimos (MFA, EDR, backups) antes de asegurar.
- MBCO: si el MBCO de un hospital es 'soporte vital operativo', todo lo demas puede esperar.

Teoria Complementaria — ExamCompass

18. Un archivo Honey se puede utilizar para:

26. En el contexto de la seguridad informática, el término "biometría" se refiere tanto a las características biológicas del cuerpo humano como a los rasgos de comportamiento que pueden utilizarse con fines de identificación y control de acceso.

Respuesta no detectada automaticamente

Preguntas Topic — ExamCompass (11 preguntas)

1. El proceso de determinar los riesgos potenciales que podrían afectar la capacidad de una organización para alcanzar sus objetivos se denomina:

✓ **A) Evaluación de riesgos**

✓ **B) Identificación de riesgos**

C) Análisis de riesgos

D) Gestión de riesgos

Fuente: Topic: Risk Management

---

2. ¿Cuál de las siguientes respuestas se refiere a un método de evaluación de riesgos basado en la necesidad, que generalmente se lleva a cabo en respuesta a eventos o cambios específicos, como después de un cambio organizacional importante o una violación de seguridad?

[EN: Which of the following answers refers to a risk assessment method based on need, typically conducted in response to spec]

✓ **A) A propósito**

B) Periódico
C) una sola vez
D) Continuo

** Respuesta corregida manualmente*

Fuente: Topic: Risk Management

---

3. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de evaluación de riesgos recurrentes?

[EN: Which of the answers listed below refers to an example of recurring risk assessment?]

✓ A) Monitoreo en tiempo real de amenazas a la seguridad de la red
B) Evaluación del riesgo después de un cambio organizacional importante o una violación de seguridad
C) Evaluaciones de riesgos trimestrales o anuales
D) Evaluación de riesgos para el lanzamiento de un nuevo producto.

Fuente: Topic: Risk Management

---

4. ¿Cuál de las siguientes respuestas se refiere a una evaluación de riesgos realizada para un propósito o proyecto específico, sin planes para una reevaluación periódica (por ejemplo, evaluación de riesgos para el lanzamiento de un nuevo producto)?

[EN: Which of the following answers refers to a risk assessment conducted for a specific purpose or project, without plans fo]

✓ A) una sola vez
B) Periódico
C) A propósito
D) Continuo

** Respuesta corregida manualmente*

Fuente: Topic: Risk Management

---

5. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de evaluación continua de riesgos?

[EN: Which of the answers listed below refers to an example of continuous risk assessment?]

A) Evaluaciones de riesgos trimestrales o anuales
B) Evaluación de riesgos para el lanzamiento de un nuevo producto.
C) Evaluación del riesgo después de un cambio organizacional importante o una violación de seguridad
✓ D) Monitoreo en tiempo real de amenazas a la seguridad de la red

** Respuesta corregida manualmente*

Fuente: Topic: Risk Management

---

6. ¿Cuál de los términos enumerados a continuación se refiere a un término general que describe la actitud general de una organización hacia la asunción de riesgos?

[EN: Which of the terms listed below refers to a general term that describes an organization's overall attitude towards risk-]

A) Estrategia de riesgo
B) control de riesgos
✓ C) Apetito de riesgo
D) Tolerancia al riesgo

Fuente: Topic: Risk Management

---

7. ¿El seguro de ciberseguridad es un ejemplo de qué estrategia de gestión de riesgos?

[EN: Cybersecurity insurance is an example of which risk management strategy?]

A) Evitación de riesgos
B) Disuasión de riesgos

✓ **C) Transferencia de riesgo**

D) Aceptación de riesgos

Fuente: Topic: Risk Management

---

8. En la estrategia de aceptación de riesgos, la práctica de incumplir temporalmente una norma o política debido a un escenario de riesgo específico se denomina:

A) Exclusión

✓ **B) Excepción**

C) Evasión

D) Exención

Fuente: Topic: Risk Management

---

9. ¿Cuál de los siguientes términos describe el proceso de tomar medidas proactivas para reducir el impacto de los riesgos identificados?

[EN: Which of the following terms describes the process of taking proactive measures to reduce the impact of identified risks]

A) Aceptación de riesgos

B) Evitación de riesgos

C) Transferencia de riesgo

✓ **D) Mitigación de riesgos**

Fuente: Topic: Risk Management

---

10. ¿Cuál de las siguientes define la cantidad máxima aceptable de pérdida de datos medida en un momento específico antes de un desastre o interrupción?

[EN: Which of the following defines the maximum acceptable amount of data loss measured by a specific point in time before a]

A) RPO

B) MTBF

C) RTO

✓ **D) MTTR**

Fuente: Topic: Risk Management

---

11. Un valor MTBF alto indica que un componente o sistema proporciona baja confiabilidad y es más probable que falle.

A) Verdadero

✓ **B) FALSO**

Fuente: Topic: Risk Management

Preguntas Adicionales — Generadas (3 preguntas)

1. ¿Cuál es la fórmula del ALE (Annualized Loss Expectancy)?

✓ **A) ALE = SLE × ARO**

B) ALE = SLE + ARO

C) ALE = ARO / SLE

D) ALE = SLE × (1 - ARO)

Fuente: Extra: Risk Management

---

2. Si el ALE de un riesgo es menor que el coste del control de seguridad, ¿qué estrategia de riesgo es más adecuada?

✓ **A) Aceptar el riesgo (risk acceptance)**

B) Transferir el riesgo (risk transfer)

C) Mitigar el riesgo (risk mitigation)

D) Evitar el riesgo (risk avoidance)

Fuente: Extra: Risk Management

---

3. ¿Cuál es la diferencia entre evaluación de riesgo cualitativa y cuantitativa?

✓ A) La cuantitativa usa valores numéricos (€/$); la cualitativa usa términos subjetivos (alto/medio/bajo)

B) La cualitativa usa números exactos; la cuantitativa usa opiniones

C) La cuantitativa es más rápida y subjetiva; la cualitativa es más precisa

D) Son equivalentes — solo difieren en el nombre

Fuente: Extra: Risk Management

Flashcards — 5.2 (4 tarjetas)

Q: Fórmula ALE	ALE = SLE × ARO
	SLE = valor del activo × porcentaje de pérdida
	ARO = frecuencia anual del incidente
Q: 4 estrategias de gestión de riesgo	Mitigar (reducir probabilidad/impacto) · Transferir (seguro, tercero) · Aceptar (documentado) · Evitar (eliminar actividad)
Q: Cualitativa vs Cuantitativa (riesgo)	Cualitativa: alto/medio/bajo (subjetivo, rápido)
	Cuantitativa: valores en € (preciso, requiere datos históricos)
Q: Risk Appetite vs Risk Tolerance	Appetite: nivel de riesgo que la org QUIERE asumir (estratégico)
	Tolerance: variación aceptable alrededor del appetite (operativo)

5.3 Riesgos de terceros

Conceptos Clave — Professor Messer

Cumplimiento y Marco Legal

GDPR

Reglamento General de Proteccion de Datos (UE). Datos personales de ciudadanos europeos. Multas hasta 20M EUR.

HIPAA

Health Insurance Portability and Accountability Act (EEUU). Datos medicos. PHI (Protected Health Information).

PCI DSS

Payment Card Industry Data Security Standard. Datos de tarjetas de pago. 12 requisitos.

SOX (Sarbanes-Oxley)

Empresas cotizadas en EEUU. Controles internos financieros. Retencion de registros.

NIST CSF

NIST Cybersecurity Framework. Voluntario. Identifica, Protege, Detecta, Responde, Recupera.

ISO 27001

Estandar internacional de SGSI (Sistema de Gestion de Seguridad de la Informacion). Certificable.

Due Diligence
Investigar adecuadamente antes de tomar una decision. Evaluar riesgos de terceros.

Due Care
Aplicar el cuidado razonable para proteger activos. Implementar controles apropiados.

Puntos clave para el examen:

- GDPR: notificacion de brecha en 72 horas. Sin notificacion: multa. Aplica a cualquier empresa que trate datos de ciudadanos UE.
- HIPAA: PHI incluye nombre, direccion, SSN, historico medico, numero de seguro. Cifrado obligatorio en transit y rest.
- PCI DSS: 12 requisitos incluyen: firewall, no defaults, proteger datos de tarjeta, cifrar transmision, antivirus, acceso
minimo.
- NIST CSF: Identify → Protect → Detect → Respond → Recover. Marco de referencia mas usado en EEUU.
- ISO 27001: proceso de certificacion con auditoria externa. Valido 3 anos con auditorias anuales.

Teoria Complementaria — ExamCompass

41. Un valor MTBF alto indica que un componente o sistema proporciona baja confiabilidad y es más

probable que falle.

5.3 - Explicar la evaluacion y gestion de riesgos de terceros.

■ Evaluacion: Pruebas de penetracion, Derecho a auditoria, Analisis de cadena de suministro

■ Seleccion: Due diligence, Conflicto de intereses

■ Acuerdos: SLA, MOA, MOU, MSA, NDA, BPA, SOW, ISA

■ Monitorizacion continua de proveedores

GESTION DE RIESGOS DE TERCEROS - Por que es critico:

■ El 60%+ de las brechas de seguridad implican a un tercero (proveedor, partner, contratista)

■ Cuando contratas a un proveedor, le das acceso a tus sistemas, datos o red y heredas sus riesgos

■ Ejemplos reales: Target (brecha via proveedor HVAC), SolarWinds (ataque a cadena de suministro), MOVEit (software de

transferencia de archivos comprometido)

PROCESO DE EVALUACION DE PROVEEDORES:

■ Diligencia debida (Due diligence): investigacion exhaustiva ANTES de contratar. Incluye: historial de brechas, certificaciones

(ISO 27001, SOC 2), referencias, revision de politicas

■ Cuestionario de proveedor: cuestionario de seguridad que el proveedor debe responder. Evalua sus controles tecticos, fisicos y

administrativos

■ Clausula de derecho a auditoria (Right-to-audit): clausula en el contrato que te da derecho a auditar al proveedor. CRITICO

incluirla

■ Prueba de penetracion: realizar o exigir pentests periodicos al proveedor

■ Conflicto de intereses: verificar que el proveedor no tiene intereses que puedan comprometer la seguridad

■ Analisis de cadena de suministro: no solo evaluar al proveedor directo, sino tambien a sus proveedores

TIPOS DE ACUERDOS - Los MAS preguntados en el examen:

■ SLA (Acuerdo de Nivel de Servicio): define los niveles MINIMOS de servicio garantizados. Incluye: uptime (99.9%), tiempo de

respuesta ante incidentes, penalizaciones

■ NDA (Acuerdo de No Divulgacion): protege informacion sensible compartida con terceros

■ MOU (Memorando de Entendimiento): acuerdo de INTENCIONES. NO es legalmente vinculante. Comun entre organismos

publicos

■ MOA (Memorando de Acuerdo): MAS FORMAL que MOU. Describe compromisos especificos

■ MSA (Acuerdo Marco de Servicios): contrato MARCO que establece las condiciones generales de una relacion de largo plazo

■ SOW (Declaracion de Trabajo): describe el ALCANCE ESPECIFICO de un proyecto concreto

■ BPA (Acuerdo de Colaboracion Empresarial): acuerdo entre socios de negocio

■ ISA (Acuerdo de Seguridad de Interconexion): acuerdo tecnico que define como se conectaran de forma segura dos redes de

Preguntas Adicionales — Generadas (3 preguntas)

1. ¿Qué es due diligence en el contexto de gestión de riesgos de terceros?

✓ A) Investigar y evaluar a un proveedor antes de contratarlo para identificar riesgos

B) Auditar al proveedor después de un incidente de seguridad

C) Firmar un NDA con el proveedor para proteger información confidencial

D) Monitorizar el rendimiento del proveedor durante el contrato

Fuente: Extra: Third Party Risk

---

2. El ataque SolarWinds (2020) es el ejemplo más citado de ataque a la cadena de suministro. ¿Qué hicieron los atacantes?

✓ A) Comprometieron el software de actualización de SolarWinds e inyectaron malware (SUNBURST) que se distribuyó a miles de clientes

B) Atacaron directamente las redes de los clientes por phishing

C) Explotaron un zero-day en el servidor web de SolarWinds

D) Realizaron un DDoS contra la infraestructura de SolarWinds

Fuente: Extra: Third Party Risk

---

3. ¿Qué es un MSA (Master Service Agreement)?

✓ A) Contrato marco con términos generales de la relación, sobre el que se construyen acuerdos específicos

B) Acuerdo de confidencialidad

C) Contrato que define niveles mínimos de servicio

D) Acuerdo de intención sin fuerza legal

Fuente: Extra: Third Party Risk

Flashcards — 5.3 (2 tarjetas)

Q: Due Diligence vs Due Care	Due Diligence: investigar/evaluar ANTES de tomar una decisión
	Due Care: actuar responsablemente DURANTE la relación

Q: SolarWinds — lección de supply chain	Verificar integridad de software de terceros (hash/firma) · SBOM · Menor privilegio para software de gestión · Monitorizar tráfico de herramientas de actualización

5.4 Cumplimiento normativo

Conceptos Clave — Professor Messer

Auditorias y Evaluaciones de Seguridad

Auditoria interna
Realizada por el propio personal de la organizacion. Independiente del departamento auditado.

Auditoria externa
Realizada por terceros independientes. Mas credibilidad. Requerida para certificaciones.

Penetration test
Simula un ataque real para encontrar vulnerabilidades explotables. Requiere autorizacion.

Vulnerability assessment
Identifica vulnerabilidades sin explotarlas. Menos intrusivo que pentest.
SOC 1 / SOC 2 / SOC 3
System and Organization Controls. SOC 2 = controles de seguridad y privacidad. Muy solicitado en SaaS.

Right to audit clause
Clausula contractual que da derecho a auditar al proveedor de servicios.

Puntos clave para el examen:

- SOC 2 Type I: diseno de controles en un momento. SOC 2 Type II: efectividad durante un periodo (6-12 meses). Type II
es mas riguroso.
- Pentest requiere RoE (Rules of Engagement): alcance, sistemas excluidos, horario, contacto de emergencia.
- Right to audit: incluirla en TODOS los contratos de terceros que manejan datos sensibles.
- Auditoria interna: detecta problemas antes que auditores externos. Mejor practica continua.

Teoria Complementaria — ExamCompass

estándares de codificación, vulnerabilidades de seguridad y errores.

■ Soberania de datos: los datos deben almacenarse y tratarse segun las leyes del pais donde residen

■ Interes legitimo: base legal para procesar datos sin consentimiento explicito cuando hay un interes legitimo justificado

REPORTE DE CUMPLIMIENTO Y CONSECUENCIAS:

■ Atestacion (Attestation): declaracion FORMAL de cumplimiento firmada por un responsable (DPO, CISO, CEO)

■ Cumplimiento interno: auditorias internas, autoevaluaciones, revision de politicas

■ Cumplimiento externo: auditores externos independientes, certificaciones (ISO 27001, SOC 2 Tipo II)

■ Consecuencias del incumplimiento:

- Multas economicas (GDPR: hasta 4% revenue global)
- Sanciones regulatorias (suspension de licencias)

• Dano reputacional (perdida de clientes)
• Responsabilidad civil (demandas de los afectados)
• Responsabilidad penal (en casos graves de negligencia)

■ DPO (Delegado de Proteccion de Datos): rol requerido por GDPR en organizaciones que procesan datos a gran escala.

Supervisa el cumplimiento y actua como punto de contacto con reguladores

Preguntas de practica (32):

7. En la arquitectura de seguridad Zero Trust, el punto de aplicación de políticas (PEP) es un componente del plano de datos que aplica las políticas de seguridad definidas en el plano de control por el punto de decisión de políticas (PDP).

Respuesta no detectada automaticamente

Preguntas Adicionales — Generadas (3 preguntas)

1. ¿A cuántas horas obliga el GDPR a notificar una brecha de datos a la autoridad de control?

✓ **A) 72 horas**
B) 24 horas
C) 48 horas
D) 7 días

Fuente: Extra: Compliance

2. ¿Qué norma de cumplimiento aplica a organizaciones que procesan datos de tarjetas de crédito?

✓ **A) PCI DSS**
B) HIPAA
C) GDPR
D) SOX

Fuente: Extra: Compliance

3. ¿Cuántos requisitos tiene PCI DSS?

✓ **A) 12**
B) 6
C) 18
D) 8

Fuente: Extra: Compliance

Flashcards — 5.4 (3 tarjetas)

Q: GDPR, HIPAA, PCI DSS — resumen	GDPR: datos personales UE · 72h notificación
	HIPAA: datos médicos EEUU · BAA obligatorio
	PCI DSS: tarjetas de crédito · 12 requisitos
Q: NIST CSF — 5 funciones	Identify → Protect → Detect → Respond → Recover
Q: ISO 27001 vs SOC 2	ISO 27001: certificación internacional de SGSI
	SOC 2 Type II: auditoría de controles durante período de 6-12 meses (más riguroso que Type I)

5.5 Auditorias y evaluaciones

Conceptos Clave — Professor Messer

Privacidad y Proteccion de Datos
PII (Personally
Identifiable Information)
Cualquier dato que identifica a una persona: nombre, email, SSN, IP, cookie ID.
PHI (Protected Health
Information)
PII en contexto medico. Protegida por HIPAA en EEUU.

Privacy by design
Integrar privacidad desde el diseno del sistema. No como anadido. Principio de GDPR.

Data minimization
Solo recopilar los datos estrictamente necesarios para el proposito declarado.

Consent management
Gestion del consentimiento del usuario para el tratamiento de sus datos.

Right to be forgotten
GDPR: el usuario puede pedir que se eliminen todos sus datos de la organizacion.
Cross-border data
transfer
Transferencia de datos fuera de la UE solo a paises con nivel adecuado de proteccion o
con garantias.

Puntos clave para el examen:

- Privacy by design: no es opcional en GDPR. Hay que demostrar que se consideró desde el inicio.
- Data minimization: si no necesitas la fecha de nacimiento, no la pidas. Cada dato extra es un riesgo.
- Right to be forgotten: tecnicamente complejo (backups, logs, terceros). Documentar el proceso.
- Transferencia fuera UE: EEUU tiene Privacy Shield 2.0 (Data Privacy Framework). China/Rusia = problematico.

Teoria Complementaria — ExamCompass

■ Reglas de participacion (RoE): documento LEGAL que debe firmarse ANTES de cualquier pentest. Define: alcance, metodos

permitidos, ventanas de tiempo, contacto de emergencia

EVALUACION DE VULNERABILIDADES vs PRUEBA DE PENETRACION:

■ Evaluacion de vulnerabilidades: identifica y CLASIFICA vulnerabilidades. NO las explota. Mas rapido y barato. Resultado: lista

de vulnerabilidades con su severidad (CVSS)

■ Prueba de penetracion: identifica Y EXPLOTA vulnerabilidades para demostrar el IMPACTO REAL. Mas lento y caro. Resultado:

informe de vulnerabilidades + evidencias de explotacion exitosa

■ Programa de recompensas por errores (Bug bounty): la organizacion PAGA a investigadores externos por encontrar y reportar

vulnerabilidades de forma responsable

Preguntas de practica (21):

1. En los ejercicios de ciberseguridad, el equipo defensor se conoce como:

2. En las pruebas de penetración, el reconocimiento activo implica recopilar cualquier tipo de información disponible públicamente que pueda usarse más adelante para explotar las vulnerabilidades encontradas en el sistema objetivo.

3. En los ejercicios de ciberseguridad, el equipo defensor se conoce como:

4. En las pruebas de penetración, el reconocimiento activo implica recopilar cualquier tipo de información disponible públicamente que pueda usarse más adelante para explotar las vulnerabilidades encontradas en el sistema objetivo.

Preguntas Adicionales — Generadas (3 preguntas)

1. ¿Cuál es la diferencia entre SOC 2 Type I y Type II?

✓ A) Type I evalúa el diseño de controles en un momento; Type II evalúa su efectividad durante un período (6-12 meses)

B) Type II es para empresas pequeñas; Type I para grandes corporaciones

C) Type I incluye pruebas de penetración; Type II solo revisión documental

D) Son equivalentes — Type II es simplemente más reciente

Fuente: Extra: Audits

---

2. ¿Qué es una auditoría interna vs externa?

✓ A) Interna: personal propio de la organización; externa: tercero independiente (mayor objetividad)

B) Externa: personal propio; interna: tercero

C) Interna evalúa controles técnicos; externa evalúa administrativos

D) Son equivalentes — solo difiere quién firma el informe

Fuente: Extra: Audits

---

3. ¿Qué es un 'right to audit' en un contrato con proveedor?

✓ A) Cláusula que permite al cliente auditar las operaciones, instalaciones y registros del proveedor

B) Derecho del proveedor a auditar el uso del software por el cliente

C) Obligación de publicar resultados de auditoría externamente

D) Cláusula que limita las auditorías a una vez al año

Fuente: Extra: Audits

Flashcards — 5.5 (1 tarjetas)

Q: Auditoría interna vs externa	Interna: personal propio, menos objetiva, más barata
	Externa: tercero independiente, más objetiva, requerida por regulaciones como SOX, PCI DSS

5.6 Concienciacion y formacion

Conceptos Clave — Professor Messer

Concienciacion y Formacion en Seguridad

Security Awareness

Training

Formacion periodica para todos los empleados. Cultura de seguridad.

Phishing simulation

Enviar phishing simulado a empleados para medir y mejorar la concienciacion.

Role-based training

Formacion especifica segun el rol: devs aprenden OWASP, RRHH aprende sobre PII,

etc.

Social engineering

awareness

Reconocer intentos de manipulacion: phishing, vishing, pretexting.

Insider threat awareness

Reconocer comportamiento sospechoso en companeros. Reporte anonimo.

Clean desk / Screen lock

Politicas de escritorio limpio y bloqueo de pantalla. Prevencion de shoulder surfing.

Puntos clave para el examen:

- El usuario es el eslabón mas debil de la seguridad. La formacion reduce el riesgo hasta un 70%.
- Phishing simulation: el que cae debe recibir formacion inmediatamente, no sancion.
- Frecuencia recomendada: formacion anual minima. Simulaciones de phishing trimestrales.
- Reporte de incidentes: cultura sin castigo para errores reportados voluntariamente. Mejor reportar que esconder.
- Gamificacion: simulaciones, concursos, badges → mayor engagement que videos aburridos.

Teoria Complementaria — ExamCompass

de un cambio organizacional importante o una violación de seguridad?

■ Formacion en concienciacion de seguridad: formacion periodica obligatoria para TODOS los empleados, incluyendo la direccion.

Contenido: phishing, ingenieria social, manejo de datos, uso de dispositivos, incidentes

■ Reconocimiento de politicas: los empleados firman que han leido, entendido y se comprometen a cumplir las politicas. Critico

para demostrar cumplimiento y para procedimientos disciplinarios

■ Formacion por rol: formacion especifica segun el rol. Los desarrolladores necesitan formacion sobre OWASP. Los de RRHH

sobre proteccion de datos. Los ejecutivos sobre BEC y whaling

■ Formacion inicial vs periodica: formacion en la incorporacion + actualizaciones periodicas (minimo anual) + formacion adicional

tras incidentes

SIMULACION DE PHISHING - El metodo mas efectivo:

■ Enviar emails de phishing FALSOS y controlados a empleados sin que lo sepan

■ Medir: % que abre el email, % que hace clic en el enlace, % que introduce credenciales, % que reporta el intento

■ Los que 'caen': reciben formacion inmediata y especifica

■ Objetivo: reducir el porcentaje de clics con el tiempo. Un buen programa baja del 30% inicial al 5% en 12 meses

■ NO es para castigar. Es para identificar quienes necesitan mas formacion

INDICADORES DE COMPORTAMIENTO DE RIESGO:

■ Comportamiento arriesgado: acciones que aumentan el riesgo aunque no sean intencionadamente maliciosas

Ejemplos: conectar un USB encontrado en el parking, usar WiFi publica sin VPN, compartir credenciales con companeros

■ Comportamiento inesperado: comportamiento inusual que puede indicar compromiso de cuenta o amenaza interna

Ejemplos: acceder a datos fuera del horario habitual, descargar grandes cantidades de datos, acceder a sistemas fuera de su rol

■ Amenaza interna no intencionada: empleado bien intencionado que causa un incidente por error

Ejemplos: enviar email con datos sensibles a la direccion equivocada, publicar credenciales en GitHub por error

■ Amenaza interna maliciosa: empleado que actua deliberadamente en contra de la organizacion

Indicadores: descontento laboral reciente, sancion disciplinaria, conocimiento de despido inminente

CONTENIDO CLAVE DE LA FORMACION:

■ Reconocer phishing: remitente sospechoso, urgencia artificial, links que no coinciden, adjuntos no esperados, errores

ortograficos

■ Gestion de contrasenas: usar gestor de contrasenas (Bitwarden, 1Password), nunca reutilizar contrasenas, activar MFA en

todas las cuentas

■ Ingenieria social: verificar siempre la identidad del solicitante por un canal alternativo antes de dar informacion o accesos

■ Manejo de datos: clasificar los datos antes de compartirlos, no enviar PII sin cifrar, no almacenar datos sensibles en dispositivos

no aprobados

■ Reporte de incidentes: a quien reportar, como hacerlo, que informacion incluir. El tiempo es critico

Preguntas de practica (9):

Glosario de Acronimos - SY0-701

Preguntas Adicionales — Generadas (3 preguntas)

1. ¿Con qué frecuencia mínima se recomienda realizar formación de concienciación en seguridad?

✓ **A) Anual**

B) Mensual

C) Trimestral

D) Solo en el onboarding

Fuente: Extra: Security Awareness

2. ¿Con qué frecuencia se recomienda realizar simulaciones de phishing?

✓ **A) Trimestralmente**

B) Anualmente

C) Mensualmente

D) Solo cuando hay una amenaza activa

Fuente: Extra: Security Awareness

---

3. ¿Qué concepto describe el entrenamiento específico según el rol del empleado (ej: diferente para desarrolladores vs contables)?

✓ **A) Role-based training**

B) Security awareness general

C) Tabletop exercises

D) Phishing simulation

Fuente: Extra: Security Awareness

Flashcards — 5.6 (2 tarjetas)

Q: Security awareness — frecuencias	Formación general: anual mínimo
	Simulación phishing: trimestral
	Role-based training: según puesto (devs, RRHH, directivos)
Q: ¿Qué es una cultura 'sin castigo al reporte'?	Los empleados reportan incidentes sin miedo a represalias. Mejora la detección temprana. El castigo desincentiva el reporte

Practice Tests Mixtos — 24 tests de todos los dominios

Sin clasificar (12 preguntas)

1. ¿Qué tipo de cuenta de usuario viola el concepto de no repudio?

[EN: Which type of user account violates the concept of non-repudiation?]

A) Cuenta de usuario estándar

✓ **B) cuenta compartida**

C) Cuenta de usuario invitado

D) cuenta de servicio

Fuente: Practice Test 1

---

2. ¿Cuál de los siguientes es un ejemplo de un algoritmo de extensión de claves?

[EN: Which of the following is an example of a key stretching algorithm?]

A) RIPEMD

B) sha

C) HMAC

✓ **D) PBKDF2**

Fuente: Practice Test 5

---

3. ¿Cuál de las siguientes sería la mejor solución para una empresa que necesita servicios de TI pero carece de personal de TI?

[EN: Which of the following would be the best solution for a company that needs IT services but lacks any IT personnel?]

A) MSA

B) MaaS

✓ C) MSP

D) MSSP

Fuente: Practice Test 7

---

4. La funcionalidad integrada de un dispositivo móvil que permite el uso de aplicaciones de localización se conoce como:

A) WPS

B) GSM

C) SIM

✓ D) GPS

Fuente: Practice Test 13

---

5. ¿Cuál de las respuestas enumeradas a continuación se refiere al software que facilita la aplicación de políticas y procedimientos de dispositivos móviles?

[EN: Which of the answers listed below refers to software that facilitates the enforcement of mobile device policies and proc]

A) NAC

✓ B) DM

C) XDR

D) PAM

** Respuesta corregida manualmente*

Fuente: Practice Test 15

---

6. El término "análisis de código estático" se refiere al proceso de descubrir errores de tiempo de ejecución de la aplicación.

A) Verdadero

✓ B) FALSO

Fuente: Practice Test 16

---

7. En SNMP, cada nodo en una MIB se identifica de forma única mediante un(a):

A) ESD

✓ B) OID

C) CSU

D) OUI

Fuente: Practice Test 18

---

8. ¿Cuál de las respuestas enumeradas a continuación se refiere a un reemplazo seguro de Telnet?

[EN: Which of the answers listed below refers to a secure replacement for Telnet?]

A) RSH

B) IPSec

✓ C) SSH

D) RTPS

Fuente: Practice Test 18

---

9. ¿Cuál de las siguientes contraseñas es la más compleja?

[EN: Which of the following passwords is the most complex?]

A) $7C52WL4SU

B) GdL3tU8wxYz

C) @TxBL$nW@Xt

✓ D) G$L3tU8wY@z

Fuente: Practice Test 20

---

10. Un valor MTBF alto indica que un componente o sistema proporciona baja confiabilidad y es más probable que falle.

A) Verdadero

✓ B) FALSO

Fuente: Practice Test 23

---

11. En los ejercicios de ciberseguridad, el equipo defensor se conoce como:

A) equipo rojo

✓ B) equipo azul

✓ C) equipo blanco

D) equipo morado

Fuente: Practice Test 24

---

12. ¿Cuál de los siguientes términos se utiliza para describir una prueba de penetración en la que la persona que realiza la prueba tiene acceso limitado a información sobre el funcionamiento interno del sistema objetivo?

[EN: Which of the following terms is used to describe a penetration test in which the person conducting the test has limited]

A) Pruebas de caja negra

B) Prueba de fuzz

✓ C) Pruebas de caja gris

D) Pruebas de caja blanca

Fuente: Practice Test 24

Dominio 1: Conceptos Generales de Seguridad (119 preguntas)

13. ¿Cuál de las siguientes respuestas se puede utilizar para describir los controles técnicos de seguridad? (Seleccione 3 respuestas)

[EN: Which of the following answers can be used to describe technical security controls? (Select 3 answers)]

A) Enfocados en proteger los bienes materiales

✓ B) A veces se les llama controles de seguridad lógicos.

✓ C) Ejecutado por sistemas informáticos (en lugar de personas)

D) También conocidos como controles administrativos.

✓ E) Implementado con tecnología.

F) Principalmente implementado y ejecutado por personas (a diferencia de los sistemas informáticos)

Fuente: Practice Test 1

---

14. ¿Cuál de las siguientes respuestas se refiere a los rasgos característicos de los controles de seguridad gerenciales? (Seleccione 3 respuestas)

[EN: Which of the following answers refer to the characteristic features of managerial security controls? (Select 3 answers)]

A) También conocidos como controles administrativos.

B) A veces denominados controles de seguridad lógicos.

✓ **C) Enfocados en reducir el riesgo de incidentes de seguridad**

D) Ejecutado por sistemas informáticos (en lugar de personas)

✓ **E) Documentado en políticas escritas.**

F) Enfocados en proteger los bienes materiales

Fuente: Practice Test 1

---

15. ¿Cuál de las respuestas enumeradas a continuación se puede utilizar para describir los controles de seguridad operativos? (Seleccione 3 respuestas)

[EN: Which of the answers listed below can be used to describe operational security controls (Select 3 answers)]

A) También conocidos como controles administrativos.

✓ **B) Enfocados en los procedimientos del día a día de una organización.**

C) Ejecutado por sistemas informáticos (en lugar de personas)

✓ **D) Se utiliza para garantizar que el equipo continúe funcionando según lo especificado.**

E) Enfocados en la gestión del riesgo

✓ **F) Principalmente implementado y ejecutado por personas (a diferencia de los sistemas informáticos)**

Fuente: Practice Test 1

---

16. ¿Cuál de las respuestas enumeradas a continuación se refiere a controles de seguridad diseñados para disuadir, detectar y prevenir el acceso no autorizado, el robo, el daño o la destrucción de activos materiales?

[EN: Which of the answers listed below refers to security controls designed to deter, detect, and prevent unauthorized access]

A) Controles de seguridad gerenciales

✓ **B) Controles de seguridad física**

C) Controles técnicos de seguridad

D) Controles operativos de seguridad

Fuente: Practice Test 1

---

17. ¿Cuáles son los ejemplos de controles preventivos de seguridad? (Seleccione 3 respuestas)

[EN: What are the examples of preventive security controls? (Select 3 answers)]

A) Cifrado

B) identificación

C) Sensores

✓ **D) Cortafuegos**

E) Señales de advertencia

✓ **F) software audiovisual**

Fuente: Practice Test 1

---

18. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

[EN: Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)]

A) Iluminación

✓ **B) Monitoreo de registros**

C) Zona de arena

✓ **D) Auditorías de seguridad**

✓ **E) circuito cerrado de televisión**

✓ **F) identificación**

✓ **G) Escaneo de vulnerabilidades**

Fuente: Practice Test 1

---

19. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a controles de seguridad compensatorios? (Seleccione todo lo que corresponda)

[EN: Which of the answers listed below refer(s) to compensating security control(s)? (Select all that apply)]

A) Sistemas de energía de respaldo

B) Videovigilancia

✓ **C) Ministerio de Asuntos Exteriores**

✓ **D) Zona de pruebas de aplicaciones**

✓ **E) Segmentación de red**

Fuente: Practice Test 1

---

20. ¿Cuál de los siguientes términos entran en la categoría de controles de seguridad directivos? (Seleccione 2 respuestas)

[EN: Which of the following terms fall into the category of directive security controls? (Select 2 answers)]

A) PIR

✓ **B) PUA**

C) identificación

D) Ministerio de Asuntos Exteriores

E) IPS

Fuente: Practice Test 1

---

21. El término "no repudio" describe la incapacidad de negar la responsabilidad por realizar una acción específica. En el contexto de la seguridad de los datos, el no repudio garantiza la confidencialidad de los datos, proporciona prueba de la integridad de los datos y prueba del origen de los datos.

A) Verdadero

✓ **B) FALSO**

Fuente: Practice Test 1

---

22. En la arquitectura de seguridad AAA, el proceso de otorgar o denegar acceso a recursos se conoce como:

A) Autenticación

✓ **B) Autorización**

✓ **C) Contabilidad**

Fuente: Practice Test 1

---

23. ¿Cuál de las siguientes soluciones proporciona la funcionalidad AAA? (Seleccione todo lo que corresponda)

[EN: Which of the following solutions provide(s) the AAA functionality? (Select all that apply)]

A) CAP

✓ **B) TACACS+**

C) PAPILLA

✓ **D) RADIO**

E) MS-CHAP

Fuente: Practice Test 1

---

24. ¿Cuáles de las respuestas que se enumeran a continuación se refieren a métodos comunes de autenticación de dispositivos utilizados dentro del marco AAA? (Seleccione 3 respuestas)

[EN: Which of the answers listed below refer to common methods of device authentication used within the AAA framework? (Selec]

A) Nombres de usuario y contraseñas

✓ **B) Certificados digitales**

✓ **C) direcciones IP**

D) Ministerio de Asuntos Exteriores

E) Autenticación biométrica

✓ **F) Direcciones MAC**

Fuente: Practice Test 1

---

25. ¿Cuál de los siguientes términos describe el proceso de identificar diferencias entre la postura de seguridad actual de una organización y su postura de seguridad deseada?

[EN: Which of the following terms describes the process of identifying differences between an organization's current security]

A) Ejercicio de mesa

✓ **B) Análisis de brechas**

C) Capacitación en concientización sobre seguridad.

D) Evaluación de riesgos

Fuente: Practice Test 2

---

26. En la arquitectura de seguridad Zero Trust, el punto de aplicación de políticas (PEP) es un componente del plano de datos que aplica las políticas de seguridad definidas en el plano de control por el punto de decisión de políticas (PDP).

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 2

---

27. Un sistema jerárquico para la creación, gestión, almacenamiento, distribución y revocación de certificados digitales se conoce como:

✓ **A) PKI**

B) REAL ACADEMIA DE BELLAS ARTES

C) PKCS

D) California

** Respuesta corregida manualmente*

Fuente: Practice Test 2

---

28. ¿Cuál es el uso típico de una clave pública?

[EN: What is the typical use of a public key?]

✓ **A) Cifrado de datos**

B) Descifrado de datos

C) Autenticación de usuario/dispositivo

D) Todo lo anterior

** Respuesta corregida manualmente*

Fuente: Practice Test 2

---

29. ¿Cuál de las siguientes respuestas se refiere a un dispositivo de almacenamiento de datos equipado con funcionalidad de cifrado a nivel de hardware?

[EN: Which of the following answers refers to a data storage device equipped with hardware-level encryption functionality?]

A) HSM

B) TPM

C) EFS

✓ **D) SED**

Fuente: Practice Test 2

---

30. ¿Cuál de las respuestas enumeradas a continuación se refiere a tecnología de software diseñada para brindar confidencialidad a todo un dispositivo de almacenamiento de datos?

[EN: Which of the answers listed below refers to software technology designed to provide confidentiality for an entire data s]

A) TPM

✓ **B) FDE**

C) EFS

D) HSM

** Respuesta corregida manualmente*

Fuente: Practice Test 2

---

31. La especificación MIME extiende el formato de los mensajes de correo electrónico más allá del texto plano, permitiendo la transferencia de archivos de gráficos, audio y vídeo a través del sistema de correo de Internet. S/MIME es una versión mejorada del protocolo MIME que habilita funciones de seguridad del correo electrónico al proporcionar cifrado, autenticación, integridad de mensajes y otros servicios relacionados.

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 3

---

32. SFTP es una extensión del protocolo FTP que agrega soporte para cifrado SSL/TLS.

A) Verdadero

✓ **B) FALSO**

Fuente: Practice Test 3

---

33. Un protocolo de cifrado utilizado principalmente en redes Wi-Fi que implementan el estándar de seguridad WPA2 se llama:

A) TKIP

✓ **B) CCMP**

C) SSL

D) IPSec

Fuente: Practice Test 3

---

34. ¿Cuál de las siguientes respuestas se refiere a protocolos de cifrado y funciones hash criptográficas obsoletas o inseguras? (Seleccione todo lo que corresponda)

[EN: Which of the following answers refer(s) to deprecated/insecure encryption protocols and cryptographic hash functions? (S]

A) DES

B) AES-256

✓ **C) MD5**

D) ECC

✓ **E) SHA-1**

✓ **F) SSL**

✓ **G) RC4**

Fuente: Practice Test 3

---

35. Ejemplos de técnicas utilizadas para cifrar información incluyen el cifrado simétrico (también llamado cifrado de clave pública) y el cifrado asimétrico (también llamado cifrado de clave secreta o cifrado de clave de sesión).

A) Verdadero

✓ B) FALSO

Fuente: Practice Test 3

---

36. ¿Cuáles de los algoritmos enumerados a continuación no son cifrados simétricos? (Seleccione 3 respuestas)

[EN: Which of the algorithms listed below are not symmetric ciphers? (Select 3 answers)]

A) AES

✓ B) DES

✓ C) DHE

✓ D) ECC

E) IDEA

F) RC4

✓ G) RSA

Fuente: Practice Test 3

---

37. El término "KEK" se refiere a un tipo de clave criptográfica que se utiliza a menudo en sistemas de administración de claves para agregar una capa adicional de seguridad al cifrar y descifrar otras claves criptográficas.

✓ A) Verdadero

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 3

---

38. ¿Cuál de las siguientes respuestas se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

[EN: Which of the following answers refers to a protocol used to set up secure connections and exchange of cryptographic keys]

A) SSL

✓ B) IKE

C) ESP

D) DHE

** Respuesta corregida manualmente*

Fuente: Practice Test 3

---

39. ¿Cuál de las siguientes respuestas se refiere a un algoritmo de cifrado de bloque de clave simétrica heredado?

[EN: Which of the following answers refers to a legacy symmetric-key block cipher encryption algorithm?]

A) RC4

✓ B) DES

C) RSA

D) DSA

Fuente: Practice Test 4

---

40. ¿Cuál de las respuestas enumeradas a continuación se refiere a un cifrado de flujo obsoleto utilizado en algunas aplicaciones heredadas, como WEP?

[EN: Which of the answers listed below refers to a deprecated stream cipher used in some legacy applications, such as WEP?]

A) RSA

B) DES

C) SSL

✓ D) RC4

** Respuesta corregida manualmente*

Fuente: Practice Test 4

---

41. ¿Qué modo de bloque transforma un cifrado de bloque en un cifrado de flujo que permite el cifrado de bits o bytes de datos individuales?

[EN: Which block mode transforms a block cipher into a stream cipher enabling the encryption of individual bits or bytes of d]

✓ A) CFB

B) CBC

C) GCM

D) BCE

** Respuesta corregida manualmente*

Fuente: Practice Test 4

---

42. ¿Cuál de los modos de cifrado de bloques enumerados a continuación es el más simple/débil y, por lo tanto, no se recomienda su uso?

[EN: Which of the block cipher modes listed below is the simplest/weakest and therefore not recommended for use?]

A) CBC

✓ B) GCM

✓ C) BCE

D) marca comunitaria

Fuente: Practice Test 4

---

43. En criptografía, la cantidad de bits de una clave utilizada por un algoritmo criptográfico se denomina tamaño de clave o longitud de clave. La longitud de la clave determina el número máximo de combinaciones necesarias para romper el algoritmo de cifrado; por lo tanto, normalmente una clave más larga significa una seguridad criptográfica más sólida.

✓ A) Verdadero

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 4

---

44. ¿Cuál de las siguientes respuestas se refiere a un microcontrolador integrado que se utiliza para arranque seguro, cifrado de disco y verificación de la integridad del sistema?

[EN: Which of the following answers refers to an embedded microcontroller used for secure boot, disk encryption, and system i]

A) TPM

B) SoC

C) UEFI

✓ D) HSM

Fuente: Practice Test 4

---

45. ¿Cuál de las siguientes respuestas se refiere a un servidor centralizado que se utiliza para distribuir claves criptográficas y autenticar usuarios y servicios dentro de una red informática?

[EN: Which of the following answers refers to a centralized server that is used to distribute cryptographic keys and authenti]

A) PKI

B) RAS

✓ C) KDC

D) NAS

Fuente: Practice Test 4

---

46. En criptografía y seguridad, el término "enclave seguro" generalmente se refiere a un entorno de hardware o software protegido y aislado dentro de un dispositivo informático, como un teléfono inteligente, una tableta o una computadora, donde los datos confidenciales y las operaciones criptográficas se pueden almacenar y procesar de forma segura.

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 4

---

47. ¿Cuál es el propósito de la esteganografía?

[EN: What is the purpose of steganography?]

A) Comprobación de la integridad de los datos

B) Verificando valores hash

✓ **C) Ocultar datos dentro de otro dato**

D) Cifrar datos

Fuente: Practice Test 4

---

48. Las funciones hash encuentran uso en una variedad de aplicaciones, que incluyen:

A) Criptografía

B) Verificación de la integridad de los datos

C) Verificación y almacenamiento de contraseña

D) Firmas digitales

E) tecnología de cadena de bloques

✓ **F) Todo lo anterior**

Fuente: Practice Test 4

---

49. ¿Cuál de las siguientes respuestas se refiere a una familia de funciones hash criptográficas diseñadas para diversas aplicaciones relacionadas con la seguridad, incluidas firmas digitales, almacenamiento de contraseñas, comunicaciones seguras y verificación de la integridad de los datos?

[EN: Which of the following answers refers to a family of cryptographic hash functions designed for various security-related]

A) RSA

B) AES

C) PKCS

✓ **D) sha**

Fuente: Practice Test 5

---

50. ¿Cuál de los siguientes combina una función hash criptográfica con una clave secreta para proporcionar un medio para verificar tanto la autenticidad como la integridad de un mensaje o datos?

[EN: Which of the following combines a cryptographic hash function with a secret key to provide a means of verifying both the]

A) MD5

B) DSA

✓ **C) HMAC**

D) DES

Fuente: Practice Test 5

---

51. ¿Cuál de las respuestas enumeradas a continuación se refiere a una función hash no criptográfica que se utiliza a menudo con fines de verificación de errores?

[EN: Which of the answers listed below refers to a non-cryptographic hash function often used for error-checking purposes?]

A) MD5

✓ **B) CDN**

C) sha

D) RIPEMD

** Respuesta corregida manualmente*

Fuente: Practice Test 5

---

52. ¿Cuál de las siguientes respuestas se refiere a algoritmos utilizados para generar y verificar firmas digitales? (Seleccione 3 respuestas)

[EN: Which of the following answers refer to algorithms used for generating and verifying digital signatures? (Select 3 answe]

✓ **A) ECDSA**

✓ **B) RSA**

C) ECDHE

✓ **D) DSA**

E) GPG/PGP

** Respuesta corregida manualmente*

Fuente: Practice Test 5

---

53. Dadas las limitaciones computacionales de los dispositivos IoT, las tarjetas inteligentes y los dispositivos móviles, ¿cuál de los siguientes algoritmos de firma digital sería la opción más eficiente debido a su menor tamaño de clave y menores requisitos de procesamiento?

[EN: Given the computational limitations of IoT devices, smartcards, and mobile devices, which of the following digital signa]

A) RSA

B) ECDHE

C) DSA

✓ **D) ECDSA**

E) ECC

Fuente: Practice Test 5

---

54. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de estándares y especificaciones que definen diversas técnicas criptográficas, incluidos formatos para claves públicas, claves privadas, firmas digitales y certificados digitales?

[EN: Which of the answers listed below refers to a set of standards and specifications that define various cryptographic tech]

A) ITIL

B) RFC

✓ **C) PKCS**

D) ISO/CEI

** Respuesta corregida manualmente*

Fuente: Practice Test 5

---

55. ¿Cuál de las respuestas enumeradas a continuación se refiere a un tercero de confianza responsable de emitir, revocar y gestionar los certificados digitales?

[EN: Which of the answers listed below refers to a trusted third party responsible for issuing, revoking, and managing digita]

A) REAL ACADEMIA DE BELLAS ARTES

B) DN

✓ **C) California**

D) CSP

** Respuesta corregida manualmente*

Fuente: Practice Test 5

---

56. ¿Cuál de las siguientes respuestas se puede utilizar para describir los certificados digitales autofirmados? (Seleccione 3 respuestas)

[EN: Which of the following answers can be used to describe self-signed digital certificates? (Select 3 answers)]

A) Respaldado por un tercero conocido y confiable

✓ B) Los navegadores web y otras aplicaciones no confían de forma predeterminada

✓ C) Se utiliza en entornos confiables, como redes internas y entornos de desarrollo.

D) Adecuado para sitios web y otras aplicaciones accesibles al público

E) Confiado de forma predeterminada por los navegadores web y otras aplicaciones

✓ F) No respaldado por un tercero conocido y confiable

Fuente: Practice Test 6

---

57. Los certificados digitales de terceros, emitidos por CA confiables, son automáticamente confiables para la mayoría de los navegadores y sistemas operativos, implican un costo y requieren la validación de la identidad del solicitante. Por el contrario, los certificados autofirmados, emitidos por la propia entidad, no son de confianza automáticamente, son de creación y uso gratuitos y no requieren validación por parte de una CA.

✓ A) Verdadero

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 6

---

58. ¿Cuál de las respuestas enumeradas a continuación se refiere a un modelo de confianza PKI?

[EN: Which of the answers listed below refers to a PKI trust model?]

A) Modelo de CA única

B) Modelo jerárquico (CA raíz + CA intermedias)

C) Modelo de malla (CA con certificación cruzada)

D) Modelo web de confianza (todas las CA funcionan como CA raíz)

E) Modelo de cadena de confianza (múltiples CA en una cadena secuencial)

F) Modelo puente (certificación cruzada entre PKI independientes)

G) Modelo híbrido (combinando aspectos de diferentes modelos)

✓ H) Todo lo anterior

Fuente: Practice Test 6

---

59. Un tipo de certificado digital que se puede utilizar para proteger varios subdominios dentro de un dominio principal se conoce como:

A) Certificado de firma raíz

✓ B) Certificado de nombre alternativo del sujeto (SAN)

C) Certificado de validación extendida (EV)

✓ D) Certificado comodín

Fuente: Practice Test 6

---

60. ¿Cuál de las respuestas enumeradas a continuación se refiere a un identificador utilizado para objetos PKI?

[EN: Which of the answers listed below refers to an identifier used for PKI objects?]

✓ A) OID

B) DN

C) SAN

D) GUID

** Respuesta corregida manualmente*

Fuente: Practice Test 6

---

61. Una colección de funciones precompiladas diseñadas para ser utilizadas por más de una aplicación de Microsoft Windows simultáneamente para ahorrar recursos del sistema se conoce como:

✓ A) DLL

B) API

C) EXE

D) INI

** Respuesta corregida manualmente*

Fuente: Practice Test 7

---

62. Un tipo de exploit en el que una aplicación sobrescribe el contenido de un área de memoria a la que no debería tener acceso se llama:

A) inyección de DLL

✓ B) Desbordamiento del búfer

C) pérdida de memoria

D) Escalada de privilegios

Fuente: Practice Test 7

---

63. ¿Cuál de las siguientes respuestas se refiere a un tipo de software integrado en un chip de hardware?

[EN: Which of the following answers refers to a type of software embedded into a hardware chip?]

✓ A) firmware

B) software intermedio

C) Controlador de dispositivo

D) Código máquina

** Respuesta corregida manualmente*

Fuente: Practice Test 8

---

64. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica de ciberataque que se basa en proporcionar información DNS falsa a un solucionador de DNS con el fin de redirigir o manipular la resolución de nombres de dominio a direcciones IP maliciosas?

[EN: Which of the answers listed below refers to a cyberattack technique that relies on providing false DNS information to a]

✓ A) Suplantación de DNS

B) Relleno de credenciales

C) Secuestro de URL

D) Secuestro de dominio

** Respuesta corregida manualmente*

Fuente: Practice Test 9

---

65. Cuando los registrantes de dominio debido a acciones ilegales de terceros pierden el control sobre sus nombres de dominio, son víctimas de:

A) Ataque de sibila

✓ B) Secuestro de dominio

C) Error tipográfico

D) Secuestro de URL

Fuente: Practice Test 9

---

66. ¿Cuál de los siguientes facilita(n) los ataques de escalada de privilegios? (Seleccione todo lo que corresponda)

[EN: Which of the following facilitate(s) privilege escalation attacks? (Select all that apply)]

A) Vulnerabilidades del sistema/aplicación

B) Hash de contraseña

✓ C) Configuraciones erróneas del sistema/aplicación

D) Segmentación de red

✓ E) Técnicas de ingeniería social

Fuente: Practice Test 9

---

67. Un ataque de punto, punto y barra también se conoce como:

A) Ataque de disociación

B) Ataque en el camino

✓ C) Ataque transversal de directorio

D) Ataque de degradación

Fuente: Practice Test 9

---

68. ¿Cuál de las siguientes URL es un indicador potencial de un ataque de cruce de directorio?

[EN: Which of the following URLs is a potential indicator of a directory traversal attack?]

A) http://www.example.com/var/../etc/passwd

B) http://www.example.com/var/www/../../etc/passwd

C) http://www.example.com/var/www/files/../../../etc/passwd

D) http://www.example.com/var/www/files/images/../../../../etc/passwd

✓ E) Cualquiera de los anteriores

Fuente: Practice Test 10

---

69. Se produce una colisión de hash cuando la función hash criptográfica produce dos resúmenes diferentes para la misma entrada de datos.

A) Verdadero

✓ B) FALSO

Fuente: Practice Test 10

---

70. Un ataque contra datos cifrados que depende en gran medida de la potencia informática para comprobar todas las claves y contraseñas posibles hasta encontrar la correcta se denomina:

A) Repetir ataque

✓ B) Ataque de fuerza bruta

C) Ataque de diccionario

D) Ataque de cumpleaños

Fuente: Practice Test 10

---

71. ¿Cuál de las siguientes opciones indicaría un intento de ocultar evidencia de actividad maliciosa?

[EN: Which of the following would indicate an attempt to hide evidence of malicious activity?]

A) Bloqueo de cuenta

B) Inaccesibilidad de recursos

✓ C) Registros faltantes

D) Uso simultáneo de sesiones

Fuente: Practice Test 10

---

72. ¿Cuál de las siguientes respuestas no se refiere al concepto de aislamiento de sistema/aplicación?

[EN: Which of the following answers does not refer to the concept of system/application isolation?]

A) Virtualización

B) Contenedorización

C) Zona de arena

✓ D) Cifrado de datos

Fuente: Practice Test 10

---

73. El término "nube híbrida" se refiere a un entorno informático mixto que puede incluir diferentes modelos de servicios de nube, como nubes públicas y privadas, así como infraestructura local.

✓ A) Verdadero

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 11

---

74. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de empaquetar una aplicación y sus dependencias en una unidad única e independiente, que puede ejecutarse en diferentes entornos informáticos?

[EN: Which of the answers listed below refers to the process of packaging an application and its dependencies into a single,]

A) Computación de borde

✓ B) Contenedorización

C) Virtualización

D) Computación en la nube

** Respuesta corregida manualmente*

Fuente: Practice Test 11

---

75. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

[EN: Which of the answers listed below refers to a protocol used to set up secure connections and exchange of cryptographic k]

A) SSL

✓ B) IKE

C) ESP

D) DHE

Fuente: Practice Test 13

---

76. ¿Qué parte de IPsec proporciona confidencialidad, integridad de datos y autenticación?

[EN: Which part of IPsec provides confidentiality, data integrity, and authentication?]

A) AES

B) sha

C) Ah

✓ D) ESP

Fuente: Practice Test 13

---

77. El propósito de PCI DSS es brindar protección para:

✓ A) Datos del titular de la tarjeta de crédito

B) Software con licencia

C) Contraseñas de usuario

D) Información de salud personal

** Respuesta corregida manualmente*

Fuente: Practice Test 13

---

78. Los métodos de cifrado utilizados para proteger los datos en tránsito incluyen: (Seleccione todos los que correspondan)

A) NFS

✓ B) vpn

C) SED

✓ D) IPSec

E) FDE

✓ F) TLS

Fuente: Practice Test 13

---

79. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología que proporciona control sobre el uso de un dispositivo móvil dentro de un área designada?

[EN: Which of the answers listed below refers to a technology that provides control over the usage of a mobile device within]

✓ A) Geocerca

B) Seguimiento de dispositivos

C) Seguridad perimetral

D) Geolocalización

** Respuesta corregida manualmente*

Fuente: Practice Test 13

---

80. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica que permite convertir datos de entrada en una cadena de tamaño fijo, lo que dificulta revertir o recuperar los datos originales?

[EN: Which of the answers listed below refers to a technique that enables converting input data into a fixed-size string, mak]

✓ A) Ofuscación

✓ B) Tokenización

C) hash

D) Cifrado

Fuente: Practice Test 13

---

81. ¿Cuál de las respuestas enumeradas a continuación se refiere a las ventajas de la segmentación como método para proteger los datos? (Seleccione 3 respuestas)

[EN: Which of the answers listed below refer to the advantages of segmentation as a method for securing data? (Select 3 answe]

A) Mejora la seguridad al limitar la propagación de ciberataques

✓ B) Ayuda a las organizaciones a cumplir con los requisitos normativos de datos aislando y protegiendo tipos de datos específicos

C) Proporciona seguridad para los datos en tránsito con el uso de cifrado.

D) Garantiza la recuperación de datos en caso de eliminación accidental o fallas del sistema.

✓ E) Proporciona un mejor control sobre el acceso de los usuarios a datos confidenciales.

Fuente: Practice Test 13

---

82. Nivel RAID de hardware 0: (seleccione todo lo que corresponda)

A) Requiere un mínimo de 2 unidades para implementar

✓ B) También se conoce como segmentación de discos.

✓ C) Disminuye la confiabilidad (la falla de cualquier disco en la matriz resulta en la pérdida de todos los datos en la matriz)

D) También se conoce como duplicación de disco.

E) Ofrece menos capacidad de volumen en comparación con RAID 1

F) Requiere al menos 3 unidades para implementarse

✓ **G) Es adecuado para sistemas donde el rendimiento tiene mayor prioridad que la tolerancia a fallos.**

H) Ofrece confiabilidad mejorada al crear conjuntos de datos idénticos en cada unidad (la falla de una unidad no destruye la matriz ya que cada unidad contiene una copia idéntica de los datos)

Fuente: Practice Test 14

---

83. Hardware RAID Nivel 5: (Seleccione 3 respuestas)

A) Requiere al menos 2 unidades para implementar

B) Continúa funcionando en caso de falla de más de 1 unidad

C) También se conoce como segmentación de discos con doble paridad.

✓ **D) Requiere al menos 3 unidades para implementarse**

✓ **E) Ofrece mayor rendimiento y tolerancia a fallas (la falla de una sola unidad no destruye la matriz y las unidades restantes pueden recrear los datos perdidos)**

✓ **F) Requiere al menos 4 unidades para implementarse**

✓ **G) También se conoce como división de discos con paridad.**

Fuente: Practice Test 14

---

84. Hardware RAID Nivel 10 (también conocido como RAID 1+0): (Seleccione 3 respuestas)

A) Requiere un mínimo de 4 unidades para implementar

✓ **B) Se conoce como banda de espejos, es decir, una combinación de RAID 1 (duplicación de disco) y RAID 0 (división de disco).**

C) Requiere un mínimo de 5 unidades para implementar

✓ **D) Ofrece mayor rendimiento y tolerancia a fallos (el fallo de una unidad en cada par de unidades de disco reflejadas no destruye la matriz)**

E) Requiere un mínimo de 3 unidades para implementar

F) Continúa funcionando en caso de falla de más de 2 unidades

G) Se conoce como banda de espejos, es decir, una combinación de RAID 1 (división de discos) y RAID 0 (duplicación de discos).

Fuente: Practice Test 14

---

85. ¿Cuál de las respuestas enumeradas a continuación se refiere a la función principal del equilibrio de carga?

[EN: Which of the answers listed below refers to the primary function of load balancing?]

A) Mantiene copias idénticas de datos en múltiples servidores para mejorar la disponibilidad y confiabilidad de los datos.

✓ **B) Distribuye la carga de trabajo entre múltiples servidores para mejorar el rendimiento.**

✓ **C) Agrupa servidores para proporcionar alta disponibilidad y tolerancia a fallos.**

D) Distribuye contenido geográficamente entre múltiples servidores para mejorar el rendimiento, reducir la latencia y manejar grandes volúmenes de tráfico.

Fuente: Practice Test 14

---

86. ¿Cuál de las respuestas enumeradas a continuación se refiere a un escenario simulado llevado a cabo en un entorno controlado, que generalmente implica discusiones y planificación en torno a incidentes de seguridad hipotéticos?

[EN: Which of the answers listed below refers to a simulated scenario conducted in a controlled environment, typically involv]

✓ **A) Ejercicio de mesa**

B) Zona de arena

C) caza de amenazas

D) Capacitación en concientización sobre seguridad.

** Respuesta corregida manualmente*

Fuente: Practice Test 14

---

87. La implementación del cifrado completo del dispositivo es uno de los métodos para proteger los datos confidenciales en un teléfono inteligente. Cuando está habilitado, este tipo de cifrado funciona junto con el bloqueo de pantalla del teléfono, es decir, para descifrar el teléfono (que permanece cifrado siempre que está bloqueado), el usuario primero debe desbloquear la pantalla. En los dispositivos Android, los métodos de desbloqueo incluyen ingresar un PIN, una contraseña o dibujar un patrón simple con un dedo. Los dispositivos Apple utilizan códigos de acceso, reconocimiento facial (Face ID) y huellas dactilares (Touch ID).

✓ A) Verdadero

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 15

---

88. ¿Cuál de las respuestas que se enumeran a continuación se refieren a técnicas de refuerzo de estaciones de trabajo? (Seleccione 3 respuestas)

[EN: Which of the answers listed below refer to workstation hardening techniques? (Select 3 answers)]

A) Ocultar cuentas de administrador

✓ B) Aplicar periódicamente parches de seguridad y actualizaciones del sistema operativo y del software instalado.

C) Deshabilitar todo el acceso a Internet

✓ D) Eliminar o deshabilitar controladores, servicios, software y protocolos de red innecesarios

✓ E) Limitar el acceso de usuarios no autorizados o no autenticados

Fuente: Practice Test 15

---

89. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de evaluación del entorno físico, como la distribución del edificio, para identificar posibles fuentes de interferencia y determinar la ubicación óptima de un WAP?

[EN: Which of the answers listed below refers to the process of assessing the physical environment, such as the layout of the]

A) Análisis de brechas

B) Planificación de capacidad

✓ C) Estudio del sitio

D) Escaneo de vulnerabilidades

Fuente: Practice Test 15

---

90. Un SSID es un identificador único (también conocido como nombre de red inalámbrica) para una WLAN. Las redes inalámbricas anuncian su presencia transmitiendo periódicamente SSID en un paquete especial llamado marco de baliza. En redes inalámbricas con funciones de seguridad deshabilitadas, conocer el SSID de la red es suficiente para acceder a la red. SSID también identifica el enrutador inalámbrico que actúa como WAP. Los enrutadores inalámbricos del mismo fabricante suelen configurarse con nombres SSID predeterminados (conocidos). Dado que varios dispositivos con el mismo SSID mostrado en la lista de redes disponibles crean confusión y fomentan el acceso accidental por parte de usuarios no autorizados (se aplica a redes que carecen de seguridad), cambiar el SSID predeterminado es una práctica recomendada.

✓ A) Verdadero

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 15

---

91. ¿Cuáles son las características del modo empresarial WPA2/WPA3? (Seleccione 3 respuestas)

[EN: What are the characteristic features of WPA2/WPA3 Enterprise mode? (Select 3 answers)]

A) Adecuado para grandes redes corporativas

B) IEEE 802.1D

C) No requiere un servidor de autenticación

✓ D) IEEE 802.1X

E) Adecuado para todo tipo de LAN inalámbricas

✓ F) Requiere servidor de autenticación RADIUS

Fuente: Practice Test 15

---

92. ¿Cuál de las siguientes siglas se refiere a un método de autenticación de cliente utilizado en el modo WPA3 Personal?

[EN: Which of the following acronyms refers to a client authentication method used in WPA3 Personal mode?]

✓ A) SAE

B) IKE

C) PSK

D) AES

** Respuesta corregida manualmente*

Fuente: Practice Test 15

---

93. ¿Cuáles son los rasgos característicos de RADIUS? (Seleccione 3 respuestas)

[EN: What are the characteristic features of RADIUS? (Select 3 answers)]

A) Se utiliza principalmente para acceso a la red.

B) Cifra toda la carga útil del paquete de solicitud de acceso.

✓ C) Combina autenticación y autorización

✓ D) Cifra solo la contraseña en el paquete de solicitud de acceso.

E) Se utiliza principalmente para la administración de dispositivos.

F) Separa la autenticación y la autorización

Fuente: Practice Test 15

---

94. ¿Cuál de las siguientes respuestas se refiere a un protocolo de autenticación inalámbrica obsoleto desarrollado por Cisco?

[EN: Which of the following answers refers to a deprecated wireless authentication protocol developed by Cisco?]

A) PEAP

B) EAP-TTLS

✓ C) SALTO

D) EAP-TLS

Fuente: Practice Test 16

---

95. ¿Cuáles de los aspectos de programación enumerados a continuación son críticos en el proceso de desarrollo seguro de aplicaciones? (Seleccione 2 respuestas)

[EN: Which of the programming aspects listed below are critical in the secure application development process? (Select 2 answ]

A) Gestión de parches

✓ B) Validación de entrada

C) Protección con contraseña

✓ D) Manejo de errores y excepciones

E) Lista blanca de aplicaciones

Fuente: Practice Test 16

---

96. ¿Cuál de las siguientes respuestas se refiere a una contramedida contra la inyección de código?

[EN: Which of the following answers refers to a countermeasure against code injection?]

A) Fuzzing

✓ B) Validación de entrada

C) firma de código

D) Normalización

Fuente: Practice Test 16

---

97. ¿Cuál de las respuestas que se enumeran a continuación se refieren a los rasgos característicos del análisis de código estático? (Seleccione 3 respuestas)

[EN: Which of the answers listed below refer to the characteristic features of static code analysis? (Select 3 answers)]

A) Implica examinar el código sin ejecutarlo.

✓ B) A menudo se utiliza al principio del proceso de desarrollo.

✓ C) Examina la estructura, la sintaxis y la semántica del código para detectar problemas como errores de sintaxis, violaciones de estándares de codificación, vulnerabilidades de seguridad y errores.

D) Normalmente se utiliza más adelante en el ciclo de vida del desarrollo de software.

E) Implica ejecutar el código y analizar su comportamiento en tiempo de ejecución.

F) Analiza las propiedades del tiempo de ejecución, como el uso de la memoria, el rendimiento y el manejo de errores, para identificar problemas como pérdidas de memoria, cuellos de botella en el rendimiento y errores de tiempo de ejecución.

Fuente: Practice Test 16

---

98. ¿Cuál de las siguientes afirmaciones describe las características del análisis de código dinámico? (Seleccione 3 respuestas)

[EN: Which of the following statements describe the features of dynamic code analysis? (Select 3 answers)]

A) Normalmente se utiliza más adelante en el ciclo de vida del desarrollo de software.

B) Implica examinar el código sin ejecutarlo.

✓ C) Analiza las propiedades del tiempo de ejecución, como el uso de la memoria, el rendimiento y el manejo de errores, para identificar problemas como pérdidas de memoria, cuellos de botella en el rendimiento y errores de tiempo de ejecución.

D) A menudo se utiliza al principio del proceso de desarrollo.

E) Examina la estructura, la sintaxis y la semántica del código para detectar problemas como errores de sintaxis, violaciones de estándares de codificación, vulnerabilidades de seguridad y errores.

✓ F) Implica ejecutar el código y analizar su comportamiento en tiempo de ejecución.

Fuente: Practice Test 17

---

99. ¿Cuál de los términos enumerados a continuación se refiere al seguimiento y administración de componentes de aplicaciones de software, como bibliotecas de terceros y otras dependencias?

[EN: Which of the terms listed below refers to tracking and managing software application components, such as third-party lib]

✓ A) Control de versiones

B) Monitoreo de paquetes

C) Aplicación de la configuración

D) Endurecimiento de aplicaciones

** Respuesta corregida manualmente*

Fuente: Practice Test 17

---

100. Un programa de divulgación responsable es un proceso formal establecido por una organización para alentar a los investigadores de seguridad y a los piratas informáticos éticos a informar las vulnerabilidades que descubren en los sistemas o software de la organización. Un programa de recompensas por errores es un tipo específico de programa de divulgación responsable que ofrece

recompensas financieras a los investigadores de seguridad por informar vulnerabilidades válidas.

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 17

---

101. ¿Cuál de las afirmaciones enumeradas a continuación no se refiere a una técnica de respuesta y remediación de vulnerabilidades?

[EN: Which of the statements listed below does not refer to a vulnerability response and remediation technique?]

A) Aplicar actualizaciones o correcciones proporcionadas por proveedores de software para abordar la vulnerabilidad (parches)

B) Garantizar la recuperación financiera de los costos asociados con un ciberataque exitoso (seguro)

C) Dividir una red en zonas más pequeñas y aisladas para limitar el impacto potencial de una vulnerabilidad (segmentación)

D) Mitigar el riesgo asociado con una vulnerabilidad que no se puede reparar de inmediato mediante la implementación de medidas de seguridad alternativas (controles de compensación)

E) Retrasar o renunciar a un parche para un sistema específico, por ejemplo, cuando aplicar un parche puede no ser factible debido a problemas de compatibilidad o posibles interrupciones en sistemas críticos (excepciones y exenciones).

✓ **F) Todas las respuestas anteriores son ejemplos de técnicas de respuesta y remediación de vulnerabilidades.**

Fuente: Practice Test 17

---

102. ¿Cuál de las siguientes respuestas se refiere a SCAP? (Seleccione 3 respuestas)

[EN: Which of the following answers refer to SCAP? (Select 3 answers)]

A) Un tipo de sistema de seguridad diseñado para recopilar registros y eventos de diversas fuentes.

✓ **B) Diseñado para proporcionar una interfaz de usuario centralizada para acceder a los datos recopilados.**

✓ **C) Una colección de estándares desarrollados por NIST**

✓ **D) Proporciona un lenguaje común para comunicar información de seguridad.**

✓ **E) Permite que diferentes herramientas de seguridad compartan datos y trabajen juntas de manera más efectiva**

F) Permite la detección de amenazas en tiempo real, la respuesta a incidentes y el monitoreo del cumplimiento

Fuente: Practice Test 17

---

103. ¿Cuál de las siguientes siglas se refiere a soluciones de seguridad basadas en software o hardware diseñadas para detectar y prevenir el uso y la transmisión no autorizados de información confidencial?

[EN: Which of the following acronyms refers to software or hardware-based security solutions designed to detect and prevent u]

A) IPS

✓ **B) DLP**

C) identificación

D) DEP

Fuente: Practice Test 17

---

104. El Protocolo simple de administración de red (SNMP) es un protocolo de capa de aplicación basado en UDP que se utiliza en sistemas de administración de red para monitorear dispositivos conectados a la red. SNMP suele estar integrado en la mayoría de los dispositivos de infraestructura de red modernos, como enrutadores, puentes, conmutadores, servidores, impresoras, fotocopiadoras,

máquinas de fax y otros dispositivos conectados a la red. Una red administrada por SNMP consta de tres componentes esenciales: un dispositivo administrado, un módulo de software de administración de red que reside en un dispositivo administrado (Agente) y una estación de administración de red (NMS), que ejecuta aplicaciones responsables de monitorear y controlar los dispositivos administrados, así como de recopilar información SNMP de los Agentes. El administrador recibe notificaciones (Traps e InformRequests) en el puerto UDP 162, mientras que el agente SNMP recibe solicitudes en el puerto UDP 161.

✓ A) Verdadero

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 17

---

105. Filtrado web basado en agentes: (Seleccione 3 respuestas)

A) Requiere instalar software en cada dispositivo que necesita ser monitoreado

✓ B) Proporciona flexibilidad y control granular sobre la actividad web a nivel de dispositivo

✓ C) Implica un aumento de los gastos generales de gestión y del consumo de recursos del sistema.

D) Simplifica la administración y garantiza la aplicación consistente de las políticas de filtrado web en toda la red.

✓ E) No requiere la instalación de software en cada dispositivo individual

F) Requiere un servidor central en funcionamiento para que funcione el filtrado web.

Fuente: Practice Test 18

---

106. ¿Cuál de las respuestas enumeradas a continuación se refiere a técnicas de filtrado que pueden permitir o bloquear el acceso a un sitio en función de su dirección web? (Seleccione 2 respuestas)

[EN: Which of the answers listed below refer to filtering techniques that can allow or block access to a site based on its we]

A) Inspección SSL/TLS

✓ B) escaneo de URL

C) Categorización de contenido

✓ D) filtrado DNS

E) Filtrado basado en reputación

Fuente: Practice Test 18

---

107. En el entorno Windows Active Directory, esta característica permite la administración y configuración centralizada de sistemas operativos, aplicaciones y configuraciones de cuentas de usuario.

A) Usuarios y grupos locales

B) Monitor de recursos

✓ C) Política de grupo

D) Control de cuentas de usuario

Fuente: Practice Test 18

---

108. ¿Cuál de los siguientes protocolos permite la transferencia segura de archivos? (Seleccione todo lo que corresponda)

[EN: Which of the following protocols allow(s) for secure file transfer? (Select all that apply)]

A) FTPS

B) TFTP

C) ftp

✓ D) SFTP

Fuente: Practice Test 18

---

109. ¿Cuál de los protocolos enumerados a continuación permite la recuperación segura de correos electrónicos desde un servidor de correo a un cliente de correo electrónico? (Seleccione 2 respuestas)

[EN: Which of the protocols listed below enable secure retrieval of emails from a mail server to an email client? (Select 2 a]

A) FTPS

✓ B) IMÁGENES

✓ C) pop3s

D) INICIO

E) SMTP

Fuente: Practice Test 18

---

110. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de red seguro utilizado para proporcionar cifrado, autenticación e integridad para la comunicación multimedia en tiempo real?

[EN: Which of the answers listed below refers to a secure network protocol used to provide encryption, authentication, and in]

A) IPSec

B) SORBO

C) VoIP

✓ D) SRTP

Fuente: Practice Test 18

---

111. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método de autenticación que permite firmar un mensaje de correo electrónico saliente con una firma digital?

[EN: Which of the answers listed below refers to an authentication method that enables the signing of an outbound email messa]

A) FPS

✓ B) DKIM

C) DMARC

D) PEM

** Respuesta corregida manualmente*

Fuente: Practice Test 19

---

112. ¿Cuál de las siguientes respuestas se refiere a un mecanismo de autenticación de correo electrónico que permite a los propietarios de dominios especificar qué direcciones IP están autorizadas para enviar correos electrónicos en nombre de su dominio?

[EN: Which of the following answers refers to an email authentication mechanism that allows domain owners to specify which IP]

A) DMARC

B) PEM

C) DKIM

✓ D) FPS

** Respuesta corregida manualmente*

Fuente: Practice Test 19

---

113. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar criptográfico (y un formato de archivo) utilizado para el almacenamiento y transmisión de claves privadas en comunicaciones por correo electrónico?

[EN: Which of the answers listed below refers to a cryptographic standard (and a file format) used for the storage and transm]

✓ A) PEM

B) DMARC

C) FPS

D) DKIM

** Respuesta corregida manualmente*

Fuente: Practice Test 19

---

114. ¿Cuál de las siguientes respuestas se refiere(s) al modelo de control de acceso obligatorio (MAC)? (Seleccione todo lo que corresponda)

[EN: Which of the following answers refer(s) to the Mandatory Access Control (MAC) model? (Select all that apply)]

A) Los usuarios no pueden cambiar las políticas de acceso a su propia discreción.

✓ B) Las etiquetas y los niveles de autorización solo pueden ser aplicados y modificados por un administrador

C) Cada objeto tiene un propietario que, a su propia discreción, determina qué tipo de permisos pueden tener otros usuarios sobre ese objeto.

D) Acceso a recursos según la identidad del usuario.

✓ E) Cada recurso tiene una etiqueta de confidencialidad que coincide con un nivel de autorización asignado a un usuario.

Fuente: Practice Test 19

---

115. ¿Qué tipo de modelo de control de acceso conecta los permisos de los usuarios con sus responsabilidades específicas?

[EN: Which type of control access model connects user permissions to their specific responsibilities?]

A) CAD

✓ B) RBAC

C) IMPERMEABLE

D) ABAC

Fuente: Practice Test 19

---

116. ¿Cuál de los siguientes métodos de control de acceso sería el más adecuado para programar tareas de mantenimiento del sistema durante períodos de baja actividad del usuario?

[EN: Which of the following access control methods would be the most suitable for scheduling system maintenance tasks during]

A) Aprovisionamiento de recursos

✓ B) Restricciones horarias

C) Principio de privilegio mínimo

D) Permisos justo a tiempo

Fuente: Practice Test 20

---

117. ¿Cuál de las respuestas enumeradas a continuación se refiere a un tipo de medio que se puede utilizar como token de autenticación de hardware? (Seleccione todo lo que corresponda)

[EN: Which of the answers listed below refer(s) to a medium type that can be used as a hardware authentication token? (Select]

A) tarjeta inteligente

✓ B) llavero

✓ C) clave de seguridad

D) frase de contraseña

E) Lector biométrico

✓ F) insignia rfid

Fuente: Practice Test 20

---

118. Los dos factores que se consideran importantes para crear contraseñas seguras son: (Seleccione 2 respuestas)

A) Longitud de la contraseña

B) Edad mínima de la contraseña

C) Historial de contraseñas

✓ **D) Complejidad de la contraseña**

E) Edad máxima de la contraseña

Fuente: Practice Test 20

---

119. ¿Cuál de las respuestas enumeradas a continuación se refiere a una herramienta de software diseñada específicamente para almacenar y administrar las credenciales de inicio de sesión?

[EN: Which of the answers listed below refers to a software tool specifically designed to store and manage login credentials?]

A) BitLocker

✓ **B) Administrador de contraseñas**

C) depósito de claves

D) Bóveda de contraseñas

** Respuesta corregida manualmente*

Fuente: Practice Test 20

---

120. ¿Cuál de los términos enumerados a continuación se refiere al concepto de acceso efímero, donde el acceso a sistemas, recursos o permisos se proporciona por un tiempo limitado? (Seleccione todo lo que corresponda)

[EN: Which of the terms listed below refer(s) to the concept of ephemeral access, where access to systems, resources, or perm]

A) TOTP

✓ **B) OTP**

✓ **C) Permisos justo a tiempo**

D) Contraseña de usuario

E) clave API

Fuente: Practice Test 20

---

121. ¿Cuál de los términos enumerados a continuación se refiere a un proceso que se ocupa de coordinar y gestionar múltiples tareas repetitivas?

[EN: Which of the terms listed below refers to a process that deals with coordinating and managing multiple repetitive tasks?]

A) Secuenciación

✓ **B) Orquestación**

C) secuencias de comandos

D) Automatización

** Respuesta corregida manualmente*

Fuente: Practice Test 21

---

122. En el proceso de respuesta a incidentes, el paso que implica identificar y comprender incidentes potenciales para determinar su alcance, impacto y causa raíz es parte de:

A) Etapa de preparación

✓ **B) Etapa de detección y análisis.**

C) Etapa de contención, erradicación y recuperación.

D) Etapa de actividad posterior al incidente

Fuente: Practice Test 21

---

123. ¿Qué etapa del proceso de respuesta a incidentes implica la actualización de los planes, políticas y procedimientos de respuesta a incidentes?

[EN: Which stage of the incident response process involves updating incident response plans, policies, and procedures?]

A) Preparación

B) Detección y análisis

C) Contención, erradicación y recuperación

✓ **D) Actividad posterior al incidente**

Fuente: Practice Test 21

---

124. ¿Cuál de las siguientes respuestas se refiere a un término general utilizado para describir un grupo especializado dentro de una organización que se centra en tareas o áreas de responsabilidad específicas?

[EN: Which of the following answers refers to a general term used to describe a specialized group within an organization focu]

A) Concejo

B) consejo asesor

✓ **C) Comité**

D) grupo de trabajo

** Respuesta corregida manualmente*

Fuente: Practice Test 22

---

125. ¿Cuál de las respuestas enumeradas a continuación se refiere a organizaciones del sector público que establecen y hacen cumplir leyes y regulaciones a nivel local, regional o nacional?

[EN: Which of the answers listed below refers to public sector organizations that set and enforce laws and regulations at loc]

✓ **A) Entidades gubernamentales**

B) Asociaciones comerciales

C) Organismos estatutarios

D) Agencias reguladoras

** Respuesta corregida manualmente*

Fuente: Practice Test 22

---

126. ¿Cuál de las respuestas enumeradas a continuación se refiere a organizaciones o personas responsables de garantizar el cumplimiento de las leyes de protección de datos?

[EN: Which of the answers listed below refers to organizations or individuals responsible for ensuring compliance with data p]

✓ **A) Controladores**

B) Mayordomos

C) Propietarios

D) Procesadores

** Respuesta corregida manualmente*

Fuente: Practice Test 22

---

127. ¿Cuál de los términos enumerados a continuación se refiere a un término general que describe la actitud general de una organización hacia la asunción de riesgos?

[EN: Which of the terms listed below refers to a general term that describes an organization's overall attitude towards risk-]

A) Estrategia de riesgo

B) control de riesgos

✓ **C) Apetito de riesgo**

D) Tolerancia al riesgo

Fuente: Practice Test 23

---

128. ¿Cuál de las siguientes respuestas se refiere a una disposición contractual que otorga a una parte el derecho de inspeccionar las operaciones, instalaciones, procesos y registros de la otra parte?

[EN: Which of the following answers refers to a contractual provision that grants one party the right to inspect the other pa]

✓ **A) Cláusula de derecho de auditoría**

B) Cláusula de supervisión

C) Cláusula de verificación de cumplimiento

D) Cláusula de transparencia

** Respuesta corregida manualmente*

Fuente: Practice Test 23

---

129. ¿Cuál de los términos enumerados a continuación se refiere a una situación en la que la imparcialidad de una parte podría ser cuestionada debido a posibles ganancias personales o financieras?

[EN: Which of the terms listed below refers to a situation where a party's impartiality could be questioned due to potential]

A) relación dual

B) Influencia indebida

✓ C) Incompatibilidad

D) Auto-negociación

Fuente: Practice Test 23

---

130. ¿Cuál de las siguientes siglas se refiere a un documento que autoriza, inicia y rastrea el progreso y la finalización de un trabajo o tarea en particular?

[EN: Which of the following acronyms refers to a document that authorizes, initiates, and tracks the progress and completion]

A) SEMBRAR

✓ B) WO

C) SLA

D) MSA

Fuente: Practice Test 23

---

131. En la comunicación por correo electrónico, ¿qué señales pueden ayudar a reconocer un intento de phishing?

[EN: In email communication, what signs can be of help in recognizing a phishing attempt?]

A) El mensaje contiene mala ortografía y gramática.

B) El mensaje pide información personal.

C) El mensaje incluye un llamado a la acción con sentido de urgencia.

D) El mensaje incluye enlaces o archivos adjuntos sospechosos.

✓ E) Cualquiera de los anteriores

Fuente: Practice Test 24

Dominio 2: Amenazas, Vulnerabilidades y Mitigaciones (56 preguntas)

132. ¿Cuáles de las siguientes afirmaciones sobre los honeypots son ciertas? (Seleccione 2 respuestas)

[EN: Which of the following statements about honeypots are true? (Select 2 answers)]

A) Los Honeypots siempre son parte de una Honeynet.

✓ B) Los Honeypots imitan sistemas reales para atraer ciberatacantes

C) Los Honeypots son un tipo de solución antimalware

✓ D) Los Honeypots contienen vulnerabilidades aparentes que son monitoreadas de cerca por un equipo de seguridad.

E) Los Honeypots se utilizan para lanzar ataques contra ciberatacantes

Fuente: Practice Test 2

---

133. ¿Cuál de los algoritmos criptográficos enumerados a continuación es el menos vulnerable a los ataques?

[EN: Which of the cryptographic algorithms listed below is the least vulnerable to attacks?]

✓ **A) AES**

B) DES

C) RC4

D) 3DES

** Respuesta corregida manualmente*

Fuente: Practice Test 3

---

134. Elija una respuesta de la lista desplegable de la derecha para hacer coincidir un tipo de actor de amenaza a la izquierda con su atributo de vector de ataque común.

Pregunta interactiva (drag-and-drop). Drag-and-drop: Nation-state=Direct hacking; Insider=Internal access; Script kiddie=Public exploits; Hacktivista=Public defacement; Crimen organizado=Financial fraud

Fuente: Practice Test 6

---

135. Relacione cada tipo de actor de amenaza con su correspondiente atributo de recursos/financiación.

Pregunta interactiva (drag-and-drop). Drag-and-drop: Nation-state=Well-funded; Insider=Minimal; Script kiddie=Minimal; Hacktivista=Crowd-funded; Crimen organizado=Well-funded

Fuente: Practice Test 6

---

136. Asigne el atributo de nivel de sofisticación a cada tipo de actor de amenazas que se enumera a continuación.

Pregunta interactiva (drag-and-drop). Drag-and-drop: Nation-state=Highly sophisticated; Insider=Low-Moderate; Script kiddie=Low; Hacktivista=Low-Moderate; Crimen organizado=Moderate-High

Fuente: Practice Test 6

---

137. En la lista desplegable de la derecha, seleccione las motivaciones típicas detrás de las acciones de cada tipo de actor de amenaza.

Pregunta interactiva (drag-and-drop). Drag-and-drop: Nation-state=Espionage/disruption; Insider=Financial gain/revenge; Script kiddie=Notoriety; Hacktivista=Ideology; Crimen organizado=Financial gain

Fuente: Practice Test 6

---

138. ¿Cuál de los siguientes términos se utiliza para describir ciberataques sofisticados y prolongados, a menudo llevados a cabo por grupos organizados y bien financiados, como los Estados-nación?

[EN: Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-fund]

A) MitM

✓ **B) APTO**

C) XSRF

D) DDoS

Fuente: Practice Test 6

---

139. ¿Cuál de las respuestas enumeradas a continuación se refiere a un vector de amenaza basado en correo electrónico?

[EN: Which of the answers listed below refers to an email-based threat vector?]

A) suplantación de identidad

B) Phishing

C) Ataques BEC

D) Enlaces maliciosos

E) Archivos adjuntos de malware

✓ **F) Todo lo anterior**

Fuente: Practice Test 6

---

140. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de un vector de amenaza potencial en la comunicación basada en mensajería instantánea?

[EN: Which of the answers listed below refers to an example of a potential threat vector in IM-based communication?]

A) Ataque de phishing

B) Distribución de malware

C) Ataque de suplantación de identidad

D) Escuchar a escondidas

E) Secuestro de cuenta

F) Enlace/adjunto malicioso

✓ **G) Todo lo anterior**

Fuente: Practice Test 6

---

141. ¿Cuál de las respuestas enumeradas a continuación se refiere a un vector de amenaza basado en archivos?

[EN: Which of the answers listed below refers to a file-based threat vector?]

A) Explotaciones de PDF

B) Macros maliciosas en documentos

C) Archivos comprimidos (ZIP, RAR)

D) Scripts maliciosos en páginas web

E) Imágenes infectadas

F) Ejecutables maliciosos

✓ **G) Todo lo anterior**

Fuente: Practice Test 6

---

142. Ejemplos de vectores de amenazas directamente relacionados con el uso de dispositivos extraíbles incluyen: (Seleccione 2 respuestas)

A) Pretexto

✓ **B) Entrega de malware**

C) Ataques de abrevadero

✓ **D) Exfiltración de datos**

E) Ataques de ingeniería social

Fuente: Practice Test 6

---

143. ¿Cuál de las siguientes respuestas se refiere a vectores de amenazas de software sin agentes? (Seleccione 2 respuestas)

[EN: Which of the following answers refer to agentless software threat vectors? (Select 2 answers)]

A) Correo electrónico de phishing

B) Unidad USB maliciosa

✓ **C) Vulnerabilidad del protocolo de red**

D) Macro infectada

✓ **E) rastreo de paquetes**

Fuente: Practice Test 6

---

144. La explotación de una vulnerabilidad conocida es un vector de amenaza común para:

A) Sistemas/aplicaciones heredados

✓ **B) Sistemas/aplicaciones no compatibles**

C) Sistemas/aplicaciones recientemente lanzados

D) Sistemas/aplicaciones con vulnerabilidad de día cero

Fuente: Practice Test 7

---

145. ¿Cuáles de las tecnologías inalámbricas enumeradas a continuación se consideran vectores de amenazas potenciales y deben evitarse debido a sus vulnerabilidades conocidas? (Seleccione todo lo que corresponda)

[EN: Which of the wireless technologies listed below are considered potential threat vectors and should be avoided due to the]

A) WPS

B) WAP

✓ **C) WPA**

D) WAF

✓ **E) WPA2**

✓ **F) WEP**

Fuente: Practice Test 7

---

146. ¿Qué ataque de ingeniería social se basa en el robo de identidad?

[EN: Which social engineering attack relies on identity theft?]

A) Pretexto

B) Phishing de lanza

C) Seguir de cerca

✓ **D) Interpretación**

Fuente: Practice Test 7

---

147. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica de ingeniería social en la que un atacante crea un escenario o situación falsa para engañar a la víctima para que revele información confidencial?

[EN: Which of the answers listed below refers to a social engineering technique where an attacker creates a false scenario or]

A) Interpretación

B) Recolección de credenciales

✓ **C) Pretexto**

D) Ataque al abrevadero

Fuente: Practice Test 7

---

148. El término "secuestro de URL" (también conocido como "Typosquatting") se refiere a una práctica engañosa que implica el registro deliberado de nombres de dominio con errores ortográficos o ligeras variaciones que se parecen mucho a nombres de dominio populares y bien establecidos. El objetivo principal de esta estrategia es explotar los errores tipográficos comunes que cometen los usuarios al ingresar URL en la barra de direcciones de su navegador web. Más allá de capturar tráfico inadvertido, la typosquatting también se puede utilizar para alojar sitios de phishing para engañar a los usuarios para que divulguen información confidencial, distribuir malware a través de sitios web engañosos, generar ingresos publicitarios al redirigir el tráfico mal escrito o participar en la suplantación de marcas para dañar la reputación de marcas auténticas o engañar a los usuarios.

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 7

---

149. Un tipo de vulnerabilidad en el que el estado de un recurso se verifica en un momento dado pero puede cambiar antes de que el recurso se utilice realmente se denomina:

A) TOC

✓ B) TOC/TOU

C) TÚ

D) TIG

Fuente: Practice Test 7

---

150. ¿Cuál de las siguientes respuestas no se refiere a un tipo común de vulnerabilidad basada en el sistema operativo?

[EN: Which of the following answers does not refer to a common type of OS-based vulnerability?]

A) Vulnerabilidades de control de acceso y permisos (contraseñas débiles, escalada de privilegios)

B) Vulnerabilidades en aplicaciones instaladas, utilidades del sistema y controladores de dispositivos.

C) Vulnerabilidades relacionadas con la memoria (pérdidas de memoria, desbordamientos de búfer, condiciones de carrera)

D) Vulnerabilidades en la gestión de parches y actualizaciones (parches de seguridad y retrasos en las actualizaciones, actualizaciones maliciosas)

E) Vulnerabilidades relacionadas con configuraciones erróneas del sistema/seguridad

F) Vulnerabilidades relacionadas con la red (ataques DoS, ataques de ejecución remota de código)

✓ G) Todas las opciones de respuesta anteriores son ejemplos de vulnerabilidades basadas en sistemas operativos.

Fuente: Practice Test 7

---

151. ¿Cuál de las respuestas enumeradas a continuación se refiere a una vulnerabilidad de seguridad que permite insertar código malicioso en campos de entrada, como barras de búsqueda o formularios de inicio de sesión, para ejecutar comandos no autorizados en una base de datos?

[EN: Which of the answers listed below refers to a security vulnerability that enables inserting malicious code into input fi]

A) ICE

✓ B) SQLi

C) XSS

D) CSRF

Fuente: Practice Test 8

---

152. ¿Cuál de las respuestas enumeradas a continuación describe las características de un ataque de secuencias de comandos entre sitios? (Seleccione 3 respuestas)

[EN: Which of the answers listed below describe the characteristics of a cross-site scripting attack? (Select 3 answers)]

A) Explota la confianza que el navegador web de un usuario tiene en un sitio web

✓ B) Se inyecta un script malicioso en un sitio web confiable

✓ C) El navegador del usuario ejecuta el script del atacante

D) Explota la confianza que un sitio web tiene en el navegador web del usuario.

E) Un atacante engaña a un usuario para que envíe solicitudes web no autorizadas

F) El sitio web ejecuta las solicitudes del atacante

Fuente: Practice Test 8

---

153. El malware que restringe el acceso a un sistema informático cifrando archivos o bloqueando todo el sistema hasta que el usuario realice la acción solicitada se llama:

A) Grayware

B) software publicitario

✓ C) ransomware

D) software espía

Fuente: Practice Test 8

---

154. ¿Qué tipo de troyano permite el acceso remoto no autorizado a un sistema comprometido?

[EN: Which type of Trojan enables unauthorized remote access to a compromised system?]

A) APTO

✓ B) RATA

C) MaaS

D) CACHORRO

Fuente: Practice Test 8

---

155. El código malicioso activado por un evento específico se llama:

A) criptomalware

B) Puerta trasera

C) rootkit

✓ D) Bomba lógica

Fuente: Practice Test 8

---

156. A diferencia de los simples ataques DoS que normalmente se realizan desde un solo sistema, un ataque DDoS utiliza múltiples sistemas informáticos comprometidos para realizar el ataque contra su objetivo. Los sistemas intermediarios que se utilizan como plataforma para el ataque (a menudo denominados zombies y colectivamente botnet) son las víctimas secundarias del ataque DDoS.

✓ A) Verdadero

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 9

---

157. ¿Qué define un ataque DDoS reflejado?

[EN: What defines a reflected DDoS attack?]

A) Abrumar al objetivo con un gran volumen de tráfico para saturar su ancho de banda

B) Explotar vulnerabilidades en los protocolos de red para consumir recursos e interrumpir servicios

✓ C) Utilizar servidores de terceros para reflejar y amplificar el tráfico de ataque hacia el objetivo.

D) Apuntar a vulnerabilidades en aplicaciones o servidores web para agotar los recursos.

Fuente: Practice Test 9

---

158. La práctica de obtener acceso no autorizado a un dispositivo Bluetooth se conoce como:

A) Phishing

B) bluejacking

C) aplastando

✓ D) Bluesnarfing

Fuente: Practice Test 9

---

159. Un ataque de interferencia inalámbrica es un tipo de:

A) Ataque criptográfico

✓ B) Ataque DoS

C) Ataque de fuerza bruta

D) Ataque de degradación

Fuente: Practice Test 9

---

160. ¿Cuál de las siguientes es una característica de vulnerabilidad de la comunicación NFC?

[EN: Which of the following is a vulnerability characteristic to NFC communication?]

A) Escuchar a escondidas

B) Intercepción de datos

C) Repetir ataques

D) Ataques DoS

✓ E) Todo lo anterior

Fuente: Practice Test 9

---

161. ¿Cuál de las afirmaciones enumeradas a continuación se puede utilizar para describir las características de un ataque en ruta? (Seleccione todo lo que corresponda)

[EN: Which of the statements listed below can be used to describe the characteristics of an on-path attack? (Select all that]

A) Un ataque en ruta también se conoce como ataque MITM.

✓ B) Los atacantes se sitúan en la ruta de comunicación entre dos dispositivos

✓ C) Los atacantes interceptan o modifican paquetes enviados entre dos dispositivos en comunicación

D) Los atacantes no tienen acceso a los paquetes intercambiados durante la comunicación entre dos dispositivos

Fuente: Practice Test 9

---

162. Una técnica que permite a un atacante autenticarse en un servidor remoto sin extraer una contraseña en texto claro de un resumen se llama:

✓ A) pasar el hash

B) Repetir ataque

C) Ataque de fuerza bruta

D) Ataque de fumigación

** Respuesta corregida manualmente*

Fuente: Practice Test 9

---

163. ¿Cuál de los siguientes exploits apunta a un protocolo utilizado para administrar y acceder a recursos en red?

[EN: Which of the following exploits targets a protocol used for managing and accessing networked resources?]

A) Ataque CSRF/XSRF

✓ B) Ataque de inyección XML

✓ C) Ataque de inyección LDAP

D) Ataque de inyección SQL

Fuente: Practice Test 9

---

164. Una breve lista de contraseñas de uso común probadas en una gran cantidad de cuentas de usuario es un rasgo característico de:

A) Repetir ataque

B) Ataque de diccionario

✓ C) Ataque de fumigación

D) Ataque de cumpleaños

Fuente: Practice Test 10

---

165. ¿Cuál de los términos enumerados a continuación describe con mayor precisión una situación en la que se utiliza una sola cuenta desde múltiples ubicaciones/dispositivos al mismo tiempo?

[EN: Which of the terms listed below most accurately describes a situation wherein a single account is being used from multip]

A) Ataque de fumigación

✓ **B) Uso simultáneo de sesiones**

C) Inicio de sesión único (SSO)

D) viaje imposible

Fuente: Practice Test 10

---

166. ¿Cuál de los términos enumerados a continuación describe con mayor precisión una situación en la que se accede a una cuenta desde una ubicación en la que es físicamente imposible que se encuentre el usuario?

[EN: Which of the terms listed below most accurately describes a situation wherein an account is accessed from a location tha]

A) Restricciones de tiempo de inicio de sesión

✓ **B) viaje imposible**

C) Uso simultáneo de sesiones

D) Registro fuera de ciclo

Fuente: Practice Test 10

---

167. ¿Cuál de las siguientes políticas se aplica a cualquier solicitud que no cumpla con los criterios definidos en una ACL?

[EN: Which of the following policies applies to any requests that fall outside the criteria defined in an ACL?]

A) Política de acceso justo

✓ **B) Política de denegación implícita**

C) confianza transitiva

D) Autenticación consciente del contexto

Fuente: Practice Test 10

---

168. ¿Cuál de las respuestas enumeradas a continuación se refiere a la tecnología de seguridad de red diseñada para monitorear las WLAN en busca de acceso no autorizado, amenazas a la seguridad y actividades sospechosas?

[EN: Which of the answers listed below refers to network security technology designed to monitor WLANs for unauthorized acces]

A) UTM

✓ **B) WIDS**

C) NGFW

D) WAF

** Respuesta corregida manualmente*

Fuente: Practice Test 12

---

169. ¿Cuál de las siguientes respuestas se refiere a un escenario más realista que prueba la respuesta a incidentes de ciberseguridad imitando ataques reales?

[EN: Which of the following answers refers to a more realistic scenario that tests cybersecurity incident response by mimicki]

A) Toma de huellas dactilares

✓ **B) Simulación**

C) caza de amenazas

D) Ejercicio de mesa

Fuente: Practice Test 14

---

170. La práctica de encontrar vulnerabilidades en una aplicación dándole entradas incorrectas se llama:

A) Normalización

B) Endurecimiento

C) Análisis de código dinámico

✓ **D) Fuzzing**

Fuente: Practice Test 16

---

171. Un mecanismo de transporte dedicado para información sobre amenazas cibernéticas se denomina:

A) TCP/IP

B) TLS

✓ **C) TAXII**

D) S/MIME

Fuente: Practice Test 17

---

172. ¿Cuál de las siguientes afirmaciones no se aplica a la web oscura?

[EN: Which of the following statements does not apply to dark web?]

A) Normalmente requiere software especializado para acceder a sus contenidos.

✓ **B) Forma una gran parte de la web profunda.**

C) No indexado por los motores de búsqueda tradicionales.

D) A menudo se asocia con el comercio de datos robados, malware y amenazas cibernéticas.

Fuente: Practice Test 17

---

173. ¿Cuál de las respuestas enumeradas a continuación se refiere a una situación en la que no se activa ninguna alarma cuando se ha producido un ataque?

[EN: Which of the answers listed below refers to a situation where no alarm is raised when an attack has taken place?]

✓ **A) Falso negativo**

B) Verdadero positivo

C) falso positivo

D) Verdadero negativo

** Respuesta corregida manualmente*

Fuente: Practice Test 17

---

174. ¿Cuál de los siguientes términos se refiere a un marco y una base de conocimientos que proporciona comprensión de los TTP utilizados durante los ciberataques?

[EN: Which of the following terms refers to a framework and knowledge base that provides understanding of TTPs used during cy]

✓ **A) cvss**

✓ **B) ATT&CK**

C) STIX

D) TAXII

Fuente: Practice Test 17

---

175. ¿Cuál de los siguientes términos se refiere a patrones o características predefinidos de amenazas o métodos de ataque conocidos?

[EN: Which of the following terms refers to predefined patterns or characteristics of known threats or attack methods?]

A) Registros de seguridad

B) Líneas de base

C) Tendencias

✓ **D) Firmas**

Fuente: Practice Test 18

---

176. ¿Cuál de las siguientes respuestas se refiere a una solución que ayuda a las organizaciones a mitigar los riesgos asociados con filtraciones de datos, amenazas internas e infracciones de

cumplimiento?

[EN: Which of the following answers refers to a solution that helps organizations mitigate risks associated with data breache]

A) EDR

✓ **B) DLP**

C) SOY

D) UTM

** Respuesta corregida manualmente*

Fuente: Practice Test 19

---

177. ¿Cuál de las siguientes respuestas se refiere a un ejercicio más profundo, que puede incluir activar sistemas y realizar acciones reales para responder al incidente?

[EN: Which of the following answers refers to a more in-depth exercise, which can include activating systems and performing r]

A) Pruebas de penetración

B) caza de amenazas

✓ **C) Simulación**

D) Escaneo de vulnerabilidades

Fuente: Practice Test 21

---

178. El término "búsqueda de amenazas" se refiere a una búsqueda proactiva de IoC para identificar y abordar posibles amenazas y vulnerabilidades antes de que puedan convertirse en incidentes en toda regla.

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 21

---

179. ¿Cuál de las siguientes siglas se refiere a una estrategia integral y un conjunto de procedimientos diseñados para garantizar que una organización pueda continuar con sus operaciones y funciones críticas durante y después de un evento disruptivo?

[EN: Which of the following acronyms refers to a comprehensive strategy and set of procedures designed to ensure that an orga]

✓ **A) DRP**

B) CP

✓ **C) BCP**

D) COOPERATIVA

Fuente: Practice Test 21

---

180. ¿Cuál de los términos enumerados a continuación se refiere al proceso de creación y mantenimiento de aplicaciones informáticas?

[EN: Which of the terms listed below refers to the process of creating and maintaining computer applications?]

A) RAD

✓ **B) SDLC**

C) POO

D) SaaS

Fuente: Practice Test 22

---

181. Una estimación basada en datos históricos de la frecuencia con la que una amenaza lograría explotar una vulnerabilidad se conoce como:

A) CERVEZA INGLESA

B) SLA

✓ C) ARO

D) LES

Fuente: Practice Test 23

---

182. Un tipo de acuerdo no vinculante que describe objetivos mutuos y el marco general para la cooperación entre dos o más partes se denomina:

A) MOA

B) SEMBRAR

✓ C) Memorándum de Entendimiento

✓ D) MSA

Fuente: Practice Test 23

---

183. ¿Cuál de los términos enumerados a continuación se refiere a un principio legal que permite a las personas solicitar la eliminación de información personal de búsquedas en Internet y otras fuentes públicas?

[EN: Which of the terms listed below refers to a legal principle that allows individuals to request the removal of personal i]

A) Desidentificación

✓ B) Derecho a ser olvidado

C) Anonimización

D) Gestión del consentimiento

Fuente: Practice Test 24

---

184. En los ejercicios de ciberseguridad, un equipo morado asume el papel integrado de todos los demás equipos (es decir, rojo, azul y blanco).

A) Verdadero

✓ B) FALSO

Fuente: Practice Test 24

---

185. En las pruebas de penetración, el reconocimiento activo implica recopilar cualquier tipo de información disponible públicamente que pueda usarse más adelante para explotar las vulnerabilidades encontradas en el sistema objetivo.

A) Verdadero

✓ B) FALSO

Fuente: Practice Test 24

---

186. ¿Qué término describe mejor a un empleado descontento que abusa del acceso legítimo a los recursos internos de una empresa?

[EN: Which term best describes a disgruntled employee abusing legitimate access to a company's internal resources?]

A) APTO

✓ B) Amenaza interna

C) sombrero gris

D) actor de amenazas

Fuente: Practice Test 24

---

187. ¿Cuál es la mejor contramedida contra los ataques de ingeniería social?

[EN: What is the best countermeasure against social engineering attacks?]

A) Conciencia situacional

B) Política de denegación implícita

✓ C) Educación del usuario

D) Fuertes controles de seguridad

Fuente: Practice Test 24

Dominio 3: Arquitectura de Seguridad (64 preguntas)

188. ¿Cuál de las respuestas enumeradas a continuación se refiere a un enfoque de seguridad del plano de control de confianza cero que tiene en cuenta la identidad del usuario, la seguridad del dispositivo, las condiciones de la red y otra información contextual para permitir decisiones de acceso dinámico?

[EN: Which of the answers listed below refers to a Zero Trust Control Plane security approach that takes into account user id]

A) Confianza implícita

B) Monitoreo y registro

✓ C) Identidad adaptativa

D) Microsegmentación

Fuente: Practice Test 2

---

189. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de red trampa?

[EN: Which of the answers listed below refers to a honeynet example?]

A) Una red de sitios web falsos

B) Una red de servidores falsos

C) Una red de bases de datos falsas

D) Una red de archivos compartidos falsos

✓ E) Todo lo anterior

Fuente: Practice Test 2

---

190. Un archivo Honey se puede utilizar para:

A) Atraer a los ciberatacantes

B) Activar alertas cuando se accede

C) Monitoreo de la actividad de la red

✓ D) Todo lo anterior

Fuente: Practice Test 2

---

191. ¿Cuál de los siguientes no debería usarse como tokens de miel? (Seleccione todo lo que corresponda)

[EN: Which of the following should not be used as honeytokens? (Select all that apply)]

A) Credenciales de cuenta de usuario activo

B) Entradas de bases de datos que imitan datos reales

✓ C) URL reales a sitios web o recursos activos

D) Registros de servidor ficticios con información atractiva

E) Identificadores falsos, incluidos nombres de usuario, contraseñas, direcciones de correo electrónico y direcciones IP

Fuente: Practice Test 2

---

192. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de protocolos y tecnologías que proporcionan cifrado, autenticación e integridad de datos para el tráfico de red?

[EN: Which of the answers listed below refers to a suite of protocols and technologies providing encryption, authentication,]

A) TLS

B) SSH

✓ C) IPSec

D) vpn

Fuente: Practice Test 3

---

193. Un sistema que utiliza una red pública (como Internet) como medio para crear conexiones privadas cifradas entre ubicaciones remotas se denomina:

A) WWAN

✓ B) vpn

C) CACEROLA

D) VLAN

Fuente: Practice Test 3

---

194. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método de autenticación secreto compartido utilizado en WPA, WPA2 y EAP?

[EN: Which of the answers listed below refers to a shared secret authentication method used in WPA, WPA2, and EAP?]

✓ A) PSK

B) 802.1X

C) SAE

D) TKIP

** Respuesta corregida manualmente*

Fuente: Practice Test 3

---

195. Reemplazar caracteres de contraseña en un campo de contraseña con una serie de asteriscos es un ejemplo de:

✓ A) Enmascaramiento de datos

B) Tokenización

C) Anonimización

D) Pseudoanonimización

** Respuesta corregida manualmente*

Fuente: Practice Test 4

---

196. La tecnología Blockchain es un ejemplo de:

A) Pasarela de pago en línea

B) Base de datos centralizada

✓ C) Libro de contabilidad público abierto

D) sistema de almacenamiento en la nube

Fuente: Practice Test 5

---

197. ¿Cuál de las siguientes respuestas se refiere a un vector de amenaza característico únicamente de las redes cableadas?

[EN: Which of the following answers refers to a threat vector characteristic only to wired networks?]

A) Suplantación de ARP

B) salto de VLAN

✓ C) Intervención de cables

D) olfateo de puertos

E) Todo lo anterior

Fuente: Practice Test 7

---

198. ¿Cuál de las respuestas enumeradas a continuación se refiere a la causa más probable de un acceso no autorizado provocado por la explotación de un punto de entrada de red específico?

[EN: Which of the answers listed below refers to the most probable cause of an unauthorized access caused by the exploitation]

A) Software AV obsoleto

B) Cookies del navegador

✓ C) Puertos de servicio abiertos

D) Registro y seguimiento insuficientes

Fuente: Practice Test 7

---

199. La práctica de instalar aplicaciones móviles desde sitios web y tiendas de aplicaciones distintos de los mercados oficiales se conoce como:

A) jailbreak

B) Enraizamiento

✓ C) Carga lateral

D) Desbloqueo del operador

Fuente: Practice Test 8

---

200. Un programa informático malicioso independiente que normalmente se propaga a través de una red informática para afectar negativamente a los recursos del sistema y al ancho de banda de la red se denomina:

✓ A) Gusano

B) virus sin archivos

C) Bot

D) Bomba lógica

** Respuesta corregida manualmente*

Fuente: Practice Test 8

---

201. El término "clonación RFID" se refiere a copiar los datos almacenados en cualquier dispositivo habilitado para RFID (incluidas etiquetas, tarjetas, llaveros, implantes y otros objetos integrados con tecnología RFID) en otro dispositivo habilitado para RFID, que luego puede leerse y usarse de la misma manera que la etiqueta original. Si bien la clonación RFID se puede utilizar con fines legítimos, como replicar etiquetas importantes con fines de respaldo y prueba, también plantea un riesgo de seguridad significativo, ya que las etiquetas duplicadas pueden usarse potencialmente para obtener acceso no autorizado o divulgación de información no autorizada.

✓ A) Verdadero

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 8

---

202. ¿Cuáles son los rasgos característicos de una ID de sesión? (Seleccione todo lo que corresponda)

[EN: What are the characteristic features of a session ID? (Select all that apply)]

A) Permite al servidor identificar la sesión y recuperar los datos de la sesión correspondientes.

✓ B) Un identificador único asignado por el sitio web a un usuario específico.

C) Contiene las credenciales de autenticación del usuario, por ejemplo, nombre de usuario y contraseña.

✓ D) Un dato que puede almacenarse en una cookie o incrustarse como un parámetro de URL

✓ E) Almacenado en el lado del cliente (en el navegador del usuario) y enviado al servidor con cada solicitud

F) Un identificador único asignado a un servidor.

Fuente: Practice Test 9

---

203. ¿Cómo se llama una solución que aumenta la eficiencia de la gestión del espacio de direcciones IP al permitir a los administradores de red dividir las redes en subredes de diferentes tamaños?

[EN: What is the name of a solution that increases the efficiency of IP address space management by allowing network administ]

A) ADNT

✓ **B) VLSM**

C) MPLS

D) VLAN

Fuente: Practice Test 10

---

204. ¿Cuál de las respuestas enumeradas a continuación se refiere a una solución que permite una gestión y control más sencillo de las políticas de segmentación de red a través de aplicaciones de software?

[EN: Which of the answers listed below refers to a solution that allows for easier management and control of network segmenta]

A) VDI

✓ **B) SDN**

C) VPC

D) EDR

Fuente: Practice Test 10

---

205. Un mecanismo de control de acceso basado en reglas implementado en enrutadores, conmutadores y firewalls se denomina:

A) IMPERMEABLE

B) PUA

C) CAD

✓ **D) LCA**

Fuente: Practice Test 10

---

206. ¿Cuál de las respuestas enumeradas a continuación se refiere al concepto de aislamiento de datos? (Seleccione 2 respuestas)

[EN: Which of the answers listed below refer to the concept of data isolation? (Select 2 answers)]

A) DLP

B) SDN

✓ **C) EFS**

D) SWG

E) EDR

Fuente: Practice Test 11

---

207. ¿Cuál de las siguientes opciones proporciona una respuesta activa a una violación de la seguridad de la red en un sistema informático individual?

[EN: Which of the following provides active network security breach response on an individual computer system?]

A) NIDS

B) esconde

C) PNI

✓ **D) CADERAS**

Fuente: Practice Test 11

---

208. La importancia de cambiar los nombres de usuario y contraseñas predeterminados se puede ilustrar con el ejemplo de ciertos dispositivos de red (como enrutadores) que a menudo vienen con credenciales de administrador predeterminadas y conocidas que se pueden buscar en la web.

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 11

---

209. Una arquitectura sin servidor permite a los desarrolladores crear aplicaciones y servicios sin tener que administrar los recursos de infraestructura necesarios (como servidores, bases de datos y sistemas de almacenamiento), que son manejados por:

✓ **A) CSP**

B) ISP

C) MSP

D) proveedor de identidad

** Respuesta corregida manualmente*

Fuente: Practice Test 11

---

210. ¿Cuál de los siguientes proporciona aislamiento de redes informáticas externas?

[EN: Which of the following provides isolation from external computer networks?]

A) Segmentación de red

✓ **B) Entrehierro**

C) Cortafuegos de hardware

D) Distribución de cables protegida

Fuente: Practice Test 11

---

211. ¿Cuál de las respuestas enumeradas a continuación se refiere a un medio para la segmentación lógica de la red?

[EN: Which of the answers listed below refers to a means for logical network segmentation?]

A) Cambiar

✓ **B) VLAN**

C) Subred filtrada

D) Enrutador

** Respuesta corregida manualmente*

Fuente: Practice Test 11

---

212. ¿Cuál de las siguientes respuestas se refiere a tecnología de software diseñada para simplificar la gestión de la infraestructura de red?

[EN: Which of the following answers refers to software technology designed to simplify network infrastructure management?]

✓ **A) SDN**

B) SaaS

C) VDI

D) SNMP

** Respuesta corregida manualmente*

Fuente: Practice Test 11

---

213. ¿Cuál de las siguientes respuestas se refiere a técnicas de monitoreo pasivo de redes? (Seleccione 2 respuestas)

[EN: Which of the following answers refer to passive network monitoring techniques? (Select 2 answers)]

A) Grifo de red

B) Puerto troncal

✓ **C) Duplicación de puertos**

D) trampa SNMP

E) Puerto registrado

Fuente: Practice Test 11

---

214. Un sistema informático o una aplicación que actúa como intermediario entre otra computadora e Internet se denomina comúnmente:

A) Puente

B) Centro activo

C) Servidor

✓ D) Apoderado

Fuente: Practice Test 12

---

215. ¿Cuál de las respuestas enumeradas a continuación se refiere a una solución que simplifica las configuraciones del navegador web mediante el uso de reglas o scripts predefinidos para tomar decisiones de selección de servidores para tráfico web específico?

[EN: Which of the answers listed below refers to a solution that simplifies web browser configurations by using predefined ru]

✓ A) PAC

B) DDNS

C) PAM

D) NAT

** Respuesta corregida manualmente*

Fuente: Practice Test 12

---

216. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar IEEE que se puede implementar en una situación en la que un conmutador Ethernet actúa como autenticador para dispositivos que pretenden conectarse a una red a través de uno de sus puertos?

[EN: Which of the answers listed below refers to an IEEE standard that can be implemented in a situation where an Ethernet sw]

✓ A) IEEE 802.1X

B) IEEE 802.11ac

C) IEEE 802.1D

D) IEEE 802.11x

** Respuesta corregida manualmente*

Fuente: Practice Test 12

---

217. ¿Cuál de las respuestas que se enumeran a continuación se refieren a un firewall de capa 7? (Seleccione 3 respuestas)

[EN: Which of the answers listed below refer to a Layer 7 firewall? (Select 3 answers)]

A) Ofrece filtrado de tráfico complejo (más lento)

B) Filtra el tráfico según las direcciones IP de origen/destino, los puertos y los tipos de protocolo (por ejemplo, TCP/UDP)

C) Opera en la capa de transporte del modelo OSI.

✓ D) Agrega la capacidad de inspeccionar el contenido de los paquetes de datos además de la información del encabezado.

E) Ofrece filtrado de tráfico básico (más rápido)

✓ F) Opera en la capa de aplicación del modelo OSI.

Fuente: Practice Test 12

---

218. ¿Cuál de los siguientes términos se utiliza para describir un tipo de VPN que alivia los cuellos de botella y conserva el ancho de banda al permitir la utilización tanto de la VPN como de los enlaces de la red pública?

[EN: Which of the following terms is used to describe a type of VPN that alleviates bottlenecks and conserves bandwidth by en]

✓ **A) Túnel dividido**

B) Sin cliente

C) Túnel completo

D) Acceso remoto

** Respuesta corregida manualmente*

Fuente: Practice Test 12

---

219. ¿Qué tipo de VPN permite la conectividad entre dos redes?

[EN: Which type of VPN enables connectivity between two networks?]

✓ **A) Sitio a sitio**

B) Host a red

C) Acceso remoto

D) Cliente a sitio

** Respuesta corregida manualmente*

Fuente: Practice Test 12

---

220. ¿Cuál de las respuestas enumeradas a continuación se refiere a una solución de hardware o software que proporciona acceso remoto seguro a redes y recursos?

[EN: Which of the answers listed below refers to a hardware or software solution providing secure remote access to networks a]

A) NAC

B) PDR

C) SSH

✓ **D) RAS**

Fuente: Practice Test 12

---

221. Un modo IPsec que proporciona cifrado sólo para la carga útil (la parte de datos del paquete) se denomina:

A) Modo protegido

B) Modo túnel

✓ **C) Modo de transporte**

D) Modo seguro

Fuente: Practice Test 13

---

222. ¿Cuál de las siguientes respuestas se refiere a un marco de ciberseguridad que combina funciones de red y seguridad en un único servicio basado en la nube?

[EN: Which of the following answers refers to a cybersecurity framework that combines network and security functions into a s]

✓ **A) SASE**

B) SWG

C) CASB

D) SD-WAN

** Respuesta corregida manualmente*

Fuente: Practice Test 13

---

223. ¿Cuál de las siguientes regula la privacidad de los datos personales de los ciudadanos de la UE?

[EN: Which of the following regulates personal data privacy of the EU citizens?]

✓ **A) FI**

B) HIPAA

C) PCI DSS

✓ **D) RGPD**

Fuente: Practice Test 13

---

224. ¿Cuáles de las respuestas enumeradas a continuación se refieren a ejemplos de tipos de datos no legibles por humanos? (Seleccione 2 respuestas)

[EN: Which of the answers listed below refer to examples of non-human readable data types? (Select 2 answers)]

A) código binario

B) archivos XML

✓ **C) Lenguaje máquina**

D) código HTML

E) consultas SQL

Fuente: Practice Test 13

---

225. ¿Cuál de los términos enumerados a continuación se refiere a un duplicado del sitio original, con sistemas informáticos en pleno funcionamiento y copias de seguridad casi completas de los datos del usuario?

[EN: Which of the terms listed below refers to a duplicate of the original site, with fully operational computer systems as w]

A) sitio caliente

✓ **B) Sitio cálido**

C) Sitio frio

D) sitio móvil

** Respuesta corregida manualmente*

Fuente: Practice Test 14

---

226. Una instalación de recuperación ante desastres que proporciona únicamente el espacio físico para las operaciones de recuperación se conoce como:

A) sitio caliente

B) Sitio cálido

✓ **C) Sitio frio**

D) Sitio espejo

Fuente: Practice Test 14

---

227. ¿Qué sitio alternativo permite la recuperación ante desastres más rápida?

[EN: Which alternate site allows for the fastest disaster recovery?]

A) Sitio frio

✓ **B) sitio caliente**

C) sitio móvil

D) Sitio cálido

Fuente: Practice Test 14

---

228. Una representación basada en archivos del estado de una máquina virtual en un momento dado se denomina:

A) Punto de restauración

B) Copia sombra

✓ **C) Instantánea**

D) Imagen del sistema

Fuente: Practice Test 14

---

229. ¿Cuál de los siguientes términos se refiere a una estrategia de respaldo que se basa en la creación y el mantenimiento de copias de datos en tiempo real o casi en tiempo real en un sistema separado?

[EN: Which of the following terms refers to a backup strategy that relies on creating and maintaining copies of data in real-]

A) Duplicación

B) Virtualización

✓ C) Llevar un diario

✓ D) Replicación

Fuente: Practice Test 14

---

230. ¿Cuál de las siguientes soluciones de redundancia de energía sería la más adecuada para proporcionar energía de emergencia a largo plazo durante un corte inesperado de la fuente de energía principal?

[EN: Which of the following power redundancy solutions would be best suited for providing long-term emergency power during an]

A) Fuente de alimentación dual

B) UPS en espera

✓ C) Generador de respaldo

D) PDU administrada

Fuente: Practice Test 14

---

231. ¿Cuál de los términos enumerados a continuación se utiliza para describir un nivel fundamental de configuraciones y ajustes de seguridad necesarios para salvaguardar un sistema?

[EN: Which of the terms listed below is used to describe a foundational level of security configurations and settings require]

A) Segmentación lógica

✓ B) Línea de base segura

C) Niveles de control de acceso

D) Principio de privilegio mínimo

Fuente: Practice Test 15

---

232. Los datos de un dispositivo móvil perdido o robado se pueden borrar mediante:

A) Enraizamiento

B) Carga lateral

C) Formateo de bajo nivel

✓ D) Borrado remoto

Fuente: Practice Test 15

---

233. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ B) CAPTCHA

C) SSO

D) NIDS

Fuente: Practice Test 16

---

234. Una de las formas de evitar la recuperación de datos de una unidad de almacenamiento es sobrescribir su contenido. La técnica de sobrescritura de datos la utilizan las utilidades de borrado de unidades que pueden emplear diferentes métodos (incluidas múltiples rondas de sobrescritura) para disminuir la probabilidad de recuperación de datos. Como ejemplo, una utilidad de desinfección de disco podría sobrescribir los datos de la unidad con el valor de uno en la primera pasada, cambiar ese valor a cero en la segunda pasada y, finalmente, realizar algunas pasadas más, sobrescribiendo el

contenido con caracteres aleatorios.

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 16

---

235. ¿Cuál de los siguientes métodos proporciona la forma más eficaz de eliminar permanentemente los datos almacenados en una unidad magnética?

[EN: Which of the following methods provides the most effective way for permanent removal of data stored on a magnetic drive?]

A) Borrado criptográfico

B) Sobrescritura de datos

✓ **C) Desmagnetización**

D) Formateo de bajo nivel

Fuente: Practice Test 16

---

236. ¿Qué política suele especificar el período durante el cual ciertos tipos de datos deben almacenarse antes de su eliminación?

[EN: Which policy typically specifies the period during which certain types of data must be stored prior to disposal?]

A) Política de protección de datos

B) Política de clasificación de datos

C) Política de copia de seguridad de datos

✓ **D) Política de retención de datos**

Fuente: Practice Test 16

---

237. Las reglas del firewall se evalúan según su orden de prioridad. Las reglas que se encuentran en la parte superior de la lista tienen prioridad sobre las reglas que se encuentran más abajo en la lista. Una vez que se encuentra una regla coincidente, no se realiza ninguna evaluación adicional de las reglas posteriores. La política de "denegación implícita" en un firewall es un comportamiento predeterminado común en el que cualquier tráfico que no coincida explícitamente con ninguna de las reglas de permiso configuradas se deniega o bloquea automáticamente. En otras palabras, si un paquete no cumple con los criterios de ninguna regla de permiso, el comportamiento predeterminado del firewall es denegar el tráfico.

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 18

---

238. Una subred ligeramente protegida (también conocida como DMZ) que consta de servidores disponibles públicamente ubicados en el exterior del firewall de la empresa se conoce como:

A) Portal cautivo

B) Red de cuarentena

C) Extranet

✓ **D) Subred filtrada**

Fuente: Practice Test 18

---

239. TCP es un ejemplo de protocolo sin conexión. Debido a que TCP no admite el protocolo de enlace de tres vías al establecer una conexión de red, se lo conoce como protocolo no confiable o de mejor esfuerzo. Las aplicaciones de ejemplo de TCP incluyen la transmisión de datos de streaming de vídeo y audio.

A) Verdadero

✓ **B) FALSO**

Fuente: Practice Test 18

---

240. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de mantener la integridad de archivos y datos?

[EN: Which of the answers listed below refers to the process of maintaining the integrity of files and data?]

A) DLP

B) SIEM

✓ **C) FIM**

D) sha

** Respuesta corregida manualmente*

Fuente: Practice Test 19

---

241. ¿Cuáles son los rasgos característicos de SAML? (Seleccione 3 respuestas)

[EN: What are the characteristic features of SAML? (Select 3 answers)]

A) Permite solo el intercambio de datos de autorización SSO

✓ **B) Maneja tanto la autenticación como la autorización para SSO**

✓ **C) Utiliza XML para el intercambio de datos.**

✓ **D) Comúnmente utilizado en entornos empresariales y sistemas heredados.**

E) Permite solo el intercambio de datos de autenticación SSO

F) Utiliza JSON para el intercambio de datos.

G) Diseñado específicamente para aplicaciones web y móviles

Fuente: Practice Test 19

---

242. ¿Qué modelo de control de acceso permite definir reglas granulares que consideran los roles de los usuarios, las limitaciones de tiempo y las restricciones de acceso a la red?

[EN: Which access control model allows for defining granular rules that consider user roles, time constraints, and network ac]

A) ABAC

B) IMPERMEABLE

✓ **C) RuBAC**

D) CAD

E) RBAC

Fuente: Practice Test 20

---

243. ¿Qué política de contraseñas impone un cambio de contraseña obligatorio después de un tiempo específico?

[EN: Which password policy enforces a mandatory password change after a specific time?]

✓ **A) Política de caducidad de contraseñas**

B) Política de historial de contraseñas

C) Política de antigüedad mínima de la contraseña

D) Política de reutilización de contraseñas

** Respuesta corregida manualmente*

Fuente: Practice Test 20

---

244. ¿Cuál de las respuestas enumeradas a continuación se refiere a un término utilizado principalmente en el desarrollo de software para describir el costo de las decisiones a corto plazo que pueden generar problemas a largo plazo?

[EN: Which of the answers listed below refers to a term primarily used in software development to describe the cost of short-]

A) Entropía de código
B) factor de exposición
C) registro de riesgos
✓ **D) Deuda técnica**

Fuente: Practice Test 21

---

245. El proceso de identificar, recopilar y producir información almacenada electrónicamente con la intención de utilizarla en un procedimiento o investigación legal se conoce como:

A) Retención por litigio
B) Gestión de pruebas
C) Forense digital
✓ **D) descubrimiento electrónico**

Fuente: Practice Test 21

---

246. El término "Metadatos" se refiere a datos que proporcionan información sobre otros datos, pero no el contenido real de los datos. Normalmente, los metadatos no son visibles para el usuario de forma predeterminada, pero se puede acceder a ellos si es necesario. Por ejemplo, los metadatos de correo electrónico, que se encuentran en los encabezados de los correos electrónicos, incluyen información detallada sobre el remitente, el destinatario y la ruta que tomó el mensaje. Los metadatos del dispositivo móvil abarcan detalles como el modelo del dispositivo, geolocalización, información de la cámara, uso de Internet, actividad de llamadas telefónicas y mensajes de texto, estadísticas de uso de aplicaciones y metadatos de varios archivos en el dispositivo. En la navegación web, los metadatos provienen de metaetiquetas HTML ubicadas en la sección principal de una página web. Para los archivos, los metadatos incluyen detalles sobre el autor (por ejemplo, el creador del archivo), el tipo de archivo, el tamaño, la fecha y hora de creación y la fecha y hora de la última modificación.

✓ **A) Verdadero**
B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 21

---

247. ¿Cuál de las respuestas enumeradas a continuación se refiere a un proceso de interceptación de datos de tráfico de red con fines de análisis y solución de problemas?

[EN: Which of the answers listed below refers to a process of intercepting network traffic data for analysis and troubleshoot]

A) AIS
✓ **B) PCAP**
C) EDR
D) MaaS

Fuente: Practice Test 21

---

248. Una lista de verificación de configuración para nuevos usuarios incluye todas las actividades que permiten que un nuevo empleado sea productivo. Ejemplos de tales actividades (que forman parte del llamado proceso de incorporación) incluyen la configuración del entorno de hardware y software para el nuevo usuario, así como proporcionar toda la formación necesaria. Una lista de verificación de despido del usuario final aborda todas las acciones que deben tener lugar durante el proceso de baja (es decir, cada vez que un empleado deja la empresa). Ejemplos de elementos de la lista de verificación incluyen cumplir con todos los documentos requeridos, eliminar el acceso del empleado a los recursos (por ejemplo, dispositivos propiedad de la empresa, cuentas de usuario, etc.) y discutir sus motivos para irse y sus experiencias con el empleador durante una entrevista de salida.

✓ **A) Verdadero**
B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 22

---

249. ¿Cuál de las siguientes respuestas se refiere a entidades que actúan en nombre del responsable del tratamiento para realizar tareas específicas relacionadas con los datos?

[EN: Which of the following answers refers to entities that act on behalf of the data controller to perform specific data-rel]

A) Mayordomos

B) Propietarios

✓ **C) Procesadores**

D) Controladores

** Respuesta corregida manualmente*

Fuente: Practice Test 22

---

250. ¿Cuál de las siguientes define la cantidad máxima aceptable de pérdida de datos medida en un momento específico antes de un desastre o interrupción?

[EN: Which of the following defines the maximum acceptable amount of data loss measured by a specific point in time before a]

A) RPO

B) MTBF

C) RTO

✓ **D) MTTR**

Fuente: Practice Test 23

---

251. ¿Cuál de las siguientes respuestas se refiere a una entidad (como una organización o un individuo) que determina el propósito y los medios del procesamiento de datos personales?

[EN: Which of the following answers refers to an entity (such as an organization or individual) that determines the purpose a]

✓ **A) Procesador de datos**

B) Propietario de los datos

✓ **C) Responsable del tratamiento**

D) Interesado

Fuente: Practice Test 24

Dominio 4: Operaciones de Seguridad (13 preguntas)

252. Un tipo de evidencia forense que puede usarse para detectar intentos de acceso no autorizados u otras actividades maliciosas se denomina:

A) CVE

✓ **B) COI**

C) AIS

D) OSINT

Fuente: Practice Test 10

---

253. ¿Qué tipo de software permite un control centralizado sobre la configuración, monitoreo y seguridad de los dispositivos móviles utilizados dentro de una organización?

[EN: Which type of software allows centralized control over the configuration, monitoring, and security of mobile devices use]

A) MDR

B) SOY

C) SIEM

✓ **D) DM**

Fuente: Practice Test 15

---

254. ¿Cuál de los términos enumerados a continuación se refiere a un proceso de revisión de código manual o automatizado destinado a descubrir errores de lógica y sintaxis en el código fuente de la aplicación?

[EN: Which of the terms listed below refers to an automated or manual code review process aimed at discovering logic and synt]

A) Validación de entrada

B) Análisis de código dinámico

C) Fuzzing

✓ **D) Análisis de código estático**

Fuente: Practice Test 16

---

255. ¿Cuál de las siguientes tecnologías inalámbricas permite la identificación y el seguimiento de etiquetas adheridas a objetos?

[EN: Which of the following wireless technologies enables identification and tracking of tags attached to objects?]

A) GPS

B) IR

✓ **C) RFID**

D) NFC

Fuente: Practice Test 16

---

256. ¿Cuál de las siguientes opciones se refiere a un sistema que identifica, define y cataloga vulnerabilidades de ciberseguridad conocidas públicamente?

[EN: Which of the following refers to a system that identifies, defines, and catalogs publicly known cybersecurity vulnerabil]

A) TAXII

✓ **B) CVE**

C) STIX

D) cvss

Fuente: Practice Test 17

---

257. ¿Cuál de las siguientes respuestas se refiere a un mecanismo de seguridad impuesto por SELinux sobre el acceso al sistema?

[EN: Which of the following answers refers to a security mechanism imposed by SELinux over system access?]

A) CAD

B) RBAC

✓ **C) IMPERMEABLE**

D) ABAC

Fuente: Practice Test 18

---

258. ¿Cuál de las siguientes respuestas se refiere a un marco de políticas que permite a los propietarios de dominios especificar cómo los receptores de correo electrónico deben manejar los correos electrónicos que no pasan las comprobaciones de autenticación?

[EN: Which of the following answers refers to a policy framework that allows domain owners to specify how email receivers sho]

✓ **A) DKIM**

B) FPS

C) PEM

✓ **D) DMARC**

Fuente: Practice Test 19

---

259. OpenID Connect es un protocolo utilizado para:

A) Atestación

B) Autorización

C) Revisión de cuentas

✓ **D) Autenticación**

Fuente: Practice Test 19

---

260. ¿Qué modelo de control de acceso define reglas de control de acceso con el uso de declaraciones que se parecen mucho al lenguaje natural?

[EN: Which access control model defines access control rules with the use of statements that closely resemble natural languag]

A) CAD

✓ **B) ABAC**

C) IMPERMEABLE

D) RBAC

Fuente: Practice Test 20

---

261. En el contexto de la seguridad informática, el término "biometría" se refiere tanto a las características biológicas del cuerpo humano como a los rasgos de comportamiento que pueden utilizarse con fines de identificación y control de acceso.

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Practice Test 20

---

262. ¿Cuál de las respuestas enumeradas a continuación se refieren a las características de una llave de seguridad? (Seleccione 3 respuestas)

[EN: Which of the answers listed below refer to the features of a security key? (Select 3 answers)]

A) Se utiliza para generación de OTP, acceso remoto a vehículos y acceso a edificios.

✓ **B) Token de autenticación de hardware**

✓ **C) Normalmente, una memoria USB física o un dispositivo del tamaño de un llavero**

✓ **D) Utilizado principalmente para seguridad digital (2FA/MFA)**

E) Token de autenticación de software

F) Normalmente, una tarjeta de plástico del tamaño de una tarjeta de crédito con un chip integrado.

Fuente: Practice Test 20

---

263. ¿Cuál de los siguientes términos se refiere al uso de tecnología para realizar tareas individuales con mínima intervención humana?

[EN: Which of the following terms refers to the use of technology to perform individual tasks with minimal human intervention]

A) Automatización

B) secuencias de comandos

✓ **C) Orquestación**

D) Secuenciación

Fuente: Practice Test 21

---

264. ¿Cuál de los siguientes términos se refiere a un plan documentado que describe los pasos que se deben tomar en cada fase de un incidente de ciberseguridad?

[EN: Which of the following terms refers to a documented plan outlining the steps that should be taken in each phase of a cyb]

A) DRP

✓ **B) PIR**

C) BCP

D) ERP

Fuente: Practice Test 21

Dominio 5: Gestion del Programa de Seguridad (17 preguntas)

265. ¿Cuál de las siguientes respuestas se refiere a vectores de amenazas comunes que se aplican a los MSP, vendedores y proveedores en la cadena de suministro? (Seleccione 2 respuestas)

[EN: Which of the following answers refer to common threat vectors that apply to MSPs, vendors, and suppliers in the supply c]

A) Violaciones de cumplimiento

B) Daño a la reputación de la marca

✓ C) Propagación de malware

D) Interrupciones operativas

✓ E) Técnicas de ingeniería social

Fuente: Practice Test 7

---

266. El término "Enraizamiento" se refiere a la capacidad de obtener acceso administrativo al sistema operativo y a las aplicaciones del sistema en:

✓ A) Dispositivos Android

B) dispositivos iOS

C) Dispositivos Microsoft

D) Todo tipo de dispositivos móviles

** Respuesta corregida manualmente*

Fuente: Practice Test 8

---

267. ¿Cuál de las respuestas enumeradas a continuación se refiere a un dispositivo diseñado para suministrar (y monitorear la calidad de) energía eléctrica a múltiples tomacorrientes?

[EN: Which of the answers listed below refers to a device designed to supply (and monitor the quality of) electric power to m]

A) fuente de alimentación

B) MDF

✓ C) PDU

D) FDI

Fuente: Practice Test 14

---

268. ¿Cuál de las siguientes respuestas se refiere a una función de seguridad utilizada en el emparejamiento de dispositivos Bluetooth?

[EN: Which of the following answers refers to a security feature used in Bluetooth device pairing?]

A) SAE

✓ B) ALFILER

C) Ministerio de Asuntos Exteriores

D) LCA

Fuente: Practice Test 15

---

269. ¿Cuál de las siguientes respuestas se refiere a una característica específica de Windows para manejar excepciones, errores y condiciones anormales en el software?

[EN: Which of the following answers refers to a Windows-specific feature for handling exceptions, errors, and abnormal condit]

A) EPC

✓ B) SEH

C) EH

D) EXR

Fuente: Practice Test 16

---

270. La configuración de política de antigüedad máxima de la contraseña determina el período de tiempo que se debe utilizar una contraseña antes de que el usuario pueda cambiarla.

A) Verdadero

✓ **B) FALSO**

Fuente: Practice Test 20

---

271. ¿Cuál de los siguientes términos se refiere a una regulación específica de la industria?

[EN: Which of the following terms refers to an industry-specific regulation?]

A) RFC

✓ **B) ISO**

✓ **C) PCI DSS**

D) RGPD

Fuente: Practice Test 22

---

272. ¿Cuál de las respuestas enumeradas a continuación se refiere a una organización que desarrolla una amplia gama de estándares a nivel global?

[EN: Which of the answers listed below refers to an organization that develops a wide range of standards on a global level?]

A) IEEE

B) ANSI

✓ **C) ISO**

D) NIST

** Respuesta corregida manualmente*

Fuente: Practice Test 22

---

273. ¿Cuál de las respuestas enumeradas a continuación se refiere a un documento integral utilizado en la gestión de riesgos y la gestión de proyectos para identificar, evaluar y rastrear riesgos?

[EN: Which of the answers listed below refers to a comprehensive document used in risk management and project management to i]

✓ **A) registro de riesgos**

B) Mapa de calor de riesgo

C) Matriz de riesgos

D) Repositorio de riesgos

** Respuesta corregida manualmente*

Fuente: Practice Test 23

---

274. ¿El seguro de ciberseguridad es un ejemplo de qué estrategia de gestión de riesgos?

[EN: Cybersecurity insurance is an example of which risk management strategy?]

A) Evitación de riesgos

B) Disuasión de riesgos

✓ **C) Transferencia de riesgo**

D) Aceptación de riesgos

Fuente: Practice Test 23

---

275. En la estrategia de aceptación de riesgos, la práctica de incumplir temporalmente una norma o política debido a un escenario de riesgo específico se denomina:

A) Exclusión

✓ **B) Excepción**

C) Evasión

D) Exención

Fuente: Practice Test 23

---

276. ¿Cuál de los siguientes términos describe el proceso de tomar medidas proactivas para reducir el impacto de los riesgos identificados?

[EN: Which of the following terms describes the process of taking proactive measures to reduce the impact of identified risks]

A) Aceptación de riesgos

B) Evitación de riesgos

C) Transferencia de riesgo

✓ **D) Mitigación de riesgos**

Fuente: Practice Test 23

---

277. ¿Cuál de los siguientes términos se refiere a un acuerdo que especifica requisitos de desempeño para un proveedor?

[EN: Which of the following terms refers to an agreement that specifies performance requirements for a vendor?]

A) MSA

✓ **B) SLA**

C) Memorándum de Entendimiento

D) SEMBRAR

Fuente: Practice Test 23

---

278. Un acuerdo detallado entre un cliente y un proveedor que describe el trabajo a realizar en un proyecto se denomina:

A) MSA

B) SLA

C) WO

✓ **D) SEMBRAR**

Fuente: Practice Test 24

---

279. ¿Cuál de los términos enumerados a continuación se refiere a un contrato formal entre socios comerciales que describe los derechos, responsabilidades y obligaciones de cada socio con respecto a los procesos de gestión, operación y toma de decisiones dentro del negocio?

[EN: Which of the terms listed below refers to a formal contract between business partners outlining the rights, responsibili]

A) MSA

B) SLA

✓ **C) BPA**

D) MOA

Fuente: Practice Test 24

---

280. ¿Cuál de los términos enumerados a continuación se utiliza para describir las acciones tomadas para abordar y mitigar los riesgos ya identificados?

[EN: Which of the terms listed below is used to describe actions taken to address and mitigate already identified risks?]

A) debida diligencia

B) Estándar de atención

✓ **C) debido cuidado**

D) Deber fiduciario

Fuente: Practice Test 24

281. En el contexto de las auditorías, una certificación suele ser proporcionada por:

A) Organismo regulador

✓ B) Auditor externo

C) comité de auditoría

D) equipo de auditoría interna

Fuente: Practice Test 24

Messer + ExamCompass | Uso personal

Acronyms Quizzes — 10 quizzes de siglas clave

Acronyms Quiz 1 (18 preguntas)

1. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ **B) CAPTCHA**

C) LCA

D) PNI

Fuente: Acronyms Quiz 1

---

2. ¿Cuál de los términos enumerados a continuación se refiere al proceso de creación y mantenimiento de aplicaciones informáticas?

[EN: Which of the terms listed below refers to the process of creating and maintaining computer applications?]

A) RAD

✓ **B) SDLC**

C) POO

D) SaaS

Fuente: Acronyms Quiz 1

---

3. ¿Cuál de las siguientes respuestas se refiere a una solución de seguridad de red que proporciona un único punto de protección contra varios tipos de amenazas?

[EN: Which of the following answers refers to a network security solution providing a single point of protection against vari]

A) desplazado interno

B) AV

✓ **C) UTM**

D) NGFW

Fuente: Acronyms Quiz 1

---

4. ¿Cuál de las respuestas enumeradas a continuación se refiere a un lenguaje utilizado para crear y organizar el contenido de las páginas web?

[EN: Which of the answers listed below refers to a language used for creating and organizing the content of web pages?]

A) HTML

B) CSS

C) js

✓ **D) HTTP**

Fuente: Acronyms Quiz 1

---

5. ¿Cuál es el nombre de un protocolo de red que protege el tráfico web mediante cifrado SSL/TLS?

[EN: What is the name of a network protocol that secures web traffic via SSL/TLS encryption?]

A) SFTP

✓ **B) HTTPS**

C) FTPS

D) SHTTP

Fuente: Acronyms Quiz 1

---

6. ¿Qué término describe la pérdida de valor prevista para un activo en función de un único incidente de seguridad?

[EN: Which term describes the predicted loss of value to an asset based on a single security incident?]

✓ **A) LES**

B) ARO

C) CERVEZA INGLESA

D) SLA

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 1

---

7. ¿Cuál es el término común para un grupo de protocolos utilizados para transportar datos de voz a través de una red de conmutación de paquetes?

[EN: What is the common term for a group of protocols used to carry voice data over a packet-switched network?]

A) RDSI

B) PBX

✓ **C) VoIP**

D) PSTN

Fuente: Acronyms Quiz 1

---

8. ¿Cuál de los siguientes protocolos de transferencia de archivos no proporciona cifrado?

[EN: Which of the following file transfer protocols does not provide encryption?]

A) SCP

B) FTPS

✓ **C) ftp**

D) SFTP

Fuente: Acronyms Quiz 1

---

9. ¿Cuál de las respuestas enumeradas a continuación se refiere a un sistema jerárquico para la creación, gestión, almacenamiento, distribución y revocación de certificados digitales?

[EN: Which of the answers listed below refers to a hierarchical system for the creation, management, storage, distribution, a]

✓ **A) PKI**

B) REAL ACADEMIA DE BELLAS ARTES

C) PKCS

D) California

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 1

---

10. Un subsistema de autenticación que permite a un usuario acceder a múltiples componentes del sistema conectados (como hosts separados en una red) después de un único inicio de sesión en solo uno de los componentes se denomina:

A) NAC

✓ **B) SSO**

C) aaa

D) Ministerio de Asuntos Exteriores

Fuente: Acronyms Quiz 1

---

11. ¿Cuál de las siguientes respuestas ilustra la diferencia entre respuesta pasiva y activa a una violación de seguridad de la red?

[EN: Which of the following answers illustrates the difference between passive and active network security breach response?]

A) HIPS frente a NIPS
B) UTM frente a cortafuegos
C) NIPS frente a UTM
✓ **D) IDS frente a IPS**

Fuente: Acronyms Quiz 1

---

12. ¿Qué protocolo de seguridad inalámbrica ha quedado obsoleto en favor de estándares más nuevos debido a vulnerabilidades conocidas resultantes de fallas de implementación?

[EN: Which wireless security protocol has been deprecated in favor of newer standards due to known vulnerabilities resulting]

A) PAE
B) AES
C) WPA2
✓ **D) WEP**

Fuente: Acronyms Quiz 1

---

13. ¿Qué tipo de modelo de control de acceso conecta los permisos de los usuarios con sus responsabilidades específicas?

[EN: Which type of control access model connects user permissions to their specific responsibilities?]

A) CAD
✓ **B) RBAC**
C) IMPERMEABLE
D) ABAC

Fuente: Acronyms Quiz 1

---

14. Un tipo de documento que estipula reglas de comportamiento que deben seguir los usuarios de computadoras, redes y recursos asociados se denomina:

A) SLA
B) CLUF
✓ **C) PUA**
D) BPA

Fuente: Acronyms Quiz 1

---

15. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de protocolos utilizados para conectar hosts en Internet?

[EN: Which of the answers listed below refers to a suite of protocols used for connecting hosts on the Internet?]

A) NetBIOS
B) IPv4
✓ **C) TCP/IP**
D) IPv6

Fuente: Acronyms Quiz 1

---

16. ¿Cuál de las siguientes respuestas se refiere a un dispositivo de almacenamiento de datos equipado con funcionalidad de cifrado a nivel de hardware?

[EN: Which of the following answers refers to a data storage device equipped with hardware-level encryption functionality?]

A) HSM
B) TPM
C) EFS
✓ **D) SED**

Fuente: Acronyms Quiz 1

---

17. ¿Cuál de los términos enumerados a continuación se refiere a una empresa que proporciona acceso a Internet?

[EN: Which of the terms listed below refers to a company that provides Internet access?]

✓ **A) ISP**

B) CSP

C) proveedor de identidad

D) MSP

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 1

---

18. Un tipo de protocolo de red criptográfico para comunicación segura de datos, inicio de sesión remoto en la línea de comandos, ejecución remota de comandos y otros servicios de red seguros entre dos computadoras en red se conoce como:

A) PDR

✓ **B) SSH**

C) Telnet

D) SCP

Fuente: Acronyms Quiz 1

Acronyms Quiz 2 (14 preguntas)

1. ¿Cuál de las siguientes siglas se refiere a soluciones de seguridad basadas en software o hardware diseñadas para detectar y prevenir el uso y la transmisión no autorizados de información confidencial?

[EN: Which of the following acronyms refers to software or hardware-based security solutions designed to detect and prevent u]

A) IPS

✓ **B) DLP**

C) identificación

D) DEP

Fuente: Acronyms Quiz 2

---

2. ¿Qué tipo de firmware realiza comprobaciones iniciales de hardware después de encender la computadora?

[EN: Which type of firmware performs initial hardware checks after the computer is powered on?]

✓ **A) BIOS**

B) CORREO

C) CMOS

D) PASEO

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 2

---

3. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología de software diseñada para simplificar la gestión de la infraestructura de red?

[EN: Which of the answers listed below refers to a software technology designed to simplify network infrastructure management]

✓ **A) SDN**

B) calidad de servicio

C) VDI

D) CDN

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 2

---

4. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar de seguridad introducido para abordar las vulnerabilidades encontradas en WEP?

[EN: Which of the answers listed below refers to a security standard introduced to address the vulnerabilities found in WEP?]

A) TKIP

B) AES

✓ C) WPA

D) CCMP

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 2

---

5. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de protocolos y tecnologías que proporcionan cifrado, autenticación e integridad de datos para el tráfico de red?

[EN: Which of the answers listed below refers to a suite of protocols and technologies providing encryption, authentication,]

A) TLS

B) SSH

✓ C) IPSec

D) vpn

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 2

---

6. Un tipo de red que conecta computadoras dentro de un área geográfica pequeña, como un edificio o grupo de edificios, se denomina:

A) CACEROLA

✓ B) LAN

C) HOMBRE

D) PÁLIDO

Fuente: Acronyms Quiz 2

---

7. ¿Cuál de las siguientes respuestas se refiere a un método de autenticación secreto compartido utilizado en WPA, WPA2 y EAP?

[EN: Which of the following answers refers to a shared secret authentication method used in WPA, WPA2, and EAP?]

✓ A) PSK

B) 802.1X

C) SAE

D) TKIP

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 2

---

8. ¿Qué tipo de mensajes no solicitados se basan en la comunicación basada en texto?

[EN: Which type of unsolicited messaging relies on text-based communication?]

A) VAM

✓ B) SPIM

C) JMS

D) ESCUPIR

Fuente: Acronyms Quiz 2

---

9. ¿Cuál de las siguientes respuestas se refiere a una familia de funciones hash criptográficas utilizadas en una variedad de aplicaciones de seguridad, incluidas firmas digitales, almacenamiento de contraseñas, comunicaciones seguras y verificación de la integridad de los datos?

[EN: Which of the following answers refers to a family of cryptographic hash functions used in a variety of security applicat]

A) RSA

B) IDEA

C) AES

✓ D) sha

Fuente: Acronyms Quiz 2

---

10. ¿Cuál de los términos enumerados a continuación se aplica al proceso de autenticación?

[EN: Which of the terms listed below applies to the authentication process?]

✓ A) Ministerio de Asuntos Exteriores

B) MMC

C) DM

D) MFD

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 2

---

11. ¿Cuál de los términos enumerados a continuación se refiere a inteligencia sobre amenazas recopilada de fuentes disponibles públicamente?

[EN: Which of the terms listed below refers to threat intelligence gathered from publicly available sources?]

A) COI

✓ B) OSINT

C) RFC

D) CVE/NVD

Fuente: Acronyms Quiz 2

---

12. ¿Cuál de las soluciones enumeradas a continuación permite comprobar si un certificado digital ha sido revocado?

[EN: Which of the solutions listed below allows to check whether a digital certificate has been revoked?]

A) LOC

✓ B) CRL

C) RSE

D) OSPF

Fuente: Acronyms Quiz 2

---

13. ¿Cuál de las siguientes soluciones alivia el problema del agotamiento del espacio de direcciones IPv4 al permitir que varios hosts en la misma LAN privada compartan una única dirección IP pública?

[EN: Which of the following solutions alleviates the problem of the depleting IPv4 address space by allowing multiple hosts o]

A) DNS

B) APIPA

✓ C) NAT

D) DHCP

Fuente: Acronyms Quiz 2

---

14. ¿Cuál de las respuestas enumeradas a continuación se refiere a una persona o función responsable de supervisar y garantizar el cumplimiento de las leyes y políticas de protección de datos dentro de una organización?

[EN: Which of the answers listed below refers to an individual or role responsible for overseeing and ensuring compliance wit]

A) CTO

✓ B) DPO

C) CIO

D) OSC

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 2

Acronyms Quiz 3 (10 preguntas)

1. Un documento menos formal que describe los objetivos mutuos y la cooperación establecida entre dos o más partes se denomina:

A) MOA

B) SEMBRAR

✓ C) Memorándum de Entendimiento

D) MSA

Fuente: Acronyms Quiz 3

---

2. ¿Cuál de las siguientes respuestas se refiere a una organización global de desarrollo de estándares compuesta por diferentes organismos nacionales de estándares?

[EN: Which of the following answers refers to a global standard development organization composed of different national stand]

A) NIST

✓ B) ISO

C) IEEE

D) ANSI

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 3

---

3. ¿Cuál de las respuestas enumeradas a continuación se refiere a un lenguaje de programación dedicado utilizado en la gestión de bases de datos?

[EN: Which of the answers listed below refers to a dedicated programming language used in database management?]

A) PHP

B) do

✓ C) SQL

D) js

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 3

---

4. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología de seguridad de red diseñada para monitorear, detectar y mitigar el acceso no autorizado, las amenazas a la seguridad y las actividades sospechosas en las WLAN?

[EN: Which of the answers listed below refers to a network security technology designed to monitor, detect, and mitigate unau]

A) WIPS

B) NIDS

C) PNI

✓ D) WIDS

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 3

---

5. ¿Cuál de las siguientes respuestas se refiere a un método para crear y verificar firmas digitales?

[EN: Which of the following answers refers to a method for creating and verifying digital signatures?]

A) DHE

B) AES

✓ **C) DSA**

D) sha

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 3

---

6. ¿Cuál de las siguientes respuestas se refiere a una central telefónica interna o sistema de conmutación implementado en un negocio u oficina?

[EN: Which of the following answers refers to an internal telephone exchange or switching system implemented in a business or]

A) MONTONES

B) VoIP

✓ **C) PBX**

D) PSTN

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 3

---

7. ¿Cuál de las siglas enumeradas a continuación se refiere a un período de tiempo máximo tolerable necesario para restaurar las funciones comerciales después de una falla o desastre?

[EN: Which of the acronyms listed below refers to a maximum tolerable period of time required for restoring business function]

A) SLA

✓ **B) RTO**

C) PUA

D) RPO

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 3

---

8. ¿Cuál de las siguientes respuestas se refiere a un microcontrolador integrado que se utiliza para arranque seguro, cifrado de disco y verificación de la integridad del sistema?

[EN: Which of the following answers refers to an embedded microcontroller used for secure boot, disk encryption, and system i]

✓ **A) TPM**

B) SoC

C) UEFI

D) HSM

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 3

---

9. ¿Cuál de las respuestas enumeradas a continuación se refiere a un término genérico utilizado para identificar cualquier recurso?

[EN: Which of the answers listed below refers to a generic term used to identify any resource?]

A) OUI

✓ **B) URI**

C) OID

D) URL

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 3

---

10. ¿Cuál de los siguientes términos se utiliza para describir ciberataques sofisticados y prolongados, a menudo llevados a cabo por grupos organizados y bien financiados, como los Estados-nación?

[EN: Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-fund]

A) MitM

✓ **B) APTO**

C) XSRF

D) DDoS

Fuente: Acronyms Quiz 3

Acronyms Quiz 4 (13 preguntas)

1. ¿Cuál de las respuestas enumeradas a continuación se refiere a un concepto que proporciona información sobre los métodos y herramientas que utilizan los ciberdelincuentes para llevar a cabo ataques?

[EN: Which of the answers listed below refers to a concept that provides insights into methods and tools that cybercriminals]

✓ **A) TTP**

B) CVE

C) ATT&CK

D) cvss

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 4

---

2. ¿Cuál de las siguientes soluciones proporciona una respuesta activa a las violaciones de seguridad de la red en un sistema informático individual?

[EN: Which of the following solutions provides active network security breach response on an individual computer system?]

A) NIDS

B) esconde

C) PNI

✓ **D) CADERAS**

Fuente: Acronyms Quiz 4

---

3. Una tecnología de software diseñada para brindar confidencialidad a todo un dispositivo de almacenamiento de datos se conoce como:

A) TPM

✓ **B) FDE**

C) EFS

D) HSM

Fuente: Acronyms Quiz 4

---

4. ¿Qué parte de la arquitectura de seguridad AAA se ocupa de la verificación de la identidad de una persona o proceso?

[EN: Which part of the AAA security architecture deals with the verification of the identity of a person or process?]

A) Contabilidad

✓ **B) Autenticación**

C) Revisión de cuentas

D) Autorización

Fuente: Acronyms Quiz 4

---

5. ¿Cuál de las siguientes respuestas se refiere a un protocolo de enrutamiento utilizado en redes informáticas para determinar la mejor ruta para enrutar paquetes de datos de un nodo de red a otro?

[EN: Which of the following answers refers to a routing protocol used in computer networks to determine the best path for rou]

A) BGP

B) EIGRP

C) ROTURA

✓ **D) OSPF**

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 4

---

6. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar de la industria para evaluar y calificar la gravedad de las vulnerabilidades de seguridad de los sistemas informáticos?

[EN: Which of the answers listed below refers to an industry standard for assessing and scoring the severity of computer syst]

A) SIEM

✓ **B) cvss**

C) OSINT

D) REMONTARSE

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 4

---

7. ¿Cuál de las siguientes respuestas se refiere a una solución de hardware o software que proporciona acceso remoto seguro a redes y recursos?

[EN: Which of the following answers refers to a hardware or software solution providing secure remote access to networks and]

A) NAC

B) PDR

C) SSH

✓ **D) RAS**

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 4

---

8. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de autenticación de acceso remoto que periódicamente vuelve a autenticar al cliente a intervalos aleatorios para evitar el secuestro de sesión?

[EN: Which of the answers listed below refers to a remote access authentication protocol that periodically re-authenticates c]

A) PAE

✓ **B) CAP**

C) PAPILLA

D) PEAP

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 4

---

9. ¿Cuál de las siguientes siglas se refiere a una estrategia integral y un conjunto de procedimientos diseñados para garantizar que una organización pueda continuar con sus operaciones y funciones críticas durante y después de un evento disruptivo?

[EN: Which of the following acronyms refers to a comprehensive strategy and set of procedures designed to ensure that an orga]

A) DRP

B) CP

✓ **C) BCP**

D) COOPERATIVA

Fuente: Acronyms Quiz 4

---

10. El término "IA" se refiere a sistemas informáticos y algoritmos que pueden realizar tareas que normalmente requieren inteligencia humana, como la resolución de problemas, el aprendizaje y la toma

de decisiones.

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 4

---

11. Un tipo de ciberataque centrado en hacer que un sitio web, servicio o red no esté disponible para los usuarios sobrecargándolo con tráfico o solicitudes maliciosas se denomina:

A) SQLi

B) XSS

C) CSRF

✓ **D) DoS**

Fuente: Acronyms Quiz 4

---

12. ¿Cuál de las siguientes respuestas se refiere a un archivo criptográfico generado por una entidad que solicita un certificado digital a una CA?

[EN: Which of the following answers refers to a cryptographic file generated by an entity requesting a digital certificate fr]

A) OID

✓ **B) RSE**

C) DN

D) CRL

Fuente: Acronyms Quiz 4

---

13. ¿Cuál de las respuestas enumeradas a continuación se refiere a un término amplio que abarca varios sistemas de control y automatización utilizados en entornos industriales para controlar y monitorear procesos físicos y maquinaria?

[EN: Which of the answers listed below refers to a broad term that encompasses various control and automation systems used in]

✓ **A) ICS**

B) SOCIEDAD ANÓNIMA

C) SCADA

D) HMI

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 4

Acronyms Quiz 5 (16 preguntas)

1. ¿Cuál de las siguientes respuestas se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

[EN: Which of the following answers refers to a protocol used to set up secure connections and exchange of cryptographic keys]

A) SSL

✓ **B) IKE**

C) ESP

D) DHE

Fuente: Acronyms Quiz 5

---

2. ¿Cuál de las siglas enumeradas a continuación se refiere a una herramienta de software criptográfico para la comunicación segura por correo electrónico y la protección de datos?

[EN: Which of the acronyms listed below refers to a cryptographic software tool for secure email communication and data prote]

A) DES

B) PEM

C) EFS

✓ **D) PGP**

Fuente: Acronyms Quiz 5

---

3. Un tipo de vulnerabilidad en el que el estado de un recurso se verifica en un momento dado pero puede cambiar antes de que el recurso se utilice realmente se denomina:

A) TOC

✓ **B) TOC/TOU**

C) TÚ

D) TIG

Fuente: Acronyms Quiz 5

---

4. ¿Cuál de los siguientes términos se refiere a un marco y una base de conocimientos que proporciona comprensión de los TTP utilizados durante los ciberataques?

[EN: Which of the following terms refers to a framework and knowledge base that provides understanding of TTPs used during cy]

A) cvss

✓ **B) ATT&CK**

C) TAXII

D) STIX

Fuente: Acronyms Quiz 5

---

5. ¿Cuál de las siguientes respuestas se refiere a un sistema que contiene asignaciones de nombres de dominio a varios tipos de datos, como direcciones IP numéricas?

[EN: Which of the following answers refers to a system containing mappings of domain names to various types of data, such as]

A) TCP/IP

✓ **B) DNS**

C) SQL

D) DHCP

Fuente: Acronyms Quiz 5

---

6. ¿Cuál de los acrónimos enumerados a continuación se refiere a una pieza de hardware y software/firmware asociado diseñado para proporcionar funciones criptográficas y de administración de claves?

[EN: Which of the acronyms listed below refers to a piece of hardware and associated software/firmware designed to provide cr]

A) EFS

✓ **B) HSM**

C) SFC

D) TPM

Fuente: Acronyms Quiz 5

---

7. Una medida de la probabilidad de que un sistema de seguridad biométrico rechace incorrectamente un intento de acceso por parte de un usuario autorizado se denomina:

A) LEJOS

B) CER

C) CDN

✓ **D) FRR**

Fuente: Acronyms Quiz 5

---

8. ¿Cuál de los acrónimos enumerados a continuación se refiere a una estrategia integral y un conjunto de procedimientos diseñados para garantizar que una organización pueda continuar con sus operaciones y funciones críticas durante y después de un evento disruptivo?

[EN: Which of the acronyms listed below refers to a comprehensive strategy and set of procedures designed to ensure that an o]

A) BIA

B) LES

✓ **C) BCP**

D) BPA

Fuente: Acronyms Quiz 5

---

9. ¿Qué tipo de software se utiliza para prevenir, detectar y eliminar malware de sistemas y redes informáticas?

[EN: Which type of software is used to prevent, detect, and remove malware from computer systems and networks?]

A) identificación

B) SaaS

✓ **C) AV**

D) WAF

Fuente: Acronyms Quiz 5

---

10. ¿Cuál de las respuestas enumeradas a continuación se refiere a un mecanismo de control de acceso basado en reglas asociado con archivos y/o directorios?

[EN: Which of the answers listed below refers to a rule-based access control mechanism associated with files and/or directori]

A) EFS

✓ **B) FACL**

C) FIM

D) NTFS

Fuente: Acronyms Quiz 5

---

11. ¿Cuál de las siguientes respuestas se refiere a un registro DNS TXT que permite al propietario de un dominio especificar todos los servidores autorizados para enviar correo desde su dominio?

[EN: Which of the following answers refers to a DNS TXT record that allows the owner of a domain to specify all the servers a]

A) DKIM

B) SRV

C) CNOMBRE

✓ **D) FPS**

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 5

---

12. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método criptográfico utilizado para verificar que un mensaje o dato ha permanecido inalterado durante la transmisión y proviene de una fuente autorizada?

[EN: Which of the answers listed below refers to a cryptographic method used to verify that a message or data has remained un]

✓ **A) IMPERMEABLE**

B) CBC

C) PEM

D) GCM

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 5

---

13. En los sistemas operativos modernos, esta característica evita que se ejecute código malicioso en ciertas regiones de la memoria destinadas a los datos.

✓ **A) DEP**

B) BCE

C) DLP

D) CDN

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 5

---

14. Un modelo de servicio de computación en la nube que ofrece acceso remoto a aplicaciones basado en una tarifa de suscripción mensual o anual se denomina:

A) PaaS

✓ **B) SaaS**

C) IaaS

D) DaaS

Fuente: Acronyms Quiz 5

---

15. ¿Qué longitud de clave AES proporciona el mayor nivel de seguridad?

[EN: Which AES key length provides the highest level of security?]

A) clave de 128 bits

B) clave de 192 bits

✓ **C) clave de 256 bits**

D) clave de 320 bits

Fuente: Acronyms Quiz 5

---

16. La especificación MIME amplía el formato de los mensajes de correo electrónico más allá del simple texto, permitiendo la transferencia de archivos de gráficos, audio y vídeo a través del sistema de correo de Internet. S/MIME es una versión mejorada del protocolo MIME que habilita funciones de seguridad del correo electrónico al proporcionar cifrado, autenticación, integridad de mensajes y otros servicios relacionados.

✓ **A) Verdadero**

B) FALSO

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 5

Acronyms Quiz 6 (10 preguntas)

1. Un protocolo de red utilizado para la transferencia segura de archivos a través de SSH se conoce como:

A) TFTP

✓ **B) SFTP**

C) SCP

D) FTPS

Fuente: Acronyms Quiz 6

---

2. ¿Cuál de las respuestas enumeradas a continuación se refiere a una plataforma de virtualización para entregar escritorios virtuales a una comunidad de usuarios?

[EN: Which of the answers listed below refers to a virtualization platform for delivering virtual desktops to a community of]

A) VDE

B) VNC

✓ **C) VDI**

D) PDR

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 6

---

3. ¿Cuál de las siguientes respuestas se refiere a un intérprete de comandos basado en texto y un lenguaje de programación para sistemas operativos tipo Unix?

[EN: Which of the following answers refers to a text-based command interpreter and scripting language for Unix-like operating]

A) CLI

B) js

✓ **C) Intento**

D) cmd.exe

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 6

---

4. ¿Cuál de las respuestas enumeradas a continuación se refiere a un modelo de implementación de dispositivos móviles en el que las organizaciones proporcionan y poseen los dispositivos y permiten su uso personal?

[EN: Which of the answers listed below refers to a mobile device deployment model where organizations provide and own the dev]

A) BYOD

✓ **B) AFRONTAR**

C) VDI

D) CYOD

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 6

---

5. ¿Cuál de las siguientes respuestas se refiere a una función hash no criptográfica que se utiliza a menudo con fines de comprobación de errores?

[EN: Which of the following answers refers to a non-cryptographic hash function often used for error-checking purposes?]

A) MD5

✓ **B) CDN**

C) sha

D) RIPEMD

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 6

---

6. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de estándares y especificaciones que definen diversas técnicas criptográficas, incluidos formatos para claves públicas, claves privadas, firmas digitales y certificados digitales?

[EN: Which of the answers listed below refers to a set of standards and specifications that define various cryptographic tech]

A) ITIL

B) RFC

✓ **C) PKCS**

D) ISO/CEI

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 6

---

7. ¿Cuál de las respuestas enumeradas a continuación se refiere a una operación lógica comúnmente utilizada en el contexto de la ciberseguridad, particularmente en técnicas de cifrado y ofuscación?

[EN: Which of the answers listed below refers to a logical operation commonly used in the context of cybersecurity, particula]

A) Y

B) O

C) NO

✓ **D) XOR**

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 6

---

8. ¿Cuál de las siguientes respuestas se refiere a un criptosistema de clave pública utilizado para firmas digitales, intercambio seguro de claves y cifrado?

[EN: Which of the following answers refers to a public-key cryptosystem used for digital signatures, secure key exchange, and]

A) DHE

✓ **B) RSA**

C) AES

D) DSA

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 6

---

9. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de mantener la integridad de archivos y datos?

[EN: Which of the answers listed below refers to the process of maintaining the integrity of files and data?]

A) DLP

B) SIEM

✓ **C) FIM**

D) sha

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 6

---

10. ¿Cuál de las siguientes respuestas se refiere a un algoritmo de cifrado de bloque de clave simétrica obsoleto (en gran medida reemplazado por AES)?

[EN: Which of the following answers refers to a deprecated (largely replaced by AES) symmetric-key block cipher encryption al]

A) ECDSA

B) RSA

✓ **C) IDEA**

D) DSA

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 6

Acronyms Quiz 7 (13 preguntas)

1. ¿Cuál es la forma más rápida de comprobar la validez de un certificado digital?

[EN: What is the fastest way for checking the validity of a digital certificate?]

A) CRL

B) OSPF

C) RSE

✓ **D) OCSP**

Fuente: Acronyms Quiz 7

---

2. En una red protegida por Kerberos, este tipo de token seguro se otorga a los usuarios durante su inicio de sesión inicial para permitirles acceder a múltiples servicios de red sin la necesidad de volver a ingresar su información de inicio de sesión.

A) OTP

✓ **B) TGT**

C) COMO

D) TGS

Fuente: Acronyms Quiz 7

---

3. ¿Cuál de las siguientes respuestas se refiere a un lenguaje utilizado principalmente para automatizar la evaluación de vulnerabilidades de seguridad y problemas de configuración en sistemas informáticos?

[EN: Which of the following answers refers to a language primarily used for automating the assessment of security vulnerabili]

✓ **A) OVAL**

B) SAML

C) XML

D) JABÓN

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 7

---

4. Un conjunto de procedimientos implementados para recuperar sistemas y datos de TI después de una interrupción importante se denomina:

✓ **A) DRP**

B) BIA

C) LES

D) BCP

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 7

---

5. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de red utilizado para sincronizar relojes a través de una red informática?

[EN: Which of the answers listed below refers to a network protocol used for synchronizing clocks over a computer network?]

✓ **A) NTP**

B) VTP

C) NNTP

D) RTP

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 7

---

6. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo utilizado por enrutadores, hosts y dispositivos de red para generar mensajes de error y solucionar problemas con la entrega de paquetes IP?

[EN: Which of the answers listed below refers to a protocol used by routers, hosts, and network devices to generate error mes]

A) CCMP

B) RSTP

✓ **C) ICMP**

D) SNMP

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 7

---

7. ¿Cuál de las respuestas enumeradas a continuación se refiere a un modelo de implementación de dispositivos móviles que permite a los empleados utilizar dispositivos móviles privados para acceder a datos y aplicaciones restringidos de la empresa?

[EN: Which of the answers listed below refers to a mobile device deployment model that allows employees to use private mobile]

A) AFRONTAR

✓ **B) BYOD**

C) JBOD

D) CYOD

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 7

---

8. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de autenticación inalámbrica obsoleto desarrollado por Cisco?

[EN: Which of the answers listed below refers to a deprecated wireless authentication protocol developed by Cisco?]

A) PEAP

B) EAP-TTLS

✓ **C) SALTO**

D) EAP-TLS

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 7

---

9. ¿Qué registros DNS TXT se utilizan para la gestión de spam? (Seleccione 3 respuestas)

[EN: Which DNS TXT records are used for spam management? (Select 3 answers)]

A) FPS

✓ **B) DKIM**

C) SRV

✓ **D) DMARC**

E) PTR

Fuente: Acronyms Quiz 7

---

10. Un enfoque de desarrollo de software que tiene como objetivo la creación rápida de aplicaciones y la mejora continua a través del desarrollo iterativo y la colaboración de los usuarios se denomina:

A) FDD

B) DevOps

✓ **C) RAD**

D) SaaS

Fuente: Acronyms Quiz 7

---

11. ¿Cuál de las siguientes respuestas se refiere a una herramienta de software que proporciona una única interfaz de administración para dispositivos móviles, PC, impresoras, dispositivos IoT y wearables?

[EN: Which of the following answers refers to a software tool that provides a single management interface for mobile devices,]

A) DM

B) RCS

✓ **C) UEM**

D) mamá

Fuente: Acronyms Quiz 7

---

12. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología que permite que los dispositivos USB actúen como hosts y periféricos, permitiéndoles conectarse y comunicarse con otros dispositivos USB directamente sin la necesidad de una computadora o un host dedicado?

[EN: Which of the answers listed below refers to a technology that allows USB devices to act as both hosts and peripherals, e]

A) PnP

✓ B) OTG

C) P2P

D) HCl

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 7

---

13. ¿Cuál de las siguientes siglas se refiere a un alto ejecutivo responsable de la toma de decisiones y la planificación relacionadas con la tecnología?

[EN: Which of the following acronyms refers to a senior executive responsible for technology-related decision-making and plan]

A) CIO

B) director ejecutivo

✓ C) CTO

D) OSC

Fuente: Acronyms Quiz 7

Acronyms Quiz 8 (14 preguntas)

1. ¿Cuál de las respuestas enumeradas a continuación se refiere a la funcionalidad integrada de un dispositivo móvil que permite el uso de aplicaciones de localización?

[EN: Which of the answers listed below refers to a mobile device's built-in functionality enabling the usage of locator appli]

A) WPS

B) GSM

C) SIM

✓ D) GPS

Fuente: Acronyms Quiz 8

---

2. En las PC más antiguas que no están basadas en UEFI, el primer sector de una unidad de almacenamiento que contiene información sobre las particiones y un fragmento de código ejecutable utilizado para cargar el sistema operativo instalado se llama:

✓ A) MBR

B) GPT

C) PXE

D) GUID

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 8

---

3. ¿Cuál de las respuestas enumeradas a continuación se refieren a DSA? (Seleccione 3 respuestas)

[EN: Which of the answers listed below refer to DSA? (Select 3 answers)]

A) Algoritmo asimétrico

B) Utilizado para el proceso de intercambio de claves.

C) Algoritmo simétrico

✓ D) Proporciona autenticación, integridad y no repudio.

✓ E) Diseñado específicamente para crear y verificar firmas digitales.

F) Utilizado para cifrado

Fuente: Acronyms Quiz 8

---

4. ¿Cuál de las respuestas enumeradas a continuación describe las características de ECDSA? (Seleccione todo lo que corresponda)

[EN: Which of the answers listed below describe(s) the characteristics of ECDSA? (Select all that apply)]

A) Proporciona autenticación, integridad y no repudio.

✓ B) Basado en criptografía de curva elíptica

C) Diseñado para el cifrado de datos

✓ D) Diseñado específicamente para crear y verificar firmas digitales.

✓ E) Más eficiente computacionalmente que otros algoritmos de firma

F) Habilita el proceso de intercambio de claves.

Fuente: Acronyms Quiz 8

---

5. ¿Cuál de las siguientes respuestas se refiere a un cifrado de flujo obsoleto utilizado en algunas aplicaciones heredadas, como WEP?

[EN: Which of the following answers refers to a deprecated stream cipher used in some legacy applications, such as WEP?]

A) RSA

B) DES

C) SSL

✓ D) RC4

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 8

---

6. ¿Cuál de los siguientes términos se refiere a una tecnología que permite la comunicación de audio y video en tiempo real entre individuos o grupos?

[EN: Which of the following terms refers to a technology that enables real-time audio and video communication between individ]

A) VPC

✓ B) VTC

C) VoIP

D) VDI

Fuente: Acronyms Quiz 8

---

7. ¿Cuál de las respuestas enumeradas a continuación se puede utilizar para describir XSRF? (Seleccione 3 respuestas)

[EN: Which of the answers listed below can be used to describe XSRF? (Select 3 answers)]

A) Explota la confianza que un sitio web tiene en el navegador web del usuario.

✓ B) Un atacante engaña a un usuario para que envíe solicitudes web no autorizadas

✓ C) El sitio web ejecuta las solicitudes del atacante

D) Explota la confianza que el navegador web de un usuario tiene en un sitio web

✓ E) Se inyecta un script malicioso en un sitio web confiable

✓ F) El navegador del usuario ejecuta el script del atacante

Fuente: Acronyms Quiz 8

---

8. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método de codificación (y un formato de archivo) para almacenar objetos criptográficos como certificados X.509, CRL y claves privadas?

[EN: Which of the answers listed below refers to an encoding method (and a file format) for storing cryptographic objects suc]

A) BCE

✓ B) PEM

C) FIM

D) PFS

Fuente: Acronyms Quiz 8

---

9. Una característica de IA que le permite realizar tareas basadas en datos de entrenamiento sin instrucciones humanas explícitas se llama:

A) AGI

✓ B) ml

C) NN

D) LLM

Fuente: Acronyms Quiz 8

---

10. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de intercambio de claves que genera claves temporales para cada sesión, proporcionando secreto directo para proteger las comunicaciones pasadas y futuras?

[EN: Which of the answers listed below refers to a key exchange protocol that generates temporary keys for each session, prov]

A) PFS

B) sha

C) PGP

✓ D) DHE

Fuente: Acronyms Quiz 8

---

11. ¿Cuál de las respuestas que se enumeran a continuación se refieren a los rasgos característicos del NIDS? (Seleccione 3 respuestas)

[EN: Which of the answers listed below refer to the characteristic features of NIDS? (Select 3 answers)]

A) Toma medidas proactivas para bloquear o mitigar los intentos de intrusión.

✓ B) No toma medidas directas para bloquear o prevenir ataques.

✓ C) Genera alertas y notifica al personal de seguridad o a los administradores cuando se detecta actividad sospechosa.

✓ D) Supervisa el tráfico de la red sin participación directa en el enrutamiento del tráfico o la modificación de paquetes.

E) Puede descartar o rechazar paquetes de red, finalizar conexiones o tomar otras acciones para detener el ataque.

F) Opera en modo en línea, interceptando e inspeccionando activamente el tráfico de la red.

Fuente: Acronyms Quiz 8

---

12. ¿Cuál de las siguientes respuestas se refiere a un marco de ciberseguridad que combina funciones de red y seguridad en un único servicio basado en la nube?

[EN: Which of the following answers refers to a cybersecurity framework that combines network and security functions into a s]

✓ A) SASE

B) SIEM

C) SWG

D) REMONTARSE

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 8

---

13. ¿Cuál de los términos enumerados a continuación se refiere a un plan documentado que describe los pasos que se deben tomar en cada fase de un incidente de ciberseguridad?

[EN: Which of the terms listed below refers to a documented plan outlining the steps that should be taken in each phase of a]

A) DRP

✓ **B) PIR**

C) BCP

D) ERP

Fuente: Acronyms Quiz 8

---

14. ¿Cuál de los siguientes combina una función hash criptográfica con una clave secreta para proporcionar un medio para verificar tanto la autenticidad como la integridad de un mensaje o datos?

[EN: Which of the following combines a cryptographic hash function with a secret key to provide a means of verifying both the]

A) MD5

B) DSA

✓ **C) HMAC**

D) DES

Fuente: Acronyms Quiz 8

Acronyms Quiz 9 (10 preguntas)

1. ¿Cuál de las siguientes soluciones sería la más adecuada para una empresa que necesita servicios de TI integrales pero carece de personal de TI calificado?

[EN: Which of the following solutions would be best suited for a company that needs comprehensive IT services but lacks quali]

A) MSA

B) MaaS

✓ **C) MSP**

D) MSSP

Fuente: Acronyms Quiz 9

---

2. ¿Cuál de los términos enumerados a continuación se refiere a un proveedor externo que ofrece servicios de gestión de seguridad de TI?

[EN: Which of the terms listed below refers to a third-party vendor offering IT security management services?]

A) MSP

B) MaaS

C) MSA

✓ **D) MSSP**

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 9

---

3. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método básico para establecer un enlace punto a punto dedicado entre dos dispositivos en red?

[EN: Which of the answers listed below refers to a basic method for establishing a dedicated point-to-point link between two]

A) PPTP

B) IGMP

✓ **C) APP**

D) MPLS

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 9

---

4. ¿Cuál de las respuestas enumeradas a continuación describe las características de un VDI no persistente? (Seleccione 2 respuestas)

[EN: Which of the answers listed below describe the characteristics of a non-persistent VDI? (Select 2 answers)]

A) Al final de una sesión, el escritorio del usuario vuelve a su estado original.

B) Cada usuario ejecuta su propia copia del escritorio virtual.

C) Al final de una sesión, se guardan los datos del usuario y la configuración personal.

✓ D) El escritorio virtual se comparte entre varios usuarios

Fuente: Acronyms Quiz 9

---

5. ¿Cuál de las siguientes respuestas se refiere a un protocolo obsoleto utilizado para la transferencia segura de datos a través de la web?

[EN: Which of the following answers refers to an obsolete protocol used for secure data transfer over the web?]

A) SMTP

B) SRTP

✓ C) SHTTP

D) S/MIME

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 9

---

6. ¿Cuál de las siguientes respuestas se refiere a una herramienta de software diseñada para simplificar el proceso de creación y mantenimiento de contenido en línea?

[EN: Which of the following answers refers to a software tool designed to simplify the process of creating and maintaining on]

A) VDI

B) SaaS

✓ C) CMS

D) SDK

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 9

---

7. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método obsoleto basado en TLS para proteger SMTP?

[EN: Which of the answers listed below refers to a deprecated TLS-based method for securing SMTP?]

A) desplazados internos

✓ B) INICIO

C) DKIM

D) SMTP

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 9

---

8. ¿Cuál de las respuestas enumeradas a continuación se refiere a un lenguaje utilizado para estructurar y describir datos en un formato que sea legible tanto por humanos como por máquinas?

[EN: Which of the answers listed below refers to a language used to structure and describe data in a format that is both huma]

A) HTML

✓ B) XML

C) JSON

D) HTML

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 9

---

9. ¿Cuál de las siguientes siglas se refiere a un modo de cifrado de bloques que funciona encadenando los bloques de texto cifrado, de modo que cada bloque de texto cifrado dependa del bloque anterior?

[EN: Which of the following acronyms refers to a block cipher mode that works by chaining the ciphertext blocks together, suc]

✓ A) CBC

B) GCM

C) BCE

D) CFB

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 9

---

10. ¿Cuál de las siguientes tecnologías permite el manejo automatizado de múltiples incidentes de seguridad?

[EN: Which of the following technologies enables automated handling of multiple security incidents?]

A) JABÓN

B) SIEM

✓ C) REMONTARSE

D) SASE

Fuente: Acronyms Quiz 9

Acronyms Quiz 10 (17 preguntas)

1. Un acuerdo detallado entre un cliente y un proveedor que describe el trabajo a realizar en un proyecto se conoce como:

A) MSA

B) SLA

C) WO

✓ D) SEMBRAR

Fuente: Acronyms Quiz 10

---

2. Un protocolo diseñado para mejorar la seguridad de las implementaciones WEP existentes se conoce como:

A) SRTP

✓ B) TKIP

C) CCMP

D) WPA2

Fuente: Acronyms Quiz 10

---

3. ¿Cuál de las siguientes opciones proporciona control granular sobre el acceso de los usuarios a segmentos y recursos de red específicos en función de sus roles y permisos asignados?

[EN: Which of the following provides granular control over user access to specific network segments and resources based on th]

✓ A) SOY

B) SSO

C) PAM

D) Ministerio de Asuntos Exteriores

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 10

---

4. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tarjeta inteligente utilizada en teléfonos móviles para identificar al usuario del teléfono?

[EN: Which of the answers listed below refers to a smart card used in mobile phones to identify the phone user?]

A) IMSI

B) SoC

C) IMEI

✓ **D) SIM**

Fuente: Acronyms Quiz 10

---

5. ¿Cuáles son las aplicaciones de PGP? (Seleccione 3 respuestas)

[EN: What are the applications of PGP? (Select 3 answers)]

A) Comprimir datos

✓ **B) Cifrar y descifrar datos**

✓ **C) Firmar y verificar firmas digitales**

✓ **D) Gestión de claves públicas y privadas.**

E) Asegurar el tráfico del sitio web

Fuente: Acronyms Quiz 10

---

6. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de tunelización comúnmente utilizado en la creación de VPN?

[EN: Which of the answers listed below refers to a tunneling protocol commonly used in creating VPNs?]

A) VRRP

✓ **B) GRE**

C) RTSP

D) BGP

Fuente: Acronyms Quiz 10

---

7. ¿Cuál de los términos enumerados a continuación se refiere a una iniciativa del gobierno de EE. UU. para compartir en tiempo real indicadores de amenazas cibernéticas?

[EN: Which of the terms listed below refers to a US government initiative for real-time sharing of cyber threat indicators?]

A) NVD

✓ **B) AIS**

C) TTP

D) cvss

Fuente: Acronyms Quiz 10

---

8. ¿Cuál de los siguientes modos de cifrado de bloques es el más simple/débil y, por lo tanto, no se recomienda su uso?

[EN: Which of the following block cipher modes is the simplest/weakest and therefore not recommended for use?]

A) CBC

B) GCM

✓ **C) BCE**

D) CTR

Fuente: Acronyms Quiz 10

---

9. ¿Qué puesto ejecutivo senior asume la responsabilidad de proteger los activos, los datos y las personas de posibles amenazas?

[EN: Which senior executive position assumes the responsibility for protecting assets, data, and people from potential threat]

A) director ejecutivo

B) CIO

✓ **C) OSC**

D) CTO

Fuente: Acronyms Quiz 10

---

10. Una empresa u organización que ofrece servicios de computación en la nube a través de Internet se denomina:

A) ISP

B) MSSP

✓ **C) CSP**

D) MSP

Fuente: Acronyms Quiz 10

---

11. ¿Cuál de las siguientes respuestas se refiere a un dispositivo diseñado para suministrar (y monitorear la calidad de) energía eléctrica a múltiples tomacorrientes?

[EN: Which of the following answers refers to a device designed to supply (and monitor the quality of) electric power to mult]

A) fuente de alimentación

B) MDF

✓ **C) PDU**

D) FDI

Fuente: Acronyms Quiz 10

---

12. ¿Cuál de las respuestas enumeradas a continuación se refiere a una organización global de desarrollo de estándares compuesta por diferentes organismos nacionales de estándares?

[EN: Which of the answers listed below refers to a global standard development organization composed of different national st]

A) NIST

✓ **B) ISO**

C) IEEE

D) ANSI

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 10

---

13. ¿Cuál de las siguientes respuestas se refiere a un protocolo de red para entregar audio y video a través de redes IP?

[EN: Which of the following answers refers to a network protocol for delivering audio and video over IP networks?]

A) PDR

B) VoIP

✓ **C) RTP**

D) UDP

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 10

---

14. ¿Cuál de las siguientes respuestas se refiere a un protocolo de cifrado utilizado principalmente en redes Wi-Fi que implementan el estándar de seguridad WPA2?

[EN: Which of the following answers refers to an encryption protocol primarily used in Wi-Fi networks implementing the WPA2 s]

A) TKIP

✓ **B) CCMP**

C) SSL

D) HMAC

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 10

---

15. ¿Cuál de las siglas enumeradas a continuación se refiere a un protocolo utilizado en los sistemas de administración de redes para monitorear dispositivos conectados a la red?

[EN: Which of the acronyms listed below refers to a protocol used in network management systems for monitoring network-attach]

A) SSH

B) VNC

✓ C) SNMP

D) PDR

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 10

---

16. ¿Cuál de las respuestas enumeradas a continuación se refiere a una solución que simplifica las configuraciones del navegador web mediante el uso de reglas o scripts predefinidos para tomar decisiones de selección de servidores para tráfico web específico?

[EN: Which of the answers listed below refers to a solution that simplifies web browser configurations by using predefined ru]

✓ A) PAC

B) DDNS

C) PAM

D) NAT

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 10

---

17. ¿Cuál de las siguientes siglas hace referencia a un programa de investigación discontinuado enfocado a promover la innovación y el desarrollo en el campo de las telecomunicaciones y las tecnologías de la información?

[EN: Which of the following acronyms refers to a discontinued research program focused on promoting innovation and developmen]

A) IETF

B) CERN

✓ C) DARPA

D) CARRERA

** Respuesta corregida manualmente*

Fuente: Acronyms Quiz 10